

OSSTMM 3

The Open Source Security Testing Methodology Manual
Contemporary Security Testing and Analysis



Created by Pete Herzog
Developed by ISECOM

ISECOM
INSTITUTE FOR SECURITY AND OPEN METHODOLOGIES

OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

Este manual proporciona casos de prueba que dan como resultado hechos verificados. Estos hechos proporcionan información procesable que puede mejorar considerablemente su seguridad operativa. Al utilizar OSSTMM, ya no tendrá que depender de las mejores prácticas generales, evidencia anecdótica o supersticiones porque tendrá información verificada específica para sus necesidades en la cual basar sus decisiones de seguridad.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

Instrucciones

Esta es una metodología para probar la seguridad operativa de ubicaciones físicas, interacciones humanas y todas las formas de comunicaciones, como inalámbricas, por cable, analógicas y digitales. Aquellos que quieran comenzar a realizar pruebas mientras lo utilizan pueden encontrar útil la siguiente información de inicio rápido.

Inicio rápido

Para comenzar a realizar una prueba OSSTMM, deberá realizar un seguimiento de lo que prueba (los objetivos), cómo los prueba (las partes de los objetivos probadas y no las herramientas o técnicas utilizadas), los tipos de controles descubiertos y lo que no prueba (objetivos y partes de los objetivos). Luego podrá realizar la prueba como está acostumbrado con el objetivo de poder responder las preguntas del Informe de auditoría de prueba de seguridad (STAR) disponible al final de este manual o como documento propio. STAR brinda información de prueba específica sobre el estado del alcance para obtener los beneficios de tener una declaración clara de las métricas de seguridad y detalles para realizar comparaciones con pruebas de seguridad anteriores o promedios de pruebas de la industria. Más detalles sobre la información requerida para el STAR están disponibles a lo largo de este manual y se puede consultar según sea necesario.

Como puedes ver, adoptar este enfoque implica que se requiere muy poco tiempo además de una prueba estándar y la formalización del informe. Se ha informado que esta metodología en realidad reduce el tiempo de prueba y presentación de informes debido a las eficiencias introducidas en el proceso. No debe haber ninguna razón financiera o de tiempo para evitar el uso del OSSTMM y no se imponen restricciones irrazonables al evaluador.

Actualización desde versiones anteriores

Si está familiarizado con la serie OSSTMM 2.x, encontrará que la metodología ha cambiado por completo. El nuevo rav proporciona una métrica objetiva de la superficie de ataque que es mucho más precisa para medir la susceptibilidad a los ataques. También hay muchos otros cambios y mejoras, pero el enfoque principal ha sido alejarse de las pruebas basadas en soluciones que suponen que se encontrarán soluciones de seguridad específicas en un alcance y que son necesarias para la seguridad (como un firewall). Otro cambio que puede notar es que ahora existe una metodología de prueba de seguridad única para todos los canales: redes humanas, físicas, inalámbricas, de telecomunicaciones y de datos.

La información rav de 2.x a 3.0 es incompatible. Aquellos con un borrador rav 3.0 temprano (antes de RC 12) requerirán que los valores se vuelvan a calcular usando este cálculo final de la superficie de ataque que está disponible como una calculadora de hoja de cálculo en <http://www.isecom.org/ravs>. Las métricas de seguridad anteriores de OSSTMM medían el riesgo con degradación, pero esta versión no lo hace. En cambio, ahora la atención se centra en una métrica para la superficie de ataque (la exposición) de un objetivo o alcance. Esto permite una métrica fáctica que no tiene sesgos ni opiniones como el riesgo. Nuestra intención es eliminar eventualmente el uso del riesgo en áreas de seguridad que no tienen un valor de precio fijo para un activo (como las personas, la privacidad personal e incluso los mercados fluctuantes) en favor de métricas de confianza que se basan completamente en hechos.

Gran parte de la terminología ha cambiado en esta versión para proporcionar una definición profesional de lo que realmente se puede crear o desarrollar. Esto es más notable en las definiciones de seguridad y protección, que adquieren significados más específicos y concretos para las operaciones internas.

Dado que han cambiado muchas cosas con respecto a las versiones anteriores, ya que se trata de una metodología completamente reescrita, le recomendamos que la lea una vez antes de usarla. Hay más ayuda disponible en <http://www.isecom.org>. Los cursos que lo ayudarán a realizar pruebas, sistemas y procesos de seguridad exhaustivos y adecuados están disponibles a través de ISECOM y lo ayudarán a aprovechar al máximo OSSTMM.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

Información de versión

La versión actual del Manual de metodología de pruebas de seguridad de código abierto (OSSTMM) es 3.02. Esta versión de OSSTMM finaliza la serie 2.x. Todas las versiones de OSSTMM anteriores a la 3.0, incluidas las versiones candidatas a la 3.0 (versiones RC), ahora están obsoletas.

La versión original fue publicada el lunes 18 de diciembre de 2000. Esta versión actual se publicó el martes 14 de diciembre de 2010.

Acerca de este proyecto

Este proyecto es mantenido por el Instituto de Seguridad y Metodologías Abiertas (ISECOM), desarrollado en una comunidad abierta y sujeto a revisión interdisciplinaria y por pares. Este proyecto, como todos los proyectos de ISECOM, está libre de influencias comerciales y políticas. La financiación de todos los proyectos de ISECOM se proporciona a través de asociaciones, suscripciones, certificaciones, licencias e investigaciones basadas en estudios de casos. ISECOM es una organización sin ánimo de lucro registrada y establecida en Nueva York, EE.UU. y en Cataluña, España.

Soporte local

Las oficinas regionales de ISECOM pueden estar disponibles en su área para brindar soporte lingüístico y comercial. Encuentre el socio de ISECOM en su área en <http://www.isecom.org/tp>.

Soporte comunitario

Para un mayor desarrollo se requiere la evaluación de este documento por parte de los lectores, las sugerencias de mejora y los resultados de su aplicación para estudios posteriores. Contáctenos en <http://www.isecom.org> para ofrecer apoyo en la investigación, revisión y asistencia para la edición.

Edición impresa

La edición impresa de este manual está disponible para su compra en el sitio web de ISECOM.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

Restricciones

Cualquier información contenida en este documento no puede modificarse ni venderse sin el consentimiento expreso de ISECOM. La venta comercial de este documento o la información contenida en este documento, incluida la metodología aplicada dentro de una herramienta, software o lista de verificación NO se puede proporcionar sin el permiso explícito de ISECOM.

Este documento de investigación es de lectura gratuita, redistribución gratuita sin fines comerciales, citación o aplicación gratuita en investigaciones académicas o comerciales, y uso o aplicación gratuitos en los siguientes compromisos comerciales: pruebas, educación, consultoría e investigación.

Este manual tiene licencia de ISECOM bajo Creative Commons 3.0 Atribución-No Comercial-SinDerivadas y la Licencia de Metodología Abierta 3.0.

El logotipo de ISECOM es una marca comercial oficial y no puede usarse ni reproducirse comercialmente sin el consentimiento de ISECOM. El gráfico del colibrí OSSTMM tiene derechos de autor de Marta Barceló Jordan, tiene licencia de ISECOM y no puede usarse ni reproducirse comercialmente sin permiso.

Como proyecto colaborativo y abierto, OSSTMM no debe distribuirse por ningún medio que genere ganancias comerciales, ya sea por sí solo o como parte de una colección. Como estándar, puede haber solo una versión oficial del OSSTMM en cualquier momento y esa versión no debe modificarse ni bifurcarse de ninguna manera que pueda causar confusión en cuanto al propósito de la metodología original. Por lo tanto, no se permite ninguna derivación del OSSTMM.

Como metodología, la OSSTMM está protegida bajo la Licencia de Metodología Abierta 3.0 que aplica la protección que se otorga a los Secretos Comerciales. Sin embargo, cuando un secreto comercial requiere esfuerzos suficientes para conservar un secreto, la OML requiere que el usuario haga el esfuerzo suficiente para ser lo más transparente posible sobre la aplicación de la metodología. Por lo tanto, el uso y aplicación del OSSTMM se considera como aceptación de la responsabilidad del usuario de cumplir con los requisitos del OML. No existen restricciones comerciales sobre el uso o aplicación de la metodología dentro del OSSTMM. El OML está disponible al final de este manual y en <http://www.isecom.org/oml>.

Todas y cada una de las preguntas o solicitudes sobre licencias deben dirigirse a ISECOM.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

Desarrolladores primarios

- ISECOM
 - Marta Barceló, Directora, Miembro de la Junta de ISECOM
 - Pete Herzog, Director, Líder del Proyecto OSSTMM, Miembro de la Junta de ISECOM

Contribuyentes principales

Las siguientes personas están enumeradas alfabéticamente por empresa. Cada uno ha sido una influencia sustancial para el desarrollo de este OSSTMM.

@Mediaservice.net, Italia Raoul Chiesa, miembro de la junta directiva de ISECOM Marco Ivaldi Fabio Guasconi Fabrizio Sensibile	ISECOM, EE.UU. Robert E. Lee, miembro de la junta directiva de ISECOM
adMERITia GmbH, Alemania Heiko Rudolph, miembro de la junta directiva de ISECOM Aarón Brown	GCP Global, México francisco puente
Bell Canadá, Canadá Rick Mitchell	KCT Data, Inc., EE. UU. Kim Truett, miembro de la junta directiva de ISECOM
Blue Secure Limited, Nueva Zelanda Richard Feist, miembro de la junta directiva de ISECOM	URL de La Salle, España Jaume Abella, miembro de la junta directiva de ISECOM
Dreamlab Technologies Ltd., Suiza Nick Mayencourt, miembro de la junta directiva de ISECOM Urs B. Weber Adrian Gschwend Thomas Bader	Lab106 y Outpost24, Países Bajos Coro Rosielle
	OneConsult GmbH, Suiza Christoph Baumgartner, miembro de la junta directiva de ISECOM
	Outpost24, Suecia Jack C. Louis



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

Colaboradores, revisores y asistentes

Un enorme y sincero agradecimiento a todos aquellos que han aplicado sus esfuerzos para hacer realidad esta versión de OSSTMM. Sin usted, no habría habido las discusiones sensatas que dieron origen a este manual.

Un agradecimiento especial a Jack C. Louis (5 de enero de 1977 - 15 de marzo de 2009), un brillante investigador de seguridad, una persona increíble y uno de los primeros capacitadores OPST y OPSA certificados por ISECOM. En ISECOM apreciamos enormemente todos sus esfuerzos y por la presente los dejamos vivir como un punto de referencia que esperamos inspirar a otros profesionales de la seguridad a alcanzar. Sus contribuciones a la OSSTMM nunca serán olvidadas. ¡Gracias!

Contribuciones

Alberto Perrone, @Mediaservice.net, Italia
 Martin Dion, Above Security, Canadá
 Lars Heidelberg, adMERITia GmbH, Alemania
 Martin Pajonk, adMERITia GmbH, Alemania
 Dru Lavigne, Universidad de Carleton, Canadá
 Todd A. Jacobs, Codegnome, EE. UU.
 Phil Robinson, Digital Assurance, Reino Unido
 Philipp Egli, Dreamlab Technologies Ltd., Suiza
 Daniel Hulliger, Dreamlab Technologies Ltd., Suiza
 Simon Nussbaum, Dreamlab Technologies Ltd., Suiza
 Sven Vetsch, Dreamlab Technologies Ltd., Suiza
 Colby Clark, Guidance Software, EE. UU.
 Andy Moore, Hereford InfoSec, Reino Unido
 Peter Klee, IBM, Alemania
 Daniel Fernandez Bleda, Internet Security Auditors, España
 Jay Abbott, Outpost24 / Lab106, Países Bajos
 Steve Armstrong, Logically Secure, Reino Unido
 Simon Wepfer, OneConsult GmbH, Suiza
 Manuel Krucker, OneConsult GmbH, Suiza
 Jan Alsenz, OneConsult GmbH, Suiza
 Tobias Ellenberger, OneConsult GmbH, Suiza
 Shaun Copplestone, The Watchers Inc., Canadá
 Ian Latter, Pure Hacking, Australia
 Ty Miller, Pure Hacking, Australia
 Jordi André i Vallverdú, La Caixa, España
 Jim Brown, ThruPoint, EE. UU.
 Chris Griffin, ISECOM, EE. UU.
 Charles Le Grand, EE. UU.
 Dave Lauer, EE. UU.
 John Hoffoss, Minnesota State Colleges and Universities, EE. UU.
 Mike Mooney, EE. UU.
 Pablo Endres, Venezuela / Alemania
 Jeremy Wilde, cumplimentotutorial.com, Reino Unido / Francia
 Rob J. Meijer, Países Bajos

Revisión y asistencia

Gunnar Peterson, Arctec Group, EE.UU.
 Dieter Sarrazyn, Ascore nv., Bélgica
 Bob Davies, Bell Canadá, Canadá
 Josep Ruano, Capside, España
 Adrien de Beaupre, Canadá
 Clement Dupuis, CCCure, Canadá
 Armand Puccetti, CEA, Francia
 José Luis Martin Mas, davinci Consulting, España
 Sylvie Reinhard, Dreamlab Technologies Ltd., Suiza
 Raphaël Haberer-Proust, Dreamlab Technologies Ltd., Suiza
 Josh Zelonis, Dyad Security, EE. UU.
 Bora Turan, Ernst and Young, Turquía
 Luis Ramón García Solano, GCP Global, México
 John Thomas Regney, Gedas, España
 Mike Aiello, Goldman Sachs, EE. UU.
 Dirk Kuhlmann, HP, Reino Unido
 John Rittinghouse, Hypersecurity LLC, EE. UU.
 Massimiliano Graziani, IISFA, Italia
 José Navarro, Indiseg, España
 Timothy Phillips, Information Assurance Solutions, EE. UU.
 Joan Ruiz, La Salle URL, España
 Víktu Pons i Colomer, La Salle URL, España
 Roman Drahtmueller, Novell, Alemania
 Hernán Marcelo Racciatti, SICLABS, Argentina
 Tom Brown, RWE Shared Services IS, Reino Unido
 Marcel Gerardino, Sentinel, República Dominicana
 Manuel Atug, SRC Security Research & Consulting GmbH, Alemania
 Torsten Duwe, SUSE, Alemania
 Alexander J. Herzog, EE. UU.
 Drex Lagui, L&A Inc, Filipinas
 Ruud van der Meulen, Países Bajos
 Chris Gatford, HackLabs, Australia
 Wim Rues, Bélgica
 Estados Unidos / Alemania
 Gary Axtén, Reino Unido/España
 Alan Tang, Reino Unido
 Jason Woloz, EE.UU.
 John R. Moser, EE.UU.
 Tom O'Connor, Irlanda
 Mike Vasquez, Ciudad



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

Prefacio

La verificación de seguridad solía requerir un especialista interdisciplinario que entendiera la seguridad tan profundamente como comprendía las reglas, leyes, premisas subyacentes, operación, procesos y tecnología involucradas.

Algún tiempo después, la verificación por parte de terceros surgió de la noción popular de ceguera del constructor que dice que aquellos más cercanos al objetivo generalmente y por lo general involuntariamente pasarán por alto la mayoría de los problemas. Esto se convirtió en el procedimiento estándar durante un tiempo y todavía se considera cierto como cierto, aunque en realidad significa que un extraño con menos conocimiento del objetivo es supuestamente más capaz de comprenderlo que el operador. En algún momento, el péndulo comenzó a girar hacia el otro lado. No está claro si esto ocurrió por razones económicas o de eficiencia, pero ha provocado un cambio importante para proporcionar a los operadores la capacidad de realizar pruebas de seguridad. Ha llevado a marcos, software, listas de verificación, kits de herramientas y muchas otras formas simplificadas de hacer que las pruebas de seguridad sean lo suficientemente fáciles como para que cualquiera pueda realizarlas. Eso es bueno.

Desgraciadamente, no existe ningún tema complejo en el que el proceso de simplificación no sea complejo en sí mismo ni el resultado final sea significativamente menor que el conjunto. Esto significa que para hacer que una solución de pruebas de seguridad sea lo suficientemente simple para que la ejecuten los no expertos, la solución requiere un back-end complejo para recopilar los datos de acuerdo con reglas preconcebidas. Esto supone que las operaciones siempre se ejecutan según el diseño y la configuración. También supone que el desarrollador de la solución ha tenido en cuenta todas las posibilidades sobre dónde, qué y cómo se pueden recopilar los datos. Además, se supone que los datos recopilados se pueden clasificar adecuadamente en un formato uniforme para su comparación y análisis basado en reglas. Ninguna de esas tareas es sencilla.

Suponiendo que eso pueda hacerse, todavía se necesitaría una base de datos exhaustiva de posibilidades para que las numerosas representaciones de seguridad y capas de controles deduzcan problemas de seguridad. Mientras se minimizan los falsos positivos a través de correlaciones basadas en las reglas, leyes, premisa subyacente, operación, proceso y tecnología involucradas. Esta solución podría entonces proporcionar un informe y una métrica claros y concisos. Esta solución necesitaría tener algo más que el marco, el software, la lista de verificación o el conjunto de herramientas que produce; necesitaría una metodología.

Una metodología de seguridad no es algo sencillo. Es el back-end de un proceso o solución que define qué o quién se prueba, así como cuándo y dónde. Debe tomar un proceso complejo y reducirlo a procesos elementales y explicar suficientemente los componentes de esos procesos. Luego la metodología debe explicar las pruebas para verificar qué hacen esos procesos elementales mientras hacen, se mueven y cambian. Finalmente, la metodología debe contener métricas tanto para asegurar que la metodología se ha llevado a cabo correctamente como para comprender o calificar el resultado de la aplicación de la metodología. Entonces, crear una metodología de prueba de seguridad no es tarea fácil.

Con cada nueva versión del OSSTMM nos acercamos a expresar la seguridad de manera más satisfactoria que las versiones anteriores. No es que este OSSTMM 3 promueva ideas revolucionarias, sino que aplica muchos conceptos pragmáticos nuevos que mejorarán la seguridad. Estamos cada vez más cerca de comprender verdaderamente lo que nos hace estar seguros y protegidos.

Para tener la oportunidad de tener esta iluminación, quiero agradecer a todos los contribuyentes de OSSTMM, al equipo de ISECOM, a todos los estudiantes certificados de ISECOM que se preocupan por la forma correcta de realizar pruebas de seguridad, a todos aquellos que enseñan Hacker Highschool a la próxima generación, a todos. partidarios de los proyectos de ISECOM, incluidos los socios de capacitación de ISECOM, los auditores autorizados de ISECOM y, finalmente, mi muy paciente y solidaria esposa, que comprende lo importante que es esto para mí y para el mundo que necesitamos mejorar.

Gracias a todos por su ayuda.

Pete Herzog

Director, ISECOM



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

Tabla de contenido

Instrucciones.....	2
Inicio rápido.....	2
Actualización desde versiones anteriores.....	2
Información de la versión.....	3
Acerca de este proyecto.....	4
Restricciones.....	4
Desarrolladores primarios.....	5
Contribuyentes principales.....	5
Colaboradores, revisores y asistentes.....	6
Prólogo	7
Introducción	11
Propósito.....	13
Alcance del documento.....	13
Responsabilidad.....	14
Certificación y Acreditación.....	14
Proyectos relacionados.....	17
Capítulo 1 – Lo que necesita saber.....	20
1.1 Seguridad.....	23
1.2 Controles.....	24
1.3 Objetivos de aseguramiento de la información.....	27
1.4 Limitaciones.....	28
1.5 Seguridad real.....	31
1.6 Cumplimiento.....	31
Capítulo 2 – Lo que debe hacer	33
2.1 Definición de una prueba de seguridad.....	34
2.2 Alcance	34
2.3 Tipos de pruebas comunes.....	36
2.4 Reglas de enfrentamiento.....	38
2.5 El proceso de prueba de seguridad operativa.....	41
2.6 Proceso de cuatro puntos.. ..	43
2.7 La Trifecta.....	44
2.8 Manejo de errores.....	46
2.9 Divulgación.....	51
Capítulo 3 - Análisis de seguridad.....	53
3.1 Pensamiento crítico en materia de seguridad.....	56
3.2 Reconocer el modelo OpSec.....	56
3.3 Buscar coincidencia de patrones como señal de errores.....	57
3.4 Caracterizar los resultados.....	57
3.5 Busque señales de intuición... ..	58
3.6 Informes transparentes.....	59
Capítulo 4 – Métricas de seguridad operativa.....	62
4.1 Conociendo al Rav.....	63
4.2 Cómo hacer un Rav.....	67
4.3 Girar Resultados de la prueba en una medición de la superficie de ataque.....	70
4.4 La fórmula de seguridad operativa.....	79
4.5 El Fórmula de controles.....	80
4.6 La fórmula de limitaciones.....	83
4.7 La fórmula de seguridad real	85



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

Capítulo 5 – Análisis de confianza.....	87
5.1 Entendiendo la confianza	87
5.2 Falacias en la confianza.....	89
5.3 Las Diez Propiedades del Fideicomiso.....	90
5.4 Las reglas de confianza.....	9
5.5 Aplicación de reglas de confianza a las pruebas de seguridad.....	
Capítulo 6 – Flujo de trabajo.....	96
6.1 Flujo de la metodología.....	97
6.2 Los módulos de prueba	99
6.3 Una Metodología.....	103
Capítulo 7 - Pruebas de seguridad humana.....	105
Capítulo 8 - Pruebas de seguridad física.....	120
Capítulo 9: Pruebas de seguridad inalámbrica.....	138
Capítulo 10 - Pruebas de seguridad de las telecomunicaciones.....	151
Capítulo 11 - Pruebas de seguridad de redes de datos.....	167
Capítulo 12 - Cumplimiento.....	185
Reglamento.....	186
Capítulo 13 – Informes con el STAR.....	192
Capítulo 14 – Lo que obtienes.....	204
Defensa de Möbius.....	205
Obtener lo que necesitamos.....	206
Capítulo 15 – Licencia de Metodología Abierta.....	208
3.....	208



En el arte, el resultado final es algo bello, mientras que en la ciencia, los medios para alcanzar el resultado final son algo bello. Cuando una prueba de seguridad es un arte, entonces el resultado no es verificable y eso socava el valor de una prueba. Una forma de garantizar que una prueba de seguridad tenga valor es saber que se ha realizado correctamente. Para eso es necesario utilizar una metodología formal. La OSSTMM pretende serlo.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

Introducción

El Manual de metodología de pruebas de seguridad de código abierto (OSSTMM) proporciona una metodología para una prueba de seguridad exhaustiva, en lo sucesivo denominada auditoría OSSTMM. Una auditoría OSSTMM es una medición precisa de la seguridad a nivel operativo que está libre de suposiciones y evidencia anecdótica. Como metodología, está diseñada para ser consistente y repetible. Como proyecto de código abierto, permite que cualquier evaluador de seguridad contribuya con ideas para realizar pruebas de seguridad más precisas, procesables y eficientes. Además, permite la libre difusión de información y propiedad intelectual.

Desde su inicio a finales de 2000, OSSTMM creció rápidamente hasta abarcar todos los canales de seguridad con la experiencia aplicada de miles de revisores. En 2005, la OSSTMM ya no se consideraba simplemente un marco de mejores prácticas. Se había convertido en una metodología para garantizar que la seguridad se estuviera realizando correctamente en el nivel operativo. A medida que las auditorías de seguridad se generalizaron, la necesidad de una metodología sólida se volvió crítica. En 2006, OSSTMM pasó de definir pruebas basadas en soluciones como pruebas de firewall y pruebas de enrutadores a un estándar para aquellos que necesitaban una prueba de seguridad confiable en lugar de simplemente un informe de cumplimiento para una regulación o legislación específica.

Dado que los entornos son significativamente más complejos que en años pasados debido a aspectos como operaciones remotas, virtualización, computación en la nube y otros nuevos tipos de infraestructura, ya no podemos pensar en pruebas simplistas destinadas únicamente a computadoras de escritorio, servidores o equipos de enrutamiento. Por lo tanto, con la versión 3, el OSSTMM abarca pruebas de todos los canales: redes humanas, físicas, inalámbricas, de telecomunicaciones y de datos. Esto también lo hace perfectamente adecuado para probar computación en la nube, infraestructuras virtuales, middleware de mensajería, infraestructuras de comunicaciones móviles, ubicaciones de alta seguridad, recursos humanos, computación confiable y cualquier proceso lógico que cubra múltiples canales y requiera un tipo diferente de prueba de seguridad. . Un conjunto de métricas de superficie de ataque, llamado ravs, proporciona una herramienta poderosa y altamente flexible que puede proporcionar una representación gráfica del estado y mostrar cambios en el estado a lo largo del tiempo. Esto se integra bien con un "panel de control" para la gestión y es beneficioso para pruebas tanto internas como externas, permitiendo una comparación/combinación de las dos. La gestión de riesgos cuantitativa se puede realizar a partir de los resultados del informe de auditoría de OSSTMM, lo que proporciona un resultado mucho mejor debido a resultados más precisos y sin errores; sin embargo, encontrará que la gestión de confianza propuesta aquí es superior a la gestión de riesgos. El OSSTMM incluye información para la planificación de proyectos, la cuantificación de resultados y las reglas de participación para la realización de auditorías de seguridad. La metodología se puede integrar fácilmente con las leyes y políticas existentes para garantizar una auditoría de seguridad exhaustiva en todos los canales.

Las regulaciones legales y específicas de la industria también suelen requerir una auditoría de seguridad como componente para cumplir. Una auditoría OSSTMM es adecuada para la mayoría de estos casos. Por lo tanto, las pruebas OSSTMM específicas se pueden conectar con requisitos de estándares de seguridad particulares, lo que convierte al propio OSSTMM en una forma de lograr el cumplimiento de esos requisitos. Esto se aplica a regulaciones y políticas que van desde la seguridad física, como la decisión de la Comisión Federal de Reserva de Energía de EE. UU., hasta los esfuerzos puros de seguridad de datos, como el último PCI-DSS, e incluyen requisitos entre canales, como se encuentran en muchas recomendaciones del NIST y especificaciones de gestión de seguridad de la información, como ISO/IEC 27001:2005, ISO/IEC 27002:2005 e ISO/IEC 27005:2008.

Se recomienda leer el OSSTMM por completo una vez antes de ponerlo en práctica. Su objetivo es ser una herramienta sencilla para la implementación y documentación de una prueba de seguridad. Más ayuda para aquellos que necesitan ayuda para comprender e implementar esta metodología está disponible en el sitio web de ISECOM.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

Una breve nota sobre el lenguaje en OSSTMM

¿Qué es una auditoría? Algunas de las palabras utilizadas en este documento pueden alejarse de la definición que usted conoce. Las nuevas investigaciones a menudo requieren actualizar, mejorar o retirar información del mundo tal como pensábamos que lo conocíamos. Esto es algo normal y, para ayudarle con los cambios, este documento intenta definir estas palabras correctamente en su nuevo contexto. En este documento, una auditoría OSSTMM o “auditoría” es el resultado del análisis realizado después de una prueba OSSTMM. La persona que realiza esta función de prueba y análisis se denomina Analista de Seguridad o simplemente “Analista”.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

Objetivo

El objetivo principal de este manual es proporcionar una metodología científica para la caracterización precisa de la seguridad operativa (OpSec) mediante el examen y la correlación de los resultados de las pruebas de manera consistente y confiable. Este manual se adapta a casi cualquier tipo de auditoría, incluidas pruebas de penetración, piratería ética, evaluaciones de seguridad, evaluaciones de vulnerabilidad, equipos rojos, equipos azules, etc. Está escrito como un documento de investigación de seguridad y está diseñado para la verificación de seguridad objetiva y la presentación de métricas a nivel profesional.

Un propósito secundario es proporcionar pautas que, si se siguen correctamente, permitirán al analista realizar una auditoría OSSTMM certificada. Estas pautas existen para asegurar lo siguiente:

1. La prueba se realizó minuciosamente.
2. La prueba incluyó todos los canales necesarios.
3. La postura para la prueba se ajustó a la ley.
4. Los resultados son mensurables de forma cuantificable.
5. Los resultados son consistentes y repetibles.
6. Los resultados contienen únicamente hechos derivados de las pruebas mismas.

Un beneficio indirecto de este manual es que puede actuar como referencia central en todas las pruebas de seguridad independientemente del tamaño de la organización, la tecnología o la protección.

Alcance del documento

El alcance de este documento es proporcionar descripciones específicas para las pruebas de seguridad operativa en todos los canales operativos, que incluyen redes humanas, físicas, inalámbricas, de telecomunicaciones y de datos, en cualquier vector, y la descripción de las métricas derivadas. Este manual solo se centra en OpSec y el uso de las palabras seguridad y protección se encuentran dentro de este contexto.

Responsabilidad

Este manual describe ciertas pruebas que están diseñadas para provocar una respuesta. Si estas pruebas causan daños o perjuicios, el Analista puede ser responsable de acuerdo con las leyes que rigen la ubicación del Analista, así como la ubicación de los sistemas probados. ISECOM no garantiza que el resultado de cualquier prueba sea inofensivo.

Cualquier Analista que aplique esta metodología no puede responsabilizar a ISECOM por los problemas que surjan durante las pruebas. Al utilizar esta metodología, el Analista acepta asumir esta responsabilidad.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

Certificación y Acreditación

Para producir una prueba certificada OSSTMM que pueda recibir acreditación para la seguridad operativa del objetivo, se requiere que el analista que realizó la prueba firme una STAR. El STAR también debe cumplir con los requisitos de presentación de informes de este manual. El STAR se puede enviar a ISECOM para su revisión y certificación oficial de ISECOM. No es necesario que una prueba certificada y un informe acreditado demuestren que se siguió todo este manual o alguna subsección específica. Sólo necesita mostrar lo que se probó y lo que no se probó para que sea aplicable a la certificación. (Consulte el Capítulo 16, Cómo hacer el STAR para obtener detalles y un ejemplo de un STAR).

Una auditoría OSSTMM certificada proporciona los siguientes beneficios:

- Sirve como prueba de una prueba factual •
- Responsabiliza al analista de la prueba •
- Proporciona un resultado claro al cliente •
- Proporciona una descripción general más completa que un resumen ejecutivo • Proporciona métricas comprensibles

La revisión de pruebas, certificación y acreditación por parte de ISECOM o un tercero acreditado está sujeta a condiciones y tarifas de operación adicionales. Póngase en contacto con ISECOM para obtener más información.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

Certificaciones para profesionales

Se dice que cualquiera que utilice esta metodología para pruebas y análisis de seguridad y complete un STAR válido ha realizado una auditoría OSSTMM. Sin embargo, la certificación individual también está disponible a través de ISECOM para las habilidades aplicadas en pruebas de seguridad profesional, análisis, procesos metódicos y estándares profesionales como se describe en las Reglas de compromiso de OSSTMM. ISECOM es la autoridad para una variedad de exámenes de certificación de habilidades y conocimientos aplicados basados en la investigación de OSSTMM. Las clases y los exámenes oficiales son impartidos por socios de formación certificados en varias regiones del mundo. Los exámenes de certificación actuales disponibles son:



OPST

El probador de seguridad profesional OSSTMM demuestra que un candidato tiene la habilidad y el conocimiento para realizar pruebas de seguridad precisas y eficientes en redes de datos.

<http://www.opst.org>



OPSA

El analista de seguridad profesional de OSSTMM demuestra que un candidato puede aplicar los principios del análisis de seguridad y las métricas de la superficie de ataque de manera precisa y eficiente.

<http://www.opsa.org>



OPSE

El experto en seguridad profesional de OSSTMM demuestra que un candidato ha aprendido todos los conceptos de seguridad dentro del OSSTMM más actual y disponible públicamente y los antecedentes de la investigación.

<http://www.opse.org>



OWSE

El experto en seguridad inalámbrica de OSSTMM demuestra que un candidato tiene la habilidad y el conocimiento para analizar y probar la seguridad operativa de las tecnologías inalámbricas en todo el espectro electromagnético de manera precisa y eficiente.

<http://www.owse.org>



El analista de confianza certificado demuestra que un candidato tiene las habilidades y el conocimiento para evaluar eficientemente las propiedades de confianza de cualquier persona, lugar, cosa, sistema o proceso y tomar decisiones de confianza precisas y eficientes.

<http://www.trustanalyst.org>



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

Certificaciones para Organizaciones

Las certificaciones para organizaciones, infraestructura y productos también están disponibles a través de ISECOM. Las siguientes certificaciones están disponibles:



Informe de auditoría de prueba de seguridad

La certificación OSSTMM está disponible para organizaciones o partes de organizaciones que validan su seguridad con STAR de ISECOM. La validación de pruebas de seguridad y métricas trimestrales están sujetas a los requisitos de validación de ISECOM para asegurar un alto nivel de confiabilidad en una organización.



Auditores autorizados por ISECOM

Los ILA han demostrado a ISECOM que tienen la competencia y la capacidad para realizar auditorías OSSTMM para ellos mismos y para otros. Esto proporciona una manera fácil y eficiente de mantener los informes de auditoría de pruebas de seguridad y obtener la certificación de esos informes por parte de ISECOM.



Sello de Aprobación OSSTMM

Los sellos de evaluación OSSTMM están disponibles para productos, servicios y procesos comerciales. Este sello define un estado operativo de seguridad, protección, confianza y privacidad. Los productos, servicios y procesos evaluados con éxito llevan su sello de certificación visible y su puntuación rav. Esto permite al comprador ver con precisión la cantidad y el tipo de cambio en la seguridad que presentan las soluciones evaluadas. Elimina las conjeturas en la adquisición y permite encontrar y comparar soluciones alternativas.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

Proyectos relacionados

Para probar adecuadamente la seguridad de cualquier cosa, primero necesita saber cómo funciona esa cosa, de qué está compuesta y cuál es el entorno en el que existe. Así es como se había abordado el OSSTMM como un medio para comprender lo mejor y la más manera más eficiente y completa de probar la seguridad. Por lo tanto, necesitábamos entender la seguridad. Resulta que esta investigación que busca la “partícula de seguridad” ha dado lugar a la aplicación y diseño de más proyectos más allá del OSSTMM.

Si bien no todas las aplicaciones del OSSTMM a áreas fuera de las pruebas de seguridad son dignas de ser proyectos. Sin embargo, algunos sí proporcionan un testimonio del hecho de que ahora sólo estamos limitados por nuestra propia imaginación. El OSSTMM se ha convertido en una herramienta con la que podemos adoptar nuevos enfoques para muchos nuevos medios de protección.

Evaluación de riesgos del análisis del código fuente (SCARE)

El proyecto SCARE aplica los ravs OSSTMM al análisis del código fuente. El resultado final es un valor SCARE que es la cantidad de código fuente con operaciones desprotegidas. <http://www.isecom.org/scare>

Metodología de Seguridad en el Hogar y Guía de Vacaciones (HSM)

El proyecto HSM aplica los ravs OSSTMM, el proceso de cuatro puntos, las métricas de confianza y el proceso de análisis para proteger y fortificar una casa. El resultado final es crear un hogar más seguro sin restringir las libertades de los ocupantes. <http://www.isecom.org/hsm>

Escuela secundaria de hackers (HHS)

HHS es un tipo diferente de programa de concientización sobre seguridad para adolescentes. Utiliza la investigación de pruebas y análisis de OSSTMM para proporcionar conocimientos y habilidades a través de lecciones prácticas y acceso a una red de pruebas basada en Internet. Sin embargo, al hacerlo, refuerza el ingenio y las habilidades de pensamiento crítico. <http://www.hackerhighschool.org>

El Proyecto Gente Mala (BPP)

El BPP es un tipo diferente de programa de concientización sobre seguridad y protección para niños y padres. Utiliza OSSTMM ravs y Trust Metrics para crear mejores reglas para los niños sobre seguridad y protección que se explicarán a través de juegos, historias y juegos de roles. Las reglas son más fáciles de recordar y están libres de contradicciones y sesgos culturales. Los padres pueden visitar y contribuir a la galería de dibujos infantiles que examina lo que piensan los niños y cómo es una mala persona. Estos dibujos se utilizan además para encontrar nuevas formas de llegar a los niños y mejorar las reglas que se les enseñan. <http://www.badpeopleproject.org>



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

Arquitectura de madurez de operaciones de seguridad (SOMA)

El proyecto SOMA tiene como objetivo dotar a la OSSTMM de procesos operativos a nivel estratégico. Este proyecto aplica ravs y Trust Metrics para determinar la madurez de la seguridad en función de qué tan bien funcionan las estrategias y tácticas de protección y no solo cómo deberían funcionar según la política. <http://www.isecom.org/soma>

Pruebas de integridad empresarial (BIT)

El proyecto BIT amplía las pruebas y análisis operativos de OSSTMM a los procesos y transacciones comerciales. Esto añade una nueva visión estratégica a la seguridad de la conducta empresarial de los empleados y al desarrollo de nuevos planes de negocio. <http://www.isecom.org/bit>

Más inteligente, más seguro, mejor

Este proyecto proporciona las herramientas y habilidades de seguridad y protección que las personas necesitan todos los días para combatir el fraude, las mentiras y el engaño. Las herramientas se basan en la investigación de OSSTMM que se centra en evitar trucos persuasivos y técnicas de manipulación. El proyecto es único en la forma en que utiliza grupos de apoyo para que las personas discutan los problemas que han encontrado y trabajen juntas para analizar los problemas. <http://www.smartersaferbetter.org>

Dominar la confianza

Este proyecto tiene como objetivo crear materiales de seminario y libros de trabajo sobre cómo utilizar las métricas de confianza de OSSTMM en la vida cotidiana para tomar mejores decisiones. Este proyecto aborda por qué nuestros instintos están rotos y cómo podemos solucionarlos y mejorarlos. Ya sea en relaciones comerciales o privadas, saber en quién puede confiar y cuánto es más que protegerse de ser lastimado, es una ventaja competitiva. <http://www.isecom.org/seminars>



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

La seguridad no tiene por qué durar para siempre; solo más que todo lo demás que pueda notar que se ha ido.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

Capítulo 1 – Lo que necesitas saber

Este manual trata sobre la seguridad operativa (OpSec). Se trata de medir qué tan bien funciona la seguridad. Si bien esto puede parecer simple y obvio: "¿No nos ocupamos todos de la seguridad operativa?" es una distinción que debe hacerse porque la mayoría de los objetivos de cumplimiento no requieren más que hacer coincidir procesos y configuraciones con un conjunto de mejores prácticas. Este manual y el proceso de prueba que describe requieren que usted no asuma que una solución, producto o proceso de seguridad se comportará durante el uso operativo como se ha designado en papel. Más simplemente, esta metodología le dirá si lo que tiene hace lo que usted quiere que haga y no sólo lo que le dijeron que hiciera.

OpSec es una combinación de separación y controles. Según OpSec, para que una amenaza sea efectiva, debe interactuar directa o indirectamente con el activo. Separar la amenaza del activo es evitar una posible interacción. Por lo tanto, es posible tener seguridad total (100%) si la amenaza y el activo están completamente separados entre sí. De lo contrario, lo que se tiene es la seguridad del activo proporcionada por los controles que se le imponen o el grado en que se reduce el impacto de la amenaza.

Por ejemplo, para estar a salvo de los rayos, uno debe moverse a donde los rayos no pueden llegar, como en lo profundo de una montaña. Las amenazas que no pueden separarse de los activos deben hacerse más seguras para que sus interacciones y cualquier efecto de las interacciones causen poco o ningún daño. En este mismo ejemplo, para estar a salvo de los rayos, uno debe permanecer adentro durante las tormentas, evitar ventanas u otras aberturas y usar pararrayos en el techo. Por lo tanto, bajo el contexto de seguridad operativa, llamamos seguridad a la separación de un activo y una amenaza y seguridad al control de una amenaza o sus efectos.

Para tener una verdadera seguridad de los activos se requieren diferentes tipos de controles. Sin embargo, los controles también pueden aumentar el número de interacciones dentro del alcance, lo que significa que más controles no son necesariamente mejores. Por lo tanto, se recomienda utilizar diferentes tipos de controles operativos en lugar de simplemente más controles. Más controles del mismo tipo de controles operativos no proporcionan una defensa en profundidad ya que el acceso a través de uno a menudo es acceso a través de todos los de ese tipo. Por eso es tan importante poder clasificar los controles según lo que hacen en las operaciones para estar seguros del nivel de protección que brindan.

Para comprender mejor cómo puede funcionar OpSec dentro de un entorno operativo, es necesario reducirlo a sus elementos. Estos elementos permiten cuantificar la Superficie de Ataque, que es la falta de separaciones específicas y controles funcionales que existen para ese Vector, la dirección de la interacción. El enfoque reduccionista nos resuelve la necesidad de ver la seguridad y la protección de una manera nueva, una que les permita existir independientemente del riesgo y totalmente capaces de crear una Seguridad Perfecta, el equilibrio exacto entre seguridad y controles con operaciones y limitaciones. Sin embargo, para ver la seguridad de una manera nueva se requiere también una nueva terminología.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

Término	Definición
Superficie de ataque	La falta de separaciones específicas y controles funcionales que existen para ese vector.
Vector de ataque	Un subalcance de un vector creado para abordar las pruebas de seguridad de un alcance complejo de manera organizada. Se basa en el paradigma de diseño de algoritmos divide y vencerás que consiste en dividir recursivamente un problema en dos o más subproblemas del mismo (o relacionados) tipo, hasta que estos se vuelvan lo suficientemente simples como para resolverlos directamente.
Control S	Controles de impacto y reducción de pérdidas. La garantía de que los activos físicos y de información, así como los propios canales, estén protegidos de diversos tipos de interacciones no válidas según lo definido por el canal. Por ejemplo, asegurar la tienda en caso de incendio es un control que no evita que el inventario se dañe o sea robado, pero pagará un valor equivalente por la pérdida. Se han definido diez controles. Los primeros cinco controles son Clase A e interacciones de control. Los cinco controles de Clase B son relevantes para los procedimientos de control. Consulte la sección 1.2 a continuación para obtener más información sobre los controles.
Limitaciones	Este es el estado actual de los límites percibidos y conocidos para los canales, operaciones y controles, según lo verificado durante la auditoría. Los tipos de limitaciones se clasifican según cómo interactúan con la seguridad a nivel operativo. Por lo tanto, las opiniones sobre el impacto, la disponibilidad en la naturaleza, la dificultad de ejecución y la complejidad no se utilizan para clasificarlos. Por ejemplo, una vieja cerradura oxidada utilizada para asegurar las puertas de una tienda a la hora de cerrar tiene una limitación de seguridad impuesta que proporciona una fracción de la fuerza de protección necesaria para retrasar o resistir un ataque. Determinar que la cerradura es vieja y débil mediante una verificación visual se denomina limitación identificada. Determinar que es viejo y débil rompiéndolo usando 100 kg de fuerza cuando un disuasivo exitoso requiere 1000 kg de fuerza muestra una limitación verificada. Luego se clasifica una de sus limitaciones en función de la consecuencia de la acción operativa, que en este caso es el Acceso.
Operaciones	Las operaciones son la falta de seguridad que se debe tener para ser interactivo, útil, público, abierto o disponible. Por ejemplo, limitar la forma en que una persona compra bienes o servicios en una tienda a través de un canal particular, como una puerta para entrar y salir, es un método de seguridad dentro de las operaciones de la tienda.
Seguridad perfecta	El equilibrio exacto de seguridad y controles con operaciones y limitaciones.
Porosidad	Todos los puntos interactivos, operaciones, que se categorizan como Visibilidad, Acceso o Confianza.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

Término	Definición
Seguridad	Una forma de protección donde se controla la amenaza o sus efectos. Para que sea seguro, deben existir controles para garantizar que el propietario o administrador del activo minimice la amenaza en sí o los efectos de la amenaza a un nivel aceptable. Este manual cubre la seguridad como "controles", que son los medios para mitigar los ataques en un entorno operativo o en vivo.
Seguridad	Una forma de protección donde se crea una separación entre los activos y la amenaza. Esto incluye, entre otros, la eliminación del activo o de la amenaza. Para ser seguro, el activo se elimina de la amenaza o la amenaza se elimina del activo. Este manual cubre la seguridad desde una perspectiva operativa, verificando las medidas de seguridad en un entorno operativo o en vivo.
Rav	El rav es una medida a escala de una superficie de ataque, la cantidad de interacciones incontroladas con un objetivo, que se calcula mediante el equilibrio cuantitativo entre porosidad, limitaciones y controles. En esta escala, 100 rav (a veces también se muestra como 100% rav) es un equilibrio perfecto y cualquier valor inferior significa muy pocos controles y, por lo tanto, una mayor superficie de ataque. Más de 100 rav muestran más controles de los necesarios, lo que en sí mismo puede ser un problema ya que los controles a menudo agregan interacciones dentro de un alcance, así como problemas de complejidad y mantenimiento.
Objetivo	Eso dentro del alcance que está atacando, que está compuesto por el activo y cualquier protección que pueda tener el activo.
Vector	La dirección de una interacción.
Vulnerabilidad	Una clasificación de Limitación donde una persona o proceso puede acceder, negar el acceso a otros u ocultarse a sí mismo o a sus activos dentro del alcance. Más detalles y ejemplos están disponibles en la tabla de Limitaciones en 4.2.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

1.1 Seguridad

La seguridad es una función de una separación. O existe o no existe separación entre un activo y cualquier amenaza. Hay 3 formas lógicas y proactivas de crear esta separación:

1. Mueva el activo para crear una barrera física o lógica entre él y las amenazas.
2. Cambie la amenaza a un estado inofensivo.
3. Destruye la amenaza.

Al analizar el estado de seguridad podemos ver dónde hay posibilidad de interacción y dónde no. Sabemos que algunas, todas o incluso ninguna de estas interacciones pueden ser necesarias para las operaciones. Al igual que las puertas de un edificio, algunas puertas son necesarias para los clientes y otras para los trabajadores. Sin embargo, cada puerta es un punto interactivo que puede incrementar tanto las operaciones necesarias como las no deseadas, como el robo.

Dado que es posible que el evaluador de seguridad no conozca en este momento la justificación comercial de todos estos puntos interactivos, nos referimos a esto como porosidad. La porosidad reduce la separación entre una amenaza y un acceso. Además, se clasifica como uno de los 3 elementos, visibilidad, acceso o confianza, que describe su función en las operaciones y que además permite agregar los controles adecuados durante la fase de remediación para mejorar la protección.

Entonces considere que si la separación existe adecuadamente de las amenazas, como un hombre dentro de una montaña evitando un rayo, entonces esa seguridad es verdadera; es 100%. Por cada agujero en la montaña, por cada medio para que un rayo cause daño a ese hombre, la porosidad aumenta como Acceso. Cada punto de interacción reduce la seguridad por debajo del 100%, donde el 100% representa una separación total. Por lo tanto, el aumento de la porosidad es la disminución de la seguridad y cada poro es Visibilidad, Acceso o Confianza.

Término	Definición
Visibilidad	La ciencia policial sitúa la "oportunidad" como uno de los tres elementos que fomentan el robo, junto con el "beneficio" y el "riesgo disminuido". La visibilidad es un medio para calcular las oportunidades. Es el activo de cada objetivo que se sabe que existe dentro del alcance. Los activos desconocidos sólo corren peligro de ser descubiertos, en lugar de estar en peligro de ser atacados.
Acceso	Dado que la seguridad es la separación de una amenaza y un activo, la capacidad de interactuar directamente con el activo es acceder a él. El acceso se calcula por el número de lugares diferentes donde puede ocurrir la interacción. Eliminar la interacción directa con un activo reducirá a la mitad el número de formas en que se puede eliminar.
Confianza	Medimos la confianza como parte de OpSec como cada relación que existe en la que el objetivo acepta la interacción libremente de otro objetivo dentro del alcance. Si bien un fideicomiso puede ser un agujero de seguridad, es un reemplazo común de la autenticación y un medio para evaluar las relaciones de manera racional y repetible. Por lo tanto, se recomienda el uso de métricas de confianza que permitirán medir qué tan válido es un fideicomiso calculando la cantidad de confiabilidad del fideicomiso.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

1.2 Controles

Cuando la amenaza está presente, son los controles los que proporcionarán seguridad en las operaciones. Los controles son un medio para influir en el impacto de las amenazas y sus efectos cuando se requiere interacción.

El hecho de que no puedas controlarlo directamente no significa que no pueda controlarse. Controla el entorno y controlarás todo lo que hay en él.

Si bien existen muchos nombres y tipos diferentes de controles de operación, solo hay 12 categorías principales que contienen todos los controles posibles. Sin embargo, dos de las categorías, Identificación, la verificación de una identidad existente, y Autorización, la concesión de permisos de la autoridad legítima, no pueden funcionar solas en un entorno operativo y, en cambio, en las operaciones, se combinan y se agregan al control de Autenticación. Esto deja a OpSec con diez posibles controles que un analista deberá identificar y comprender.

La razón por la cual la Identificación y Autorización no se pueden expresar operativamente es porque ninguna de las dos se puede transferir. La identidad existe tal cual y si bien los medios de identificación, como proceso, son un aspecto operativo, el proceso real consiste en verificar una identidad proporcionada previamente por otra fuente o por la última de una cadena de fuentes. Incluso en circunstancias en las que una agencia gubernamental cambia oficialmente la identidad de una persona, sigue siendo la misma persona desde las marcas de identificación hasta su ADN y solo cambia su documentación. Por lo tanto, un proceso de seguridad puede intentar identificar a alguien verificando su identidad pero en este caso no se concede ni proporciona nada. No existe una verdadera "concesión" de identidad, como tampoco puede haber un verdadero "robo" de identidad. Además, la identidad es una colección de pensamientos, emociones, experiencias, relaciones e intenciones, así como formas o marcas físicas. Eres quien eres porque existes, no porque alguien te lo haya concedido. Un duplicado o clon perfecto de ti todavía no eres tú porque desde el origen tus experiencias serán diferentes. Si bien esto puede parecer más una filosofía que una seguridad, es muy importante que los analistas comprendan esto. Los procesos de identificación sólo se verifican con respecto a un proceso de identificación anterior. Si ese proceso se ha corrompido o se puede eludir, entonces toda la base de seguridad que requiere una identificación adecuada está defectuosa.

La autorización, al igual que la Identificación, es otro control de las operaciones que no puede transferirse. Es el control para otorgar permisos. Un empleado autorizado a entrar a una habitación puede mantener la puerta abierta para que entre otra persona. Esto no autoriza a la nueva persona. La autorización no fue transferida. Esta nueva persona está invadiendo un área restringida y el empleado que mantuvo abierta la puerta en realidad era parte de una limitación en el proceso de autenticación para otorgar acceso.

Otra propiedad de la Autorización es que requiere identificación para funcionar. Sin identificación, la autorización es un "permitirlo todo" generalizado sin siquiera saber qué es todo. Sin embargo, en las operaciones esto es en sí mismo una paradoja porque autorizar todo sin escrutinio significa que no hay autorización. Por lo tanto para no autorizar no utilizas la autorización.

El control de Autenticación combina identificación y autorización para mapear Acceso. El proceso consiste simplemente en saber quién (o qué) es y qué, dónde, cuándo y cómo pueden acceder antes de que se les conceda el acceso. Debido a que la autenticación es un control de la interactividad, es uno de los cinco controles de Clase A, también conocidos como "Controles Interactivos".



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

Controles interactivos

Los controles interactivos Clase A constituyen exactamente la mitad de todos los controles de operación. Estos controles influyen directamente en la visibilidad, el acceso o las interacciones de confianza. Las categorías de Clase A son Autenticación, Indemnización, Subyugación, Continuidad y Resiliencia.

1. La autenticación es un control mediante la impugnación de credenciales basado en la identificación y autorización.
2. La indemnización es un control mediante un contrato entre el propietario del activo y la parte que interactúa. Este contrato puede adoptar la forma de una advertencia visible como precursor de una acción legal si no se siguen las reglas publicadas, de una protección legislativa pública específica o de un proveedor de seguros externo en caso de daños, como una compañía de seguros.
3. La resiliencia es un control sobre todas las interacciones para mantener la protección de los activos en caso de corrupción o fracaso.
4. La subyugación es un control que garantiza que las interacciones se produzcan sólo según procesos definidos. El propietario del activo define cómo se produce la interacción, lo que elimina la libertad de elección pero también la responsabilidad de pérdida de la parte que interactúa.
5. La continuidad es un control sobre todas las interacciones para mantener la interactividad con los activos en caso de corrupción o fracaso.

Controles de proceso

La otra mitad de los controles de operación son los controles de Clase B que se utilizan para crear procesos defensivos. Estos controles no influyen directamente en las interacciones, sino que protegen los activos una vez que la amenaza está presente. Estos también se conocen como controles de proceso e incluyen no repudio, confidencialidad, privacidad, integridad y alarma.

6. El no repudio es un control que impide que la parte interactuante niegue su papel en cualquier interactividad.
7. La confidencialidad es un control para asegurar que un activo sea exhibido o intercambiado entre personas que interactúan. Los partidos no pueden ser conocidos fuera de esos partidos.
8. La privacidad es un control para asegurar los medios mediante los cuales se accede, muestra o intercambia un activo. entre partes no puede conocerse fuera de esas partes.
9. La integridad es un control para asegurar que las partes que interactúan sepan cuándo se han modificado los activos y procesos. cambió.
10. La alarma es un control para notificar que está ocurriendo o ha ocurrido una interacción.

Si bien los controles son una influencia positiva en OpSec, al minimizar la superficie de ataque, ellos mismos pueden aumentar la superficie de ataque si ellos mismos tienen limitaciones. Muchas veces este efecto no se nota y si los mecanismos de protección no se prueban exhaustivamente para comprobar cómo funcionan en todas las condiciones, es posible que esto no se haga evidente. Por lo tanto, el uso de controles debe garantizar que no insinúen nuevos vectores de ataque en el objetivo. Por lo tanto, a veces ningún control es mejor que malos controles.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

El ejemplo de la cerradura incorrecta

¿Es mejor una mala cerradura en una puerta que ninguna cerradura? Un analista debe utilizar el pensamiento crítico de seguridad, una forma de habilidades lógicas para superar el sentido innato de seguridad que tenemos y comprender por qué los malos controles pueden aumentar la superficie de ataque a más que ningún control.

El pensamiento común es que agregar controles con limitaciones es mejor que no tener ninguno. ¿No es mejor tener una mala cerradura que no tener ninguna? Después de todo, como sugiere la sabiduría convencional, una sabiduría nacida de la emoción más que de la verificación, algo de “seguridad” es mejor que nada. Es por eso que la analogía de la cerradura es un buen ejemplo y, de hecho, responde mejor a la pregunta que cualquier otra porque muestra muy bien cómo malinterpretamos los controles que son tan comunes a nuestro alrededor.

Pregúntele a cualquiera que haya tenido que forzar una puerta cerrada con patadas o golpes para abrirla. Esa respuesta difiere si se trata de una cerradura con llave abierta desde el exterior o una cerradura con cerrojo en el interior. Hay una razón para esto.

Cuando se agrega una cerradura (que se considera el control de autenticación) a una puerta, es necesario ahuecar un espacio en la puerta sólida y pesada para insertar la cerradura. Eso crea una limitación, un punto débil en la puerta. También lo hace agregar un identificador. Las puertas sin manijas ni cerraduras internas no tienen esta limitación. Sin embargo, requieren que la puerta se abra desde el interior de otra manera. Entonces, para abrir una puerta con ese tipo de cerradura, pateas o golpeas la puerta en la manija o el mecanismo de la cerradura.

Si hay cerradura con cerrojo, esa limitación no existe porque la puerta permanece sólida. Esas puertas a menudo requieren una fuerza para abrirse que antes romperá la puerta que la cerradura. Las puertas hechas para soportar altas presiones tienen los pernos en el exterior y el mecanismo de apertura en el centro de la puerta como un pequeño orificio, como las puertas de un barco o submarino, para evitar los puntos débiles de ahuecar parte de la puerta.

Ahora para responder más directamente a la pregunta: si es mejor tener un candado débil que ningún candado. Esta pregunta se refiere a una puerta con lo mínimo, una cerradura con llave (autenticación) barata o sencilla que pueda ser saltada por alguien que quiera entrar. Entonces, si sabemos que la autenticación es débil, entonces sabemos que alguien puede entrar y, peor aún, puede hacerlo sin dañar la cerradura o la puerta, lo que significa que es posible que no tengamos conocimiento de la intrusión. Si piensas, bueno, está bien porque nuestro problema no son los verdaderos delincuentes, sino los oportunistas que buscan la fruta más fácil, entonces estás tomando una decisión de riesgo y eso no afecta tu superficie de ataque, que está hecha de lo que tienes y no lo que quieres. Además, tener una cerradura implica, sobre todo para los oportunistas, que hay algo de valor en su interior.

Si agregas un control, cualquier control, aumentas la superficie de ataque de cualquier cosa. Si eso nuevo que agregas trae un nuevo vector de ataque, entonces probablemente estarías mejor sin él. En algunos casos, el nuevo vector de ataque es menor que la cantidad real de seguridad que le brinda el nuevo control. Sin embargo, un buen control no tendrá limitaciones y puede reducir la superficie de ataque.

La cerradura de una puerta no debe subvertirse fácilmente ni aumentar la superficie de ataque de manera significativa. Una cerradura de este tipo requiere fuerza para abrirse y eso añade otro control que proporciona la cerradura: la alarma. Una cerradura rota también es una buena señal de robo.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

1.3 Objetivos de aseguramiento de la información

Para facilitar la comprensión de los controles operativos, se pueden relacionar con los tres objetivos de garantía de la información: confidencialidad, disponibilidad e integridad. Estos objetivos se utilizan en toda la industria de la seguridad de la información, aunque debido en parte a su excesiva simplificación, tienen más como objetivo gestionarla que crearla o probarla. El mapeo no es perfecto 1:1, sin embargo, es suficiente para demostrar los controles operativos según la tríada básica de la CIA. Debido a que las definiciones utilizadas para CIA son muy amplias, las asignaciones parecen ser las siguientes:

Objetivos de aseguramiento de la información	Controles de operación
Confidencialidad	Confidencialidad Privacidad Autenticación Resiliencia
Integridad	Integridad No repudio Subyugación
Disponibilidad	Continuidad Indemnización Alarma



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

1.4 Limitaciones

La incapacidad de los mecanismos de protección para funcionar son sus limitaciones. Por lo tanto, el estado de seguridad con respecto a fallas y restricciones conocidas dentro del alcance de las operaciones se denomina Limitación. Son los agujeros, vulnerabilidades, debilidades y problemas para mantener esa separación entre un activo y una amenaza o para garantizar que los controles sigan funcionando correctamente.

Las limitaciones se han clasificado en cinco categorías y estas categorías definen el tipo de vulnerabilidad, error, mala configuración o deficiencia por operación. Esto es diferente de cómo se clasifican las limitaciones en la mayoría de los marcos y mejores prácticas de gestión de seguridad, por lo que utilizamos el término Limitación en lugar de términos más comunes para evitar confusiones. Esos otros términos se refieren a vulnerabilidades o deficiencias porque se clasifican por el tipo de ataque o, a menudo, por la amenaza misma. Hay un enfoque en el riesgo del ataque. Sin embargo, para eliminar el sesgo de las métricas de seguridad y proporcionar una evaluación más justa, eliminamos el uso del riesgo. El riesgo en sí está muy sesgado y, a menudo, es muy variable según el entorno, los activos, las amenazas y muchos más factores. Por lo tanto, en OpSec utilizamos el término Limitaciones para expresar la diferencia de categorizar cómo falla OpSec en lugar de por el tipo de amenaza.

Dado que no se puede conocer la cantidad y el tipo de amenazas, tiene más sentido comprender un mecanismo de seguridad en función de cuándo fallará. Esto permite al analista probar las condiciones en las que ya no mantendrá el nivel de protección necesario. Sólo una vez que tengamos este conocimiento podremos comenzar a jugar el juego de amenazas y riesgos. Luego también podremos invertir en el tipo apropiado de separación o controles requeridos y crear planes precisos para desastres y contingencias.

Aunque las limitaciones se clasifican aquí del 1 al 5, esto no significa que estén en un formato jerárquico de gravedad. Más bien, están numerados sólo para diferenciarlos tanto en la planificación operativa como en las métricas. Esto también significa que es posible que se pueda aplicar más de un tipo de limitación a un solo problema. Además, el peso (valor) de una Limitación particular se basa en los demás controles y áreas interactivas disponibles y correspondientes al alcance, no puede haber una jerarquía específica ya que el valor de cada uno es específico de las medidas de protección en el alcance que se está auditando.

Dentro del OSSTMM las cinco clasificaciones de Limitaciones son:

1. Vulnerabilidad es la falla o error que: (a) niega el acceso a activos a personas o procesos autorizados, (b) permite acceso privilegiado a activos a personas o procesos no autorizados, o (c) permite que personas o procesos no autorizados oculten activos o ellos mismos dentro del alcance.
2. Debilidad es la falla o error que perturba, reduce, abusa o anula específicamente los efectos de los cinco controles de interactividad: autenticación, indemnización, resiliencia, subyugación y continuidad.
3. Preocupación es la falla o error que interrumpe, reduce, abusa o anula los efectos del flujo o ejecución de los cinco controles del proceso: no repudio, confidencialidad, privacidad, integridad y alarma.
4. La exposición es una acción, falla o error injustificable que proporciona visibilidad directa o indirecta de objetivos o activos dentro del canal de alcance elegido.
5. Anomalía es cualquier elemento no identificable o desconocido que no ha sido controlado y no puede ser contabilizados en operaciones normales.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

Mapeo de limitaciones

Para comprender mejor cómo encajan las limitaciones en el marco de OpSec, se puede ver cómo se relacionan con la seguridad y la protección:

Categoría		Seguridad de Operaciones	Limitaciones
Operaciones		Visibilidad	Exposición
		Acceso	Vulnerabilidad
		Confianza	
Control S	Clase A - Interactivo	Autenticación	Debilidad
		Indemnización	
		Resiliencia	
		Subyugación	
		Continuidad	
	Clase B - Proceso	No repudio	Inquietud
		Confidencialidad	
		Privacidad	
		Integridad	
		Alarma	
			Anomalías

Este mapeo muestra cómo las limitaciones afectan la seguridad y cómo se determinan sus valores.

Una vulnerabilidad es la falla o error que: (a) niega el acceso a activos a personas o procesos autorizados (b) permite acceso privilegiado a activos a personas o procesos no autorizados, o (c) permite a personas o procesos no autorizados ocultar activos o a ellos mismos dentro del alcance. Esto significa que la vulnerabilidad debe asignarse a todos los puntos de interacción o OpSec y debido a que la vulnerabilidad puede eludir o anular los controles, estos también deben considerarse en la ponderación de la vulnerabilidad.

Una debilidad es una falla en los controles de Clase A; sin embargo, puede afectar a OpSec, por lo que se asigna a todos los parámetros de OpSec, además de a esta clase interactiva de controles.

Una preocupación solo se puede encontrar en los controles de Clase B; sin embargo, puede afectar a OpSec, por lo que se asigna a todos los parámetros de OpSec y a esta clase de controles de proceso.

Una exposición nos brinda inteligencia sobre la interacción con un objetivo y, por lo tanto, se asigna directamente a Visibilidad y Acceso. Esta inteligencia también puede ayudar a un atacante a navegar por algunos o todos los controles, por lo que la exposición también se asigna a ambas clases de control. Finalmente, la Exposición no tiene valor en sí misma a menos que haya una manera de utilizar esta inteligencia para explotar el activo o un Control y, por lo tanto, las Vulnerabilidades, Debilidades y Preocupaciones también juegan un papel en la ponderación del valor de la Exposición.

Una anomalía es cualquier elemento no identificable o desconocido que no ha sido controlado y no puede ser contabilizado en las operaciones normales. El hecho de que no haya sido controlado y no pueda ser contabilizado significa un vínculo directo con Trust. Esta Limitación también puede provocar anomalías en el funcionamiento de los Controles, por lo que también están incluidos en la ponderación. Finalmente, al igual que con una Exposición, una Anomalía por sí sola no afecta a OpSec sin la existencia de una Vulnerabilidad, Debilidad o Preocupación que pueda explotar este comportamiento inusual.

Además, se puede aplicar más de una categoría a una limitación cuando la falla rompe OpSec en más de



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

un lugar. Por ejemplo, un control de autenticación que permite a una persona secuestrar las credenciales de otra tiene una debilidad y, si las credenciales permiten el acceso, también tiene una vulnerabilidad.

En otro ejemplo, un control de Autenticación utiliza una lista común de nombres correspondientes a direcciones de correo electrónico. Cada dirección que se puede encontrar o adivinar y utilizar como inicio de sesión es una Exposición, mientras que el control en sí tiene una Debilidad por su incapacidad para identificar al usuario correcto del mecanismo de Autenticación del inicio de sesión. Si alguna de esas credenciales permite el acceso, también la incluimos como vulnerabilidad.

Justificación de las limitaciones

El concepto de que las limitaciones sólo son limitaciones si no tienen una justificación empresarial es falso. Una limitación es una limitación si se comporta en uno de los factores limitantes como se describe aquí. Una justificación para una limitación es una decisión de riesgo que se enfrenta con un control de algún tipo o simplemente con la aceptación de la limitación. Las decisiones de riesgo que aceptan las limitaciones tal como son a menudo se reducen a: el daño que una limitación puede causar no justifica el costo de arreglar o controlar la limitación, la limitación debe permanecer de acuerdo con la legislación, los contratos o la política, o una conclusión de que La amenaza no existe o es poco probable para esta limitación en particular. Dado que las justificaciones de riesgo no forman parte del cálculo de una superficie de ataque, todas las limitaciones descubiertas deben contarse dentro de la superficie de ataque independientemente de si las mejores prácticas, las prácticas comunes o las prácticas legales indican que no son un riesgo. De lo contrario, la auditoría no mostrará una representación real de la seguridad operativa del alcance.

Manejo de limitaciones

Otro concepto que se debe tener en cuenta es el de gestionar fallas y errores en una auditoría.

Las tres formas más sencillas de gestionar las limitaciones son eliminar por completo el área problemática que proporciona el punto interactivo, solucionarlas o aceptarlas como parte de la actividad empresarial conocida como justificación empresarial.

Una auditoría suele descubrir más de un problema por objetivo. El analista debe informar las limitaciones por objetivo y no solo cuáles son los objetivos débiles. Estas limitaciones pueden estar en las propias medidas de protección y controles, disminuyendo así OpSec. Cada limitación debe calificarse en función de lo que ocurre cuando se invoca el problema, incluso si esa invocación es teórica o la verificación es de ejecución limitada para restringir los daños reales. La categorización teórica, en la que no se puede realizar ninguna verificación, es una pendiente resbaladiza y debería limitarse a los casos en los que la verificación reduciría la calidad de las operaciones. Luego, al categorizar los problemas, cada limitación debe examinarse y calcularse en términos específicos de operación en sus componentes más básicos. Sin embargo, el analista debe asegurarse de no informar nunca un “defecto dentro de un defecto” en el que los defectos compartan el mismo componente y el mismo efecto operativo. Un ejemplo de esto sería una puerta abierta con una ventana rota. La apertura de la puerta es un Acceso incluso si la ventana rota también lo es, pero ambas son para el mismo componente, la puerta, y el mismo efecto operativo, una apertura. Un ejemplo de redes de datos sería un sistema informático que envía una respuesta del kernel, como un paquete ICMP T03C03 de “puerto cerrado” para un puerto en particular. Esta interacción no se cuenta para todos esos puertos ya que el acceso proviene del mismo componente, el kernel, y tiene el mismo efecto operativo: envía un paquete T03C03 por puerto consultado.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

1.5 Seguridad real

La función de los controles es controlar la porosidad en OpSec. Es como tener diez formas de controlar las amenazas que llegan a través de un agujero en una pared. Para cada hoyo, se pueden aplicar un máximo de diez controles diferentes que devuelven la seguridad al 100% y, en ocasiones, a más. Las limitaciones reducen entonces la eficacia de OpSec y los controles. El resultado de una auditoría que descubre y muestra la seguridad, los controles y las limitaciones demuestra efectivamente la seguridad real.

Seguridad real es un término para una instantánea de una superficie de ataque en un entorno operativo. Es una representación logarítmica de los controles, limitaciones y OpSec en un momento particular. Es logarítmico porque representa la realidad del tamaño donde un alcance mayor tendrá una superficie de ataque mayor incluso si matemáticamente los controles equilibrarán el OpSec. Al utilizar esto como elementos básicos para comprender mejor cómo funciona la seguridad, la visualización que creamos a partir de esto es el equilibrio efectivo creado entre dónde puede ocurrir un ataque, dónde están implementados los controles para gestionar un ataque y las limitaciones de las medidas de protección.

Otro beneficio de la representación matemática de una superficie de ataque como seguridad real es que además de mostrar dónde faltan medidas de protección, también puede mostrar lo contrario. Dado que es posible tener más controles de los necesarios, esto se puede representar matemáticamente como más del 100% rav. Si una evaluación de riesgos puede hacer que este punto parezca imposible, la representación matemática es útil para mostrar los residuos. Puede utilizarse para demostrar cuándo se está gastando demasiado dinero en tipos de controles incorrectos o controles redundantes.

1.6 Cumplimiento

El cumplimiento es algo diferente a la seguridad y existe aparte de la seguridad. Es posible ser compatible pero no seguro y es posible ser relativamente seguro pero no compatible y, por lo tanto, de baja confiabilidad.

Los proyectos de cumplimiento no son el momento para redefinir los requisitos de seguridad operativa como resultado de una prueba OSSTMM; sin embargo, pueden ser el momento para especificar el uso de pruebas OSSTMM, de forma periódica, para cumplir con un requisito de control redactado como resultado de un fideicomiso. evaluación que ha determinado el número mínimo de controles necesarios para lograr un estado conforme (pero no necesariamente seguro).

El gran problema con el cumplimiento es que requiere mucha documentación que debe versionarse y actualizarse. Esta documentación puede ser de procesos comerciales, narrativas, evaluaciones de confianza, evaluaciones de riesgos, pruebas de diseño aprobadas, auditorías operativas, certificaciones, etc. Esta documentación es examinada por auditores internos y externos y lógicamente debe cumplir con su existencia en el mundo de un Estado conforme.

Los esfuerzos de cumplimiento más recientes han sido impulsados por los requisitos a corto plazo de las regulaciones impuestas con requisitos de implementación a corto plazo. Esto ha creado muchos requisitos de recursos y costos. Si tenemos tiempo para pensar en ello, intentamos incorporar el cumplimiento y la producción de evidencia en un proceso y gestionar este requisito y costo de recursos.

El cumplimiento es un enfoque amplio para la aplicación de las mejores prácticas, en lo que respecta a la tecnología de la información, como COBIT e ITIL; Una prueba OSSTMM debe proporcionar documentación que proporcione un nivel de calidad comprensible y verificable. Sin embargo, el uso de OSSTMM está diseñado para permitir que el analista vea y comprenda la seguridad y la protección. Por lo tanto, con el uso de esta metodología, cualquier cumplimiento es, al menos, la producción de evidencia de gobernanza dentro del proceso empresarial de seguridad.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

Los hechos no surgen de los grandes avances del descubrimiento, sino más bien de los pequeños y cuidadosos pasos de la verificación.



Capítulo 2 – Lo que necesitas hacer

¿Por dónde empiezas? Las pruebas son un asunto complicado y, cuando se trata de algo complicado, se aborda en partes pequeñas y comprensibles para asegurarse de no cometer errores.

La sabiduría convencional dice que la complejidad es enemiga de la seguridad. Sin embargo, esto sólo está en desacuerdo con la naturaleza humana. Todo lo que se hace más complejo no es intrínsecamente inseguro. Considere una computadora que gestiona tareas complejas. El problema tal como lo conocemos no es que la computadora cometa errores, confunda las tareas u olvide completar algunas. A medida que se agregan más tareas a la computadora, se vuelve cada vez más lenta y lleva más tiempo completar todas las tareas. Las personas, sin embargo, cometen errores, olvidan tareas y abandonan deliberadamente tareas que no son importantes o no son necesarias en ese momento. Entonces, al probar la seguridad, lo que hay que hacer es gestionar adecuadamente cualquier complejidad. Esto se hace definiendo adecuadamente la prueba de seguridad.

2.1 Definición de una prueba de seguridad

Estos 7 pasos lo llevarán al inicio de una prueba de seguridad adecuadamente definida.

1. Define qué quieres proteger. Estos son los activos. Los mecanismos de protección de estos activos son los controles que probará para identificar limitaciones.
2. Identificar el área alrededor de los activos que incluye los mecanismos de protección y los procesos o servicios construidos alrededor de los activos. Aquí es donde tendrá lugar la interacción con los activos. Esta es tu zona de compromiso.
3. Defina todo lo que necesita fuera de la zona de participación para mantener sus activos operativos. Esto puede incluir cosas en las que quizás no puedas influir directamente, como electricidad, alimentos, agua, aire, suelo estable, información, legislación, regulaciones y cosas con las que puedas trabajar, como sequedad, calidez, frescura, claridad, contratistas, colegas, , marca, asociaciones, etc. Cuente también lo que mantiene operativa la infraestructura, como procesos, protocolos y recursos continuos. Este es su alcance de prueba.
4. Defina cómo interactúa su alcance dentro de sí mismo y con el exterior. Compartimente lógicamente los activos dentro del alcance a través de la dirección de las interacciones, como de adentro hacia afuera, de afuera hacia adentro, de adentro hacia adentro, del departamento A al departamento B, etc. Estos son sus vectores. Idealmente, cada vector debería ser una prueba separada para mantener corta la duración de cada prueba compartimentada antes de que puedan ocurrir demasiados cambios en el medio ambiente.
5. Identifique qué equipo se necesitará para cada prueba. Dentro de cada vector, pueden ocurrir interacciones en varios niveles. Estos niveles pueden clasificarse de muchas maneras; sin embargo, aquí se han clasificado según su función en cinco canales. Los canales son Redes Humanas, Físicas, Inalámbricas, Telecomunicaciones y de Datos. Cada canal debe probarse por separado para cada vector.
6. Determine qué información desea aprender de la prueba. ¿Probarán las interacciones con los activos o también la respuesta de las medidas de seguridad activas? El tipo de prueba debe definirse individualmente para cada prueba; sin embargo, aquí se identifican seis tipos comunes: ciego, doble ciego, caja gris, caja gris doble, tándem e inversión.
7. Asegúrese de que la prueba de seguridad que ha definido cumpla con las Reglas de compromiso, una guía para garantizar que el proceso sea una prueba de seguridad adecuada sin crear malentendidos, conceptos erróneos o falsas expectativas.

El resultado final será una medición de su superficie de ataque. La superficie de ataque es la parte desprotegida del Alcance de un Vector definido.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

2.2 Alcance

El alcance es el entorno de seguridad operativo total posible para cualquier interacción con cualquier activo, que también puede incluir los componentes físicos de las medidas de seguridad. El alcance se compone de tres clases de las cuales existen cinco canales: Canales de seguridad de Redes de Datos y Telecomunicaciones de clase COMSEC, Canales de Seguridad Física y Humana de clase PHYSSEC y Canal de Seguridad Inalámbrica de espectro completo de clase SPECSEC. Las clases provienen de designaciones oficiales que se utilizan actualmente en la industria de la seguridad, el gobierno y el ejército. Las clases se utilizan para definir un área de estudio, investigación u operación. Sin embargo, los Canales son el medio específico de interactuar con los activos. Un activo puede ser cualquier cosa que tenga valor para el propietario. Los activos pueden ser propiedades físicas como oro, personas, planos, computadoras portátiles, la típica señal telefónica de frecuencia de 900 MHz y dinero; o propiedad intelectual como datos personales, una relación, una marca, procesos comerciales, contraseñas y cualquier cosa que se diga a través de la señal telefónica de 900 MHz. A menudo, el alcance se extiende mucho más allá del alcance del propietario del activo, ya que las dependencias están más allá de la capacidad del propietario del activo para proporcionar servicios de forma independiente. El alcance requiere que todas las amenazas se consideren posibles, incluso si no son probables. Aunque, hay que dejar claro que un análisis de seguridad debe restringirse a aquello que está dentro de un tipo de certeza (no confundir con riesgo que no es una certeza sino una probabilidad). Estas restricciones incluyen:

1. No eventos, como la erupción de un volcán donde no existe ningún volcán,
2. No impacto, como la luz de la luna a través de la ventana del centro de datos, o
3. Impacto global, como el impacto de un meteorito catastrófico.

Si bien una auditoría de seguridad exhaustiva requiere probar los cinco canales, de manera realista, las pruebas se realizan y clasifican según la experiencia requerida del analista y el equipo requerido para la auditoría.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

Canales

Clase	Canal	Descripción
Seguridad física (FÍSICO)	Humano	Comprende el elemento humano de la comunicación donde la interacción es física o psicológica.
	Físico	Pruebas de seguridad física donde el canal es de naturaleza tanto física como no electrónica. Comprende el elemento tangible de seguridad donde la interacción requiere esfuerzo físico o un transmisor de energía para manipular.
Seguridad del espectro (ESPECIFICACIONES)	Inalámbrico	Comprende todas las comunicaciones, señales y emanaciones electrónicas que tienen lugar en el espectro EM conocido. Esto incluye ELSEC como comunicaciones electrónicas, SIGSEC como señales y EMSEC que son emanaciones no unidas por cables.
Comunicaciones Seguridad (COMSEC)	Telecomunicaciones	Comprende todas las redes de telecomunicaciones, digitales o analógicas, donde la interacción se realiza a través de líneas telefónicas establecidas o de redes similares.
	Redes de datos	Comprende todos los sistemas electrónicos y redes de datos donde la interacción se realiza a través de líneas de redes cableadas y cableadas establecidas. Redes de datos

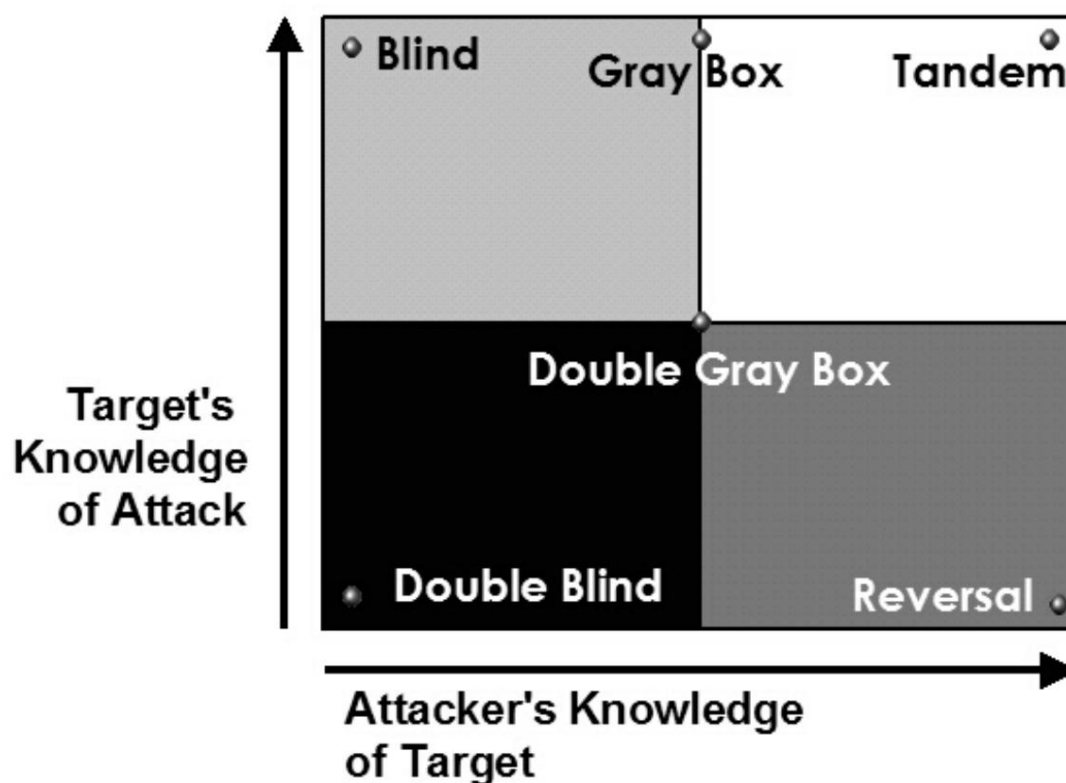
Si bien los canales y sus divisiones pueden representarse de cualquier forma, en este manual están organizados como medios reconocibles de comunicación e interacción. Esta organización está diseñada para facilitar el proceso de prueba y al mismo tiempo minimizar los gastos generales ineficientes que a menudo se asocian con metodologías estrictas.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

2.3 Tipos de pruebas comunes

Estos seis tipos difieren según la cantidad de información que el evaluador conoce sobre los objetivos, lo que el objetivo sabe sobre el evaluador o espera de la prueba y la legitimidad de la prueba. Algunas pruebas pondrán a prueba la habilidad del evaluador más que probar la seguridad de un objetivo.



Tenga en cuenta que al informar la auditoría, a menudo existe el requisito de identificar exactamente el tipo de auditoría realizada. Con demasiada frecuencia, las auditorías basadas en diferentes tipos de pruebas se comparan para rastrear el delta (desviaciones) de una línea base establecida del alcance. Si el tipo de prueba preciso no está disponible para un revisor o regulador externo, la auditoría en sí debe considerarse una prueba ciega, que es la que tiene menos mérito para una prueba de seguridad exhaustiva.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

Tipo		Descripción
1	Ciego	El Analista ataca al objetivo sin conocimiento previo de sus defensas, activos o canales. El objetivo está preparado para la auditoría, conociendo de antemano todos los detalles de la misma. Una auditoría ciega pone a prueba principalmente las habilidades del analista. La amplitud y profundidad de una auditoría ciega sólo puede ser tan amplia como lo permitan el conocimiento aplicable y la eficiencia del analista. En COMSEC y SPECSEC, esto a menudo se denomina piratería ética y en la clase PHYSSEC, generalmente se escribe como juegos de guerra o juegos de guerra.
2	Doble ciego	El Analista ataca al objetivo sin conocimiento previo de sus defensas, activos o canales. No se notifica al objetivo con antelación el alcance de la auditoría, los canales probados o los vectores de prueba. Una auditoría doble ciego pone a prueba las habilidades del analista y la preparación del objetivo ante variables desconocidas de agitación. La amplitud y profundidad de cualquier auditoría ciega sólo puede ser tan amplia como lo permitan el conocimiento aplicable y la eficiencia del analista. Esto también se conoce como prueba de caja negra o prueba de penetración.
3	Caja Gris	El Analista aborda el objetivo con un conocimiento limitado de sus defensas y activos y un conocimiento pleno de los canales. El objetivo está preparado para la auditoría, conociendo de antemano todos los detalles de la misma. Una auditoría de caja gris pone a prueba las habilidades del analista. La naturaleza de la prueba es la eficiencia. La amplitud y profundidad dependen de la calidad de la información proporcionada al Analista antes de la prueba, así como del conocimiento aplicable del Analista. Este tipo de prueba a menudo se denomina prueba de vulnerabilidad y la mayoría de las veces la inicia el objetivo como una autoevaluación.
4	Doble Gris Caja	El Analista aborda el objetivo con un conocimiento limitado de sus defensas y activos y un conocimiento pleno de los canales. Se notifica al objetivo con antelación el alcance y el plazo de la auditoría, pero no los canales probados ni los vectores de prueba. Una auditoría de doble caja gris pone a prueba las habilidades del analista y la preparación del objetivo ante variables desconocidas de agitación. La amplitud y profundidad dependen de la calidad de la información proporcionada al analista y al objetivo antes de la prueba, así como del conocimiento aplicable del analista. Esto también se conoce como prueba de caja blanca .
5	tándem	El Analista y el objetivo están preparados para la auditoría, conociendo ambos de antemano todos los detalles de la misma. Una auditoría en tándem prueba la protección y los controles del objetivo. Sin embargo, no puede probar la preparación del objetivo ante variables desconocidas de agitación. La verdadera naturaleza de la prueba es la minuciosidad, ya que el analista tiene una visión completa de todas las pruebas y sus respuestas. La amplitud y profundidad dependen de la calidad de la información proporcionada al Analista antes de la prueba (transparencia), así como del conocimiento aplicable del Analista. Esto a menudo se conoce como auditoría interna o prueba de Crystal Box y el analista suele ser parte del proceso de seguridad.
6	Inversión	El analista interactúa con el objetivo con pleno conocimiento de sus procesos y seguridad operativa, pero el objetivo no sabe nada de qué, cómo o cuándo realizará las pruebas el analista. La verdadera naturaleza de esta prueba es auditar la preparación del objetivo ante variables y vectores de agitación desconocidos. La amplitud y profundidad dependen de la calidad de la información proporcionada al Analista y del conocimiento y la creatividad aplicables del Analista. A esto también se le suele llamar ejercicio del Equipo Rojo.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

2.4 Reglas de compromiso Estas

reglas definen las pautas operativas de prácticas aceptables en marketing y venta de pruebas, realización de trabajos de prueba y manejo de los resultados de los compromisos de prueba.

A. Ventas y marketing

1. El uso del miedo, la incertidumbre, la duda y el engaño no se pueden utilizar en presentaciones de ventas o marketing, sitios web, materiales de apoyo, informes o discusiones sobre pruebas de seguridad con el fin de vender o proporcionar pruebas de seguridad. Esto incluye, entre otros, resaltar delitos, hechos, perfiles de delincuentes o piratas informáticos glorificados y estadísticas para motivar las ventas.
2. Queda prohibida la oferta de servicios gratuitos por no lograr la penetración en el objetivo.
3. Están prohibidos los concursos públicos de craqueo, piratería informática y traspaso para promover la garantía de seguridad para la venta o comercialización de pruebas de seguridad o productos de seguridad.
4. Solo se permite nombrar clientes pasados o presentes en el marketing o las ventas para clientes potenciales si el trabajo para el cliente era específicamente el mismo que se comercializa o vende y el cliente nombrado ha proporcionado permiso por escrito para hacerlo.
5. Se requiere que los clientes sean informados de manera veraz y objetiva con respecto a sus medidas de seguridad y protección. La ignorancia no es excusa para una consultoría deshonesta.

B. Evaluación/Entrega estimada

6. Realizar pruebas de seguridad en cualquier ámbito sin el permiso explícito por escrito del objetivo. propietario o autoridad competente está estrictamente prohibido.
7. Las pruebas de seguridad de sistemas, ubicaciones y procesos obviamente altamente inseguros e inestables son prohibido hasta que se haya establecido la infraestructura de seguridad adecuada.

C. Contratos y Negociaciones

8. Con o sin un contrato de acuerdo de confidencialidad, el analista de seguridad debe brindar confidencialidad y no divulgación de la información del cliente y los resultados de las pruebas.
9. Los contratos deberían limitar la responsabilidad al costo del trabajo, a menos que se haya demostrado una actividad maliciosa.
10. Los contratos deben explicar claramente los límites y peligros de la prueba de seguridad como parte de la declaración de trabajar.
11. En el caso de pruebas remotas, el contrato deberá incluir el origen de los Analistas por domicilio, número de teléfono o dirección IP.
12. El cliente debe proporcionar una declaración firmada que proporcione permiso de prueba que exima a los Analistas de traspasar el alcance y responsabilice por daños y perjuicios al costo del servicio de auditoría con la excepción de que se haya demostrado actividad maliciosa.
13. Los contratos deben contener nombres y números de teléfono de contactos de emergencia.
14. El contrato debe incluir permisos claros y específicos para pruebas que involucren fallas de supervivencia, denegación de servicio, pruebas de procesos e ingeniería social.
15. Los contratos deben contener el proceso para futuros cambios en el contrato y la declaración de trabajo (SOW).
16. Los contratos deben contener conflictos de intereses verificados para una prueba e informe de seguridad fáctico.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

D. Definición del alcance

17. El alcance debe definirse claramente contractualmente antes de verificar los servicios vulnerables.
18. La auditoría debe explicar claramente los límites de cualquier prueba de seguridad según su alcance.

E. Plan de prueba

19. El plan de pruebas no podrá contener planes, procesos, técnicas o procedimientos que estén fuera del área de especialización o nivel de competencia del Analista.

F. Proceso de prueba

20. El Analista debe respetar y mantener la seguridad, la salud, el bienestar y la privacidad del público tanto dentro como fuera del alcance.
21. El Analista siempre debe operar dentro de la ley de la ubicación física de los objetivos, además a las reglas o leyes que rigen la ubicación de la prueba del Analista.
22. Para evitar aumentos temporales en la seguridad durante la duración de la prueba, notifique únicamente a las personas clave sobre la prueba. Es el juicio del cliente el que discierne quiénes son las personas clave; sin embargo, se supone que serán guardianes de información y políticas, administradores de procesos de seguridad, personal de respuesta a incidentes y personal de operaciones de seguridad.
23. Si es necesario para pruebas con privilegios, el cliente debe proporcionar dos tokens de acceso separados, ya sean contraseñas, certificados, números de identificación seguros, insignias, etc., y deben ser típicos para los usuarios de los privilegios que se están probando, en lugar de estar especialmente vacíos. o accesos seguros.
24. Cuando las pruebas incluyen privilegios conocidos, el analista primero debe realizar pruebas sin privilegios (como en un entorno de caja negra) antes de realizar la prueba nuevamente con privilegios.
25. Se requiere que los analistas conozcan sus herramientas, de dónde provienen, cómo funcionan y que las prueben en un área de prueba restringida antes de usarlas en la organización del cliente.
26. La realización de pruebas que están explícitamente destinadas a probar la denegación de un servicio o proceso o la capacidad de supervivencia solo se puede realizar con un permiso explícito y solo en el alcance donde no se causan daños fuera del alcance o de la comunidad en la que reside el alcance. .
27. Las pruebas que involucren a personas solo podrán realizarse en aquellas identificadas en el alcance y no podrán incluir a personas privadas, clientes, socios, asociados u otras entidades externas sin el permiso escrito de dichas entidades.
28. Las limitaciones verificadas, como infracciones descubiertas, vulnerabilidades con tasas de explotación conocidas o altas, vulnerabilidades que son explotables para un acceso completo, no monitoreado o imposible de rastrear, o que pueden poner inmediatamente en peligro vidas, descubiertas durante las pruebas, deben informarse al cliente con una solución práctica. tan pronto como se encuentren.
29. Cualquier forma de prueba de inundación en la que el alcance se vea abrumado por una fuente más grande y más potente está prohibida en canales que no sean de propiedad privada.
30. El Analista no puede dejar el alcance en una posición de menor seguridad real que cuando estaba proporcionó.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

G. Informes

31. El Analista debe respetar la privacidad de todos los individuos y mantener su privacidad para todos los resultados.
32. Los resultados que involucren a personas no capacitadas en seguridad o personal ajeno a la seguridad sólo podrán reportarse a través de medios no identificativos o estadísticos.
33. El Analista no podrá firmar resultados de pruebas e informes de auditoría en los que no haya participado directamente.
34. Los informes deben ser objetivos y sin falsedades ni malicia dirigida personalmente.
35. Se requieren notificaciones al cliente cada vez que el Analista cambia el plan de pruebas, cambia el lugar de prueba de origen, tiene resultados de baja confianza o se produce cualquier problema de prueba. Se deben proporcionar notificaciones antes de ejecutar pruebas nuevas, peligrosas o de alto tráfico, y se requieren actualizaciones periódicas del progreso.
36. Cuando en el informe se incluyan soluciones y recomendaciones, estas deben ser válidas y práctico.
37. Los informes deben señalar claramente todas las incógnitas y anomalías.
38. Los informes deben indicar claramente las medidas de seguridad exitosas y fallidas descubiertas y las pérdidas. control S.
39. Los informes deben utilizar únicamente métricas cuantitativas para medir la seguridad. Estas métricas deben basarse en hechos y estar libres de interpretaciones subjetivas.
40. El cliente debe ser notificado cuando se envía el informe para esperar su llegada y confirmar recibo de entrega.
41. Todos los canales de comunicación para la entrega del informe deben ser confidenciales de extremo a extremo.
42. Los resultados y los informes nunca podrán utilizarse para obtener beneficios comerciales más allá de la interacción con el cliente.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

2.5 El proceso de prueba de seguridad operativa ¿Por qué probar

las operaciones? Desafortunadamente, no todo funciona según lo configurado. No todo el mundo se comporta según lo entrenado. Por tanto la verdad de la configuración y el entrenamiento está en las operaciones resultantes. Por eso necesitamos probar las operaciones.

El proceso de prueba OpSec es una prueba de eventos discretos de un sistema estocástico dinámico. Esto significa que realizará una secuencia cronológica de pruebas en un sistema que cambia y no siempre proporciona el mismo resultado para la entrada proporcionada. El objetivo es un sistema, una colección de procesos interactuantes y codependientes que también está influenciado por el entorno estocástico en el que existe. Ser estocástico significa que el comportamiento de los eventos en un sistema no se puede determinar porque el siguiente estado ambiental sólo puede ser parcial pero no totalmente determinado por el estado anterior. El sistema contiene un número finito pero posiblemente extremadamente grande de variables y cada cambio en las variables puede presentar un evento y un cambio de estado. Dado que el entorno es estocástico, existe un elemento de aleatoriedad y no hay medios para predeterminar con certeza cómo afectarán todas las variables al estado del sistema.

La mayor parte de lo que la gente entiende sobre OpSec proviene del aspecto defensivo, lo cual es comprensible ya que la seguridad generalmente se considera una estrategia defensiva. Las pruebas agresivas de OpSec quedan entonces relegadas a la misma clase que la explotación y elusión del diseño o configuración actual. Sin embargo, el problema fundamental de esta técnica es que un diseño o configuración no equivale a funcionamiento.

Nos encontramos con muchos casos en la vida donde la operación no se ajusta a la configuración. Un ejemplo sencillo es una descripción de trabajo típica. Es más común que la política que dicta el trabajo de una persona, también conocida como descripción del trabajo, no refleje realmente lo que hacemos en el trabajo. Otro ejemplo es el canal de televisión. El hecho de que un canal esté configurado en una frecuencia particular (configurada) no significa que recibiremos el programa transmitido en ese canal o solo ese programa.

Esta metodología de prueba de seguridad está diseñada según el principio de verificar la seguridad de las operaciones. Si bien es posible que no siempre se prueben los procesos y las políticas directamente, una prueba exitosa de las operaciones permitirá el análisis de datos tanto directos como indirectos para estudiar la brecha entre operaciones y procesos. Esto mostrará el tamaño de la brecha entre lo que la gerencia espera de las operaciones a partir de los procesos que desarrollaron y lo que realmente está sucediendo. Dicho de manera más simple, el objetivo del analista es responder: "¿cómo funcionan las operaciones actuales y en qué se diferencian de cómo la gerencia cree que funcionan?"

Un punto a destacar es la extensa investigación disponible sobre el control de cambios en los procesos para limitar la cantidad de eventos indeterminables en un sistema estocástico. El analista a menudo intentará exceder las limitaciones del control de cambios y presentará escenarios hipotéticos que los implementadores del control de cambios tal vez no hayan considerado. Una comprensión profunda del control de cambios es esencial para cualquier analista.

Por lo tanto, una prueba de seguridad operativa requiere una comprensión profunda del proceso de prueba, elegir el tipo correcto de prueba, reconocer los canales y vectores de prueba, definir el alcance según el índice correcto y aplicar la metodología correctamente.

Curiosamente, en ninguna parte, excepto en las pruebas de seguridad, el proceso de eco se considera la prueba de facto. Al igual que gritar en un área cavernosa y esperar la respuesta, el proceso de eco requiere interactuar y luego monitorear las emanaciones del objetivo en busca de indicadores de un estado particular, como seguro o inseguro, vulnerable o protegido, encendido o apagado, izquierda o derecha. El proceso de eco es del tipo de verificación de causa y efecto. El Analista determina la causa y analiza el efecto sobre el objetivo. Es extraño que este sea el medio principal para probar algo tan crítico como la seguridad porque, aunque es una prueba muy rápida, también es muy propensa a errores, algunos de los cuales pueden ser devastadores para el objetivo. Considere que en una prueba de seguridad que utiliza el proceso de eco, un objetivo que no responde se considera seguro. Siguiendo esa lógica, un



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

El objetivo solo necesita no responder a un tipo particular de solicitud para dar la apariencia de seguridad; sin embargo, aún debe ser completamente interactivo con otros tipos de solicitudes, lo que demuestra que no ha habido separación.

Si los hospitales utilizaran el proceso de eco para determinar la salud de un individuo, rara vez ayudaría a las personas, pero al menos el tiempo en la sala de espera sería muy corto. Sin embargo, los hospitales, como la mayoría de las otras industrias científicas, aplican el proceso de cuatro puntos, que incluye una función del proceso de eco llamada "interacción" como una de las cuatro pruebas. Las otras tres pruebas son: la "investigación" de lectura de emanaciones del paciente como pulso, presión arterial y ondas cerebrales; la "intervención" de cambiar y enfatizar las condiciones operativas tales como la homeostasis, el comportamiento, la rutina o el nivel de comodidad del paciente; y la "inducción" de examinar el entorno y cómo puede haber afectado al objetivo, como analizar con qué ha interactuado, tocado, comido, bebido o respirado el paciente. Sin embargo, en las pruebas de seguridad, la mayoría de las pruebas se basan en la proceso de eco solo. Hay tanta información perdida en pruebas unidimensionales que deberíamos estar agradecidos de que la industria del cuidado de la salud haya evolucionado más allá del simple "¿Duele si hago esto?" forma de diagnóstico.

El proceso de prueba de seguridad de esta metodología no recomienda el proceso de eco por sí solo para obtener resultados confiables. Si bien el proceso de eco puede usarse para ciertas pruebas, en particular donde el margen de error es pequeño y la mayor eficiencia permite pasar tiempo a otras técnicas que requieren mucho tiempo, no se recomienda para pruebas fuera de un entorno determinista. El Analista debe elegir cuidadosamente cuándo y bajo qué condiciones aplicar el proceso de eco.

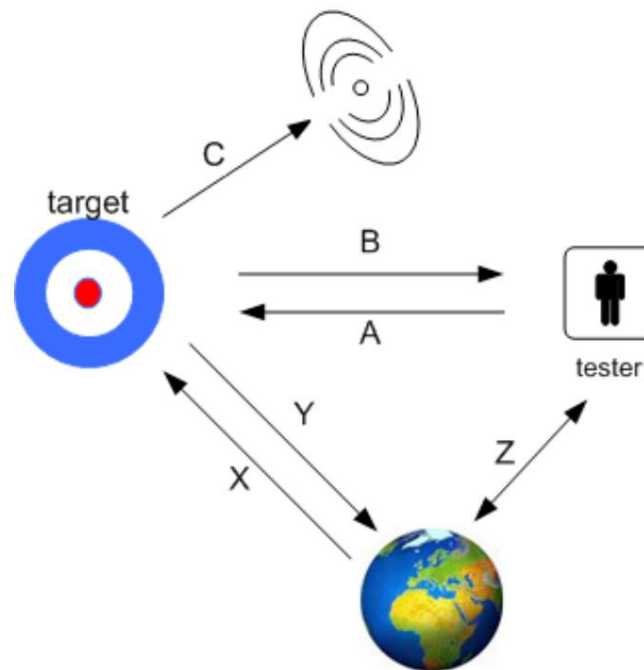
Si bien existen muchos procesos de prueba, el proceso de cuatro puntos para pruebas de seguridad está diseñado para lograr una eficiencia, precisión y minuciosidad óptimas para garantizar la validez de las pruebas y minimizar los errores en entornos estocásticos y no controlados. Está optimizado para escenarios de prueba del mundo real fuera del laboratorio. Si bien también utiliza agitación, se diferencia del proceso de eco en que permite determinar más de una causa por efecto y más de un efecto por causa.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

2.6 Proceso de cuatro puntos

El Proceso de Cuatro Puntos (4PP) analiza una prueba desde el principio hasta el final. Estas son cosas que ya hace un grupo de pruebas experimentado. No confunda la formalidad en la disección del proceso con la formalidad del informe. No es necesario que muestre cada paso que se está realizando, pero debe comprender cómo llegó de A a C. Es como darle a la gente indicaciones para llegar en automóvil. Les dices los pasos sobre dónde girar y la proximidad relativa a las cosas que verán para saber que van en el camino correcto, pero no les dices cada calle por la que conducen ni cada señal de tráfico que deben obedecer para llegar al final. . Bueno, el 4PP son las direcciones específicas y los medios y la presentación de informes son en realidad relativistas.



Interacciones dentro del proceso de 4 puntos

1. Inducción: (Z) establecer verdades principales sobre el objetivo a partir de leyes y hechos ambientales. El analista determina los principios fácticos con respecto al objetivo a partir del entorno donde reside el objetivo. Como el objetivo estará influenciado por su entorno, su comportamiento será determinable dentro de esta influencia. Cuando el objetivo no está influenciado por su entorno, existe una anomalía que debe comprenderse.
2. Investigación: (C) investigar las emanaciones del objetivo. El Analista investiga las emanaciones del objetivo y cualquier rastro o indicador de esas emanaciones. Un sistema o proceso generalmente dejará una firma de su existencia a través de interacciones con su entorno.
3. Interacción: (A/B) como pruebas de eco, interacciones estándar y no estándar con el objetivo para desencadenar respuestas. El analista preguntará o agitará al objetivo para generar respuestas para el análisis.
4. Intervención: (X/Y/Z) cambiar las interacciones de recursos con el objetivo o entre objetivos. El Analista intervendrá con los recursos que el objetivo requiere de su entorno o de sus interacciones con otros objetivos para comprender los extremos bajo los cuales puede continuar operando adecuadamente.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

2.7 La trífectoria

Esta metodología de pruebas de seguridad tiene una base sólida que puede parecer bastante complicada, pero en realidad es sencilla en la práctica. Está diseñado como un diagrama de flujo; sin embargo, a diferencia del diagrama de flujo estándar, el flujo, representado por las flechas, puede ir tanto hacia atrás como hacia adelante. De esta forma, está más integrada y si bien el principio y el final están claros, la auditoría tiene mayor flexibilidad. El analista crea un camino único a través de la metodología en función del objetivo, el tipo de prueba, el tiempo asignado para la auditoría y los recursos aplicados a la prueba. Para una orquesta, el compositor escribe la partitura para designar el orden y la duración de las notas, pero sólo el director puede controlar la ejecución de la interpretación. Esta metodología es como la partitura, designando las pruebas necesarias, pero el Analista controla el orden, la duración, así como la ejecución. La razón principal para exigir este nivel de flexibilidad en el OSSTMM es que ninguna metodología puede presumir con precisión las justificaciones para las operaciones de los gateways de canal en un objetivo y su nivel adecuado de seguridad. Más directamente, esta metodología no puede presumir una mejor práctica para realizar todas las auditorías, ya que las mejores prácticas se basan en una configuración específica de operaciones.

Las mejores prácticas sólo son las mejores para algunos; generalmente el creador de la práctica. Las operaciones dictan cómo se deben ofrecer los servicios, y esos servicios dictan los requisitos para la seguridad operativa. Por lo tanto, una metodología que se invoca de manera diferente para cada auditoría y por cada Analista aún puede tener el mismo resultado final si el Analista completa la metodología. Por esta razón uno de los fundamentos del OSSTMM es registrar precisamente lo que no fue probado. Al comparar lo que se probó y la profundidad de las pruebas con otras pruebas, es posible medir la seguridad operativa (OpSec) en función de los resultados de las pruebas.

Por lo tanto, la aplicación de esta metodología cumplirá el objetivo del analista de responder las siguientes tres preguntas que conforman la Trífectoria, la respuesta a las necesidades de OpSec.

1. ¿Cómo funcionan las operaciones actuales?

Las métricas derivadas se pueden aplicar para determinar las áreas problemáticas dentro del alcance y qué problemas deben abordarse. Las métricas de esta metodología están diseñadas para mapear los problemas de diferentes maneras a fin de mostrar si el problema es general o más específico, como un descuido o un error.

2. ¿En qué se diferencian de cómo la dirección cree que funcionan?

El acceso a políticas o una evaluación de confianza (o incluso de riesgo) se relacionará con las diferentes categorías de métricas. Las categorías proporcionan los valores del estado actual donde se puede hacer una comparación tanto con un estado óptimo según las políticas como con uno según las amenazas evaluadas.

3. ¿Cómo necesitan trabajar?

Cuando las métricas no muestran ninguna brecha entre los valores óptimos de la evaluación de la política o la confianza (o el riesgo), pero la prueba de seguridad muestra que efectivamente existe un problema de protección independientemente de los controles implementados en la política, es posible indicar claramente un problema. A menudo, sin siquiera mapear las políticas, una discrepancia entre los controles implementados y la pérdida de protección es simplemente evidente.

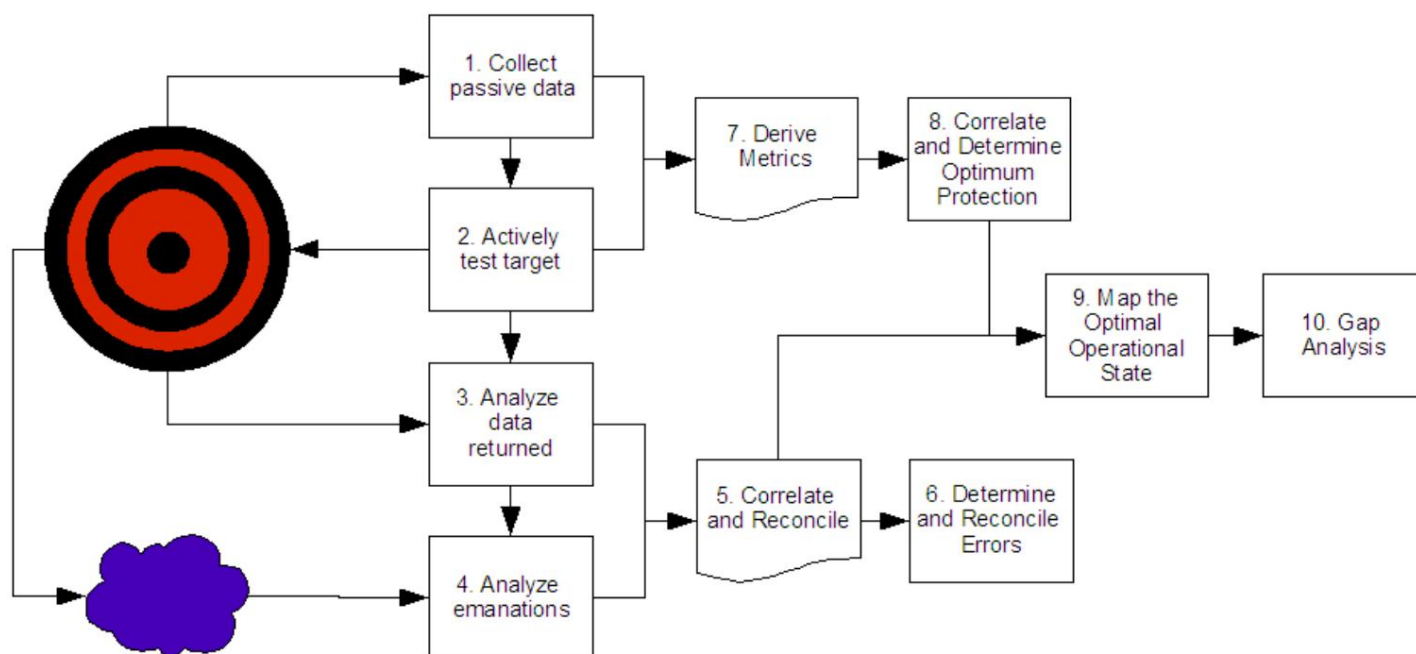


OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

Combinando la Trifecta y el Proceso de 4 Puntos

La Trifecta combinada con el Proceso de los Cuatro Puntos proporciona una aplicación sustancialmente exhaustiva de esta metodología. Los pasos de esta aplicación se pueden resumir de la siguiente manera:

1. Recopile pasivamente datos de operaciones normales para comprender el objetivo.
2. Pruebe activamente las operaciones agitando las más allá de la línea base normal.
3. Analizar los datos recibidos directamente de las operaciones probadas.
4. Analizar datos indirectos de recursos y operadores (es decir, trabajadores, programas).
5. Correlacionar y conciliar la inteligencia de los resultados de las pruebas de datos directos (paso 3) e indirectos (paso 4) con determinar los procesos operativos de seguridad.
6. Determinar y conciliar errores.
7. Derivar métricas tanto de operaciones normales como agitadas.
8. Correlacionar y conciliar la inteligencia entre operaciones normales y agitadas (pasos 1 y 2) para determinar el nivel óptimo de protección y control que sería mejor implementar.
9. Asigne el estado óptimo de las operaciones (paso 8) a los procesos (paso 5).
10. Crear un análisis de brechas para determinar qué mejoras se necesitan para los procesos que rigen protección y controles necesarios (paso 5) para lograr el estado operativo óptimo (paso 8) desde el actual.



Combinando la Trifecta y el Proceso de 4 Puntos



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

2.8 Manejo de errores La

veracidad en una prueba de seguridad no está en la suma de sus errores, sino en la contabilidad de sus errores. Dado que los errores pueden no ser culpa del analista, comprender cómo y dónde pueden existir errores dentro de una prueba es mucho más razonable que esperar que un analista realice pruebas sin errores. Además, es el analista que intenta lo que no debería ser posible el que tiene más probabilidades de encontrar errores; por lo tanto, señalar los errores como algo negativo descarta la práctica de pruebas exhaustivas.

Tipo de error		Descripción
1	falso positivo	Algo determinado como verdadero en realidad se revela falso. La respuesta objetivo indica un estado particular como verdadero aunque en realidad el estado no es verdadero. Un falso positivo ocurre a menudo cuando las expectativas o suposiciones del analista sobre lo que indica un estado particular no se ajustan a las condiciones del mundo real, que rara vez son blancas o negras.
2	falso negativo	Algo determinado como falso en realidad se revela como verdadero. La respuesta objetivo indica que un estado particular no es verdadero, aunque en realidad el estado es verdadero. Un falso negativo a menudo ocurre cuando las expectativas o suposiciones del analista sobre el objetivo no se ajustan a las condiciones del mundo real, las herramientas no son adecuadas para la prueba, las herramientas se utilizan mal o el analista carece de experiencia. Un falso negativo puede ser peligroso ya que es un diagnóstico erróneo de un estado seguro cuando no existe.
3	Gris Positivo	Algo responde verdadero a todo incluso si es falso. La respuesta del objetivo indica un estado particular como verdadero; sin embargo, el objetivo está diseñado para responder a cualquier causa con este estado, ya sea verdadero o no. Este tipo de seguridad a través de la oscuridad puede ser peligroso, ya que no se puede garantizar que la ilusión funcione de la misma manera para todos los estímulos.
4	Gris Negativo	Algo responde falso a todo, incluso si es verdadero. La respuesta del objetivo indica que un estado particular no es verdadero; sin embargo, el objetivo está diseñado para responder a cualquier causa con este estado, ya sea verdadero o no. Este tipo de seguridad a través de la oscuridad puede ser peligroso, ya que no se puede garantizar que la ilusión funcione de la misma manera para todos los estímulos.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

Tipo de error		Descripción
5 espectro		Algo responde verdadero o falso pero el estado real se revela como desconocido. La respuesta objetivo indica un estado particular como verdadero o falso aunque en realidad no se puede conocer el estado. Un espectro suele ocurrir cuando el analista recibe una respuesta de un estímulo externo que se percibe como proveniente del objetivo. Un espectro puede ser intencional, una anomalía dentro del canal o el resultado de un descuido o inexperiencia del Analista. Uno de los problemas más comunes en el proceso de eco es la suposición de que la respuesta es resultado de la prueba. Las pruebas de causa y efecto en el mundo real no pueden lograr resultados consistentemente confiables ya que ni la causa ni el efecto pueden aislarse adecuadamente.
6 indiscreción		Algo responde verdadero o falso dependiendo de cuándo se pregunta. La respuesta objetivo indica un estado particular como verdadero o falso, pero solo durante un tiempo particular, que puede seguir o no un patrón. Si la respuesta no se puede verificar en un momento en que el estado cambia, puede impedir que el analista comprenda el otro estado. Un analista también puede determinar que se trata de una anomalía o un problema con el equipo de prueba, especialmente si no calibra el equipo antes de la prueba o no realiza la logística y los controles adecuados. Una indiscreción puede ser peligrosa ya que puede dar lugar a informes falsos sobre el estado de seguridad.
7 Error de entropía		La respuesta se pierde o se confunde en el ruido de la señal. La respuesta del objetivo no puede indicar con precisión un estado particular como verdadero o falso debido a una alta relación ruido-señal. De manera similar a la idea de perder el haz de una linterna en la luz del sol, el analista no puede determinar adecuadamente el estado hasta que se reduzca el ruido. Este tipo de error causado por el entorno rara vez existe en un laboratorio; sin embargo, es algo normal en un entorno no controlado. La entropía puede ser peligrosa si sus efectos no pueden contrarrestarse.
8 Falsificación		La respuesta cambia dependiendo de cómo y dónde se hace la pregunta. La respuesta objetivo indica un estado particular como verdadero o falso, aunque en realidad el estado depende de variables en gran medida desconocidas debido al sesgo del objetivo. Este tipo de seguridad a través de la oscuridad puede ser peligroso, ya que el sesgo cambiará cuando las pruebas provengan de diferentes vectores o empleen diferentes técnicas. También es probable que el objetivo no sea consciente del sesgo.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

Tipo de error		Descripción
9	Error de muestreo	La respuesta no puede representar el todo porque se ha alterado el alcance. El objetivo es una muestra sesgada de un sistema más grande o de un mayor número de estados posibles. Este error normalmente ocurre cuando una autoridad influye en el estado operativo del objetivo durante la prueba. Esto puede deberse a limitaciones de tiempo específicas en la prueba o a una tendencia a probar solo los componentes designados como "importantes" dentro de un sistema. Este tipo de error provocará una tergiversación de la seguridad operativa general.
10	restricción	La respuesta cambia dependiendo de las limitaciones de las herramientas utilizadas. Las limitaciones de los sentidos humanos o de las capacidades de los equipos indican que un estado particular es verdadero o falso, aunque se desconoce el estado real. Este error no se debe a un mal juicio o a una elección incorrecta del equipo, sino que se trata de una falta de reconocimiento de las restricciones o limitaciones impuestas.
11	propagación	Se presume que la respuesta es de un estado u otro aunque no se hizo ninguna prueba. El Analista no realiza una prueba particular o tiene el sesgo de ignorar un resultado particular debido a un resultado presunto. Esto suele ser un cegamiento por experiencia o un sesgo de confirmación. La prueba se puede repetir muchas veces o se pueden modificar las herramientas y el equipo para obtener el resultado deseado. Como su nombre lo indica, un proceso que no recibe retroalimentación y los errores permanecen desconocidos o ignorados propagará más errores a medida que continúen las pruebas. Los errores de propagación pueden ser peligrosos porque los errores propagados desde las primeras etapas de las pruebas pueden no ser visibles durante un análisis de conclusiones. Además, se requiere un estudio de todo el proceso de prueba para descubrir errores de propagación.
12	error humano	La respuesta cambia según la habilidad del analista. Un error causado por falta de capacidad, experiencia o comprensión no es un sesgo y siempre es un factor presente, independientemente de la metodología o técnica. Si bien un analista experimentado puede cometer errores de propagación, es más probable que uno sin experiencia no reconozca el error humano, algo que la experiencia enseña a reconocer y compensar. Estadísticamente, existe una relación indirecta entre la experiencia y el error humano. Cuanta menos experiencia tenga un analista, mayor será la cantidad de errores humanos que puede contener una auditoría.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

Trabajar con errores de prueba

Durante la fase de análisis, un analista puede realizar un seguimiento de la cantidad y gravedad de los errores operativos de la prueba. Una simple autoevaluación puede crear un margen de errores operativos causados durante la prueba que el analista puede utilizar para enmarcar la minuciosidad de la auditoría actual u otras auditorías de sistemas similares.

Al tratarse de una autoevaluación, tendrá tendencia a ser sesgada. El analista debe tener mucho cuidado de que sea lo más objetivo posible como forma de garantía de calidad de la prueba y del proceso de prueba. Aunque algunos pueden intentar descartar los errores de prueba que fueron culpa del analista, realizar un seguimiento de todos los errores sólo puede mejorar las pruebas futuras y no es algo que deba ocultarse. Los errores ocurrirán y no son más que el intento del analista de interactuar con un sistema en constante cambio. Independientemente del número y la gravedad de los errores, el seguimiento de los errores de las pruebas servirá como registro de la dificultad y complejidad de la auditoría y de la competencia del Analista para deducir los errores.

Un registro de errores de prueba del alcance también ayudará a resumir el entorno de una manera simplista. Es una reducción sencilla del Resumen ejecutivo que a menudo describe la opinión del analista sobre el estado de seguridad en el que pocos o ningún error mostrarán un objetivo y un entorno bastante estáticos. Muchos errores muestran un entorno caótico y que puede carecer de controles para gestionar cambios o pérdidas.

En general, los registros de errores de prueba son útiles para comprender la complejidad de la auditoría y el control de cambios entre auditorías de intervalos regulares.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

Resultados de la prueba

Los resultados de las pruebas suelen ir acompañados de soluciones recomendadas u ofertas de consultoría, ninguna de las cuales es necesaria en una auditoría OSSTMM. Las soluciones recomendadas pueden proporcionarse como valor agregado a una prueba de seguridad, pero no se consideran obligatorias. A menudo no existen soluciones adecuadas basadas en la visión limitada que tiene un analista del entorno del cliente. Por lo tanto, no se requieren soluciones como parte de una auditoría OSSTMM.

Con frecuencia, una prueba excederá los límites de un control de seguridad. Dentro de un compromiso, el Analista siempre debe informar el estado actual de seguridad, cualquier limitación dentro de ese estado actual y cualquiera de los procesos que causaron esas limitaciones de los controles y protecciones aplicados.

Para medir tanto la minuciosidad de la prueba como la seguridad del objetivo, el uso de esta metodología debe concluir con el Informe de auditoría de prueba de seguridad (STAR), disponible en este manual o en el sitio web de ISECOM.

STAR requiere la siguiente información:

1. Fecha y hora de la prueba
2. Duración de la prueba
3. Nombres de los analistas responsables
4. Tipo de prueba
5. Alcance de la prueba
6. Índice (método de enumeración de objetivos)
7. Canal probado
8. Vector de prueba
9. Métrica de superficie de ataque
10. Qué pruebas se han completado, no completado o parcialmente completado, y en qué medida
11. Cualquier problema relacionado con la prueba y la validez de los resultados
12. Cualquier proceso que influya en las limitaciones de seguridad
13. Cualquier incógnita o anomalía

El uso exitoso del OSSTMM muestra una medición real de seguridad y controles. La tergiversación de los resultados en los informes puede dar lugar a una verificación fraudulenta de los controles de seguridad y a un nivel de seguridad inexacto. Para ello, el Analista debe aceptar la responsabilidad y la responsabilidad limitada por informes inexactos.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

2.9 Divulgación

Durante una prueba de seguridad, pueden salir a la luz la aparición de limitaciones de seguridad previamente desconocidas o no publicadas. Lo que un analista hace con estos es, ante todo, el resultado de las regulaciones legales de la región del analista y de la región donde se realiza el trabajo.

Derechos de divulgación

Lo que sí debe hacer es asegurarse de que su acceso y uso del producto o solución no requiera ningún tipo de disposición, contrato de confidencialidad o Acuerdo de licencia de usuario final (EULA) que le niegue el derecho a reclamar, anunciar, o distribuir cualquier vulnerabilidad descubierta. Si así fue y usted o el cliente aceptaron este contrato, entonces no podrá revelarlo a nadie, tal vez ni siquiera al fabricante, sin posibles repercusiones legales. Además, si trabaja para la empresa que fabrica ese producto o es un cliente legal suyo, es posible que tampoco pueda revelar nada legalmente. Además, sus derechos en cualquier caso pueden ser impugnados de acuerdo con el proceso legal de su región y no con el precedente legal existente.

Responsabilidades

Sin embargo, si esos casos no se aplican, entonces usted es efectivamente el propietario de esa vulnerabilidad y cuanto antes la haga pública, más derechos tendrá como propietario. En muchos países, los procesos y la información pueden estar protegidos por ley y, a menudo, el proceso legal requiere su publicación o presentación legal con atribución. Si su divulgación no puede causar ningún daño FÍSICO (como gritar fuego en un cine lleno de gente), es suyo y ninguna postura legal necesita sacudirlo cuando tiene razón. Sin embargo, para estar más seguro, también debe promover, junto con la vulnerabilidad revelada, los controles que se pueden aplicar para solucionar el problema. Por ejemplo, si hay un problema con la forma en que uno se autentica con una solución, entonces sugiera un esquema de autenticación alternativo y cómo se puede integrar exitosamente. No es necesario esperar a que el fabricante publique una solución o un retiro del mercado para permitir que la gente solucione el problema. Sin embargo, si decide trabajar en el contexto de notificar al fabricante, deberá darle tiempo suficiente para solucionar el problema antes de hacerlo público. Existe un argumento válido de que es posible que la vulnerabilidad ya sea conocida en los círculos criminales y requiera atención inmediata. Por lo tanto, si decide publicar sin la ayuda del fabricante, tenga en cuenta que incluir una solución también demostrará legalmente que tuvo buenas intenciones y gran parte del sistema legal se centra en la intención implícita.

Su elección depende de si las demandas frívolas se aceptan o prevalecen en su región. Recuerde, no es usted el analista quien debe realizar las pruebas de control de calidad para el fabricante, por lo tanto, no les debe ninguna información del trabajo que haya realizado, incluso si incluye su producto.

La divulgación completa es útil siempre y cuando no pueda causar daño físico o humano. Además, los consumidores no deberían tener que esperar a que los fabricantes solucionen sus problemas para que sus productos sean seguros. Si el producto no se vende como una solución específica de seguridad, entonces depende de los consumidores hacerlo seguro o no utilizarlo. Si se vende como seguro, entonces corresponde al fabricante arreglarlo; sin embargo, es posible que el consumidor no quiera esperar hasta que el fabricante pueda hacerlo. La divulgación completa permite esta elección.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

La debilidad no se encuentra analizando qué
es sino analizando qué hace.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

Capítulo 3 – Análisis de seguridad

El análisis de seguridad aquí se refiere a la habilidad de convertir la información en inteligencia de seguridad. Esto requiere comprender más que solo la información, sino también de dónde proviene, cómo y cuándo se recopiló, y las limitaciones del proceso de recolección. La parte final del proceso de análisis es crear inteligencia procesable, información derivada de hechos que pueda usarse para tomar decisiones. Ésta es la clara distinción entre seguridad y análisis de riesgos. En el análisis de seguridad, se producen hechos incluso si esos hechos indican que algo no se puede saber a partir de la información proporcionada. En el análisis de riesgos, se especula y se derivan opiniones basadas en información. El análisis de riesgos puede utilizar el análisis de seguridad para generar respuestas mejores y más precisas; sin embargo, el análisis de seguridad no puede utilizar el análisis de riesgos para mejorar la precisión. Por este motivo recomendamos el análisis de confianza.

Analizando la seguridad de todo

La diferencia fundamental entre hacer un análisis de riesgos versus un análisis de seguridad es que en el análisis de seguridad nunca se analiza la amenaza. Esto se debe a que suponer que se sabe qué amenazas existen, cuándo pueden aparecer, cómo llegarán y adónde irán es algo reservado al análisis de riesgos. En el análisis de seguridad, se estudia y mide la superficie de ataque de un objetivo y sus alrededores. Esto le permitirá comprender dónde pueden atacar las amenazas, cualquier amenaza, si es que atacan. Por ejemplo, considere un muro alto y largo. El análisis de riesgos considerará lo que puede atravesar la pared, pero el análisis de seguridad se centrará en dónde están las grietas, si los cimientos son sólidos y si la pared es lo suficientemente gruesa o alta como para impedir el acceso durante el tiempo suficiente para que llegue ayuda y responda. el ataque. Un análisis de seguridad también le permitirá asegurarse de que existan los controles adecuados, funcionen como deberían y cubran adecuadamente los puntos interactivos de los distintos vectores y canales accesibles.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

3.1 Pensamiento crítico de seguridad

El pensamiento crítico de seguridad, tal como se utiliza aquí, es un término para la práctica de utilizar la lógica y los hechos para formarse una idea sobre la seguridad. Esa idea puede ser una respuesta, una conclusión o una caracterización de algo o alguien para que se puedan definir bien las pruebas de verificación. Como respuesta o conclusión, el pensamiento crítico en materia de seguridad proporcionará lo que tenga más sentido. A modo de caracterización te mostrará qué necesitas verificar, según qué necesitas verificar, según qué vector, cómo y cuáles serán los objetivos. También le ayudará a respetar las diferentes opiniones o puntos de vista más allá de la seguridad misma y la interconexión que la seguridad genera con las personas, los lugares, los procesos y el dinero. Le ayudará a abordar conclusiones contradictorias y explorar consecuencias alternativas. Por lo tanto, incluso si el modelo de pensamiento crítico de seguridad no puede proporcionar una respuesta, debería indicarle qué datos aún faltan y de dónde debe obtenerlos.

El proceso de pensamiento crítico de seguridad depende de que el analista pueda discernir declaraciones verdaderas o al menos reconocer el grado de posible falsedad o propiedades dinámicas de una declaración. Una forma de hacerlo es reconocer la cantidad de confianza que se puede tener en un hecho mediante el uso de métricas de confianza. Otra forma es poder deconstruir una afirmación, separando los argumentos falaces. En la práctica, un analista deberá hacer ambas cosas. El analista deberá tener una buena comprensión de lo que se está analizando y una buena comprensión de las falacias lógicas utilizadas para formular calificativos, declaraciones basadas en conceptos falaces, generalmente en forma de axiomas o mejores prácticas.

La técnica del análisis de seis pasos

Desafortunadamente, el mundo no es prescriptivo. No todas las preguntas tienen una respuesta correcta. La exactitud de una respuesta depende de muchas cosas, incluida, más importante, cómo se pregunta. Este es un problema que afecta a todas las industrias, pero a ninguna tan obviamente como la seguridad, razón por la cual el pensamiento crítico en materia de seguridad es tan importante. Como técnica de análisis, se puede reducir a 6 pasos simples para determinar resultados factuales con un alto nivel de confianza en cuanto a su exactitud, incluso cuando las soluciones no son lineales, como cuando no hay conexión entre el punto A y el punto B. Por lo tanto, la capacidad de validar fuentes y Medir la confianza es crucial para obtener inteligencia adecuada y procesable a partir de las pruebas. En estos pasos, "objetivo" se refiere a cualquier cosa que esté analizando en preparación de una prueba, ya sean personas, computadoras, edificios o procesos.

1. Desarrolla tu conocimiento sobre el objetivo a partir de una variedad de los recursos fácticos más contemporáneos, evitando al mismo tiempo información especulativa y sesgada comercialmente.
2. Determinar el nivel global de experiencia para el tipo de objetivo y la cantidad de información.
posiblemente se sepa al respecto.
3. Determinar posibles sesgos o segundas intenciones en las fuentes de información.
4. Traducir la jerga de fuentes de información a palabras similares o conocidas para compararlas porque lo que puede parecer nuevo o complicado puede ser simplemente un truco para diferenciar algo común.
5. Asegúrese de que el equipo de prueba haya sido calibrado adecuadamente y que el entorno de prueba se haya verificado para
Asegúrese de que los resultados no estén contaminados por la prueba en sí.
6. Asegurar que el estado de traducción de herramientas o procesos de prueba se haya eliminado en la medida de lo posible para que los resultados no provengan de fuentes indirectas en un proceso o del análisis previo de algunas herramientas.

Lo más importante que hay que entender aquí es que a la hora de hacer una caracterización no te preocupes por tener razón. Es más importante tener razón sobre lo incorrecto o lo correcto, lo que significa que se realizaron las pruebas correctas para verificar la caracterización. Entonces, si la caracterización es incorrecta, al menos sabremos con certeza que es incorrecta y podremos volver a caracterizarla. Así es como funciona el método científico. No se trata de creer o confiar en tu experiencia, por amplia que sea, sino de conocer hechos sobre los que podemos construir.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

Falacias como calificativos

Un problema adicional de la humanización de las pruebas como una forma de arte en lugar de manejarlas como una ciencia es que introduce todo tipo de errores nuevos. Comprender nuestras propias limitaciones como seres humanos y cómo pensamos influye en cómo se puede percibir y definir la seguridad. Esto lleva a muchos profesionales de la seguridad a proporcionar calificativos para lo que no entienden o no pueden cumplir. Aunque la mayoría de las veces simplemente se repiten como axiomas sin pensarlo más, eventualmente se aceptan como verdades de seguridad. Esto perjudica aún más nuestra capacidad de proporcionar una seguridad adecuada porque nuestro análisis está pervertido por frases hechas y mejores prácticas que pueden no tener base real ni ahora ni nunca.

Por ejemplo, algunos axiomas comunes que todavía se utilizan parecerán mucho menos reglas de oro y más excusas cuando se los ponga a la luz de cuestiones críticas de seguridad. Estos axiomas son tan comunes porque existe una incapacidad generalizada para pensar críticamente sobre la seguridad o separarla del riesgo como concepto. La seguridad no se trata de riesgo. Se trata de protección y controles. El riesgo tiene que ver con el riesgo. El riesgo se especula, se idea, se deriva y se correlaciona. El riesgo también es subjetivo. La seguridad no debería serlo. Para comprender mejor cómo estos calificadores afectan nuestra capacidad de realizar un buen análisis de seguridad, podemos examinar las falacias en los calificadores comunes:

1. No existe el 100% de seguridad.

La declaración no proporciona condiciones como el tiempo y la métrica para la cual se pueden utilizar porcentajes como escala. Como declaración de riesgo, podría ser cierta: "No existe el hecho de estar siempre 100% libre de riesgos". porque según la definición de riesgo, incluso nuestro propio cuerpo está sujeto al tiempo y a las lesiones autoinfligidas. Sin embargo, como declaración de seguridad, puede tener demasiadas excepciones para ser cierta.

2. Incluso si estás seguro, si un atacante quiere entrar lo suficiente, entrará.

La afirmación no proporciona la condición del tiempo, que para cualquier atacante humano sería finito, e incluye una forma de falacia de equívoco que califica el deseo del atacante.

Por lo tanto, si ningún atacante ha entrado, entonces aparentemente no quería entrar "lo suficiente".

Además, la declaración hace un uso demasiado amplio de la frase "entrar" de modo que la idea está ganando terreno, pero podría aplicarse a cualquier número de ataques potenciales y dañinos.

3. No existe una seguridad perfecta.

La declaración no proporciona la condición de tiempo que implica que el axioma significa "siempre", que es en sí mismo un absoluto y difícil de probar. Esta breve afirmación también cae en las categorías de dos falacias lógicas, la falacia del Nirvana y la falacia de la Solución Perfecta. En la falacia del Nirvana, nos inducen a rechazar algo porque no puede ser perfecto. Sin embargo, puede ser lo suficientemente bueno para las necesidades de uno. En la falacia de la solución perfecta, el argumento supone que incluso existe una solución perfecta. Esta suposición es fácil de argumentar en términos de productos para aquellos que sólo entienden los conceptos de seguridad en términos de productos. En realidad, "perfecto" es un concepto subjetivo y lo que puede no ser perfecto para una persona puede serlo para otra. En el contexto de este manual, "perfecto" significa una ecuación perfectamente equilibrada al calcular la superficie de ataque que consta de OpSec y limitaciones contra los controles.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

4. La seguridad es un proceso, no un producto.

Si bien esta declaración pretende informar a quienes piensan en la seguridad en términos de productos, este eslogan en realidad utiliza las falacias del falso dilema y la presunción para persuadir. Como Falso Dilema plantea que sólo existen dos opciones, un producto y un proceso y por tanto la seguridad debe ser una o la otra. Como Presunción, la conclusión de la declaración ya se presume como un proceso siendo el medio para la seguridad. En conjunto, estas falacias no permiten que productos y procesos se combinen en la formación de seguridad ni permiten algo completamente diferente. En realidad, la definición pública de seguridad está mal definida y en realidad no es alcanzable, lo cual es, en primer lugar, la razón probable de todos estos axiomas. Esto deja espacio para muchas interpretaciones de lo que puede ser la seguridad y la razón principal por la que el analista debe comprometerse con una definición de seguridad alcanzable y mensurable. Afirmar entonces que la seguridad es una cosa u otra es falso, especialmente cuando la seguridad en sí misma no está definida y se presta a interpretaciones estándar de diccionario. Es también por eso que este manual define claramente la seguridad como algo medible.

Se requiere que un analista aplique habilidades de pensamiento crítico en seguridad a la información tal como se proporciona, así como a las declaraciones que se hacen sobre la información analizada para formar inteligencia objetiva. La inteligencia creada de esta manera proporcionará métricas precisas e imparciales, así como una comprensión clara de cómo la seguridad es deficiente sin necesidad de calificadores.

3.2 Reconocer el modelo OpSec

Hay dos problemas con el análisis de seguridad en el uso práctico en operaciones. La primera es que la tecnología suele estar muy por delante de la capacidad de cada analista para comprender cómo funciona todo, si es que es posible obtener este conocimiento en el actual estado cerrado de la mayoría de los productos tecnológicos comerciales. El segundo problema es que, irónicamente, la deconstrucción de cómo funciona algo, incluidos los procesos comerciales, puede ser ilegal para proteger el riesgo financiero y la privacidad del fabricante frente al comprador, aunque, como usuario del producto, el comprador en realidad necesite esa información para protegerse de amenazas reales que probablemente no sean sus clientes. Sin embargo, incluso en los casos en los que una tecnología o proceso no se puede analizar directamente, el producto se puede analizar dentro del entorno con el que interactúa.

Para cada vector y canal que se analiza, el analista superpondrá el modelo OpSec sobre los objetivos. Aplicar el modelo OpSec es simplemente contar los controles para cada punto interactivo de Acceso o Confianza, así como el descubrimiento de oportunidades en forma de Visibilidad. Cuando un objetivo es algo desconocido como una caja negra que no se puede abrir, el analista necesita abordar los controles sobre las interacciones del sistema en su entorno. El proceso se verá así:

1. ¿Qué se ve en el visor? ¿Qué es de posible valor que se conoce? ¿Qué objetivos pueden ser?
¿determinado?
2. ¿Cuáles son los puntos de acceso interactivos a esos objetivos y desde qué vector o canal?
3. ¿Cuáles son los Fideicomisos dentro del alcance y sobre qué vector o canal?
4. ¿Cuáles son los controles para dichos Accesos y Fideicomisos?
5. ¿Los controles están completos o tienen limitaciones?

Incluso una aplicación rápida del modelo OpSec le dirá si un Acceso o un Fideicomiso está equilibrado con controles. Esto le indicará el tamaño de la superficie de ataque y qué puntos interactivos están abiertos sin ningún control para controlarlos.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

3.3 Busque la coincidencia de patrones como señal de errores

Si comienza buscando exactamente lo que busca, es posible que sólo encuentre lo que espera encontrar. Esto es adecuado cuando se buscan calcetines a juego, pero no tan bueno cuando se mira el panorama general de una superficie de ataque. Es el principal problema conocido como coincidencia de patrones, el rasgo humano de saltarse pasos, a veces sin saberlo, que se consideran innecesarios debido a un resultado "obvio". También hace que la gente vea causa y efecto donde puede que no los haya. Es un punto ciego que los analistas desarrollarán después de años de realizar tareas iniciales, básicas o redundantes. Estas tareas se hacen más eficientes mediante atajos que afectan a la calidad de las pruebas de verificación y, en última instancia, al análisis.

Para la inteligencia procesable, un resultado es tan bueno como los métodos utilizados para obtenerlo. No saber cómo obtuvo un resultado en particular limitará gravemente las medidas que puede tomar para solucionarlo. Cuando un analista utiliza la coincidencia de patrones para omitir pasos, no se puede conocer correctamente el método. Aún así, el deseo de "ir al grano" para llegar al meollo de un problema y al mismo tiempo suponer un estado que en realidad se desconoce es un problema en muchas áreas de la ciencia. La seguridad no es una excepción. Por lo tanto, un analista debe reconocer cuándo se han omitido pruebas o se han manipulado datos para proporcionar resultados no verificados.

Para detectar la coincidencia de patrones, examine los métodos de prueba y los datos de los resultados para lo siguiente:

1. Pruebas utilizando amenazas específicas en lugar de una interacción exhaustiva con la superficie de ataque.
2. La falta de detalles sobre los procesos resultantes detrás de las interacciones con el objetivo.
3. Poca o ninguna información sobre controles para diversos objetivos.
4. Sólo algunos de los objetivos se informan para determinadas pruebas y esos tienen resultados completamente negativos.
5. Objetivos no probados por motivos anecdóticos (notas en las que una persona ha dicho que no hay nada allí para probar o ha sido asegurado).
6. Pruebas de objetivos que evidentemente no han sido asegurados.

3.4 Caracterizar los resultados

El método científico no es una lista de verificación. Es un proceso que permite la inteligencia y la imaginación. Se formula una hipótesis y luego se recopilan datos mediante pruebas y observación para evaluar esa hipótesis. En una prueba de seguridad, esencialmente se formula una hipótesis cada vez que se realiza una verificación contra un punto interactivo directo o indirecto en el alcance. El analista tiene los datos empíricos de esas pruebas y debe considerar si las pruebas realmente verificaron la hipótesis. ¿Se hicieron las pruebas correctas? ¿Se hicieron suficientes pruebas? ¿Se probaron los canales o vectores correctos? ¿Se crearon nuevas interacciones que luego también se probaron? Para ello, caracterizamos los resultados.

Caracterizar una prueba de seguridad utilizando el método científico es descubrir las propiedades del alcance para asegurar que se realizaron las pruebas correctas. El evaluador formula una hipótesis sobre la interactividad de un punto en la superficie de ataque. La prueba arrojará que el punto es interactivo y se suma a la superficie de ataque o no, y si aún se suma a la superficie de ataque, los controles implementados, las limitaciones en esos controles, las limitaciones en la seguridad definida y las anomalías. En este punto, el analista puede estar equivocado acerca de la función del proceso en operación, sin embargo, puede no estar equivocado en cuanto a qué pruebas deben usarse para verificar cuál es realmente la función. Por eso es necesario tanto el conocimiento del proceso como la imaginación creativa de la interacción indirecta.

Por ejemplo, el analista puede caracterizar un proceso como que incluye la interacción entre un visitante y la red a través de la tarjeta de acceso. Entonces, si bien este visitante no tiene las credenciales para acceder a la red, debido a que el lector de tarjetas está vinculado al sistema informático, ese visitante accede a la red deslizando la tarjeta. El analista debe considerar cómo probar qué sucede cuando el visitante interactúa con el lector de tarjetas para obtener acceso, así como los efectos secundarios de que se lea la tarjeta. Sin embargo, incluso si las pruebas muestran que el lector de tarjetas está conectado a un sistema informático independiente y no está conectado a la red,



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

El analista ha verificado adecuadamente que se realizaron las pruebas correctas contra los objetivos correctos para lograrlo. respuesta.

Por lo tanto, el analista examinará el alcance de dónde podría ocurrir una interacción, así como también dónde las operaciones muestran que ocurren interacciones. Esto permitirá una caracterización de los puntos de interacción, cualquier posible interacción indirecta y todos los efectos secundarios de dichas interacciones. Esta caracterización debe luego compararse con las pruebas realizadas para determinar si se realizaron todas las pruebas correctas.

3.5 Busque señales de intuición

Una cosa en la que las máquinas son claramente mejores que los humanos es en la coherencia. Los seres humanos generalmente se aburren, se confunden o se descuidan. Cuando una máquina cuenta monedas, no pierde la cuenta y necesita empezar de nuevo. No duda de sí mismo y empieza de nuevo. Tampoco utilizará la intuición. También llamado "instinto visceral", el poder de la intuición es increíble. Permite a las personas imaginar, aplicar la creatividad a un trabajo y saber cuándo algo anda mal. Es parte de la condición humana detectar problemas inconscientemente y prepararse en consecuencia. Sin embargo, es precisamente esto lo que a veces nos lleva a cometer errores. Esto nunca es más obvio que cuando contamos grandes cantidades de objetos de apariencia similar. Sin una concentración total, podemos comenzar a sentirnos incómodos con la cuenta y eventualmente podemos sentirnos obligados a comenzar de nuevo o simplemente aceptar un número particular que suena correcto donde creemos que lo dejamos y continuar desde allí.

Hay un momento en que una prueba requiere una concentración precisa; durante una gran cantidad de secuencias repetitivas. Generalmente, tendemos a crear herramientas para manejar este tipo de repetición, sin embargo, puede que no siempre sea posible debido a la naturaleza dinámica de la prueba, como cuando se interactúa con personas en lugar de objetos inanimados o máquinas. Entonces, a medida que avanza la prueba, el evaluador puede usar la intuición para presumir que la prueba será innecesaria. El Analista debe prestar especial atención a estas pruebas y buscar signos de intuición en parte del evaluador.

Los signos de problemas de la intuición en las pruebas son:

1. Inconsistencias en los tipos de pruebas realizadas en múltiples objetivos similares.
2. El número de pruebas disminuye entre objetivos.
3. La duración de las pruebas disminuye entre objetivos.
4. El mismo objetivo probado más de una vez con las mismas pruebas.

La detección de la intuición en las pruebas mostrará un proceso de prueba inadecuado y la calidad de los resultados debe considerarse con sospecha. Puede ser necesario volver a realizar la prueba.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

3.6 Informes transparentes

Rara vez un análisis de seguridad terminará con todas las respuestas. Dado que las pruebas dependerán de OpSec y los controles de un canal y vector en particular, habrá incógnitas. Puede haber un objetivo visible que no proporciona interacción y no se puede determinar más información sobre ese objetivo a partir de este vector y este canal. Esto es correcto. El Analista debe informar con certeza lo que ha encontrado y no sólo lo que podría ser. No hay lugar para adivinar al medir una superficie de ataque.

Además de la información sobre la prueba en sí y cómo se realizó, el analista deberá informar los siguientes 7 resultados de la prueba:

1. Incógnitas

A medida que se analicen más vectores y canales, habrá más información disponible y lo que se informe cambiará y proporcionará inteligencia procesable. Por el contrario, tal vez más resultados no sean concluyentes o la correlación de los resultados proporcione respuestas contradictorias, y se desconoce la inteligencia procesable resultante. Desconocido es una respuesta válida para informar. Lo que no se puede saber es tan válido e importante en seguridad como lo que se descubre. Lo que se desconoce muestra lo que es difícil de probar o analizar. Lo desconocido no tiene por qué verse como una falla del evaluador, sino que puede ser causado por una protección superior o un ataque que consume un gran costo de tiempo o recursos que no son posibles en una prueba. Ningún analista debería temer informar sobre algo desconocido. Es un resultado poderoso en el que basar un análisis de riesgo adicional.

2. Objetivos no

probados Además, el analista debe informar otro tipo de objetivos desconocidos en el alcance que no han sido probados en un vector o canal en particular. Si una prueba no se puede completar debido a limitaciones de tiempo, limitaciones de herramientas, objetivos inestables, el entorno de prueba es demasiado dinámico o demasiado ruidoso para recopilar resultados adecuados, o porque el propietario del objetivo no quería las pruebas, entonces es necesario saberlo. Al informar lo que no se probó, es posible realizar comparaciones adecuadas de las pruebas con pruebas futuras. También ayudará a evitar trampas probando únicamente el segmento bien protegido de una mira e ignorando el resto para crear la ilusión de una pequeña superficie de ataque.

3. Limitaciones identificadas y verificadas

Además de las incógnitas, el Analista también debe informar cualquier limitación identificada y verificada, como vulnerabilidades en los objetivos. Una limitación identificada es aquella que ha sido determinada a través del conocimiento y la correlación. Esto resulta útil cuando las pruebas en sí son peligrosas o muy costosas. A veces una prueba puede ser perjudicial para un objetivo o causar daños colaterales inaceptables o incluso criminales. Una limitación verificada es aquella en la que el problema se ha probado específicamente para determinar si existe.

4. Falsos positivos y los medios para generarlos Durante

las pruebas, algunas limitaciones identificadas no serán vulnerables a esos ataques particulares durante la verificación. Sin embargo, esto no concluye que el objetivo no tenga esas limitaciones. Solo significa que esa prueba en particular en ese momento en particular y de ese probador en particular no expuso la vulnerabilidad identificada. También podría significar que el objetivo es vulnerable pero está protegido por un control particular. Estos falsos positivos determinados deben notificarse para que, durante el desarrollo posterior de técnicas de protección y defensa, se pueda examinar el problema más de cerca, especialmente desde un vector diferente.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

5. Procesos y procedimientos de seguridad fallidos

Durante el análisis, los resultados de las pruebas mostrarán más que solo OpSec, tipos de controles y cantidad de limitaciones. Mostrará un panorama más amplio, uno de los procesos y procedimientos que se utilizan para formalizar las medidas de protección. Estos pueden ser sobre cualquier cosa que esté diseñada para llevar las medidas de protección a su estado actual. Esto incluye, entre otros, mantenimiento, adquisiciones, identificación, autorización, limpieza, recuperación ante desastres, relaciones con socios, generación de políticas, control climático y recursos humanos. Cuando un objetivo tiene una limitación, muchas veces hay un proceso o procedimiento fallido detrás de él. El analista debería poder determinar exactamente qué es a partir de los resultados agregados de las pruebas.

6. Buenas Prácticas

El término "Mejores Prácticas" se utiliza para explicar la mejor manera para que una persona u organización haga algo. Desafortunadamente, se ha abusado de esto hasta el punto de que ahora significa que es lo mejor para todos. Esto en sí mismo ha causado problemas y desperdiciado recursos. Una forma de contrarrestar este problema es utilizar los resultados agregados de las pruebas para mostrar las prácticas que tienen éxito. Esto mostrará lo que se puede repetir para lograr un éxito equivalente en otras áreas de la organización y definirá una "Mejor Práctica" personalizada para ellas. También reducirá su dependencia de las mejores prácticas de toda la industria en favor de lo que funcione mejor para ellos.

7. Cumplimiento

Si es necesario alcanzar objetivos de cumplimiento específicos, el analista debe utilizar los resultados de las pruebas correlacionadas para determinar si se han cumplido estos objetivos. Es posible que sea necesario proporcionar esto en un formato especial según lo determine el auditor; sin embargo, el analista está mejor equipado para mostrar qué resultados de las pruebas proporcionan la información necesaria.

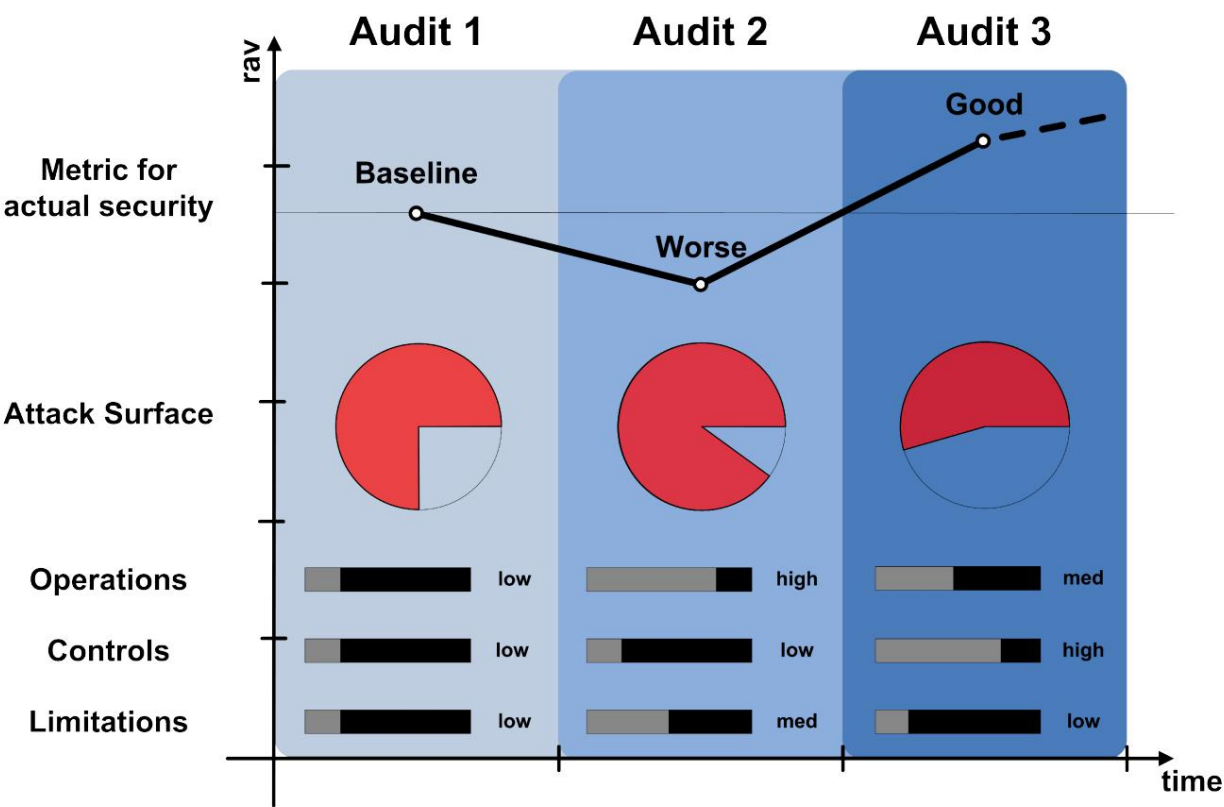


La evaluación de riesgos es un concepto para seleccionar seguridad y controles basados en el riesgo presunto. Sirve para definir la estrategia. Sin embargo, las pruebas de seguridad consisten en verificar hasta qué punto existen esa seguridad o esos controles. Funciona para definir operaciones. Para probar no se hace una evaluación de riesgos porque hacerlo restringiría su potencial y sus hallazgos. Después de todo, no deberías hacer las mismas conjeturas que ellos.



Capítulo 4 – Métricas de seguridad operativa

Las métricas de seguridad operativa son las métricas con las que estamos más familiarizados en nuestras vidas. Cuando medimos la altura, el ancho o el largo de un objeto, estamos utilizando una métrica operativa. Cuando escribimos la fecha, cumplimos años o preguntamos la puntuación de un juego estamos utilizando métricas operativas. Una métrica operativa es una medida constante que nos informa de un recuento fáctico en relación con el mundo físico en el que vivimos. Son operativas porque son números con los que podemos trabajar constantemente día a día y de persona a persona. Es difícil trabajar con mediciones relativas o inconsistentes como elegir un tono específico de amarillo para pintar una habitación, comenzar a trabajar al amanecer, tener el sabor correcto de fresa para un batido o prepararse para la próxima amenaza que afecte las ganancias de su organización porque los factores tienen muchas variables que están sesgadas o cambian con frecuencia entre personas, regiones, costumbres y ubicaciones. Por esta razón, muchas profesiones intentan estandarizar aspectos como sabores, colores y horarios de trabajo. Esto se hace a través del reduccionismo, un proceso de encontrar los elementos de tales cosas y construirlos a partir de ahí cuantificando esos elementos. De esta manera, los colores se convierten en frecuencias, las horas de trabajo en horas y minutos, los sabores en compuestos químicos y una superficie de ataque en porosidad, controles y limitaciones. El único problema real con las métricas operativas es el requisito de saber cómo aplicarlas correctamente para que sean útiles.



Usar ravs para medir y rastrear la seguridad de cualquier cosa a lo largo del tiempo.

La realización de una prueba de seguridad exhaustiva tiene la ventaja de proporcionar métricas precisas sobre el estado de seguridad. Como ocurre con el uso de cualquier métrica, cuanto menos exhaustiva sea la prueba, menos precisa será la métrica general. Los analistas menos capacitados o con menos experiencia también afectarán negativamente la calidad de la métrica, del mismo modo que las personas que no pueden decir la hora no pueden construir relojes, los diseñadores sin las herramientas adecuadas no pueden igualar los colores exactamente y



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

Los maestros cerveceros que no pueden medir los ingredientes de la cerveza no pueden fabricar lotes similares repetidamente para el mercado. Por lo tanto, una métrica de seguridad exitosa requiere una prueba que puede describirse como una medición de los vectores apropiados teniendo en cuenta las imprecisiones y tergiversaciones en los datos de prueba recopilados, así como las habilidades o experiencia de los profesionales de seguridad que realizan la prueba. Las fallas en estos requisitos dan como resultado mediciones de menor calidad y determinaciones de seguridad falsas, por lo que la métrica también debe ser lo suficientemente simple de usar sin que sea tan simple que no diga nada. Además, una métrica de seguridad adecuada debe evitar los sesgos inherentes a las evaluaciones de riesgos garantizando que las mediciones tengan integridad. Estas cualidades se han combinado para crear los ravs, una descripción objetiva e imparcial de una superficie de ataque.

4.1 Conociendo al Rav

El rav es una medida a escala de la superficie de ataque, la cantidad de interacciones incontroladas con un objetivo, que se calcula mediante el equilibrio cuantitativo entre operaciones, limitaciones y controles.

Tener los ravs es entender qué parte de la superficie de ataque está expuesta. En esta escala, 100 rav (también mostrado como 100% rav para simplificar la comprensión, aunque no es exactamente un porcentaje) es un equilibrio perfecto y cualquier valor inferior significa muy pocos controles y, por lo tanto, una mayor superficie de ataque. Más de 100 rav muestran más controles de los necesarios, lo que en sí mismo puede ser un problema ya que los controles a menudo agregan interacciones dentro de un alcance, así como problemas de complejidad y mantenimiento.

El rav no mide el riesgo de una superficie de ataque, sino que permite medirlo. No puede decir si un objetivo en particular será atacado, pero puede decir en qué parte de un objetivo será atacado, contra qué tipos de ataques el objetivo puede defenderse con éxito, a qué profundidad puede llegar un atacante y cuánto daño puede causar. Con esa información es posible evaluar los fideicomisos (y los riesgos) con mucha más precisión.

El rav son en realidad múltiples cálculos separados de porosidad, controles y limitaciones, que cuando se combinan mostrarán el tamaño de una superficie de ataque de dos maneras prácticas. La primera forma es mediante un cálculo directo. Es el cálculo del Delta, un número que describe la exposición específica de ese objetivo. Esto es útil para determinar cómo una nueva persona, cosa o proceso cambiará la seguridad operativa de un nuevo alcance o como comparación entre múltiples objetivos únicos. Esta es también la forma más sencilla de ver la Seguridad Perfecta, el equilibrio perfecto entre Porosidad, Controles y Limitaciones. El rav se muestra como un número positivo o negativo que muestra qué tan lejos está el objetivo de un equilibrio de seguridad perfecto. Un delta positivo muestra que se gasta demasiado en controles en general o incluso si el gasto excesivo se realiza en demasiado de un tipo de control. Un delta negativo muestra una falta de controles o controles en sí con limitaciones que no pueden proteger al objetivo adecuadamente. Esta es una herramienta poderosa para saber exactamente dónde y cómo se gastan los recursos para proteger un objetivo en particular. Sin embargo, no es así como el rav es más útil; eso se hace mejor de la segunda manera.

La segunda forma práctica de mostrar la superficie de ataque es comprender el panorama general. Esto se representa como Seguridad Real. Mientras que el cálculo del Delta se basa en un equilibrio perfecto, el cálculo de Seguridad Real utiliza el Delta pero también incluye controles adicionales y redundantes para proporcionar una métrica más amigable y familiar para las personas. Aquí la representación rav es similar a cómo la gente usa los porcentajes. El rav se calcula con un logaritmo en base 10, lo que hace una representación más comprensible. Mientras el rav sigue siendo un equilibrio, el equilibrio perfecto se fija en 100 y se hacen cálculos con respecto a eso. Esto permitirá a la mayoría de las personas tener una visión general rápida y sencilla de todos los objetivos en un alcance o de un solo objetivo en relación con otros objetivos. Es extremadamente flexible, por lo que Actual Security puede comparar múltiples superficies de ataque incluso si el alcance o los objetivos son muy diferentes: el 95% de rav de un alcance con 1000 sistemas informáticos es comparable al 95% de rav con solo 10 sistemas, que puede ser nuevamente en comparación con un edificio con un 95% de rav. Los tres proporcionarán la misma información a una persona de que la protección del objetivo es deficiente en un 5% y, por tanto, está expuesto a ataques. Con este conocimiento, se puede empezar a evaluar el riesgo y determinar qué está expuesto, qué queda sin controlar y si ese 5% es aceptable. Entonces, cualquier amenaza que exista, sólo puede ocurrir donde están las aberturas y eso agudizará la exactitud de un análisis de riesgo desde la espada ancha hasta el bisturí.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

¿Cómo es un Rav?

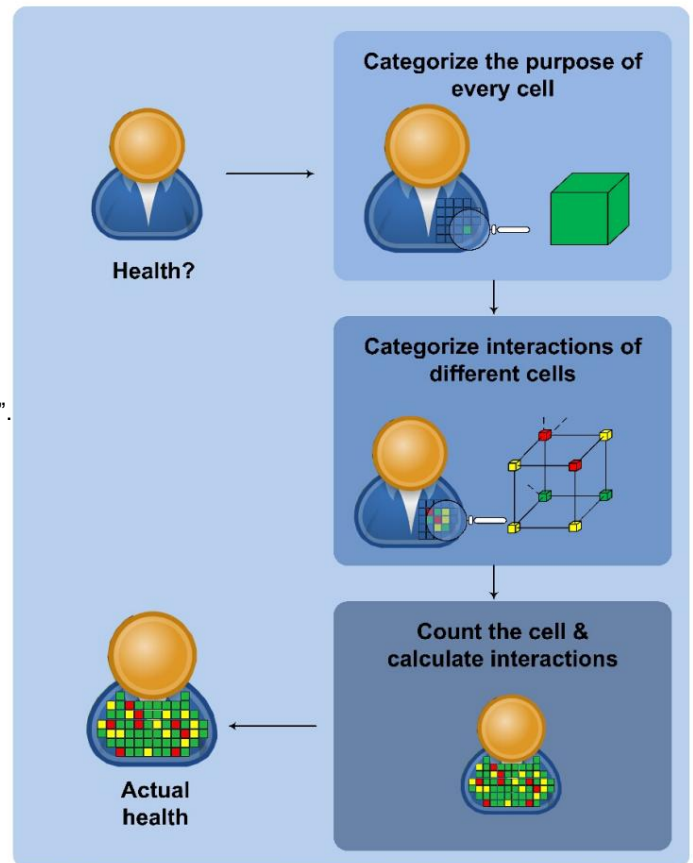
Un rav es un poco diferente de otras medidas de seguridad porque el recuento es único en el alcance. Eso es como determinar el tamaño total de una persona contando todas las células que contiene y categorizándolas según lo que hacen para determinar la salud general de la persona. Para un rav, se requieren tanto el conteo como la operación. Es por eso que el rav sólo puede derivarse de pruebas de seguridad operativa.

Imagine que existe una máquina que puede auditar todas las células de un cuerpo humano. Esta máquina funciona monitoreando las células en su entorno e incluso estimulando a cada célula de manera que pueda reaccionar para categorizar mejor su propósito. Luego podríamos ver qué hacen las distintas células y cómo contribuyen a la composición general del cuerpo humano. Algunas células forman las paredes de los tejidos como lo hacen las células de la piel. Algunos, como los glóbulos blancos, proporcionan autenticación y atacan a otras células que están en su lista de "malas". Entonces algunas células son extrañas, como bacterias que han entrado en algún momento y prosperado. La máquina clasificaría todas las células que componen a la persona, en un ámbito definido, en lugar de decir cuáles son "malas" o "buenas".

Contando las células, la máquina puede determinar principalmente qué tan bien funciona la persona como organismo (salud) y qué tan bien se adapta a su entorno actual. También puede determinar qué células están rotas, cuáles son superfluas y de qué tipo se podrían necesitar más para que la persona sea más eficiente, esté preparada para lo inesperado o para cualquier número de requisitos específicos. Dado que las células se dividen y mueren todo el tiempo, la máquina también debe realizar pruebas periódicas y registrar la capacidad de la persona para mejorar o al menos mantener la homeostasis.

Ahora además de contar células y ver cómo funcionan, la máquina también verá con qué otras células o en qué condiciones interactúan y qué tan bien. En cada operación de las funciones de la celda, la máquina puede determinar cuáles son las limitaciones de la celda. Entonces, si fuera posible que la máquina también reparara directamente un problema en las células defectuosas, fortaleciera el cuerpo cambiando el proceso de las células o eliminando las células innecesarias, podríamos afectar directamente la salud del cuerpo en su conjunto. con cada cambio. O tal vez podríamos cambiar el entorno al que está expuesto el cuerpo en lugar de las células para realizar cambios más globales. Sometiendo a la persona a una mejor nutrición, dieta o ejercicio también cambiaremos el cuerpo a nivel celular. Todo esto es posible sabiendo cómo funcionan las cosas dentro del cuerpo y qué hay en estas operaciones.

Desgraciadamente no existe tal máquina para contar todas las células del cuerpo humano. Sin embargo, existe por seguridad. Los analistas pueden contar y verificar las operaciones de los objetivos en un alcance como si fuera un superorganismo. Registran sus interacciones y los controles que rodean esas interacciones. Los clasifican por operación, recursos, procesos y limitaciones. Esos números que generan los analistas se combinan de modo que los controles aumentan la seguridad operativa y las limitaciones la restan. Incluso el valor de las limitaciones, qué tan grave es el daño de cada tipo de problema, tampoco es arbitrario porque se basa en la combinación de seguridad y controles dentro de ese alcance particular. Por lo tanto, un problema grave en un entorno protector proporcionará una exposición general menor que uno en un entorno menos controlado.



Los ravs son como contar células y clasificarlas según lo que hacen para determinar qué tan bien se adapta el organismo a un entorno.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

Ocho respuestas fundamentales de seguridad

El rav no representa riesgo donde el riesgo se conoce como $\text{Riesgo} = \text{Amenaza} \times \text{Vulnerabilidad} \times \text{Activo}$. En esa ecuación, el riesgo es el resultado de una ecuación informada, aunque muy sesgada. Si podemos eliminar la mayor parte del sesgo al conocer el nivel de protección y, por lo tanto, el nivel de impacto de la vulnerabilidad, podemos reducir el sesgo en esa ecuación y dar una evaluación de riesgo mucho mejor. Por lo tanto, el rav es en realidad la base fáctica para una evaluación de riesgos en la que un analista tiene hechos con los que trabajar. Sin embargo, el verdadero poder del rav es cómo puede proporcionar respuestas con gran precisión a las siguientes ocho preguntas de seguridad fundamentales.

1. ¿Cuánto dinero debería gastarse en seguridad?

El rav mostrará la cantidad actual de protección para realizar proyecciones de seguridad y definir hitos incluso antes de comprar una solución particular o implementar algún proceso nuevo. A partir de estas proyecciones e hitos se pueden crear restricciones financieras para cumplir las metas y obtener los resultados más específicos de la inversión. Al saber exactamente qué se controla en función del gasto actual, también se puede ver qué no se controla para ese dinero. “Más” se convierte entonces en lo que falta. Entonces es posible prever el coste de completar los controles faltantes para lograr un equilibrio perfecto o al menos un nivel de cobertura decididamente aceptable.

2. ¿Qué se debe proteger primero?

El rav se puede utilizar para ver la seguridad como parte del panorama general y como una lente macro en una parte particular de un objetivo, o cualquier combinación de ambas. Después del análisis, el rav mostrará qué parte particular del visor tiene la mayor porosidad y los controles más débiles. Comparando eso con las necesidades y el valor de los activos de cada uno, se puede generar una relación entre la fuerza de la protección y el valor para decidir exactamente por dónde empezar.

3. ¿Qué soluciones de protección necesitamos y cómo deberíamos configurarlas para obtener el máximo ¿eficacia?

Un rav completamente completado mostrará los 10 posibles controles operativos aplicados para cada objetivo y las limitaciones de esos controles. Luego puede elegir soluciones según los tipos de controles que desee implementar. La diferencia ahora es que ya no es necesario considerar una solución en términos de lo que es y no de la protección o los controles que puede proporcionar. Esto le permite ver productos para los controles que necesita proporcionar en las áreas donde los controles son actualmente deficientes.

4. ¿Cuánta mejora se logra mediante adquisiciones y procesos de seguridad específicos?

Una característica clave del rav es que puede crear un "Delta" trazando los beneficios y limitaciones de una solución particular para compararlos antes de la adquisición.

Esto significa que puede ver qué cambios realizará esa solución en el alcance para compararla con otras soluciones. Combinando ese mapa con una muestra del alcance donde se colocaría la solución, se puede medir la cantidad de mejora incluso antes de la compra. Incluso puedes predecir el valor de esa protección dividiendo el precio de la solución por el rav delta.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

5. ¿Cómo medimos los esfuerzos y mejoras periódicas en materia de seguridad?

Con auditorías periódicas, el rav se puede recalcular y comparar con el valor anterior.

De este modo, se puede justificar periódicamente el coste de nuevas soluciones y procesos, así como el coste de mantener el nivel de seguridad actual.

6. ¿Cómo sabemos si estamos reduciendo nuestra exposición a nuestras amenazas?

Con un conocimiento específico de sus controles, puede saber fácilmente qué parte o vector del alcance es débil ante las amenazas específicas y más desconocidas. En terminología rav, una amenaza desconocida es simplemente aquella que puede aparecer donde existen interacciones pero no controles. Por lo tanto, se puede trazar un mapa entre las amenazas determinadas por los Evaluadores de Riesgos y los controles establecidos. Las revisiones periódicas de métricas mostrarán cualquier cambio en este mapa y se pueden realizar con regularidad. Entonces es posible medir el costo que cada una de esas amenazas tiene para la seguridad a través del gasto en controles.

7. ¿Puede decirnos el Rav qué tan bien resiste algo los ataques?

Técnicamente, sí. Cuanto más puedas equilibrar los controles con las interacciones, más pequeña será la superficie de ataque y más capaz tendrá el objetivo de controlar tipos de interacciones conocidas y desconocidas.

8. ¿Puede el rav ayudarme con el cumplimiento normativo?

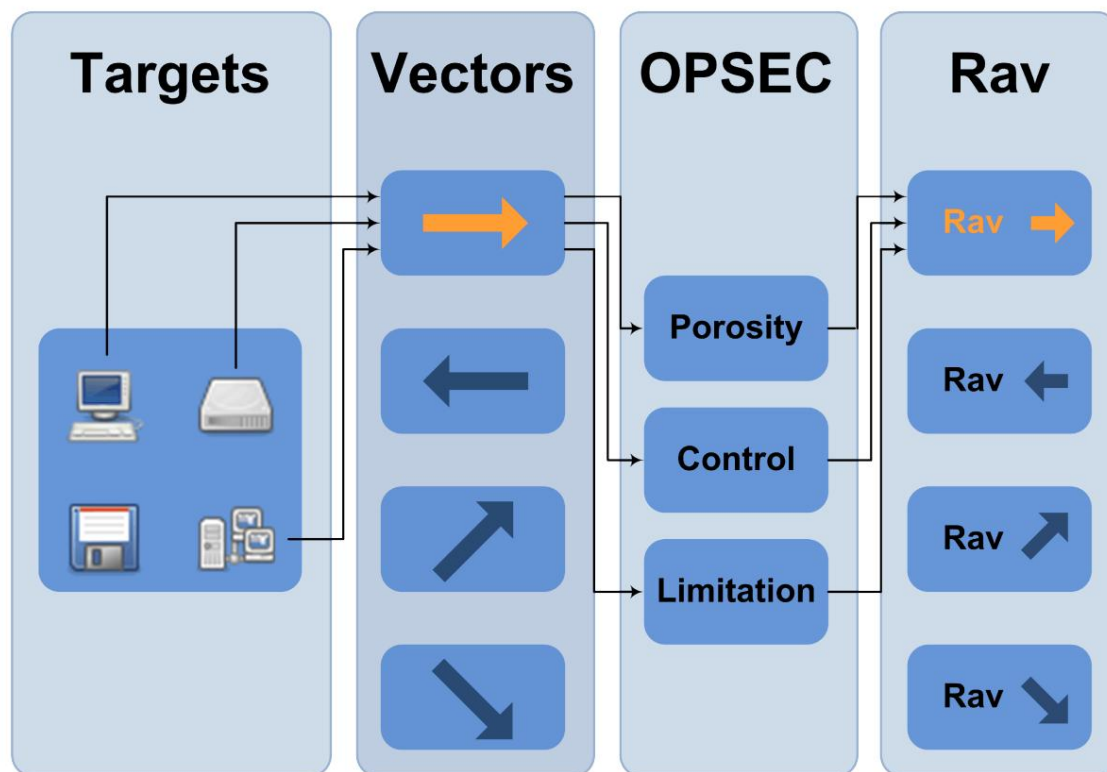
Cualquier cosa que le ayude a clasificar todos los controles y puntos de acceso en un alcance le ayudará con las auditorías de cumplimiento. El rav lo ayuda a hacer un trabajo tan bueno para controlar su seguridad que incluso puede encontrar fallas importantes en el cumplimiento de las regulaciones. Si bien no existe ningún cumplimiento particular en este momento que le solicite tener un puntaje rav particular, mostrar OSSTMM STAR con su puntaje rav lo ayudará a cumplir con varios requisitos de cumplimiento para una auditoría y documentación de terceros.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

4.2 Cómo hacer un Rav

El rav requiere una prueba de seguridad para poder contar las cosas correctas y analizar las operaciones correctas. Se puede utilizar cualquier prueba de seguridad, pero cuanto más exhaustiva y precisa sea la prueba, más concluyentes serán los resultados. El rav fue diseñado originalmente para pruebas de operaciones, como OSSTMM, donde el auditor se centra en el comportamiento del objetivo en lugar de en la configuración. Sin embargo, los experimentos muestran que es posible aplicar rav a pruebas no operativas, como en análisis de código estático para determinar el nivel de seguridad y complejidad del software o en auditorías de listas de verificación de seguridad física para determinar el nivel de protección que proporcionará un espacio físico. El proyecto SCARE (Análisis de código fuente y evaluación de riesgos) hace exactamente esto aplicando los ravs al código fuente C.



La simplicidad de hacer un rav a partir de una prueba de seguridad.

El rav mínimo se obtiene mediante el cálculo de la porosidad que son los agujeros del visor. El problema con las métricas de seguridad generalmente radica en la determinación de los evaluadores de contar lo que realmente no pueden saber. Este problema no existe en el rav. Obtienes lo que sabes de lo que hay para un vector en particular y no haces suposiciones sobre lo que no está allí. Se cuenta todo lo que es visible e interactivo fuera del alcance y permite la interacción no autenticada entre otros objetivos en el alcance. Eso se convierte en la porosidad. Este valor de porosidad constituye la primera de 3 partes del valor rav final. La siguiente parte es dar cuenta de los controles establecidos por objetivo. Esto significa ir objetivo por objetivo y determinar dónde están implementados cualquiera de los 10 controles, como autenticación, subyugación, no repudio, etc. Cada control se valora como el 10 % de un poro, ya que cada uno proporciona 1/10 del total de controles necesarios para prevenir todo tipo de ataques. Esto se debe a que tener los 10 controles para cada poro es funcionalmente lo mismo que cerrar el poro siempre que los controles no tengan limitaciones. La tercera parte del rav da cuenta de las limitaciones encontradas en la protección y los controles. Estas también se conocen como “vulnerabilidades”. El valor de estas limitaciones proviene de la porosidad y de los propios controles establecidos. Una vez completados todos los recuentos, el rav básicamente resta porosidad y limitaciones de los controles. Esto se hace más fácilmente con la calculadora de hoja de cálculo rav.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

Desafortunadamente, un analista no calificado puede proporcionar información incorrecta que se traducirá en un mal rav. Esta es una posibilidad, al igual que es posible que un carpintero no mida correctamente una tabla o que un mecánico no lea correctamente los calibres. El mundo está lleno de escenarios hipotéticos. Por lo tanto, el rav está diseñado para verse mínimamente influenciado por malas auditorías o trampas al eliminar el tamaño del alcance directo del cálculo métrico. Sin embargo, ninguna métrica puede estar inmune a la manipulación y la única forma de garantizar el rav más preciso es realizar múltiples pruebas a lo largo del tiempo para realizar los recuentos y asegurarse de que el auditor asumirá la responsabilidad de la precisión de la prueba.

Es posible tomar un atajo en las pruebas y aun así hacer un rav representativo. Si no le importa el margen de error porque sólo desea hacer una comparación rápida, puede simplemente calcular la Porosidad, lo que significa contar los objetivos visibles y accesibles. Por ejemplo, quienes ejecutan escáneres de vulnerabilidades pueden contar la porosidad y las limitaciones con relativa facilidad y asignar controles predeterminados para los servicios descubiertos. Los analistas también pueden crear una lista de verificación que ofrezca controles predeterminados para diferentes soluciones comunes encontradas. Todos estos son atajos para reducir el tiempo de cálculo, pero afectarán el rav general con un margen de error desconocido, pero quizás aceptable.

El resultado final es un cálculo de la seguridad real. Aplica múltiples controles del mismo tipo para satisfacer requisitos de doble aplicación, como la autenticación de dos factores. También utiliza Log10 para reducir grandes cantidades a una forma manejable por humanos. A la gente generalmente le gusta trabajar con números más pequeños y especialmente como porcentajes que son más fáciles de visualizar. Para un alcance pequeño, la precisión del uso de Log10 como técnica de reducción es insignificante. Sin embargo, si tiene un alcance muy grande con muchos objetivos, es posible que desee trabajar con números muy grandes para obtener una mayor precisión. Además, si desea ver el equilibrio real donde no se miden múltiples controles del mismo tipo, ese cálculo se puede encontrar bajo el título Protección verdadera.

Combinando canales y vectores

Un requisito importante al aplicar el rav es que la seguridad real solo se puede calcular por alcance.

Un cambio de canal, vector o índice es un nuevo alcance y un nuevo cálculo para la Seguridad Actual.

Sin embargo, una vez calculados, se pueden combinar varios alcances para crear una seguridad real que represente una visión más completa de la seguridad operativa de todos los alcances. Por ejemplo, se puede realizar una prueba de servidores conectados a Internet tanto desde el lado de Internet como desde dentro de la red perimetral donde residen los servidores. Eso es 2 vectores. Supongamos que el vector de Internet está indexado por dirección IP y contiene 50 objetivos. El vector de intranet está indexado por dirección MAC y está compuesto por 100 objetivos porque existen menos controles internamente para permitir una mayor interacción colaborativa entre sistemas. Una vez que se completa cada prueba y se cuenta el rav, se pueden combinar en un cálculo de 150 objetivos, así como las sumas de cada limitación y control. Esto proporcionará una métrica de seguridad real final que es más completa para esa red perimetral que la que proporcionaría cualquiera de las pruebas por sí sola. También sería posible agregar de la misma manera el análisis de las pruebas de seguridad física, inalámbrica, de telecomunicaciones y de seguridad humana. Estas combinaciones son posibles para crear una mejor comprensión de la seguridad total de forma holística.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

Calculadora Rav

Una forma sencilla y directa de crear ravs es utilizar hojas de cálculo creadas específicamente para calcular la superficie de ataque y varias métricas populares requeridas a partir de los datos de prueba. Esta hoja de cálculo está disponible en el sitio web de ISECOM. El analista solo necesita ingresar los valores en los cuadros blancos vacíos y el resto de los cálculos se manejará automáticamente.

OPSEC			
Visibility	1		
Access	3		
Trust	0		
Total (Porosity)	4		

CONTROLS			
Class A			Missing
Authentication	7		0
Indemnification	0		4
Resilience	0		4
Subjugation	0		4
Continuity	0		4
Total Class A	7		16
Class B			Missing
Non-Repudiation	0		4
Confidentiality	0		4
Privacy	1		3
Integrity	0		4
Alarm	9		0
Total Class B	10		15
			True Missing
All Controls Total	17		31
Whole Coverage	42.50%		77.50%

LIMITATIONS			
Vulnerabilities	4	Item Value	Total Value
Weaknesses	5	8.750000	35.000000
Concerns	8	5.000000	25.000000
Exposures	0	4.750000	38.000000
Anomalies	0	5.025000	0.000000
	0	4.250000	0.000000
Total # Limitations	17		98.0000

OPSEC	6.776361
True Controls	3.837843
Full Controls	4.986272
True Coverage A	20.00%
True Coverage B	25.00%
Total True Coverage	22.50%
	
Limitations	15.930239
Security Δ	-17.72
True Protection	81.13

Actual Security: 82.23

La hoja de cálculo rav para determinar el equilibrio entre porosidad, controles y limitaciones.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

4.3 Convertir los resultados de las pruebas en una medición de la superficie de ataque

Seguridad operativa

La medición de la superficie de ataque requiere mediciones de visibilidad, confianza y acceso en relación con el alcance. El número de objetivos en el alcance cuya existencia se puede determinar mediante interacción directa, interacción indirecta o emanaciones pasivas es su visibilidad. A medida que se determina la visibilidad, su valor representa el número de objetivos en el alcance. La confianza es cualquier interacción no autenticada con cualquiera de los objetivos. El acceso es el número de puntos de interacción con cada objetivo.

Categoría		Descripción
1	Visibilidad	El número de objetivos en el ámbito. Cuente todos los objetivos por índice solo una vez y mantenga el índice de manera consistente para todos los objetivos. Por lo general, no es realista tener más objetivos visibles que objetivos en el ámbito definido; sin embargo, puede ser posible debido a sangrados de vectores donde un objetivo que normalmente no es visible desde un vector es visible debido a una mala configuración o anomalía.
		Una auditoría HUMSEC emplea a 50 personas; sin embargo, sólo 38 de ellos son interactivos desde el vector y canal de prueba. Esto daría una visibilidad de 38.
2	Acceso	Esto difiere de la visibilidad en la que se determina el número de objetivos existentes. Aquí, el auditor debe contar cada acceso por punto de interacción único por sonda única.
		En una auditoría PHYSSEC, un edificio con 2 puertas y 5 ventanas todas abiertas tiene un Acceso de 7. Si todas las puertas y ventanas están selladas, entonces es un Acceso de 0 ya que estos no son puntos por donde uno pueda entrar. Para una auditoría COMSEC de redes de datos, el auditor cuenta cada respuesta de puerto como un Acceso, independientemente de cuántas formas diferentes pueda probar ese puerto. Sin embargo, si un servicio no está alojado en ese puerto (demonio o aplicación), entonces todas las respuestas provienen de la pila de IP. Por lo tanto, un servidor que responde con un SYN/ACK e interactividad de servicio a solo uno de los puertos TCP escaneados y con un RST al resto no tiene un recuento de acceso de 65536 (incluido el puerto 0) ya que 66535 de los puertos responden con el La misma respuesta de RST del kernel. Para simplificar, cuente solo los puertos con respuestas de servicio y solo una respuesta de pila de IP, independientemente de la cantidad de puertos que pueden iniciar este tipo de interactividad. Con las auditorías HUMSEC, esto se simplifica mucho más. Una persona que responde a una consulta cuenta como un Acceso con todo tipo de consultas (todas las diferentes preguntas que puedas hacer o declaraciones realizadas cuentan como el mismo tipo de respuesta en un mismo canal). Por lo tanto una persona sólo puede tener un Acceso de 1 por canal y vector. Sólo no se cuenta una persona que ignora completamente la solicitud al no reconocer el canal.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

Categoría		Descripción
3	Confianza	Esto difiere de la visibilidad donde uno está determinando el número de objetivos. Aquí, el auditor debe contar cada Fideicomiso por interacción única. punto por sonda única. En una auditoría PHYSSEC, un edificio con 2 puertas internas que separan las habitaciones que se abre tiene una confianza de 2. Si esas puertas están selladas, entonces es una confianza de 0 ya que estos no son puntos por donde se pueda pasar. Para una auditoría COMSEC de redes de datos, el auditor cuenta cada tipo de reenvío de servicio o reenvío de puerto como un Trust. Con las auditorías HUMSEC, una persona que actúa como puerta de entrada para interactuar con otras personas o para acceder a propiedades es un fideicomiso por canal. Por lo tanto, un persona sólo puede ser un Trust de 1 por canal y vector. solo una persona quien no cumple con la solicitud de Fideicomiso no se cuenta.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

Control S

El siguiente paso para calcular el rav es definir los Controles; los mecanismos de seguridad establecidos para brindar seguridad y protección durante las interacciones.

Categoría		Descripción
1	Autenticación	Cuenta cada instancia de autenticación requerida para obtener acceso. Esto requiere que la autorización y la identificación constituyan el proceso para el uso adecuado del mecanismo de autenticación. En una auditoría PHYSSEC, si se requiere una tarjeta de identificación especial y un escaneo de la huella digital para obtener acceso, agregue dos para la autenticación. Sin embargo, si Access solo requiere uno u otro, entonces solo cuenta uno.
2	Indemnización	Cuenta cada caso de métodos utilizados para exigir responsabilidad y asegurar compensación por todos los activos dentro del alcance. Un ejemplo básico de PHYSSEC es una señal de advertencia que amenaza con procesar a los intrusos. Otro ejemplo común es el seguro de propiedad. En un alcance de 200 computadoras, se aplica una póliza de seguro general contra robo a las 200 y, por lo tanto, se cuenta 200. Sin embargo, no confunda el método con el defecto del método. Una amenaza de procesar sin la capacidad o la voluntad de procesar sigue siendo un método de indemnización; sin embargo, tiene una limitación.
3	Subyugación	Cuenta cada instancia de Acceso o Confianza en el alcance que estrictamente no permite que los controles sigan la discreción del usuario o se originen fuera de sí mismo. Esto difiere de ser una limitación de seguridad en el objetivo ya que aplica al diseño o implementación de controles. En una auditoría de redes de datos COMSEC, si un inicio de sesión se puede realizar tanto en HTTP como en HTTPS pero requiere que el usuario haga esa distinción, entonces no cuenta para la subyugación. Sin embargo, si la implementación requiere el modo seguro de forma predeterminada, como un sistema de mensajería interna PKI, entonces cumple con el requisito del control de subyugación para ese alcance. Más simplemente, en HUMSEC, un proceso de no repudio en el que la persona debe firmar un registro y proporcionar un número de identificación para recibir un documento está bajo controles de subyugación cuando el proveedor del documento registra el número de identificación, en lugar de que el receptor lo haga. para eliminar el registro de un número falso con un número falso nombre.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

Categoría		Descripción
4	Continuidad	Cuenta cada instancia de Acceso o Confianza en el alcance que garantiza que no se pueda causar ninguna interrupción en la interacción sobre el canal y el vector, incluso en situaciones de falla total. Continuidad es el término general para características como la capacidad de supervivencia, el equilibrio de carga y la redundancia.
		En una auditoría PHYSSEC, si se descubre que una entrada a una tienda se bloquea de modo que no es posible una entrada alternativa y los clientes no pueden ingresar, ese acceso no tiene continuidad.
		En una auditoría de redes de datos COMSEC, si un servicio de servidor web falla debido a una carga alta y un servidor web alternativo proporciona redundancia para que no se pierdan interacciones, este acceso tiene continuidad.
5	Resiliencia	Cuenta cada instancia de Acceso o Confianza en el ámbito que no falla al abrirse ni proporciona nuevos accesos ante un fallo de seguridad. En lenguaje común, “fallar de forma segura”.
		En una auditoría PHYSSEC en la que dos guardias controlan el acceso a una puerta, si se retira uno y el guardia restante no puede abrir la puerta, entonces tiene resiliencia.
		En una auditoría de redes de datos COMSEC, si un servicio web que requiere un inicio de sesión o una contraseña pierde la comunicación con su base de datos de autenticación, entonces se debe denegar todo acceso en lugar de permitirlo para tener resiliencia.
6	No repudio	Cuenta cada instancia del Acceso o Confianza que proporciona un mecanismo de no repudio para cada interacción para brindar seguridad de que la interacción particular ocurrió en un momento particular entre las partes identificadas. El no repudio depende de que la identificación y autorización estén debidamente establecidas para su correcta aplicación sin limitaciones.
		En una auditoría PHYSSEC, el control de No Repudio existe si la entrada a un edificio requiere una cámara con escaneo facial biométrico para poder ingresar y cada vez que se utiliza, se registra la hora de ingreso con la identificación. Sin embargo, si en su lugar se utiliza una tarjeta de acceso, el control de no repudio requiere una cámara sincronizada con código de tiempo para asegurar el registro de la identidad del usuario de la tarjeta para evitar una implementación defectuosa. Si se intenta abrir la puerta sin la tarjeta de acceso, no tener la cámara sincronizada monitoreando la puerta significaría que no todas las interacciones con la entrada tienen el control de no repudio y, por lo tanto, no cuentan para este control.
		En una auditoría de redes de datos COMSEC, puede haber varios archivos de registro de no repudio. Un escaneo de puerto que interactúa en la pila de IP se registra en un registro, mientras que la interacción con el servicio web se registra en otro archivo de registro. Sin embargo, como es posible que el servicio web no registre las interacciones del método POST, el control aún se cuenta; sin embargo, también lo es la limitación de seguridad.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

Categoría		Descripción
7	Confidencialidad	Cuenta cada instancia de Acceso o Confianza en el alcance que proporciona la significa mantener el contenido de las interacciones no divulgadas entre los partes interactuantes. Una herramienta típica de confidencialidad es el cifrado. Además, la confusión de el contenido de una interacción es también un tipo de confidencialidad, aunque sea un uno defectuoso. En HUMSEC, sin embargo, un método de confidencialidad puede incluir susurrar o usando señales con las manos.
8	Privacidad	Cuenta cada instancia de Acceso o Confianza en el alcance que proporciona la significa mantener el método de interacciones no reveladas entre los partes interactuantes. Si bien "ser privado" es una expresión común, la La frase es un mal ejemplo de privacidad como control de pérdidas porque incluye elementos de confidencialidad. Como control de pérdidas, cuando algo se hace "en privado" significa que sólo "el hacer" es privado pero el contenido del mismo la interacción puede no serlo. Una herramienta típica de Privacidad es oscurecer la interacción, es decir, tener la la interacción tiene lugar fuera de la visibilidad de terceros. confusión de los medios de interacción como ofuscación es otro método de aplicación el control de Privacidad. En HUMSEC, un método de Privacidad puede ser simplemente tener en cuenta la interacción. una habitación cerrada y alejada de otras personas. En las películas vemos técnicas para cree el control de privacidad colocando dos maletas idénticas una al lado de la otra, se produce algún tipo de incidente para crear confusión, y los dos la gente cambia las maletas a la vista.
9	Integridad	Cuenta cada instancia de Acceso o Confianza en el alcance que pueda asegurar que el proceso de interacción y Acceso a los activos tiene finalidad y no puede ser dañado, detenido, continuado, redirigido o revertido sin él siendo conocido por las partes involucradas. La integridad es un proceso de control de cambios. En las redes de datos COMSEC, el cifrado o un hash de archivo pueden proporcionar la Control de integridad sobre el cambio del expediente en tránsito. En HUMSEC, segregación de funciones y otras medidas de reducción de la corrupción Los mecanismos proporcionan control de integridad. Asegurar la integridad en el personal. Requiere que se requieran dos o más personas para que un solo proceso se lleve a cabo. garantizar la supervisión de ese proceso. Esto incluye que no hay acceso maestro a todo el proceso existe. No puede haber ninguna persona con acceso completo y sin Llave maestra para todas las puertas.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

Categoría		Descripción
10	alarma	Cuenta cada instancia de Acceso o Confianza que tenga un registro o realice una notificación cuando aumente la porosidad no autorizada e involuntaria para el vector o las restricciones y controles se vean comprometidos o corruptos. En las redes de datos COMSEC, cuente cada servidor y servicio que monitorea un sistema de detección de intrusos basado en red. O cuente cada servicio que mantiene un registro monitoreado de interacción. Los registros de acceso cuentan, incluso si no se utilizan para enviar una alerta de notificación inmediatamente, a menos que nunca sean monitoreados. Sin embargo, los registros que no están diseñados para usarse en dichas notificaciones, como un contador de paquetes enviados y recibidos, no se clasifican como alarma porque hay muy pocos datos almacenados.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

Limitaciones

Finalmente, las limitaciones se verifican cuando sea posible. Los valores de cada Limitación dependen de la Porosidad y los Controles. Esto es diferente de la perspectiva de riesgo más común, donde a una vulnerabilidad se le puede asignar un nivel de riesgo en función del daño que puede causar, lo fácil que es hacerlo y la distancia dentro del alcance del ataque. Por lo tanto, los valores de limitación se calculan en función de la porosidad y los controles del objetivo en el que se encuentran.

Categoría		Descripción
1	Vulnerabilidad	Cuenta por separado cada falla o error que desafía las protecciones mediante las cuales una persona o proceso puede acceder, negar el acceso a otros u ocultarse a sí mismo o a sus activos dentro del alcance.
		En PHYSSEC, una vulnerabilidad puede ser tan simple como una puerta de vidrio, una puerta de metal corroída por el clima, una puerta que se puede sellar metiendo monedas en el espacio entre ella y su marco, equipos electrónicos que no están sellados contra plagas como hormigas o ratones, una unidad de CD de arranque en una PC o un proceso que permite a un empleado tomar un bote de basura lo suficientemente grande como para ocultar o transportar activos fuera del alcance.
		En HUMSEC, una vulnerabilidad puede ser un sesgo cultural que no permite que un empleado cuestione a otros que parecen fuera de lugar o una falta de capacitación que obliga a una nueva secretaria a brindar información comercial clasificada para uso interno únicamente.
		En la seguridad de los datos de COMSEC, una vulnerabilidad puede ser una falla en el software que permite a un atacante sobrescribir el espacio de la memoria para obtener acceso, una falla de cálculo que permite a un atacante bloquear la CPU en un uso del 100% o un sistema operativo que permite almacenar suficientes datos. copiarse en el disco hasta que ya no pueda funcionar.
		En las telecomunicaciones COMSEC, una vulnerabilidad puede ser una falla en el sistema de teléfono público que permite que los sonidos a través del receptor imiten las caídas de monedas, una cabina telefónica que permite a cualquiera acceder a la línea telefónica de otra persona, un sistema de correo de voz que proporciona mensajes desde cualquier teléfono en cualquier lugar. , o una máquina de FAX que se puede sondear de forma remota para reenviar lo último que hay en la memoria al número de la persona que llama.
		En SPECSEC, una vulnerabilidad puede ser un hardware que puede sobrecargarse y quemarse con versiones de mayor potencia de la misma frecuencia o una frecuencia cercana, un receptor estándar sin configuraciones especiales que puede acceder a los datos de la señal, un receptor que puede verse obligado a aceptar una señal de terceros en lugar de la prevista, o un punto de acceso inalámbrico que interrumpe las conexiones cerca de un horno microondas.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

Categoría	Descripción
2 debilidad	Cuenta cada falla o error en los controles de interactividad: autenticación, indemnización, resiliencia, subyugación y continuidad. En PHYSSEC, una debilidad puede ser una cerradura de puerta que se abre cuando se coloca una tarjeta entre ella y el marco de la puerta, un generador de respaldo sin combustible o un seguro que no cubre daños por inundación en una zona de inundación. En HUMSEC, una debilidad puede ser una falla en el proceso de un segundo guardia para asumir el puesto del guardia que corre detrás de un intruso o un clima cultural dentro de una empresa para permitir que amigos entren a espacios restringidos. En la seguridad de los datos de COMSEC, una debilidad puede ser un inicio de sesión que permite intentos ilimitados o una granja de servidores web con DNS por turnos para equilibrar la carga, pero cada sistema también tiene un nombre único para el enlace directo. En las telecomunicaciones COMSEC, una debilidad puede ser una PBX que todavía tiene las contraseñas de administración predeterminadas o un banco de módems para acceso remoto telefónico que no registra los números, la hora y la duración de las llamadas. En SPECSEC, una debilidad puede ser un punto de acceso inalámbrico que autentica a los usuarios basándose en direcciones MAC (que pueden ser falsificadas) o una etiqueta de seguridad RFID que ya no recibe señales y, por lo tanto, no se "abre" después de recibir una señal de una fuente de alta energía.
3 Preocupación	Cuenta cada falla o error en los controles de procesos: no repudio, confidencialidad, privacidad, integridad y alarma. En PHYSSEC, una preocupación puede ser un mecanismo de cerradura de puerta cuyos controles de operación y tipos de claves son públicos, un generador de respaldo sin medidor de energía o indicador de combustible, un proceso de equipo que no requiere que el empleado firme la salida de los materiales cuando los recibe, o una alarma de incendio que no sea lo suficientemente fuerte como para que la escuchen los trabajadores de las máquinas con tapones para los oídos. En HUMSEC, una preocupación puede ser una falla en el proceso de un guardia que mantiene el mismo horario y rutina o un clima cultural dentro de una empresa que permite a los empleados usar salas de reuniones públicas para asuntos internos. En la seguridad de los datos de COMSEC, una preocupación puede ser el uso de certificados de servidor web generados localmente para HTTPS o archivos de registro que registran solo a los participantes de la transacción y no la fecha y hora correctas de la transacción. En las telecomunicaciones COMSEC, una preocupación puede ser el uso de una máquina de FAX para enviar información privada o un sistema de correo de voz que utiliza tonos para ingresar un PIN o contraseña. En SPECSEC, una preocupación puede ser un punto de acceso inalámbrico que utiliza un cifrado de datos débil o un abridor de puerta por infrarrojos que no puede leer al remitente bajo la lluvia.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

Categoría		Descripción
4 exposición		Cuenta cada acción, falla o error injustificable que proporcione visibilidad directa o indirecta de objetivos o activos dentro del canal de alcance elegido. En PHYSSEC, una exposición puede ser una ventana que permite ver activos y procesos o un medidor de energía que muestra cuánta energía utiliza un edificio y su fluctuación en el tiempo. En HUMSEC, una exposición puede ser un guardia que permite a todos los visitantes ver la lista de nombres en la hoja de registro o un operador de la empresa que informa a las personas que llaman que una persona en particular está enferma o de vacaciones. En la seguridad de datos COMSEC, una exposición puede ser un banner descriptivo y válido sobre un servicio (los banners de desinformación no son exposiciones) o una respuesta de eco ICMP de un host. En las telecomunicaciones COMSEC, una exposición puede ser un directorio automatizado de empresas ordenado alfabéticamente, lo que permite a cualquiera consultar todas las personas y números, o una máquina de FAX que almacena los últimos números marcados. En SPECSEC, una exposición puede ser una señal que interrumpe otra maquinaria o un dispositivo infrarrojo cuyo funcionamiento es visible mediante cámaras de video estándar con capacidad nocturna.
5 anomalía		Cuenta cada elemento no identificable o desconocido que no pueda contabilizarse en las operaciones normales, generalmente cuando no se puede entender el origen o destino del elemento. Una anomalía puede ser una señal temprana de un problema de seguridad. Dado que las incógnitas son elementos que no se pueden controlar, una auditoría adecuada requiere anotar todas y cada una de las anomalías. En PHYSSEC, una anomalía pueden ser pájaros muertos descubiertos en el techo de un edificio alrededor de los equipos de comunicaciones. En HUMSEC, una anomalía pueden ser las preguntas que hace un guardia y que pueden parecer irrelevantes para el trabajo o para una pequeña charla estándar. En la seguridad de datos de COMSEC, una anomalía pueden ser respuestas correctas a una sonda desde una dirección IP diferente a la que fue investigada o esperada. En telecomunicaciones COMSEC, una anomalía puede ser una respuesta de módem de un número que no tiene módem. En SPECSEC, una anomalía puede ser una señal local que no se puede localizar adecuadamente ni causa ningún daño conocido.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

4.4 La fórmula de seguridad operativa

El rav se deriva de tres categorías definidas dentro del alcance: Seguridad Operacional, Controles y Limitaciones. Para comenzar, primero debemos agregar y asociar toda nuestra información de entrada en las categorías apropiadas para cada variable de entrada.

La ecuación rav requiere que a cada una de las categorías se le asigne un valor base logarítmico para escalar los tres factores de Seguridad Actual de acuerdo con el alcance.

Category		OPSEC	Limitations
Operations		Visibility	Exposure
		Access	Vulnerability
		Trust	
Controls	Class A - Interactive	Authentication	Weakness
		Indemnification	
		Resilience	
		Subjugation	
		Continuity	
	Class B - Prozess	Non-Repudiation	Concern
		Confidentiality	
		Privacy	
		Integrity	
		Alarm	
		Anomalies	

La información contenida en el rav se compone de cómo las operaciones se equilibran con los controles y limitaciones. No hay "pesos" que sesguen los resultados, lo que deja una cuantificación flexible de la superficie de ataque que permite compararla con la seguridad de cualquier otra cosa, sin importar el tamaño, el vector o el canal.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

Porosidad

La Seguridad Operacional, también conocida como Porosidad del alcance, es el primero de los tres factores de la Seguridad Actual. Eso debería ser determinado. Inicialmente se mide como la suma de la visibilidad (PV), el acceso (PA) y el alcance del alcance. confianza (PT).

$$\text{OpSecsum} = \text{PV} + \text{PA} + \text{PT}$$

Sin embargo, al calcular el rav es necesario determinar el valor base de la Seguridad Operacional, OpSecbase . El valor base de la Seguridad Operacional viene dado por la ecuación

$$\text{Base de seguridad operacional} = \frac{1}{100} \cdot \text{Registro2 de OpSecsum}$$

Dado que el logaritmo de 0 no está definido en el cálculo, necesitábamos incluir aquí el 1+100. el registro de 1 es 0. Entonces, si tenemos 0 porosidad y queremos expresar esta falta de interacción como una seguridad perfecta de 100 rav entonces necesitábamos sumar +1 a la ecuación. Sin el 1+100 tendríamos números indefinidos en el caso de que las sumas de cualquiera de esos factores sean 0. Esto es requerido por la metodología porque el La ausencia de interacciones representa una seguridad perfecta y, por lo tanto, el logaritmo debe ser igual a 0 para proporcionar los 100 rav.

4.5 La fórmula de controles

El siguiente paso para calcular el rav es definir los controles de pérdidas; los mecanismos de seguridad establecidos para proteger las operaciones. Primero, la suma de los Controles de Pérdidas, LCsum , debe determinarse sumando las 10 categorías de Control de Pérdidas.

Control S	Clase A		
		Autenticación	LCau
		Indemnización	LCId
		Resiliencia	LCRe
		Subyugación	LCSu
		Continuidad	LCCT
	Clase B		
		LCNR de no repudio	
		Confidencialidad	LCCF
		Privacidad	LCPR
		Integridad	LCIt
		Alarma	LCAI

Por lo tanto, la suma de control de pérdidas LCsum se da como

$$\text{LCsum} = \text{LCAu} + \text{LCId} + \text{LCRe} + \text{LCSu} + \text{LCCT} + \text{LCNR} + \text{LCCF} + \text{LCPR} + \text{LCIt} + \text{LCAI}$$



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

Controles faltantes

Dado que la combinación de cada uno de los 10 Controles de Pérdidas equilibra el valor de 1 pérdida de OpSec (visibilidad, acceso, confianza), es necesario determinar la cantidad de Controles Faltantes, MC_{sum} , para evaluar el valor de las Limitaciones de Seguridad. Esto debe hacerse individualmente para cada una de las 10 categorías de Control de Pérdidas.

Por ejemplo, para determinar los Controles Faltantes para la Autenticación ($MCAu$) debemos restar la suma de los Controles de Autenticación ($LCAu$) del alcance del $OpSec_{sum}$. Sin embargo, los controles faltantes nunca pueden ser inferiores a cero.

La ecuación para determinar los controles faltantes para la autenticación ($MCAu$) viene dada por

$$\begin{aligned} & \text{SI } OpSec_{sum} - LCAu \geq 0 \\ & \quad \text{ENTONCES } MCAu = OpSec_{sum} - LCAu \\ & \text{0 ELSE } MCAu = 0 \end{aligned}$$

Luego, se deben sumar los totales de control faltante resultantes para cada uno de los 10 controles de pérdida para llegar al valor total de control faltante (MC_{sum}), como se ve a continuación.

$$MC_{sum} = MCAu + MCId + MCre + MCSu + MCCt + MCNR + MCIi + MCPi + MCCf + MCAI$$



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

Controles verdaderos

Los controles verdaderos (TCsum) son lo inverso de los controles faltantes, lo que significa los controles verdaderos para cada individuo. El control también debe calcularse antes de que los resultados puedan contabilizarse en TCsum.

La ecuación para determinar los verdaderos controles de autenticación (TCAu) viene dada por

$$TCAu = OpSecsum - MCAu$$

Los totales de Control Verdadero resultantes para cada uno de los 10 Controles de Pérdidas deben luego sumarse para llegar al total Valor de control verdadero (TCsum) como se ve a continuación.

$$TCsum = TCAu + TCId + TCRe + TCSu + TCCt + TCNR + TCIt + TCPr + TCCf + TCAI$$

Los True Controls se utilizan para medir la ubicación ideal de los controles. El valor base también ayuda a eliminar la influencia de una colocación desproporcionada de controles sobre la seguridad. La base de True Controls (TCbase) el valor viene dado como:

$$TCbase = \log_2 \left(\frac{100}{OpSecsum - MCAu} \right)$$

Basado en la misma idea que True Controls, True Coverage (TCvg) se puede utilizar para medir el porcentaje de controles establecidos con respecto a la cantidad y ubicación óptimas de los controles. La verdadera cobertura es entonces derivado utilizando los totales de control faltante y la siguiente ecuación:

$$TCvg = \frac{SI - OpSecsum}{10} \quad \text{ENTONCES } TCvg = 0$$

$$\text{DEMAS } TCvg = 1 - \frac{MC}{10} \quad \text{suma}$$

Seguridad de Operaciones suma

Controles completos

Los controles totales, por otro lado, tienen en cuenta todos los controles establecidos independientemente de un equilibrio distribución. Este valor es importante para medir el valor de la autenticación de dos factores, por ejemplo, y otras instancias de defensa en profundidad para la misma visibilidad, acceso o confianza. La base de controles totales (FCbase) el valor viene dado como:

$$FCbase = \log_2 \left(\frac{110}{OpSecsum} \right)$$



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

4.6 La fórmula de limitaciones

A continuación, las limitaciones se ponderan individualmente. La ponderación de las Vulnerabilidades, Debilidades y Las preocupaciones se basan en una relación entre la Porosidad u OpSecsum, los Controles de Pérdidas y en el caso De Exposiciones y Anomalías la existencia de otras Limitaciones también juega un papel. Una exposición o anomalía no plantea problemas por sí solo a menos que también esté presente una vulnerabilidad, debilidad o preocupación. Piense en una exposición como un puntero. Si hay un puntero que no lleva a ninguna parte, o en este caso no conduce a nada explotable (Vulnerabilidad, Debilidad, Preocupación) y se tienen en cuenta todos los controles, luego, en el momento de la prueba, La exposición no tiene ningún efecto sobre la seguridad y, por tanto, no tiene valor en el rav.

La siguiente tabla de valores se utiliza para calcular la variable SecLimsum, como paso intermedio entre las entradas de Limitación de seguridad y la variable SecLimbase, que es la entrada básica de Limitaciones de seguridad para la ecuación rav.

$$\begin{aligned} \text{SI OpSecsum} &= 0 \\ \text{ENTONCES MCvg} &= 0 \\ \text{DEMÁS MCvg} &= \frac{\text{MC suma}}{\text{Seguridad de Operaciones suma}} \cdot 0.1 \end{aligned}$$

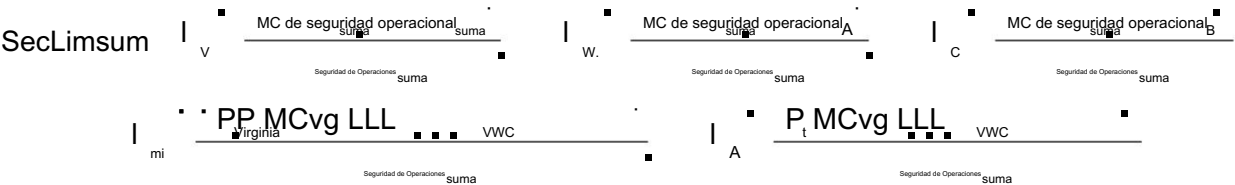
Aporte	Valor ponderado	variables
Vulnerabilidad LV	$\frac{\text{OpSec suma} \cdot \text{MC suma}}{\text{Seguridad de Operaciones suma}}$	MCsum : suma de controles faltantes
Debilidad LW	$\frac{\text{OpSec suma} \cdot \text{MC A}}{\text{Seguridad de Operaciones suma}}$	MCA : suma de controles faltantes en la clase de control A
Inquietud LC	$\frac{\text{OpSec suma} \cdot \text{MC B}}{\text{Seguridad de Operaciones suma}}$	MCB : suma de controles faltantes en la clase de control B
Exposición LE	$\frac{P_v \cdot P_{\text{Virginia}} \cdot \text{MCvg} \cdot L_v \cdot L_w \cdot L_c}{\text{Seguridad de Operaciones suma}}$	PV : suma de visibilidad PA : suma de Accesos MCvg : porcentaje de cobertura faltante
Anomalía LA	$\frac{P_t \cdot \text{MCvg} \cdot L_v \cdot L_w \cdot L_{wc}}{\text{Seguridad de Operaciones suma}}$	PT : suma de visibilidad MCvg : porcentaje de cobertura faltante



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

Base de limitaciones de seguridad

Luego, SecLimsum se calcula como el total agregado de cada entrada multiplicado por su correspondiente valor ponderado como se define en la tabla anterior.



La ecuación base de las limitaciones de seguridad viene dada por:

$$\text{SecLimbase} = \frac{1}{100} \text{SegLimsum}$$



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

4.7 La fórmula de seguridad real

Esta es la parte final para utilizar todos los cálculos anteriores de tres maneras diferentes.

Delta de seguridad real

El Delta de Seguridad Actual es útil para comparar productos y soluciones estimando previamente el cambio (delta) que el producto o solución haría en el alcance. Podemos encontrar el Delta de Seguridad Real, ActSec con la fórmula:

$$\text{ActSec} = \text{FCbase} \sim \text{OpSecbase} \sim \text{SecLimbase} .$$

Verdadera protección

Se puede utilizar como expresión simplificada para la cobertura óptima de un ámbito determinado donde 100 significa un relación óptima entre la Porosidad, los Controles Verdaderos y las Limitaciones de Seguridad. Se brinda verdadera protección

como:

$$\text{TruPro} = 100 \cdot \text{TCbase} \sim \text{OpSecbase} \sim \text{SecLimbase}$$

Seguridad real

Para medir el estado actual de las operaciones con controles aplicados y limitaciones descubiertas, se realizó un análisis final. Se requiere un cálculo para definir la seguridad real. Como su nombre lo indica, este es el valor de seguridad total. que combina los tres valores de seguridad operativa, controles y limitaciones para mostrar el estado real de seguridad.

Seguridad real (total), ActSec es el verdadero estado de seguridad proporcionado como un hash de las tres secciones. un rav de 100 significa un equilibrio perfecto de seguridad; sin embargo, la seguridad real no es un valor porcentual real. También son posibles puntuaciones superiores a 100, lo que significa que el alcance probado tiene más controles implementados. de lo necesario, lo que también podría ser una prueba de gasto excesivo. La ecuación final de rav para la seguridad real es dado como:

$$\text{ActSec} = \frac{100 \cdot \text{ActSec} \sim \text{OpSecbase}}{100} \cdot \text{FCbase} \sim \text{OpSecbase} \sim \text{SecLimbase} \cdot \text{FCbase} \sim \text{SecLimbase} \cdot$$



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

Confiar en todos es inseguro pero no
Confiar en alguien es ineficiente.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

Capítulo 5 – Análisis de confianza

“Si pudieras tomar una pastilla que te hiciera confiar más, ¿lo harías?” Así fue como un estudio informal de ISECOM comenzó a ayudar a las personas a comprender mejor cómo hacen mal uso de la confianza como concepto. El público en general responde que no a esta pregunta. Un profesional de seguridad respondió: “Sí, pero sólo si todos los demás tienen que aceptarlo también”.

La confianza puede ser tanto un problema como una solución. Es un problema que pone la seguridad en una posición comprometida. Al igual que el concepto de energía potencial en física, la confianza crea una concentración de autorización que puede explotar y convertirse en un gran problema si la confianza falla o si el objetivo en el que se confía es engañado para dañar a quien da la confianza. Sin embargo, también puede reducir la necesidad de una reautenticación continua y posiblemente redundante, aumentando la eficiencia de las operaciones. Por esa razón, la confianza a menudo se ve como un protocolo de “autenticarse una vez y marcharse”. Esto se ve con mayor frecuencia en Seguridad Humana, donde los departamentos de Recursos Humanos investigan a un candidato antes de contratarlo y luego esa persona tiene acceso continuo a los recursos hasta que ya no es empleado. Luego, la reautenticación se realiza rara o esporádicamente y rara vez con la misma profundidad que cuando se contrata.

En seguridad operativa, la confianza no es más que un factor que contribuye a la porosidad, una interacción más que hay que controlar. Se diferencia de Access (la otra forma de interacción) en cómo se relaciona con otros objetivos dentro del alcance. Entonces, donde el acceso es la interacción entre dos lados de un vector dentro y fuera del alcance, la confianza se mide como las interacciones entre objetivos dentro del alcance. Sin embargo, la mayoría de la gente no utiliza la confianza de forma tan concreta. La confianza generalmente se aplica a una persona o artículo específico y a un acto específico como, “¿Puedo confiar en que este empleado entregará antes de la fecha límite?” o “¿Puedo confiar en esta computadora?”. Hay respuestas correctas para estas preguntas, pero las personas a menudo carecen de las habilidades necesarias para cuantificar el nivel de confianza en esa persona u objeto, lo que nos permitiría tomar una decisión más racional y lógica. Sin embargo, para cuantificar la confianza, primero debemos entenderla.

5.1 Comprender la confianza

La confianza es una decisión. Si bien algunas personas afirman que es una emoción, como el amor, o un sentimiento, como el dolor, es claramente una cualidad compleja con la que nacemos los humanos. A diferencia de una emoción o un sentimiento, podemos elegir confiar o no en alguien o en algo, incluso si nos parece mal hacerlo. Parece que somos capaces de racionalizar de una manera que reemplaza lo que sentimos al confiar en un objetivo. Esto significa que podemos cuantificarlo aplicando un proceso lógico. También significa que podemos asignar valores de confianza a objetos y procesos, así como a personas, en función de estos valores. Esto aporta un nuevo poder a quienes pueden analizar la confianza y tomar decisiones basadas en ese análisis. También significa que los analistas con esta habilidad pueden controlar mejor los sesgos, identificar falacias (especialmente aquellas de fuentes autorizadas o confiables) y manejar incógnitas para generar informes transparentes.

Un punto a tener en cuenta: sin embargo, una vez que se cuantifica la confianza, es sólo un vehículo para racionalizarla. No hará que algo parezca digno de confianza ni ahora ni en el futuro. Algunas personas tienen fuertes sentimientos de aversión o atracción que pueden estar en desacuerdo con los hechos.

Como parte de OpSec, la confianza es una parte de la porosidad de un objetivo. Mientras que la seguridad es como un muro que separa las amenazas de los activos, la confianza es un agujero en ese muro. Es donde el objetivo acepta la interacción de otros objetivos dentro del alcance. Sin embargo, las personas tienden a utilizar controles operativos inadecuados o incompletos con sus fideicomisos, como la autenticación que se ha realizado con una identificación inadecuada, como una voz por teléfono, una tarjeta de presentación o incluso simplemente la suposición de que debido a que una persona está en la habitación, están autorizados a estar allí. Esto abre a la gente al fraude y al engaño. Se requiere el uso de controles adicionales para asegurar un fideicomiso, para asegurar su integridad y resiliencia.

Desafortunadamente, si bien el uso de más controles funciona con objetos y procesos, es posible que no funcione entre personas. Muchas veces las normas sociales consideran controles más allá de la simple autenticación, como hacer coincidir una cara o



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

voz con una identidad que resulte ofensiva para la persona en la que se puede confiar. La sociedad a menudo exige que seamos más confiados como individuos para beneficiar a la sociedad en su conjunto y, a veces, a expensas de la protección individual de cada uno.

Como se indicó anteriormente, la confianza operativa se mide como algo negativo que proviene de una interacción entre dos entidades en un ámbito. Cuando un fideicomiso no tiene controles, es lo que la gente llama “confianza ciega”, lo que puede ser bueno para las relaciones y acelerar las interacciones, pero es malo para la seguridad operativa. La gente generalmente aplica controles a los fideicomisos incluso si no lo consideran como tal en ese momento. A algunos controles se les da inherentemente más peso que a otros dependiendo de la situación y la necesidad. Al seleccionar a una persona de la que necesitan depender, es posible que le den mayor valor a la integridad y la resiliencia. Al realizar una transacción financiera, es posible que le den mayor valor a la autenticación, la continuidad y la confidencialidad. Es posible que le den mayor valor a la alarma y el sometimiento a cambio de asesoramiento sobre un producto, a menos que sea una prescripción médica, entonces preferirían la privacidad y el no repudio. Sin embargo, siendo realistas, en realidad no están dando más valor a controles particulares. En lugar de eso, en realidad están evaluando las diez propiedades del fideicomiso y buscando esos controles específicos para que sus decisiones de fideicomiso sean cómodas. El uso de propiedades de confianza les permite tomar la decisión de confiar o no, incluso cuando la información que tienen sobre el objetivo está incompleta. Dado que la toma de decisiones sobre fideicomisos desinformada y sin práctica es una apuesta peligrosa, lo mínimo que puede proporcionar un proceso formal como la aplicación de las propiedades del fideicomiso es informar a quien toma las decisiones exactamente cuánto no sabe y permitirle buscar más información antes de continuar. Esto significa que la necesidad real de poder cuantificar la confianza operativa ocurre cuando debemos confiar en muchas incógnitas para determinar y racionalizar la confianza.

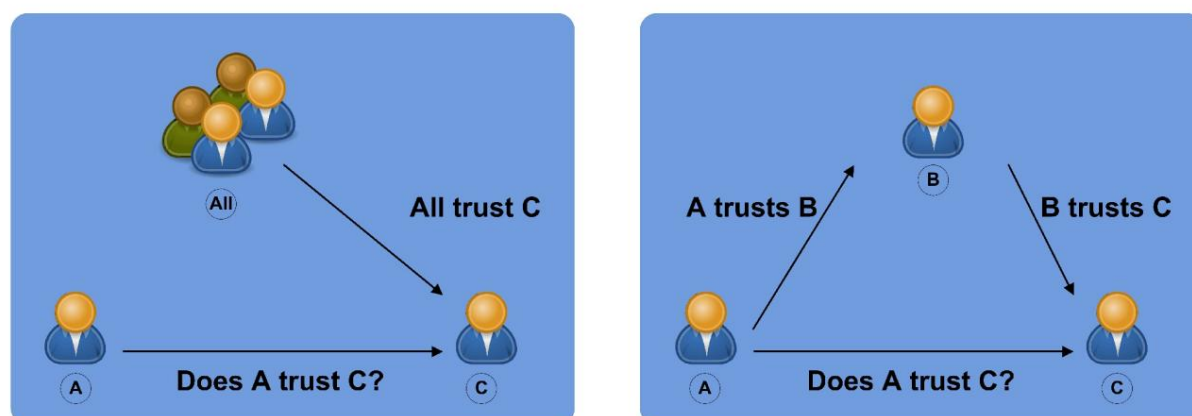
Las propiedades de la confianza son los elementos objetivos cuantificables que se utilizan para crear confianza. Podemos decir que estas propiedades son lo que diríamos que nos dan “razones para confiar”. Estas propiedades deben convertirse en reglas básicas basadas en el objetivo y la situación que estamos verificando. Desafortunadamente, existen muchas propiedades ilógicas de confianza y se utilizan con demasiada frecuencia, lo que nos dificulta tomar decisiones de confianza adecuadas sin que nos parezca incorrecto. Sin embargo, es exactamente la parte del sentimiento la que nos hace más propensos a cometer errores. Durante la investigación, se descubrieron muchas propiedades potenciales de fideicomiso que se usan comúnmente e incluso las regulaciones oficiales, gubernamentales y de la industria recomiendan; sin embargo, no pasaron las pruebas lógicas y fueron descartadas de nuestro conjunto de propiedades, dejando solo diez.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

5.2 Falacias en la confianza

Desafortunadamente, la mayoría de las personas no entienden ni utilizan la confianza. Existen muchos métodos ilógicos de confianza y se utilizan popularmente. Dos ejemplos de las propiedades de confianza más comunes y falaces son la componibilidad y la transitividad. Estas propiedades son utilizadas popularmente por las personas para tomar decisiones de confianza sobre lo desconocido. En la componibilidad, una persona toma una decisión de confianza basándose en lo que un gran número de personas tienen que decir sobre la cosa o persona en cuestión, incluso si no se confía en esas personas individualmente. Básicamente, una persona acepta los fideicomisos del grupo como propios. Esto es similar a la presión creada por grupos sociales o políticos y los medios de comunicación. La razón por la que esto es ilógico es porque las experiencias individuales de los demás, especialmente de los extraños, son todas relativas y no pueden verificar la confiabilidad constante de eventos futuros.



Ejemplos comunes de uso falaz de la confianza, primero con la Composabilidad y segundo, con la Transitividad.

El otro uso falaz común de la confianza es la transitividad. Es cuando una persona acepta para sí la decisión de confianza de una persona de confianza. También se la conoce como cadena de confianza: tú confías en Alice y Alice confía en Jack, por lo tanto tú puedes confiar en Jack. Sin embargo, la confianza transitiva también es ilógica porque puedes confiar en Alice para algunas cosas, pero quizás no para las mismas cosas para las que ella confía en Jack. También existe la posibilidad de que Alice se haya acercado al fideicomiso en busca de algún beneficio emocional que no está disponible para usted.

Las personas que a menudo confían en “su instinto” para tomar decisiones de confianza son elogiadas cuando tienen razón, como si tuvieran algún sentido secreto y poderoso por encima de otros humanos. Sin embargo, aparte de la suerte, algunas personas son mejores prestando atención a los detalles, viendo microexpresiones emocionales en los rostros y aplicando la lógica rápidamente a situaciones comunes que ellos mismos tal vez no puedan expresar verbalmente, pero que sí se sienten. qué ocurre. Estas personas aprendieron a hacer esto de forma natural y se basaron en una experiencia llena de prueba y error que no era realmente obvia para ellos, como tampoco nadie se da cuenta de los millones de pequeñas decisiones que toman cada día y sus consecuencias. Las propiedades de confianza permiten a las personas comunes y corrientes que no tienen esta habilidad natural analizar cualquiera de sus decisiones de confianza con habilidad, distanciándose de su propio “instinto visceral” subdesarrollado hasta que puedan reacondicionarse para hacerlo de forma automática y fluida, agudizando sus instintos. hasta que trabajen “desde las entrañas”.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

5.3 Las diez propiedades del fideicomiso

Las diez propiedades del fideicomiso para realizar un análisis de confianza adecuado son:

Propiedad fiduciaria			Descripción
1		Tamaño	El número en el que confiar. ¿Debe extenderse la confianza a uno solo o a ¿muchos? ¿Se debe confiar en el grupo que está destinado a hacer decisión colectiva?
2		Simetría	El vector (dirección) del fideicomiso. La confianza puede ser una forma (asimétrica) y se define en qué dirección debe viajar el fideicomiso o en ambos sentidos (simétrico). Una persona que también debe confiar en ti tiene que Considere la reciprocidad por romper la confianza.
3		Visibilidad	El nivel de transparencia de todas las partes y procesos operativos del objetivo y su entorno.
4		Subyugación	También llamado control, la cantidad de influencia sobre el alcance por parte del operador.
5		Consistencia	La evidencia histórica de compromiso o corrupción del objetivo.
6		Integridad	La cantidad y notificación oportuna del cambio dentro del objetivo.
7		Compensaciones	Las compensaciones de seguridad suficiente son una compensación para el donante de la confianza. o castigo para quien rompe la confianza. Es un valor puesto en la confianza. con el objetivo.
8		Valor	La compensación financiera por el riesgo, la cantidad de ganancia o ganancia por la cual el riesgo de confiar en el objetivo es suficiente para compensar el riesgo de fracaso en el confianza.
9		Componentes	El número de otros elementos que actualmente proporcionan recursos para objetivo ya sea a través de interacciones directas o indirectas, similares a Intervención del Proceso de los Cuatro Puntos.
10		Porosidad	La cantidad de separación entre el objetivo y el exterior. ambiente.



5.4 Las reglas de confianza

El uso de las propiedades de la confianza nos permite crear sólo reglas cuantificables, no reglas “blandas” que no pueden fundamentar el nivel de confianza ni perturbarlo con un peso emocional sesgado. Sin embargo, las propiedades por sí solas son inútiles si no pueden convertirse en propiedades cuantificables, objetivas o comprensibles para la persona común no necesariamente involucrada en el campo de la seguridad. Por lo tanto, todavía necesitamos convertir las propiedades del fideicomiso en reglas de confianza, cálculos de operaciones directamente relevantes realizadas a partir de todas las propiedades del fideicomiso. Hacemos esto en forma de preguntas donde las respuestas son números imparciales que se usarán para crear un porcentaje para una comprensión más fácil y que coincide con nuestro uso común de calificadores de confianza en el habla normal como casi, a veces, siempre y nunca.

Al crear reglas de confianza a partir de las propiedades del fideicomiso, es importante tener en cuenta que las decisiones de confianza no son lineales. No se puede generar confianza en un orden particular o incluso en un sistema de valores del esfuerzo donde se pueda determinar que un nivel requiere más esfuerzo que otro. En términos metodológicos, parece irracional cuando se calcula. Por lo tanto, una decisión de confiar puede concluirse con la respuesta de solo una de las siguientes pruebas que componen las reglas de confianza. Sin embargo, hacerlo es nuestra elección consciente de crear un fideicomiso donde el cálculo dice específicamente que no. Esto puede tener más sentido en una situación de vida o muerte donde el resultado de la confiabilidad es muy bajo pero el Valor de la Recompensa (la vida de uno) es tan increíblemente grande que no se puede hacer otra elección.

Las reglas de confianza deben crearse específicamente para el objetivo. Si bien esto puede parecer engorroso, es posible crear reglas de confianza genéricamente específicas para un tema que se adapten al propósito. El beneficio de esto es que las propiedades del fideicomiso se pueden convertir en reglas que se ajusten a cualquier propósito y situación en la que uno deba tomar una decisión de fideicomiso sobre otra persona, cosa, proceso, sistema o acción. Con la práctica, estas reglas de confianza se pueden crear de forma automática y muy rápida como parte del proceso de decisión, centrándose sólo en las reglas que se pueden responder y descubriendo aquellas en las que no se puede encontrar una respuesta con la información disponible.

La aplicación de las reglas de confianza en pruebas de verificación específicas que proporcionan una cantidad es buena, pero lo ideal es determinar una cantidad finita. Una cantidad infinita puede ser demasiado relativa para el probador y no proporciona las restricciones necesarias para expresar el resultado en porcentaje. Por ejemplo, para aplicar la tercera propiedad, la transparencia, los componentes deben contarse como indexados para que haya una cantidad finita. Por lo tanto, las partes de una computadora pueden tener un número final antes de que la computadora esté completamente construida y un proceso puede tener un número finito y preciso de pasos antes de completarse. Para las personas, sin embargo, esto puede no ser tan fácil de hacer, pero es posible si se aplica adecuadamente a la situación. En el caso de una autorización de seguridad, puede contar todas las relaciones dentro de un rango de tiempo determinado y, de ellas, el número que son con personas que tienen antecedentes penales. Esto permite un número finito aunque sea bastante grande. Luego, es posible que desees completar otras pruebas específicas de la tercera regla, ya que ésta solo puede dar un tipo de influencia. Otras pueden ser necesidades financieras, experiencias laborales, membresías, convicciones y cualquier cosa que dé una buena representación de cuán transparente es esa persona. Sin embargo, el cálculo final debe ser la suma total de todas las pruebas que proporcionarán un porcentaje único de transparencia para esa regla.

El porcentaje resultante para cada regla de confianza se puede ver individualmente para mostrar dónde se deben aplicar controles para mejorar o mantener los niveles necesarios de confiabilidad. Esto también puede mostrar dónde se deben realizar mejoras antes de que se pueda considerar un fideicomiso. Por ejemplo, un análisis de confianza para una campaña militar costosa y difícil puede mostrar que la regla cuatro, la subyugación, es del 10% porque algunos de los participantes necesarios son civiles y no están bajo control militar. Esto les brinda a los operadores del teatro de la campaña información específica y procesable para realizar los ajustes necesarios para llevar ese porcentaje a un nivel aceptable o aplicar más controles para asegurar mejor el cumplimiento por parte de esos miembros civiles.

Otro resultado del análisis de los porcentajes de las reglas de confianza individuales es que las incógnitas se vuelven notoriamente



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

obvio porque cuanto menos se sepa, menor será el porcentaje. Esto significa que las incógnitas estarán en el 0% o muy cerca.

Sin embargo, la métrica final es la media de todos los porcentajes. Esto proporciona una comprensión general que podría tener racionalmente del objetivo del fideicomiso. Esto es especialmente útil cuando es difícil tomar una decisión de confianza debido a prejuicios personales. El uso de reglas de confianza en el análisis de seguridad formal, así como en la toma de decisiones periódica, puede minimizar en gran medida los sesgos y los errores. Por lo tanto, el analista debe practicar esta habilidad para poder aplicarla rápidamente, de modo que pueda usarse incluso en situaciones de alta presión o de emergencia donde es necesaria una decisión rápida y una decisión equivocada es una tragedia.

Ejemplos de reglas de confianza

Esta es una muestra de reglas de confianza genéricas que cualquiera puede utilizar para tomar mejores decisiones de contratación más allá de la simple calificación técnica del solicitante. Sigue las 10 propiedades fiduciarias. El objetivo es realizar preguntas cuantificables que puedan ser respondidas para cada una de las propiedades y aplicadas por cualquier persona y sobre cualquier posible nueva contratación. Unas reglas de confianza sólidas permiten la coherencia en la calidad en lugar de depender del “instinto” de los guardianes que necesitan tomar las decisiones de confianza.

1.
 - Tamaño: 1.1. Calcular el solicitante dividido por el grupo total de solicitantes.
 - 1.2. Calcule el número de personas que el solicitante parece conocer en el grupo dividido por el total solicitantes del total del grupo.
 - 1.3. Calcule la cantidad de empleados actuales que el solicitante conoce (y de los que es “amigo”) en esta ubicación y divídalo por la cantidad total de empleados en esta ubicación.
 - 1.4. Registre el promedio de estos resultados.
2. Simetría: 2.1.
 - El número de personas en las que debe confiar el solicitante para realizar su trabajo en este puesto (incluido el solicitante) dividido por el número de profesionales que deben confiar en el solicitante en este puesto.
3. Visibilidad:
 - 3.1. El número de horas por día que el solicitante trabajará solo, sin asistencia y sin supervisión dividido por el número de horas de trabajo.
4. Sometimiento:
 - 4.1. La cantidad de decisiones que el empleado tomará diariamente, de forma independiente, sin participación, dividida por la cantidad total de decisiones que el puesto normalmente requiere en un día.
 - 4.2. El solicitante dividido por el número de miembros del equipo con los que trabajará el solicitante a diario.
 - 4.3. Registre el promedio de estos resultados.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

5. Coherencia: 5.1.

El número total de meses que el solicitante no ha estado empleado dividido por el número total de meses que el solicitante ha estado en la fuerza laboral y es elegible para el empleo.

5.2. El número total de delitos penales conocidos dividido por la edad actual menos dieciocho años (o la edad legal de un adulto en su región) del solicitante.

5.3. El número de referencias neutrales o negativas de empleadores anteriores dividido por el número total de empleadores anteriores.

5.4. Registre el promedio de estos resultados.

6. Integridad:

6.1. El número de entregables que el solicitante debe presentar o presentar semanalmente dividido por la semana laboral.

7. Compensaciones:

7.1. Cantidad de activos por valor a los que el solicitante tendrá acceso dividido por un costo estandarizado de procesamiento y costo de recuperación.

8. Valor:

8.1. El ingreso mensual creado o ahorrado por el solicitante en el puesto dividido por el costo mensual del solicitante. (No medimos el monto pagado por el puesto en comparación con el promedio nacional porque no existe una correlación clara entre el nivel salarial y la satisfacción laboral que impide que un empleado se vaya, robe o sabotee el lugar de trabajo).

9. Componentes:

9.1. El número de procesos que requiere el solicitante dividido por el número total de procesos para la posición.

9.2. El número de recursos que el empleado utilizará mensualmente dividido por el número total de recursos disponibles para todos los empleados en ese puesto.

9.3. Registre el promedio de estos resultados.

10. Porosidad:

10.1. La cantidad de tiempo semanal que el solicitante dedicaría a interactuar directamente con los competidores, socios o clientes dividido por el número total de horas de trabajo semanales.

10.2. El número de empleados que viven en la misma comunidad que el solicitante dividido por el total número de personas en la comunidad.

10.3. Registre el promedio de estos resultados.

Cada ejemplo de cálculo consiste en generar un porcentaje que se promediará con los demás porcentajes de todas las propiedades del fideicomiso para crear un valor final del fideicomiso. El valor final le dirá cuánto debe confiar en el nuevo empleado. Luego se pueden realizar reevaluaciones periódicamente para ver cuánto ha cambiado y si esto debería influir en los permisos otorgados al empleado, la tasa de pago u otras bonificaciones.



5.5 Aplicación de reglas de confianza a las pruebas de seguridad Las

pruebas de seguridad verificarán qué confianzas operativas existen; sin embargo, se requiere el uso de reglas de confianza para saber si deberían existir. Esto se determina mediante el uso de reglas de confianza durante las pruebas de seguridad.

La gestión de seguridad y la creación de políticas generalmente se basan en el riesgo que define las interacciones permitidas dentro y en toda una organización. Básicamente, este método define reglas para usuarios y configuraciones para sistemas que proporcionarán el nivel requerido de protección cuando se sigan. La política también puede dictar cómo manejar los problemas que pueden ocurrir si las reglas o configuraciones son insuficientes o no se siguen adecuadamente. Por lo tanto, la política de seguridad describirá lo que la organización determina como confiable o no y qué confianzas operativas se permitirán. Sin embargo, probar la confianza operativa tal como lo establece la política de seguridad no es una prueba de seguridad y no ayudará a una organización a determinar mejor dónde está limitada su protección.

Las pruebas de seguridad basadas en una política particular para garantizar que se sigan las reglas se denominan pruebas de cumplimiento y no son lo mismo que las pruebas de seguridad. El uso de la auditoría OSSTMM determinará las confianzas operativas existentes, ya sea que se reconozcan o no dentro de la política de seguridad. Estos hallazgos, sujetos a un análisis de confianza donde se han aplicado las Reglas de Confianza a personas, sistemas y procesos, proporcionarán una medición precisa de dónde deben estar los controles. Luego, esto se puede comparar con la política de seguridad para encontrar las deficiencias que afectan las medidas de protección actuales, así como los planes de seguridad futuros. En última instancia, el analista utilizaría métricas de confianza en lugar del análisis de riesgos como medio más preciso para proteger un alcance.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

Sólo hay 2 maneras de robar algo: o lo tomas
tú mismo o haces que otra persona lo tome y
te lo dé.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

Capítulo 6 – Flujo de trabajo

El flujo OSSTMM comienza con una revisión de la postura del objetivo. La postura es la cultura, las reglas, las normas, los contratos, la legislación y las políticas que definen el objetivo. Termina con comparaciones de resultados con alarmas, alertas, informes o registros de acceso. Se trata de un concepto de círculo completo en el que el primer paso es conocer los requisitos operativos para interactuar con el objetivo y el último paso es la revisión de los registros de la pista de auditoría. Para el analista, esto es simplemente: usted sabe lo que necesita hacer, lo hace y luego verifica lo que ha hecho.

Esta metodología separa lo que se debe hacer en este formato jerárquico:

1. CANAL 2. MÓDULO
- 3.
- TAREA

El trabajo se describe en la descripción del módulo para cada auditoría de canal en particular. Algunas auditorías se aplican a tecnologías que pueden cruzar la frontera entre dos o más canales. Por ejemplo, las LAN inalámbricas más comunes deben probarse tanto en el canal de redes de datos como en el canal inalámbrico. Por eso es tan importante un plan de pruebas adecuadamente definido. La hibridación de canales es una constante y no debe pasarse por alto. El OSSTMM es totalmente capaz de realizar una revisión de seguridad "desde la acera hasta el núcleo" y, por lo tanto, es completamente capaz de aplicar un análisis a un objetivo, ya sea que sus canales sean claramente distintos y separados o estén compuestos por múltiples canales. Por lo tanto, para todos los objetivos, el analista debe anticipar la necesidad de definir una auditoría que incluya múltiples canales. A veces, solo bajo investigación se hará evidente si el alcance contiene objetivos en un canal en particular o si el analista omitirá objetivos que solo están disponibles en otros canales.

Esta metodología se aplica a los cinco canales. Tiene 17 módulos y las mismas propiedades se aplican a los cinco canales. Si bien la metodología en sí puede ser la misma, cada canal difiere en sus tareas. Cada módulo tiene una entrada y una salida. La entrada es la información utilizada para realizar cada tarea. El resultado es el resultado de las tareas completadas. Esta salida puede o no ser inteligencia (datos analizados) para servir como entrada para otro módulo y esta salida puede además servir como entrada para más de un módulo o sección.

Por lo tanto, no completar ciertos módulos o tareas puede limitar la finalización exitosa de otros módulos o tareas. Esto limitaría la minuciosidad de la auditoría mucho más de lo que revelaría una simple contabilidad de las tareas faltantes.

Algunas tareas no producen resultados, lo que significa que existirán módulos para los cuales no hay entradas. Los módulos que no tienen entrada pueden ignorarse durante las pruebas, pero deben documentarse posteriormente con una explicación por no haberse realizado. Además, las tareas sin resultados no necesariamente indican una prueba inferior; más bien, pueden indicar una seguridad superior. En detalle, las tareas que no tienen ningún resultado final pueden significar cualquiera de estas cinco cosas:

1. El canal estuvo obstruido de alguna manera durante la realización de las tareas.
2. Las tareas no se realizaron correctamente.
3. Las tareas no eran aplicables.
4. Los datos del resultado de la tarea se han analizado incorrectamente.
5. La tarea revela una seguridad superior.

Es importante que exista imparcialidad y apertura de mente al realizar las tareas de cada módulo. El principio principal de la auditoración dice, en relación similar con el sesgo conformacional: "Cuando uno busca algo, espera encontrarlo, lo que puede llevarlo a encontrar sólo lo que está buscando". En OSSTMM, cada módulo comienza como una entrada y termina como una salida exactamente para mantener el sesgo al mínimo. Por lo tanto, cada tarea da una dirección de lo que se debe revelar para pasar a otro punto dentro de la metodología.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

Se podrá incorporar un análisis de confianza previo para determinar el alcance según vector y canal. También se puede utilizar un análisis de confianza para predeterminar qué módulos deben realizarse como pruebas independientes. Sin embargo, recuerde que los módulos son parte de una prueba completa y la suposición de que cualquier módulo en particular puede omitirse es falsa y conducirá a una prueba incorrecta. Sin embargo, si no hay entrada para un módulo en particular, se puede omitir sin degradar la calidad de la prueba. La diferencia es que, en el primer caso, el módulo o tarea se ignora basándose en una decisión de confianza, mientras que en el segundo la propia prueba dictaminó que el módulo o tarea no se puede realizar.

Al proporcionar pruebas como servicio, es importante comunicar al propietario objetivo exactamente qué parte del alcance no se ha probado o no se probará. Esto gestiona expectativas y garantías de riesgos potencialmente inapropiadas en la seguridad de un sistema.

El tiempo de prueba con los módulos es relativo al plan. Por ejemplo, si el analista prueba la seguridad física de una puerta, entonces la prueba tendría al menos dos vectores: la seguridad funcional de la puerta desde el exterior de la habitación hacia el interior, y luego desde el interior de la habitación hacia el exterior. Determinar el alcance adecuado en función del vector es importante porque aún puede haber objetivos fuera del vector y aún dentro del alcance que no constituirán el alcance de prueba actual. En general, los ámbitos más grandes con múltiples canales y múltiples vectores requieren más tiempo dedicado a cada módulo y sus tareas. Esta metodología no determina la cantidad de tiempo permitido antes de regresar con los datos de salida y depende del analista, el objetivo, el entorno de prueba y el plan de prueba.

6.1 Flujo de la metodología

La OSSTMM no permite una separación entre lo que se considera recopilación activa de datos y verificación mediante agitación; porque, en ambos casos, se requiere interacción. Tampoco diferencia entre pruebas activas y pasivas, donde las pruebas activas son la agitación para crear una interacción con el objetivo y las pruebas pasivas son el registro, la agregación y el análisis de las emanaciones del objetivo. Esta metodología requiere pruebas tanto activas como pasivas. Además, es posible que el analista no pueda diferenciar entre los datos recopilados pasivamente a partir de emanaciones de las operaciones y los que constituyen la respuesta retrasada o mal dirigida a la agitación. La introducción de cualquier evento externo, incluido el tipo pasivo, tiene el potencial de cambiar la naturaleza de las operaciones del objetivo y reducir la calidad de una prueba no influenciada sobre la seguridad operativa. Sin embargo, esto no representa una falla del Analista o del proceso de auditoría, sino simplemente un mal inevitable de probar un sistema en un entorno estocástico durante un marco de tiempo lineal. En pocas palabras, el analista a menudo no puede “retirar” la agitación una vez que se ha puesto en marcha y cualquier corrección provocará resultados adicionales y variados que no coinciden con el objetivo de la tarea original.

Esto es importante porque dificultará la comparación posterior de resultados. También significará que las pruebas anteriores influirán en las pruebas posteriores debido a la “memoria” del impacto de la prueba. Esto es muy notable al realizar pruebas en el canal PHYSSEC.

Es importante señalar que al armonizar el OSSTMM con otros estándares de prueba, es importante no restringir el flujo de esta metodología mediante la introducción de estándares tan formales e implacables que la calidad de la prueba se vea afectada.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

La memoria de las operaciones

Este es un ejemplo de cómo las pruebas operativas de PHYSSEC en un entorno estocástico durante un período de tiempo lineal se ven afectadas por su propia memoria.

Escenario 1

El analista prueba el ingreso a un área segura con autenticación falsa. El guardia examina la placa brevemente y permite la entrada al analista. El Analista realiza la auditoría hasta el punto en que se le identifica y se revela la naturaleza de la auditoría, si es que se revela.

Escenario 2

El analista prueba el ingreso a un área segura con autenticación falsa. El guardia examina brevemente la placa y, dudando de su autenticidad, no permite la entrada al Analista. El analista prueba tácticas adicionales hasta lograr la entrada. El Analista realiza la auditoría hasta el punto en que se le identifica y se revela la naturaleza de la auditoría, si es que se revela.

En ambos escenarios 1 y 2, puede quedar constancia o no del intento de entrada. Si hay un registro, ese registro puede ser reutilizado por el analista la próxima vez si se niega la insignia como prueba de su autenticidad o por el guardia que puede estar dudando de su autenticidad y quiere ver qué han hecho otros guardias.

Para la siguiente auditoría, el analista puede intentar usar la misma insignia nuevamente, intentar otros medios para ingresar mediante técnicas de ingeniería social o intentar usar una insignia diferente. Ese guardia, otros guardias con los que el guardia pudo haber hablado y cualquier registro del intento exitoso o fallido son todos recuerdos del Analista, la técnica y, si el guardia sabe de la auditoría, la auditoría misma.

Sin embargo, si ocurre el escenario 2, es posible que la interacción que se intensifica a través de las técnicas adicionales utilizadas por el analista signifique que el escenario 2 sea una prueba más exhaustiva a medida que se realizan más pruebas dentro de la misma interacción. También significa que es más probable que el guardia recuerde la auditoría y al analista.

Si el Analista no logra ingresar en absoluto, entonces la integridad de la prueba se limita en cuanto al momento en que el Analista se quedó sin técnicas, y cada técnica fallida hace que la entrada sea mucho más difícil. Si el analista pasa por todas las técnicas descritas en las tareas de la metodología, entonces las pruebas se han completado. De lo contrario, las pruebas que aún no se han realizado deberán realizarse con un guardia diferente y con resultados diferentes, ya que diferentes personas se comportan de manera diferente.

Si bien esto puede parecer un problema humano, no lo es. Una puerta o ventana que se abre a la fuerza con demasiada frecuencia permanecerá dañada hasta que se reemplace. El uso físico siempre resulta en deterioro físico. Incluso en las comunicaciones por cable, el acto de espiar el tráfico provocará retrasos (a veces perceptibles) o cambiará el consumo de energía, con resultados directos o indirectos y, a menudo, variados.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

6.2 Los módulos de prueba

Para elegir el tipo de prueba adecuado, es mejor comprender primero cómo están diseñados para funcionar los módulos.

Dependiendo de la minuciosidad, el negocio, la asignación de tiempo y los requisitos de la auditoría, es posible que el analista desee programar los detalles de la auditoría por fase.

Hay cuatro fases en la ejecución de esta metodología:

- A. Fase de Inducción B.
- Fase de Interacción C.
- Fase de Investigación
- D. Fase de Intervención

Cada fase aporta una profundidad diferente a la auditoría, pero ninguna fase es menos importante que otra en términos de seguridad real.

A. Fase de Inducción

Todo viaje comienza con una dirección. En la fase de inducción, el analista comienza la auditoría con una comprensión de los requisitos de la auditoría, el alcance y las limitaciones de la auditoría de este alcance.

A menudo, el tipo de prueba se determina mejor después de esta fase.

Módulo	Descripción	Explicación
A.1 Revisión de la postura	La revisión de la cultura, reglas, normas, reglamentos, legislación y políticas aplicables al objetivo.	Conocer el alcance y qué pruebas se deben realizar. Requerido para que la Fase C se lleve a cabo correctamente.
A.2 Logística	La medición de la interacción Conocer las limitaciones de la propia auditoría. limitaciones como distancia, velocidad, Esto minimizará el error y mejorará la fiabilidad para determinar márgenes de eficiencia. exactitud dentro de los resultados.	
A.3 Verificación de detección activa	La verificación de la práctica y conocer las restricciones impuestas sobre la amplitud de la detección de interacciones, pruebas interactivas. Esto es necesario para la respuesta y la previsibilidad de la respuesta. realizar adecuadamente las Fases B y D.	



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

B. Fase de interacción

El núcleo de la prueba de seguridad básica requiere conocer el alcance en relación con las interacciones con los objetivos transmitidos a las interacciones con los activos. Esta fase definirá el alcance.

Módulo	Descripción	Explicación
B.4 Auditoría de Visibilidad	La determinación de los objetivos a conocer. Saber qué objetivos existen y cómo se probaron dentro del alcance. La visibilidad interactúa con el alcance, en todo caso. Un objetivo considerado como "presencia" y no muerto o desaparecido también es un objetivo limitado a la vista humana. objetivo que no responde. Sin embargo, un objetivo que no responde no es necesariamente un objetivo perdido.	
B.5 Verificación de acceso	La medición de la amplitud y profundidad de los puntos de acceso interactivos dentro del objetivo y la autenticación requerida.	El punto de acceso es el punto principal de cualquier interacción de activos. Verificar que existe un punto de acceso es una parte de determinar su existencia. La verificación completa requiere saber todo lo que hay que saber sobre el punto de acceso.
B.6 Verificación de confianza	La determinación de las relaciones de confianza Los fideicomisos para nuevos procesos a menudo surgen de y entre los objetivos. Existe una confianza limitada donde los procesos más antiguos tienen una relación donde el objetivo evoluciona aparentemente caóticamente hacia la interacción aceptada entre objetivos externos. Conocer las relaciones de confianza el alcance. entre objetivos mostrará la edad o el valor de la interacción.	
B.7 Verificación del control	La medición del uso y Eficacia de los controles de pérdidas basados en procesos (Clase B): no repudio, confidencialidad, privacidad e integridad. El control de alarma se verifica al final de la metodología.	La mayoría de los procesos se definen en respuesta a una interacción necesaria y algunos permanecen mucho después de que esa interacción se detiene o ha cambiado. Saber qué controles de procesos existen es un tipo de arqueología de la seguridad.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

C. Fase de investigación

Gran parte de la auditoría de seguridad gira en torno a la información que descubre el analista. En esta fase se ponen de manifiesto los distintos tipos de valor o el detrimento que supone como activo la información fuera de lugar y mal gestionada.

Módulo		Descripción	Explicación
C.8 Verificación del proceso		La determinación de la existencia. Conocer los controladores y sus rutinas y efectividad del registro y de los controles. La mayoría de los procesos tendrán un conjunto definido de reglas; sin embargo, los niveles de seguridad o diligencia definidos por las operaciones reales reflejan toda la revisión de la postura y la eficiencia, la pereza o la paranoia que controla la indemnización. puede redefinir las reglas. Así que no se trata sólo de que el proceso esté ahí, sino también de cómo funciona.	
C.9	Verificación de configuración / Verificación de capacitación	La investigación del estado estacionario Este módulo explora el valor predeterminado (operación normal) de los objetivos como condiciones bajo las cuales los objetivos para los que han sido diseñados operan regularmente para comprender las condiciones normales para determinar la intención, la justificación comercial y los problemas subyacentes fuera de el razonamiento de los objetivos. Adicionalmente, aplicación de pruebas de estrés de seguridad. muchas regulaciones requieren información sobre cómo se planea que algo funcione y esto no siempre es evidente en la ejecución de ese trabajo.	
C.10	Validación de propiedad	La medición de la amplitud y profundidad en el uso de aplicaciones o propiedad intelectual ilegal o sin licencia dentro del objetivo.	Conocer el estado de los derechos de propiedad de la propiedad.
C.11	Revisión de la segregación	Una determinación de los niveles de información de identificación personal definida por la revisión de postura.	Sepa qué derechos de privacidad se aplican y en qué medida los descubiertos La información de identificación personal se puede clasificar según estos requisitos.
C.12	Verificación de la exposición	La búsqueda de información disponible gratuitamente que describa la visibilidad indirecta de objetivos o activos dentro del canal elegido del alcance.	La palabra en la calle tiene valor. Descubra información sobre objetivos y activos de fuentes públicas, incluida la de los propios objetivos.
C.13	Inteligencia competitiva Exploración	La búsqueda de información disponible gratuitamente de los procesos y podría dañar o afectar negativamente a los objetivos que los activos de los que son propietarios a través de protección externa. Descubrir información que significa competitivo. por sí solo o en conjunto puede influir en las decisiones empresariales competitivas.	



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

D. Fase de intervención

Estas pruebas se centran en los recursos que los objetivos requieren en el alcance. Esos recursos pueden cambiarse, sobrecargarse o privarse para provocar penetración o interrupción. Esta suele ser la fase final de una prueba de seguridad para garantizar que las interrupciones no afecten las respuestas de pruebas menos invasivas y porque es posible que la información para realizar estas pruebas no se conozca hasta que se hayan llevado a cabo otras fases. El último módulo, D.17, de Alerta y Revisión de Registros, es necesario para verificar pruebas anteriores que no proporcionaron interactividad al Analista. Es posible que la mayoría de las pruebas de seguridad que no incluyen esta fase aún necesiten ejecutar una revisión final desde la perspectiva de los objetivos y activos para aclarar cualquier anomalía.

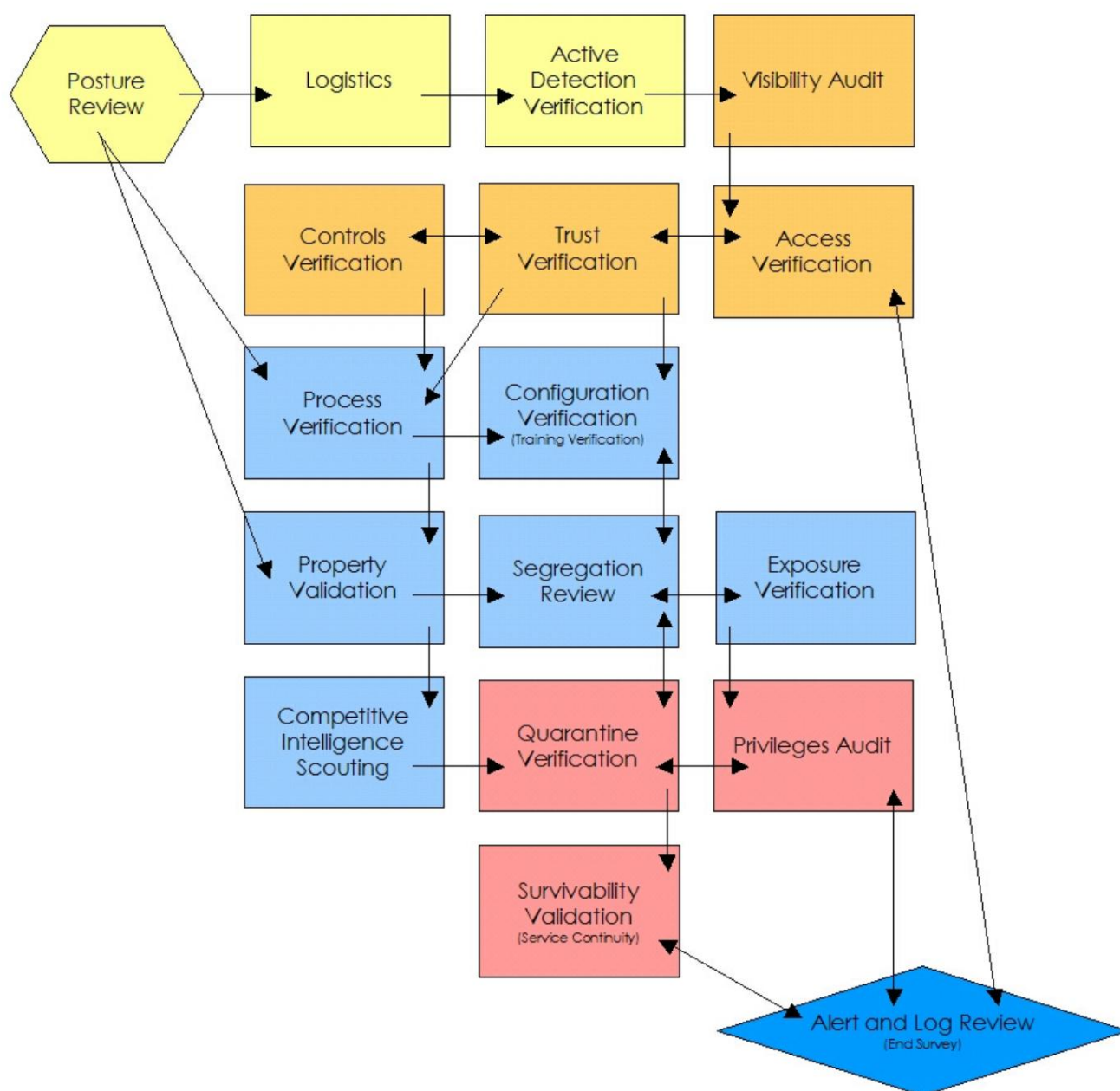
Módulo		Descripción	Explicación
D.14	Verificación de cuarentena	La determinación y medición del uso efectivo de la cuarentena para todos los accesos hacia y dentro del objetivo.	Determinar la efectividad de los controles de autenticación y subyugación en términos de cuarentenas de listas blancas y negras.
D.15	Auditoría de Privilegios	El mapeo y la medición de la autorización de subyugación en la autenticación, los controles, las credenciales y los privilegios o indemnización, y la subyugación de la escalada no autorizada de controles en términos de profundidad y roles. privilegio.	Determinar la efectividad del impacto del uso indebido de la autorización de subyugación en la autenticación, los controles, las credenciales y los privilegios o indemnización, y la subyugación de la escalada no autorizada de controles en términos de profundidad y roles. privilegio.
D.16	Validación de supervivencia / Continuidad del Servicio	La determinación y medición de la continuidad y la resiliencia controla los cambios excesivos o adversos donde a través de la verificación de la denegación de continuidad y resiliencia controla el servicio y la denegación de interactividad. se vería impactado.	Determinar la efectividad de la resiliencia del objetivo a la continuidad y la resiliencia controla los cambios excesivos o adversos donde a través de la verificación de la denegación de continuidad y resiliencia controla el servicio y la denegación de interactividad. se vería impactado.
D.17	Revisión de alertas y registros / Finalizar encuesta	Una revisión de las actividades de auditoría realizadas con la verdadera profundidad de esas actividades según lo registrado por el objetivo o por un tercero como en el control de alarma.	Sepa qué partes de la auditoría dejaron un rastro utilizable y confiable.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

6.3 Una metodología La

combinación de todos los módulos proporciona una metodología para conocer y trabajar con ella. Esta es una metodología que es aplicable a todos y cada uno de los tipos de pruebas de seguridad. Ya sea que el objetivo sea un sistema particular, una ubicación, una persona, un proceso o miles de ellos, esta metodología garantizará la prueba más exhaustiva y eficiente posible.



En la ruleta debes apostar a que la persona hace girar la rueda y lanza la bola. Como cualquier otro ser humano se aburre y cae en la rutina. Explotar a la persona cuya previsibilidad tiene inevitablemente mejores probabilidades que la máquina.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

Capítulo 7 - Pruebas de seguridad humana

Seguridad Humana (HUMSEC) es una subsección de PHYSSEC e incluye Operaciones Psicológicas (PSYOPS).

Probar este canal requiere interacción con personas en posiciones de control de activos.

Este canal abarca la implicación de las personas, principalmente del personal operativo dentro del ámbito o marco objetivo. Si bien algunos servicios consideran esto simplemente como "ingeniería social", el verdadero objetivo de cumplimiento de las pruebas de seguridad en este canal son las pruebas de concientización sobre la seguridad del personal y la medición de brechas con respecto al estándar de seguridad requerido descrito en la política de la empresa, las regulaciones de la industria o la legislación regional.

Se requerirá que el analista tenga múltiples herramientas y métodos para completar algunas tareas a fin de garantizar que no surjan sospechas entre el personal y que las pruebas no queden invalidadas debido a un descubrimiento temprano o una mayor paranoia. También puede ser pertinente limitar los sujetos de prueba a uno por departamento u otro límite.

Los analistas competentes requerirán tanto habilidades interpersonales diligentes como habilidades de pensamiento crítico para garantizar que la recopilación de datos fácticos genere resultados fácticos a través de la correlación y el análisis.

Consideraciones

Tenga en cuenta las siguientes consideraciones para garantizar una prueba segura y de alta calidad:

1. In personam: Las restricciones de alcance se dirigen a aquel personal que está bajo contrato legal directo con el propietario del alcance y, por lo tanto, tiene responsabilidad legal por su conciencia y obligaciones de seguridad.
2. Negación plausible: No se realizarán pruebas directas de seguridad del personal para el personal que no haya sido capacitado, informado o que no se pueda decir que posee experiencia u obligaciones en materia de seguridad debido a los requisitos de responsabilidad laboral.
3. Derechos humanos: cuando el personal que se someterá a la prueba se elige al azar o no se dice que tenga responsabilidades laborales directamente relacionadas con el control de acceso o la seguridad, el Analista se abstendrá de identificar personalmente a la persona e informará únicamente sobre una base estadística.
4. Incomunicación: El personal al que se le dé tiempo discutirá las acciones de la prueba con otros y alterará el curso de la prueba.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

7.1 Revisión de la postura

Los estudios iniciales de la postura incluyen las leyes, la ética, las políticas, las regulaciones de la industria y la cultura política que influyen en los requisitos de seguridad y privacidad del alcance. Esta revisión forma una matriz a la que se deben asignar las pruebas, pero no limitarlas.

7.1.1 Política

Revisar y documentar la política organizacional apropiada con respecto a las responsabilidades de seguridad, integridad y privacidad del personal en el alcance.

7.1.2 Legislación y Regulaciones

Revisar y documentar la legislación regional y nacional apropiada y las regulaciones de la industria con respecto a los requisitos de seguridad y privacidad de la organización en el alcance, así como aquello que incluye a los clientes, socios, sucursales de la organización o revendedores apropiados fuera del alcance.

7.1.3 Cultura

Revisar y documentar la cultura organizacional adecuada en el ámbito de la concientización sobre seguridad y privacidad, la capacitación del personal requerida y disponible, la jerarquía organizacional y la interacción de confianza reconocida entre los empleados.

7.1.4 Relaciones

Revisar y documentar las relaciones de influencia apropiadas entre el personal de la jerarquía organizacional dentro del alcance.

7.1.5 Cultura regional

Revisar y documentar la influencia apropiada de las culturas regionales y extranjeras en la jerarquía social en el entorno en el que reside el alcance.

7.1.6 Economía

Revisar y documentar la influencia apropiada de la economía y la escala salarial en el estatus social del personal tanto del vector de personal dentro del alcance como de la comunidad externa en la que reside el alcance.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

7.2 Logística

La preparación del entorno de prueba del canal es necesaria para evitar falsos positivos y falsos negativos que conduzcan a resultados de prueba inexactos.

7.2.1 Equipo de comunicaciones

Pruebe las comunicaciones que proporcionan identificación al receptor, como identificador de llamadas, devolución de FAX, registro de direcciones IP, insignias de localización y encabezados de puerta de enlace de correo electrónico. Pruebe si la identificación se bloqueará, eliminará u ofuscará y con qué grado de anonimato.

7.2.2 Comunicaciones

Pruebe qué idiomas se utilizan dentro del alcance y qué idiomas se comunican entre el alcance y los clientes, socios y revendedores fuera del alcance.

7.2.3 Hora

Pruebe la zona horaria, los días festivos y los horarios de trabajo para diversos roles y trabajos dentro del alcance, incluidos socios, revendedores y clientes influyentes que interactúan con el alcance.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

7.4 Auditoría de visibilidad

Pruebas de enumeración y verificación de la visibilidad del personal con el que es posible interactuar a través de todos los canales.

7.4.1 Identificación de acceso

Pruebe canales que proporcionen interacciones con personal fuera del alcance y documente todos los métodos utilizados y los resultados de esos métodos.

7.4.2 Enumeración del personal

Enumerar la cantidad de personal dentro del alcance con acceso tanto autorizado como no autorizado a los procesos dentro del alcance, independientemente del tiempo o canal de acceso, y el método para obtener esos datos.

7.5 Verificación de acceso

Pruebas para la enumeración de puntos de acceso al personal dentro del alcance. Si bien el acceso a personal fuera del alcance es un escenario real y a menudo se utiliza para el robo de propiedad de información, esto puede limitarse a una interacción únicamente dentro del alcance para proteger los derechos de privacidad independientes del personal en su vida privada.

7.5.1 Proceso de acceso

Mapear y explorar el uso de canales en el alcance para llegar a los activos. Documente todos los métodos utilizados y los resultados de esos métodos.

7.5.2 Autoridad

Utilice personal en puestos de autoridad con control de acceso o que ocupen puestos de guardián de los activos dentro del alcance. Métodos de documentación utilizados en el descubrimiento de personal clave.

7.5.3 Autenticación

Enumere y pruebe las deficiencias del personal de la puerta de enlace y qué privilegios se requieren para interactuar con ellos para garantizar que solo se proporcione acceso a las partes identificables, autorizadas y previstas.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

7.4 Auditoría de visibilidad

Pruebas de enumeración y verificación de la visibilidad del personal con el que es posible interactuar a través de todos los canales.

7.4.1 Identificación de acceso

Pruebe canales que proporcionen interacciones con personal fuera del alcance y documente todos los métodos utilizados y los resultados de esos métodos.

7.4.2 Enumeración del personal

Enumerar la cantidad de personal dentro del alcance con acceso tanto autorizado como no autorizado a los procesos dentro del alcance, independientemente del tiempo o canal de acceso, y el método para obtener esos datos.

7.5 Verificación de acceso

Pruebas para la enumeración de puntos de acceso al personal dentro del alcance. Si bien el acceso a personal fuera del alcance es un escenario real y a menudo se utiliza para el robo de propiedad de información, esto puede limitarse a una interacción únicamente dentro del alcance para proteger los derechos de privacidad independientes del personal en su vida privada.

7.5.1 Proceso de acceso

Mapear y explorar el uso de canales en el alcance para llegar a los activos. Documente todos los métodos utilizados y los resultados de esos métodos.

7.5.2 Autoridad

Utilice personal en puestos de autoridad con control de acceso o que ocupen puestos de guardián de los activos dentro del alcance. Métodos de documentación utilizados en el descubrimiento de personal clave.

7.5.3 Autenticación

Enumere y pruebe las deficiencias del personal de la puerta de enlace y qué privilegios se requieren para interactuar con ellos para garantizar que solo se proporcione acceso a las partes identificables, autorizadas y previstas.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

7.6 Verificación de confianza

Pruebas de confianza entre personal dentro del alcance donde la confianza se refiere al acceso a información o activos físicos de otros objetivos dentro del alcance.

7.6.1 Tergiversación

Pruebe y documente la profundidad de los requisitos para el acceso a los activos dentro del alcance con el uso de tergiversaciones como miembro del personal de soporte o entrega "interno" dentro del alcance sin ninguna credencial.

7.6.2 Fraude

Probar y documentar la profundidad de los requisitos para el acceso a los activos dentro del alcance con el uso de representación fraudulenta como miembro de la gerencia u otro personal clave.

7.6.3 Dirección errónea

Pruebe y documente la profundidad de los requisitos para el acceso a los activos dentro del alcance con el uso de tergiversaciones como miembro del personal de soporte o entrega fuera del alcance.

7.6.4 Phishing

Probar y documentar la profundidad de los requisitos para el acceso a información controlada por el personal o activos físicos a través de todos los canales descubiertos para el personal dentro del alcance con el uso de una puerta de enlace fraudulenta donde se solicita al personal que proporcione credenciales. Documente los métodos y todas las credenciales recopiladas de esta manera.

7.6.5 Abuso de recursos

Pruebe y documente la profundidad de los requisitos para llevar activos fuera del alcance a una fuente conocida y confiable o en todo el alcance a otro personal sin ninguna credencial requerida establecida.

7.6.6 En Terrorem

Probar y documentar la profundidad de los requisitos para incitar al miedo, la revuelta, la violencia y el caos, mediante la alteración del personal y el uso de rumores u otros abusos psicológicos.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

7.7 Verificación de controles

Pruebas para enumerar los tipos de controles de pérdidas utilizados para proteger el valor de los activos.

7.7.1 No repudio

Enumerar y probar el uso o las deficiencias del personal de la puerta de enlace para identificar y registrar adecuadamente acceso o interacciones con activos para obtener pruebas específicas para impugnar el repudio. Documentar el profundidad de la interacción que se registra.

7.7.2 Confidencialidad

Enumerar y probar el uso o las deficiencias de todos los segmentos de comunicación con el personal. dentro del alcance sobre un canal o propiedades transportadas a través de un canal utilizando líneas seguras, cifrado, interacciones personales “silenciosas” o “cerradas” para proteger la confidencialidad de la activos de información conocidos sólo por aquellos con la clasificación de autorización de seguridad adecuada de ese activo.

7.7.3 Privacidad

Enumerar y probar el uso o las deficiencias de todos los segmentos de comunicación con el personal. dentro del alcance sobre un canal o propiedades transportadas utilizando firmas individuales específicas, identificación personal, interacciones personales “tranquilas” o en “habitaciones cerradas” para proteger la privacidad de la interacción y el proceso de proporcionar activos sólo a aquellos dentro del marco de seguridad adecuado autorización para ese proceso, información o activos físicos.

7.7.4 Integridad

Enumerar y probar deficiencias en todos los segmentos de comunicación con el personal dentro del alcance. donde los activos se transportan a través de un canal mediante un proceso documentado, firmas, cifrado, hash o marcas para proteger y asegurar que la información o los activos físicos no se puedan cambiar, cambiar, redirigir o revertir sin que las partes involucradas lo sepan.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

7.8 Verificación del proceso

Pruebas para examinar el mantenimiento de la conciencia de seguridad funcional del personal en los procesos establecidos y la debida diligencia según se define en la Revisión de Postura.

7.8.1 Mantenimiento

Examinar y documentar la oportunidad, idoneidad, acceso y alcance de los procesos para la notificación y conciencia de seguridad de todo el personal con respecto a la seguridad operativa, la seguridad real y los controles de pérdidas.

7.8.2 Desinformación

Determinar hasta qué punto las notificaciones de seguridad del personal y las noticias de seguridad pueden ampliarse o alterarse con información errónea.

7.8.3 Debida diligencia

Mapee y verifique cualquier brecha entre la práctica y los requisitos según lo determinado en la Revisión de Postura a través de todos los canales.

7.8.4 Indemnización

Documentar y enumerar el abuso o la elusión de políticas de empleados, seguros, no divulgación, no competencia, contratos de responsabilidad o renunciaciones de responsabilidad de uso/usuario con todo el personal de acceso dentro del alcance en todos los canales.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

7.9 Verificación de capacitación

Pruebas para examinar la capacidad de eludir o interrumpir la educación y capacitación en concientización sobre seguridad funcional en el personal de la puerta de enlace.

7.9.1 Mapeo educativo Tipos de

mapas y frecuencia de asistencia de concientización sobre seguridad, cursos educativos y capacitación brindados al personal, socios, clientes y específicamente a los guardianes.

7.9.2 Interrupción de la política

Descubra y examine el proceso y la profundidad de la autocontrol del personal por la interrupción o no conformidad de la política de seguridad.

7.9.3 Mapeo de concientización

Mapear las limitaciones descubiertas en la capacitación de concientización sobre seguridad para el personal a través del análisis de brechas con procedimientos reales, que incluyen, entre otros: el suministro de activos a través de cualquier canal, la capacidad de reconocer identificaciones inadecuadas y falsificadas o los métodos requeridos, el método de identificación adecuada entre el personal, el uso de medidas de seguridad personal para uno mismo y sus bienes, el manejo de activos confidenciales y sensibles y la conformidad con la política de seguridad de la organización.

7.9.4 Secuestro de conciencia

Descubra y examine en qué medida una persona no oficial proporciona información errónea sobre la política de seguridad de manera autorizada para eludir o violar intencionalmente la política de seguridad.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

7.10 Validación de propiedad

Pruebas para examinar información y propiedad física disponible dentro del alcance o proporcionada por personal que pueda ser ilegal o poco ética.

7.10.1 Compartir

Verificar en qué medida el personal comparte propiedad con licencia individual, privada, falsificada, reproducida, no libre o no abierta, ya sea intencionalmente a través de procesos y programas compartidos, bibliotecas y cachés personales o involuntariamente a través de una mala gestión de licencias, y recursos, o negligencia.

7.10.2 Mercado negro

Verificar en qué medida se promueve, comercializa o vende entre el personal o la organización propiedad con licencia individual, privada, falsificada, reproducida, no libre o no abierta.

7.10.3 Canales de Venta

Verifique negocios públicos, fuera del alcance, subastas o ventas de propiedades que proporcionen información de contacto a través de canales que se originen dentro del alcance.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

7.11 Revisión de segregación

Pruebas para la separación adecuada de los activos de información personal o privada de la información comercial. Al igual que una revisión de privacidad, es el punto focal del almacenamiento, transmisión y control legal y ético de la información privada del personal, los socios y los clientes.

7.11.1 Mapeo de contención de privacidad

Mapee los guardianes de los activos de información privada dentro del alcance, qué información se almacena, cómo y dónde se almacena la información y a través de qué canales se comunica la información.

7.11.2 Información evidente

Enumerar y mapear información sobre el personal de entrada individual. tales como nombres, raza, sexo, religión, días de vacaciones, páginas web personales, currículums publicados, afiliaciones personales, consultas de directorio, sucursales bancarias, registro electoral y cualquier información personal particular declarada implícitamente como privada en las regulaciones y políticas.

7.11.3 Divulgación

Examinar y documentar los tipos de divulgaciones de activos de información privada sobre el personal de los guardianes responsables de esta segregación de acuerdo con las políticas y regulaciones según lo determinado en la Revisión de Postura y el derecho humano básico a la privacidad.

7.11.4 Limitaciones

Examinar y documentar tipos de puertas de enlace y alternativas de canales con puertas de enlace accesibles para personas con limitaciones físicas dentro de ese canal.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

7.12 Verificación de exposición

Pruebas para descubrir información que proporciona o conduce a un acceso autenticado o permite un acceso no intencionado a múltiples ubicaciones con la misma autenticación.

7.12.1 Mapeo de exposición

Enumerar y mapear información del personal relacionada con la organización, como organigramas, títulos de personal clave, descripciones de puestos, números de teléfono personales y laborales, números de teléfonos móviles, tarjetas de presentación, documentos compartidos, currículums, afiliaciones organizacionales, información privada y pública. -direcciones de correo electrónico, inicios de sesión, esquemas de inicio de sesión, contraseñas, métodos de respaldo, aseguradoras o cualquier información organizacional particular declarada implícitamente como confidencial en las regulaciones y políticas.

7.12.2 Elaboración

de perfiles Perfilar y verificar la organización, los tipos de requisitos de habilidades de los empleados, las escalas salariales, la información del canal y de la puerta de enlace, las tecnologías y la dirección.

7.13 Exploración de Inteligencia Competitiva

Pruebas de eliminación de propiedades que pueden analizarse como inteligencia empresarial. Si bien la inteligencia competitiva como campo está relacionado con el marketing, el proceso aquí incluye cualquier forma de recopilación de inteligencia competitiva, incluido, entre otros, el espionaje económico e industrial.

7.13.1 Molienda empresarial

Mapee los guardianes de los activos comerciales dentro del alcance, qué información se almacena, cómo y dónde se almacena la información y a través de qué canales se comunica la información entre el personal.

7.13.2 Entorno empresarial

Explore y documente los detalles comerciales del personal de la puerta de enlace individual, como alianzas, socios, clientes principales, proveedores, distribuidores, inversores, relaciones comerciales, producción, desarrollo, información de productos, planificación estratégica, acciones y comercio, y cualquier información comercial o propiedad particular indicada implícitamente. como confidencial en las regulaciones y políticas.

7.13.3 Entorno organizacional

Examinar y documentar los tipos de divulgaciones de activos comerciales de los guardianes sobre operaciones, procesos, jerarquía, informes financieros, oportunidades de inversión, fusiones, adquisiciones, inversiones de canales, mantenimiento de canales, políticas sociales internas, insatisfacción del personal y tasa de rotación, principales tiempos de vacaciones. contrataciones, despidos y cualquier activo organizacional particular declarado implícitamente como confidencial en las regulaciones y políticas.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

7.14 Verificación de cuarentena

Pruebas para verificar el correcto despliegue y contención de contactos agresivos u hostiles en los puntos de entrada.

7.14.1 Identificación del proceso de contención

Identifique y examine los métodos y procesos de cuarentena en las puertas de entrada en todos los canales para detectar contactos agresivos y hostiles, como vendedores, cazatalentos, estafadores, periodistas, competidores, solicitantes de empleo, candidatos a empleo y personas disruptivas.

7.14.2 Niveles de Contención

Verificar el estado de contención, el tiempo y todos los canales donde la interacción con los guardianes tiene métodos de cuarentena. Asegúrese de que los métodos estén dentro del contexto y los límites legales.

7.15 Auditoría de privilegios

Pruebas en las que se proporcionan credenciales al usuario y se le otorga permiso para realizar pruebas con esas credenciales.

7.15.1 Identificación

Examinar y documentar el proceso para la obtención de identificación por medios tanto legítimos como fraudulentos en todos los canales.

7.15.2 Autorización

Verificar el uso de autorizaciones fraudulentas en todos los canales para obtener privilegios similares a los del resto del personal.

7.15.3 Escalamiento

Verifique y mapee el acceso a los activos mediante el uso de privilegios para obtener privilegios mayores o más extensos más allá de los asignados con autoridad para el rol.

7.15.4 Discriminación

Verificar la información solicitada y los privilegios otorgados a los guardianes en los casos en que la edad (específicamente aquellos que son legalmente menores de edad para la región), el sexo, la raza, las costumbres/cultura y la religión sean factores que puedan ser discriminados de acuerdo con la Revisión de Postura.

7.15.5 Subyugación

Enumerar y probar las deficiencias de los activos comunicados a través de canales donde esos controles no son necesarios, pueden ser eludidos o ignorados, como correos electrónicos inseguros o a través de una línea telefónica pública.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

7.16 Continuidad del Servicio

Determinar y medir la resiliencia de los guardianes dentro del alcance ante cambios excesivos u hostiles diseñados para causar fallas en el servicio.

7.16.1 Resiliencia

Enumere y pruebe las deficiencias en todos los canales del personal dentro del alcance, mediante el cual eliminar o silenciar al personal de la puerta de enlace permitirá el acceso directo a los activos.

7.16.2 Continuidad

Enumerar y probar las deficiencias de todo el personal con respecto a los retrasos en el acceso y el tiempo de respuesta del servicio a través de personal de respaldo o medios automatizados para el acceso al personal de la puerta de enlace alternativa.

7.16.3 Seguridad

Mapear y documentar el proceso de los guardianes que desconectan canales debido a preocupaciones de evacuación o seguridad como un análisis de brechas con la regulación y la política de seguridad.

7.17 Finalizar la encuesta

Un análisis de brechas entre las actividades realizadas con la prueba y la verdadera profundidad de esas actividades registradas o desde percepciones de terceros, tanto humanas como mecánicas.

7.17.1 Alarma

Verificar y enumerar el uso de un sistema, registro o mensaje de advertencia localizado o de todo el alcance para cada puerta de enlace de acceso a través de cada canal donde el personal detecta una situación sospechosa ante la sospecha de intentos de elusión, ingeniería social o actividad fraudulenta.

7.17.2 Almacenamiento y

recuperación Documentar y verificar el acceso privilegiado y eficiente a las ubicaciones y propiedades de almacenamiento de alarmas, registros y notificaciones.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

Los tipos de controles de seguridad física más inútiles son los que no protegen contra lo que usted necesita y los que protegen contra cualquier cosa sin costo alguno.

razón.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

Capítulo 8 - Pruebas de seguridad física

PHYSSEC (Seguridad Física) es una clasificación para la seguridad material dentro del ámbito físico que se encuentra dentro de los límites del espacio 3D interactivo con humanos. Probar este canal requiere una interacción no comunicativa con barreras y humanos en posiciones de control de los activos.

Este canal cubre la interacción del Analista en la proximidad de los objetivos. Si bien algunos servicios consideran esto simplemente como "robo de fuerza", el verdadero objetivo de cumplimiento de las pruebas de seguridad en este canal son las pruebas de barreras físicas y lógicas y la medición de brechas según el estándar de seguridad requerido como se describe en la política de la empresa, las regulaciones de la industria o la legislación regional.

Se requerirá que el analista tenga múltiples herramientas y métodos para completar algunas tareas a fin de garantizar que no surjan sospechas entre el personal y que las pruebas no queden invalidadas debido a un descubrimiento temprano o una mayor paranoia. También puede ser pertinente limitar los sujetos de prueba a uno por departamento u otro límite. Los analistas también deberán estar preparados para la posibilidad de daños corporales accidentales causados por barreras y armas convencionales, interacciones con animales, exposición a bacterias, virus y hongos dañinos, exposición a radiación electromagnética y de microondas, especialmente aquella que puede dañar permanentemente la audición o la vista. y agentes químicos venenosos o corrosivos en cualquier forma.

Los analistas competentes necesitarán fuerza física, resistencia, agilidad y habilidades de pensamiento crítico para garantizar que la recopilación de datos fácticos genere resultados fácticos a través de la correlación y el análisis.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

Consideraciones

Tenga en cuenta las siguientes consideraciones para garantizar una prueba segura y de alta calidad:

1. Conatus: Todos los intentos de atravesar barreras físicas requieren un juicio imparcial sobre la cantidad de dificultad requerida para alcanzar e interactuar con el objetivo y el peligro involucrado. Estas consideraciones deben hacerse con respecto a la “voluntad de vivir” de los humanos, así como a cualquier efecto sobre los objetivos si el ataque se realiza sin tener en cuenta la vida (suicida).
2. Ecce hora: Todas las pruebas físicas requieren que se haga mucha atención al tiempo. Se deben mantener registros de la hora en que se realiza la prueba, el tiempo en el objetivo y la hora en que termina la prueba, ya sea exitosa o no, porque eso también ayudará a determinar qué se puede lograr dentro del rango de tiempo para fallar. Conocer dicha información puede ayudar a comprender qué puede ser un ataque engañoso para asegurarse de que no se desperdicien recursos en un área y se deje abierta otra.
3. Abuso de discreción: El Analista debe tener cuidado de no ignorar o malinterpretar los resultados de probar una barrera u obstáculo físico porque no está dentro del rango de las posibilidades físicas del Analista. El analista debe permanecer imparcial y no sobreestimar ni sobrevalorar las habilidades y capacidades personales y, en cambio, aplicar las pruebas como lo haría una persona altamente capacitada y capaz.
4. Magister pecuarius: El Analista no debe descartar el potencial razonable de que un atacante utilice animales entrenados para sortear barreras y obstáculos donde un ser humano no puede.
5. Negación plausible: No se realizarán pruebas de seguridad directas o físicas del personal que no haya sido capacitado, informado o que no se pueda decir que posee experiencia u obligaciones en materia de seguridad debido a los requisitos de responsabilidad laboral.
6. Sui generis: Toda interacción con barreras físicas dejará constancia de esta interactividad y, en casos más extremos, podrá debilitar o destruir la barrera. El analista debe tener cuidado al probar objetivos únicos que pueden no ser reemplazables. El analista también debe tener cuidado de no dejar marcas permanentes siempre que sea posible y de mantener un registro de todas las barreras probadas para verificar si presentan daños después de la auditoría.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

8.1 Revisión de la postura

Los estudios iniciales de la postura incluyen las leyes, la ética, las políticas, las regulaciones de la industria y la cultura política que influyen en los requisitos de seguridad y privacidad del alcance. Esta revisión forma una matriz a la que se deben asignar las pruebas, pero no limitarlas.

8.1.1 Política

Revisar y documentar la política organizacional apropiada con respecto a la seguridad, la integridad (es decir, la cadena de suministro) y los requisitos de privacidad para las barreras en el alcance.

8.1.2 Legislación y Regulaciones

Revisar y documentar la legislación regional y nacional apropiada y las regulaciones de la industria con respecto a los requisitos de seguridad y privacidad de la organización en el alcance, así como aquello que incluye a los clientes, socios, sucursales de la organización o revendedores apropiados fuera del alcance.

8.1.3 Cultura

Revisar y documentar la cultura organizacional adecuada en el ámbito de la concientización sobre seguridad y privacidad, la capacitación del personal requerida y disponible, la jerarquía organizacional y la interacción de confianza reconocida entre los empleados.

8.1.4 Relaciones

Revisar y documentar las relaciones de influencia apropiadas entre el personal de la jerarquía organizacional dentro del alcance.

8.1.5 Cultura regional

Revisar y documentar la influencia apropiada de las culturas regionales y extranjeras en la seguridad, la jerarquía social, la cadena de suministro y los servicios en el entorno en el que reside el alcance.

8.1.6 Economía

Revisar y documentar la influencia apropiada de la economía y la escala salarial en el estatus social y la intención criminal del personal tanto del vector de personal dentro del alcance como de la comunidad externa en la que reside el alcance.

8.1.7 Medio ambiente

Revisar para la región objetivo los patrones climáticos, los extremos climáticos peligrosos (es decir, inundaciones, tornados, huracanes), temperaturas extremas, humedad máxima, calidad del aire, estabilidad tectónica, fauna típica, formas de desastres naturales o provocados por el hombre e infestación general de insectos.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

8.2 Logística

La preparación del entorno de prueba del canal es necesaria para evitar falsos positivos y falsos negativos que conduzcan a resultados de prueba inexactos.

8.2.1 Medio ambiente

- (a) Examinar el alcance para determinar si se requiere algún equipo especial para el entorno de los objetivos. El equipo puede variar desde cuerdas para escalar paredes hasta equipo de buceo para viajar bajo el agua. Los tipos de equipos no se limitan sólo al entorno sino también a las barreras que uno debe sortear.
- (b) Verificar el equipo de seguridad dañado que pueda provocar lesiones al Analista. (c) Examinar los objetivos en busca de terreno, aire, agua, edificios o estructuras peligrosos, contaminados o mal mantenidos. (d) Examinar los niveles de ruido, radiación electromagnética y campo magnético en el alcance.

8.2.2 Comunicaciones

- (a) Probar qué idiomas se utilizan dentro del alcance y qué idiomas se comunican entre el alcance y los clientes, socios y revendedores fuera del alcance. (b) Examinar los medios de comunicación entre el personal y si se potencian mediante el uso de herramientas como banderas, bengalas, radios, binoculares, visión nocturna, etc.

8.2.3 Hora

- (a) Pruebe la zona horaria, los días festivos y los horarios de trabajo para diversos roles y trabajos dentro del alcance, incluidos socios, revendedores y clientes influyentes que interactúan con el alcance.
- (b) Determinar si la disminución de la movilidad o visibilidad durante la hora del día, semana, mes o temporada (día o noche, niebla, lluvia o nieve) tendrán un impacto en las operaciones en el objetivo.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

8.3 Verificación de detección activa

La determinación de controles activos y pasivos para detectar intrusiones para filtrar o negar intentos de prueba debe realizarse antes de la prueba para mitigar el riesgo de crear falsos positivos y negativos en los datos de resultados de la prueba, así como cambiar el estado de alarma del personal o agentes de monitoreo.

8.3.1 Monitoreo

- (a) Verificar que el alcance sea monitoreado por un tercero para detectar intrusiones a través de vigías, guardias, cámaras o sensores. Se debe registrar la fecha y hora de entrada así como la salida del objetivo. (b) Determinar el alcance del monitoreo y si el viaje de una amenaza al objetivo puede ser interceptado oportunamente.
- (c) Verificar si el viaje al objetivo requiere un mayor tiempo en el objetivo y exposición. Esto incluye, entre otros: salas de cuarentena, pasillos largos y vacíos, estacionamientos, grandes extensiones vacías, terrenos difíciles o poco naturales y áreas para invitados o de espera.
- (d) Verificar que la iluminación y el contraste visible al acercarse al objetivo permitan la interceptación de amenazas.

8.3.2 Reaccionar

- (a) Verificar si los controles interactivos para el objetivo reaccionarán oportunamente ante condiciones ambientales extremas. de acuerdo con la tarea de revisión ambiental de la Revisión de Postura. (b) Verificar si el objetivo reaccionará oportunamente ante una alteración en la calidad del aire, el agua y el suelo. (c) Verificar si el objetivo reaccionará oportunamente ante perturbaciones de ruido críticas. (d) Verificar si el objetivo reaccionará oportunamente a las perturbaciones del campo magnético. (e) Verificar si el objetivo reaccionará oportunamente ante los incendios. (f) Verificar si el objetivo reaccionará oportunamente ante la denegación de acceso al objetivo mediante bloqueo o cuarentena. (g) Verificar si el objetivo reaccionará oportunamente ante amenazas de miedo, revuelta o violencia dentro del alcance. (h) Determinar la finalidad de la interceptación de amenazas.

8.4 Auditoría de Visibilidad

Pruebas de enumeración y verificación de la visibilidad de objetivos y activos. En PHYSSEC, los activos también deben incluir suministros como alimentos, agua, combustible, etc. y procesos operativos que pueden afectar esos suministros, como la eliminación adecuada de desechos y otros contaminantes, carga y descarga de envíos de suministros, ciclos de sueño y descanso, aclimatación adecuada, etc.

8.4.1 Reconocimiento

- (a) Mapear y detallar el perímetro de alcance determinado mediante técnicas de visualización visible y asistida, áreas de acceso público, planos públicos y fuentes públicas. (b) Enumerar y detallar objetivos y activos visibles desde fuera del alcance. (c) Enumerar y detallar los patrones de tráfico objetivo, el tráfico peatonal, las áreas ocupadas y los sensores visibles. fuera del alcance.
- (d) Enumerar directorios y guías telefónicas internas que identifiquen ubicaciones de información confidencial. Instalaciones de procesamiento de información que no son fácilmente accesibles para el público.
- (e) Mapear y enumerar la ubicación física y el diseño de los objetivos, el tamaño y la navegabilidad de los obstáculos, barreras y peligros que aumentarán el tiempo en el objetivo.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

8.5 Verificación de acceso

Pruebas para la enumeración de puntos de acceso para interactuar con los objetivos y activos dentro del alcance. Si bien el acceso a muros y vallas que bordean propiedades fuera del alcance es un escenario real y se utiliza a menudo en un ataque, esta auditoría se limita a la interacción únicamente del alcance para proteger los derechos de propiedad de terceros.

8.5.1 Enumeración

- (a) Mapear y explorar el terreno navegable, barreras y obstáculos en el alcance para alcanzar los objetivos y activos. Documente todos los métodos utilizados y los resultados de esos métodos. (b) Mapear y verificar todos los puntos de acceso que permitan una interacción directa, sigilosa o no supervisada (3 segundos o menos de tiempo en el objetivo) con el objetivo. (c) Verificar el tamaño y la navegabilidad de los puntos de acceso públicos y privados y todos los caminos hacia el objetivo.

8.5.2 Autenticación

- (a) Enumerar y comprobar las deficiencias de los privilegios que se requieren para acceder, el proceso de obtención de esos privilegios y garantizar que solo se proporcione acceso a partes identificables, autorizadas y previstas.
- (b) Verificar el proceso de autenticación de qué elementos pueden ser incluidos en el alcance por personal autorizado y no autorizado. (c) Verificar el proceso de autenticación de qué elementos pueden ser retirados del alcance tanto por personal autorizado como no autorizado. (d) Verificar el proceso de registro de acceso y qué elementos fueron ingresados y eliminados.

8.5.3 Ubicación

- (a) Mapear la distancia desde el perímetro del alcance hasta los objetivos y activos visibles desde fuera del alcance.
- (b) Mapear e identificar todos los caminos hacia los puntos de acceso a los que se puede llegar mediante una interacción ruidosa, no sigilosa y directa (3 segundos o menos de tiempo en el objetivo) con ese punto de acceso. Esto puede incluir ataques que son sans conatus (sin tener en cuenta la vida del atacante).

8.5.4 Penetración

- (a) Determinar qué barreras y obstáculos en el alcance brindan acceso remoto al cambio, alterar, destruir u obtener activos (visual, auditiva y magnéticamente).
- (b) Determinar la efectividad de las barreras y obstáculos para resistir las condiciones definidas en el Revisión de postura.
- (c) Determinar y calificar la efectividad de las barreras y obstáculos para resistir incendios, explosiones, y fuerzas de conmoción generales, como disparos y embestidas de vehículos.
- (d) Determinar y calificar la efectividad de las barreras y obstáculos para reducir la entrada de: niveles críticos de ruido, calor, frío, humo, humedad, olores perturbadores o cáusticos, campos magnéticos intensos, luz nociva y contaminantes. (e) Determinar y calificar la efectividad de barreras y obstáculos para reducir las emisiones: sonidos, olores, vibraciones, condiciones de aclimatación, humo, campos magnéticos, desechos y contaminantes.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

8.6 Verificación de confianza

Pruebas de confianza entre procesos dentro del alcance donde la confianza se refiere al acceso a activos sin necesidad de identificación o autenticación.

8.6.1 Tergiversación

- (a) Probar y documentar la profundidad de los requisitos para el acceso a los activos mediante el uso de declaraciones falsas como miembro del personal de apoyo o entrega “interno” sin las credenciales adecuadas.
- (b) Probar y documentar la profundidad de los requisitos para el acceso a los activos mediante el uso de declaraciones falsas como persona discapacitada.

8.6.2 Fraude

Probar y documentar la profundidad de los requisitos para el acceso a los activos mediante el uso de representación fraudulenta de autoridad como miembro de la dirección u otro personal clave.

8.6.3 Dirección errónea

Pruebe y documente la profundidad de los requisitos para el acceso a los activos con el uso de tergiversaciones como miembro del personal de soporte o entrega fuera del alcance.

8.6.4 Estiba

Pruebe y documente la profundidad de los requisitos para el acceso a los activos mediante estiba sigilosa con un transporte de apoyo o entrega para llevar la estiba fuera del alcance.

8.6.5 Malversación de fondos

Pruebe y documente la profundidad de los requisitos para ocultar activos dentro del alcance (enteros o destruidos), llevar activos fuera del alcance a una fuente conocida y confiable, y en todo el alcance a otro personal sin ninguna credencial requerida establecida.

8.6.6 En Terrorem

Probar y documentar la profundidad de los requisitos para incitar miedo, revuelta, violencia y caos, mediante la interrupción de procesos y la contaminación de suministros.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

8.7 Verificación de controles

Pruebas para enumerar los tipos de controles de pérdidas utilizados para proteger el valor de los activos.

8.7.1 No repudio

Enumerar y probar el uso o las deficiencias de los monitores y sensores para identificar y registrar adecuadamente el acceso o las interacciones con los activos para obtener pruebas específicas para impugnar el repudio. Documente la profundidad de la interacción que se registra.

8.7.2 Confidencialidad

Enumerar y probar el uso o las deficiencias de todas las señales, comunicación física y elementos transportados entre los procesos internos y externos y el personal utilizando códigos, lenguaje indescifrable, interacciones personales "tranquilas" o "cerradas" para promover la confidencialidad de la comunicación únicamente. a aquellos con la clasificación de autorización de seguridad adecuada para esa comunicación.

8.7.3 Privacidad

Enumerar y probar el uso o las deficiencias de todas las interacciones dentro del alcance utilizando envases o etiquetas sin marcar o que no sean obvios, interacciones "tranquilas" o en "cuartos cerrados" y dentro de espacios elegidos al azar para ocultar o proteger la privacidad de la interacción y únicamente a aquellos con la autorización de seguridad adecuada para ese proceso o activo.

8.7.4 Integridad

- (a) Enumerar y probar deficiencias en todas las señales y comunicación entre procesos y personal utilizando un proceso documentado, sellos, firmas, hash o marcas cifradas para proteger y asegurar que los activos no se puedan cambiar, redirigir o revertir sin que se sepa. a las partes involucradas.
- (b) Enumerar y probar las deficiencias en todos los procesos e interacciones con activos en transporte que utilizan un proceso documentado, firmas, sellos, cintas separables, marcas, etiquetas, sensores o marcas cifradas para proteger y asegurar que los activos no puedan ser modificado, redirigido o revertido sin que las partes involucradas lo sepan.
- (c) Verificar que todos los medios de almacenamiento de información no estén en peligro de deterioro no natural, como daños por calor o humedad, decoloración por la luz solar directa o degradación magnética (podredumbre de bits).



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

8.8 Verificación del proceso

Pruebas para examinar el mantenimiento de las operaciones de seguridad funcionales en los procesos establecidos y la debida diligencia según se define en la Revisión de Postura.

8.8.1 Mantenimiento

- (a) Examinar y documentar la oportunidad, idoneidad, acceso y alcance de los procesos para la reparación de equipos y barreras con respecto a la seguridad operativa, la seguridad real y los controles de pérdidas.
- (b) Verificar la reparación y determinar hasta qué punto el aviso y la calidad de las reparaciones pueden tergiversarse y falsificarse.

8.8.2 Indemnización

- (a) Documentar y enumerar la capacidad de abusar o eludir políticas de empleados, seguros, contratos de no divulgación, no competencia, responsabilidad o uso/exenciones de responsabilidad del usuario para el personal dentro del alcance.
- (b) Enumerar el uso de señales de advertencia de peligro, vigilancia o alarmas vigentes, problemas de salud y carteles de prohibición de entrada.
- (c) Verificar el alcance y la finalidad de la acción legal utilizada para hacer valer la indemnización.

8.9 Verificación de la configuración

Pruebas para examinar el funcionamiento de procesos bajo varios niveles de condiciones de seguridad. Comprender cómo funcionan los procesos bajo la rutina diaria y la eficiencia proporciona información sobre cómo deberían comportarse en condiciones más extremas.

8.9.1 Mapeo educativo

Mapee los tipos y la frecuencia de la seguridad física y la asistencia de seguridad, los cursos educativos y la capacitación brindados al personal, los socios, los clientes y específicamente a los guardianes.

8.9.2 Interrupción de la política

Descubra y examine el proceso y la profundidad de la autocontrol del personal por la interrupción o no conformidad de la política de seguridad física y protección.

8.9.3 Condiciones de amenaza

- (a) Mapear las respuestas listas de los procesos de seguridad en reacción a mayores niveles de condiciones de amenaza (es decir, alertas verdes, amarillas, naranjas y rojas) según los requisitos determinados en la Revisión de Postura.
- (b) Determinar qué factores desencadenantes son necesarios para aumentar los niveles de amenaza y verificar que se cumplan. (c) Mapear las respuestas listas de los procesos de seguridad en reacción a niveles reducidos de condiciones de amenaza según requisitos determinados en la Revisión de Postura.
- (d) Descubrir y examinar en qué medida una persona no oficial proporciona información errónea sobre los niveles de amenaza de manera autorizada para aumentar o disminuir intencionalmente el estado de listo.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

8.10 Validación de propiedad

Pruebas para examinar la propiedad física disponible dentro del alcance o proporcionada por personal que pueden ser ilegales o poco éticas.

8.10.1 Compartir

Verificar en qué medida los bienes personales o los de la organización han sido falsificados, reproducidos o compartidos ilegal e intencionalmente de acuerdo con los requisitos de la Revisión de Postura mediante servicios de intercambio, préstamo, alquiler o arrendamiento, bibliotecas personales y cachés personales o de manera no intencional por ignorancia o negligencia.

8.10.2 Mercado negro

Verificar en qué medida los bienes personales o de la organización han sido falsificados o reproducidos y están siendo promocionados, comercializados o vendidos entre el personal o por la organización.

8.10.3 Canales de Venta

Verifique activos en subastas, mercados de pulgas, anuncios de búsqueda, ventas de garaje, reuniones de intercambio o ventas de propiedades que proporcionen información de contacto a través de canales que se originan dentro del alcance.

8.10.4 Almacenamiento

- (a) Verificar que las ubicaciones de almacenamiento y los pequeños depósitos de activos de la organización se encuentren en las condiciones adecuadas. ubicación dentro del alcance.
- (b) Verificar que las ubicaciones de almacenamiento y los pequeños escondites de activos de la organización para uso o venta públicamente o a otros miembros de la organización no se estén ocultando, acaparando, controlando o guardando deliberadamente.

8.10.5 Abuso de recursos

- (a) Enumerar los artículos personales que consuman energía, combustible, alimentos, agua u otros activos dentro de los requisitos definidos en la Revisión de Postura. (b) Enumerar artículos personales utilizando canales que sean propiedad de la organización (es decir, servidores de Internet, máquinas de discos, máquinas de fax, etc.). (c) Enumerar artículos personales visibles abiertamente que simbolizan creencias que no están dentro de los requisitos definidos en la Revisión de Postura.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

8.11 Revisión de segregación

Pruebas para la separación adecuada de la propiedad de información privada o personal de la información comercial. Al igual que una revisión de privacidad, es el punto focal del almacenamiento, transporte y control legal y ético de la propiedad de información privada del personal, socios y clientes.

8.11.1 Mapeo de contención de privacidad

Mapee las ubicaciones de almacenamiento de propiedad de información privada dentro del alcance, qué información se almacena, cómo y dónde se almacena la información, y cómo y dónde se descarta la propiedad.

8.11.2 Información evidente

Enumere y mapee los documentos de destino y la propiedad física con información personal no segura, tal como se define implícitamente como privada en las regulaciones y políticas de Posture Review (es decir, nombres completos, raza, sexo, religión, días de vacaciones, páginas web personales, currículums publicados, afiliaciones personales). , consultas de directorio, sucursal bancaria, registro electoral, etc.).

8.11.3 Divulgación

Verificar el acceso a almacenes de información privada propiedad del personal según lo determine la Revisión de Postura.

8.11.4 Limitaciones

Examinar y documentar alternativas de movilidad accesibles a personas con limitaciones físicas dentro de ese canal.

8.11.4 Materiales ofensivos

Verifique que los bienes personales visibles abiertamente no hagan alarde ni ofendan como se determina que son ofensivos o privados en la Revisión de Postura.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

8.12 Verificación de exposición

Pruebas para descubrir información que proporciona o conduce a un acceso autenticado o permite el acceso a múltiples ubicaciones con la misma autenticación.

8.12.1 Mapeo de exposición

Descubra y enumere documentos y elementos no seguros con información de construcción relacionada con la organización, como planos, logística, horarios, llaves, tokens de acceso, insignias, uniformes o cualquier activo organizacional particular que proporcione un acceso más profundo o más amplio.

8.12.2 Perfilado

(a) Perfilar y verificar la definición estructural de los objetivos, incluido el tipo de material, la altura, el espesor y las propiedades de seguridad o protección. (b)

Descubrir y enumerar sensores de control de acceso, cámaras, monitores, trampas para hombres, jaulas, puertas, cercas, etc. por tipo, tecnología, fabricante, materiales y propiedades de seguridad o protección.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

8.13 Exploración de Inteligencia Competitiva

Pruebas de eliminación de propiedades que pueden analizarse como inteligencia empresarial. Si bien la inteligencia competitiva como campo está relacionado con el marketing, el proceso aquí incluye cualquier forma de recopilación de inteligencia competitiva, incluido, entre otros, el espionaje económico e industrial.

8.13.1 Molienda empresarial

Descubra y mapee las ubicaciones de almacenamiento de la propiedad comercial dentro del alcance, qué información se almacena, cómo y dónde se almacena la información, y cómo y dónde se descarta la propiedad.

8.13.2 Entorno empresarial

Descubra y enumere documentos y elementos con detalles comerciales como personal, tarifas salariales, alianzas, socios, clientes principales, proveedores, distribuidores, inversores, relaciones comerciales, producción, desarrollo, información de productos, planificación, acciones y comercio, y cualquier información comercial en particular. o propiedad determinada implícitamente como confidencial o no competitiva a partir de la Revisión de Postura.

8.13.3 Entorno organizacional

Descubra y enumere documentos y elementos con detalles organizacionales como procesos, jerarquía, informes financieros, oportunidades de inversión, fusiones, adquisiciones, inversiones de canales, mantenimiento de canales, políticas sociales internas, insatisfacción del personal y tasa de rotación, principales tiempos de vacaciones, contrataciones y despidos. y cualquier propiedad organizacional particular declarada implícitamente como confidencial o no competitiva de Posture Review.

8.13.4 Entorno operativo

Descubrir y enumerar procesos que expongan detalles operativos como embalaje, envío, distribución, horarios de llegada y salida de los empleados, administración, clientes, métodos de interacción, planes de publicidad y marketing, desarrollo de productos, capacidad del producto y cualquier propiedad operativa particular declarada implícitamente como confidencial o no competencia de la Revisión de Postura.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

8.14 Verificación de cuarentena

Pruebas para verificar el adecuado posicionamiento y contención de personas y procesos con intención agresiva u hostil dentro del alcance.

8.14.1 Identificación del proceso de contención

- (a) Identificar y examinar métodos y procesos de cuarentena física dentro del alcance de contactos agresivos y hostiles, como personas caóticas o violentas, vendedores no programados, cazadores de cabezas, estafadores, periodistas, competidores, buscadores de empleo, candidatos a empleo y personas disruptivas.
- (b) Identificar y examinar métodos y procesos de cuarentena física dentro del alcance para el manejo de artículos o sustancias peligrosas y dañinas, sustancias ilegales y propiedad de la empresa retirada ilegalmente. (c) Identificar y examinar los métodos y procesos de cuarentena física dentro del alcance para detectar comportamientos meramente sospechosos o artículos y sustancias de utilidad sospechosa.

8.14.2 Niveles de Contención

- (a) Verificar el estado del lugar de contención, la duración y el proceso del método de cuarentena. Asegúrese de que los métodos estén dentro del contexto y los límites legales según la Revisión de Postura.
- (b) Verificar que se sigan los procedimientos adecuados para un cierre total según los requisitos de la Revisión de Postura para amenazas ambientales, amenazas biológicas, químicas u otras amenazas de contaminación y en casos de violencia en el lugar de trabajo.
- (c) Verificar los procedimientos adecuados para la recuperación en cuarentena y el regreso al estado seguro adecuado después de un estado de bloqueo según los requisitos de la Revisión de Postura.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

8.15 Auditoría de privilegios

Pruebas para obtener credenciales de acceso y privilegios proporcionados a otro personal con los permisos adecuados.

8.15.1 Identificación

Examinar y documentar el proceso para obtener identificación a través de medios legítimos, ilegales (es decir, corrupción, robo, amenazas, etc.) y fraudulentos (falsificación, tergiversación, etc.).

8.15.2 Autorización

Verificar el uso de autorización fraudulenta para obtener privilegios similares a los de otro personal.

8.15.3 Escalamiento

Verifique y enumere los accesos a los activos mediante el uso de privilegios para obtener privilegios superiores a los de los guardianes.

8.15.4 Circunstancias Especiales

Verificar la obtención de privilegios de acceso según lo solicitado en los casos en que la edad (específicamente aquellos considerados legalmente menores de edad en la región), la relación (es decir, hijo, hija, padre, madre, etc.), el sexo, la raza, las costumbres/cultura y la religión sean factores que puedan ser concedidos circunstancias especiales o discriminados de acuerdo con la Revisión de Postura.

8.15.5 Subyugación

Enumerar y probar las deficiencias en el acceso a los activos no controlados por la fuente que proporciona el acceso (es decir, PIN, fotografías de identificación, etc. seleccionadas por el actor, inicios de sesión con números de identificación escritos por el actor, etc.).



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

8.16 Validación de supervivencia

Determinar y medir la resiliencia de las barreras y guardas dentro del alcance a cambios excesivos u hostiles diseñados para causar fallas en las operaciones.

8.16.1 Resiliencia

- (a) Enumerar y verificar que la distracción, remoción o silenciamiento del personal de la puerta de enlace no permitirá el acceso directo a los activos u operaciones.
- (b) Enumerar y verificar que la inhabilitación o destrucción de medidas o controles operativos de seguridad no permitirá el acceso directo a los activos u operaciones. (c) Verificar que el aislamiento del alcance de recursos como combustible, energía, alimentos, agua, comunicaciones, etc. no permite el acceso directo a activos u operaciones.
- (d) Verificar que las condiciones de amenaza de alerta alta no cierren ni minimicen las medidas o controles de seguridad operativa que permitan el acceso directo a los activos u operaciones.

8.16.2 Continuidad

- (a) Enumerar y verificar las condiciones en las que las demoras en el acceso se abordan adecuadamente a través de personal de respaldo o un medio automatizado para el acceso oportuno a los servicios, procesos y operaciones. (b) Enumerar y verificar que la distracción, remoción o silencio del personal de la puerta de entrada no detener o negar el acceso oportuno a servicios, procesos y operaciones.
- (c) Enumerar y verificar que la inutilización o destrucción de las medidas operativas de seguridad o Los controles no negarán el acceso oportuno a los servicios, procesos y operaciones.
- (d) Verificar que el aislamiento del alcance de recursos como combustible, energía eléctrica, alimentos, agua, comunicaciones, etc. no detendrá ni negará el acceso a servicios, procesos y operaciones. (e) Verificar que la imposibilidad de eliminar desechos, contaminantes u otros contaminantes del alcance no detendrá ni negará el acceso a los servicios, procesos y operaciones. (f) Verificar que las condiciones de amenaza de alerta máxima no detengan ni nieguen el acceso a servicios, procesos y operaciones.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

8.17 Revisión de alertas y registros

Un análisis de brechas entre las actividades realizadas con la prueba y la verdadera profundidad de esas actividades registradas o según las percepciones de terceros, tanto humanas como mecánicas.

8.17.1 Alarma

Verificar y enumerar el uso de un sistema, registro o mensaje de advertencia localizado o de todo el alcance para cada puerta de enlace de acceso donde el personal detecta una situación sospechosa ante la sospecha de intentos de elusión, actividad fraudulenta, traspaso o infracción. Asegúrese de que los sensores/sistemas estén instalados según los estándares nacionales, regionales o internacionales y se prueben periódicamente para cubrir todos los puntos accesibles.

8.17.2 Almacenamiento y recuperación

Documente y verifique los permisos y el acceso eficiente a las ubicaciones y propiedades de almacenamiento de alarmas, registros y notificaciones. El acceso a las áreas donde se procesa o almacena información confidencial debe controlarse y restringirse únicamente al personal autorizado; Se debe mantener de forma segura un registro de auditoría de todos los accesos.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

La información que se puede encontrar dentro del espectro inalámbrico no se limita a las especificaciones del producto.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

Capítulo 9 - Pruebas de seguridad inalámbrica

La seguridad del espectro (SPECSEC) es la clasificación de seguridad que incluye seguridad electrónica (ELSEC), seguridad de señales (SIGSEC) y seguridad de emanaciones (EMSEC). ELSEC son las medidas para denegar el acceso no autorizado a la información derivada de la interceptación y análisis de radiaciones electromagnéticas ajenas a las comunicaciones. SIGSEC son las medidas para proteger las comunicaciones inalámbricas contra accesos no autorizados e interferencias. EMSEC son las medidas para prevenir las emanaciones de las máquinas que, si son interceptadas y analizadas, revelarían la información transmitida, recibida, manejada o procesada de otra manera por los equipos de sistemas de información. Probar este canal requiere interacción con barreras a los activos en frecuencias electromagnéticas (EM) y microondas (MW).

Este canal cubre la interacción del Analista dentro del rango de proximidad de los objetivos. Si bien algunos servicios consideran esto simplemente como un "escaneo", los verdaderos objetivos de cumplimiento de las pruebas de seguridad en este canal son las pruebas de barreras físicas y lógicas y la medición de brechas con respecto al estándar de seguridad requerido descrito en la política de la empresa, las regulaciones de la industria o la legislación regional.

Se requerirá que el Analista tenga protección adecuada contra fuentes de energía electromagnéticas y otras formas de radiación. Los analistas también deberán estar preparados para la posibilidad de daños corporales accidentales por exposición a radiación electromagnética y de microondas, especialmente aquella que puede dañar permanentemente la audición o la vista. El equipo adecuado debe advertir cuando se encuentre dentro del rango de radiación electromagnética y de microondas de -12 dB y más. Frecuencias específicas pueden afectar negativamente a los dispositivos médicos implantados, provocar vértigo, dolores de cabeza, calambres estomacales, diarrea y otras molestias tanto a nivel emocional como físico.

Los analistas competentes requerirán conocimientos suficientes sobre radiación EM y MW y habilidades de pensamiento crítico para garantizar que la recopilación de datos fácticos genere resultados fácticos a través de la correlación y el análisis.

Consideraciones

Tenga en cuenta las siguientes consideraciones para garantizar una prueba segura y de alta calidad:

1. Ignorantia legis neminem excusat: los analistas que no realizan una revisión de postura adecuada para el alcance y las regiones objetivo de los negocios o las interacciones no pueden escapar al castigo por violar las leyes simplemente porque desconocían la ley; es decir, los analistas han presumido conocimiento de la ley. Los analistas son considerados profesionales en este tema y, por lo tanto, existe la suposición de que incluso lo que puede no ser de conocimiento común para la persona promedio sobre las leyes de una región extranjera con respecto a los sistemas de comunicación EM y MW, el analista lo sabrá.
2. En persona: Las pruebas deben apuntar específicamente solo a SPECSEC del personal que está bajo contrato legal directo con el propietario del alcance, sistemas informáticos en propiedad del propietario del alcance y señales EM o MW o emanaciones de un nivel de potencia lo suficientemente grande como para interrumpir o dañar. comunicaciones inalámbricas dentro del alcance. Los analistas deben hacer esfuerzos para no invadir la vida privada de una persona, como escuchar o grabar comunicaciones personales que se originen dentro del alcance, cuando esa vida privada haya hecho esfuerzos por separarse del alcance.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

9.1 Revisión de la postura

Los estudios iniciales de la postura incluyen las leyes, la ética, las políticas, las regulaciones de la industria y la cultura política que influyen en los requisitos de seguridad y privacidad del alcance. Esta revisión forma una matriz a la que se deben asignar las pruebas, pero no limitarlas.

9.1.1 Política

Revisar y documentar la política organizacional apropiada con respecto a las responsabilidades de seguridad, integridad y privacidad del alcance. Revisar y documentar contratos y acuerdos de nivel de servicio (SLA) con proveedores de servicios y otros terceros involucrados.

9.1.2 Legislación

Revisar y documentar la legislación regional y nacional apropiada y las regulaciones de la industria con respecto a los requisitos de seguridad y privacidad de la organización en el alcance, así como aquello que incluye a los clientes, socios, sucursales de la organización o revendedores apropiados fuera del alcance.

9.1.3 Cultura

Revise y documente la cultura organizacional adecuada en el ámbito de la concientización sobre seguridad y privacidad, la capacitación del personal requerida y disponible, la jerarquía organizacional, el uso de la mesa de ayuda y los requisitos para informar problemas de seguridad.

9.1.4 Edad

Revisar y documentar la antigüedad de los sistemas, el software y las aplicaciones de servicio necesarios para las operaciones.

9.1.5 Artefactos frágiles

Revise y documente cualquier sistema, software y aplicación de servicio que requiera cuidado especial debido al alto uso, inestabilidades o una alta tasa de cambio.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

9.2 Logística

La preparación del entorno de prueba del canal es necesaria para evitar falsos positivos y falsos negativos que conduzcan a resultados de prueba inexactos.

9.2.1 Equipo de comunicaciones

Pruebe equipos que puedan transmitir radiación electromagnética, como CRT, LCD, impresoras, módems y teléfonos celulares, y que puedan usarse para recrear los datos que se muestran en la pantalla, se imprimen o se transmiten, etc. Explotar esta vulnerabilidad es conocido como phreaking de Van Eck.

9.2.2 Comunicaciones

Pruebe qué protocolos se utilizan dentro del alcance y los métodos de transmisión.

9.2.3 Hora

Prueba del período de funcionamiento del equipo. Por ejemplo, ¿hay un punto de acceso inalámbrico (AP) disponible las 24 horas del día, los 7 días de la semana o solo durante el horario comercial normal?

9.3 Verificación de detección activa

La determinación de controles activos y pasivos para detectar intrusiones para filtrar o negar intentos de prueba debe realizarse antes de la prueba para mitigar el riesgo de crear falsos positivos y negativos en los datos de resultados de la prueba, así como cambiar el estado de alarma del personal o agentes de monitoreo.

9.3.1 Monitoreo de canales

Pruebe si existen controles para monitorear la intrusión o la manipulación de señales.

9.3.2 Moderación de canales

Pruebe si existen controles para bloquear señales (interferencias) o alertar sobre actividades no autorizadas.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

9.4 Auditoría de visibilidad

Pruebas de enumeración y verificación de la visibilidad del personal con el que es posible interactuar a través de todos los canales.

9.4.1 Intercepción

Localice el control de acceso, la seguridad perimetral y la capacidad de interceptar o interferir con canales inalámbricos.

9.4.2 Detección de señal pasiva

(a) Determine qué frecuencias y señales pueden filtrarse hacia o desde el área objetivo utilizando una antena direccional de alta ganancia y medios de detección pasiva, como el análisis de frecuencia. (b) Crear un mapa de calor del alcance que muestre todas las fuentes de radiación y sus radios y fortaleza.

(c) Prueba de fuentes que interactúan sin autorización. (d)

Recopilar información difundida por estas fuentes. (e)

Mapear todos los datos encontrados con los valores límite de emisión actualmente requeridos en la región para todos los radiación.

9.4.2 Detección de señal activa

Examine qué frecuencias o transmisiones de señales electromagnéticas desencadenan respuestas como las de RFID u otras fuentes inalámbricas interactivas. (Las etiquetas identificadoras de radiofrecuencia se componen de un circuito integrado, que a veces tiene la mitad del tamaño de un grano de arena, y una antena, normalmente una bobina de cables. La información se almacena en el circuito integrado y se transmite a través de la antena cuando la sonda la sondea. señal correcta. Por lo tanto, las frecuencias exactas utilizadas en los sistemas RFID pueden variar según el país o la región).



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

9.5 Verificación de acceso

Pruebas para la enumeración de puntos de acceso al personal dentro del alcance. Mientras que el acceso al personal fuera del alcance es un escenario real y uno que se utiliza a menudo para el robo de propiedad de información, el Analista puede limitarse a una interacción de alcance exclusivo para proteger los derechos de privacidad independientes del personal en su vida privada.

9.5.1 Evaluar el acceso administrativo a dispositivos inalámbricos

Determine si los puntos de acceso están apagados durante las partes del día en las que no estarán en uso.

9.5.2 Evaluar la configuración del dispositivo

Pruebe y documente mediante antenas direccionales y de alta ganancia que los dispositivos inalámbricos están configurados para configuración de energía más baja posible para mantener un funcionamiento suficiente que mantenga las transmisiones dentro de los límites seguros de la organización.

9.5.3 Evaluar la configuración, autenticación y cifrado de redes inalámbricas

Verifique que se haya cambiado el identificador de conjunto de servicios (SSID) predeterminado del punto de acceso.

9.5.4 Autenticación

Enumerar y probar deficiencias en los métodos de autenticación y autorización.

9.5.5 Control de acceso

Evaluar los controles de acceso, la seguridad perimetral y la capacidad de interceptar o interferir con comunicación, determinando el nivel de controles de acceso físico a puntos de acceso y dispositivos controlarlos (cerraduras con llave, lectores de tarjetas, cámaras, etc.).



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

9.6 Verificación de confianza

Pruebas de confianza entre personal dentro del alcance donde la confianza se refiere al acceso a información o propiedad sin necesidad de identificación o autenticación.

9.6.1 Tergiversación

Probar y documentar el método de autenticación de los clientes.

9.6.2 Fraude

Pruebe y documente la profundidad de los requisitos para el acceso a dispositivos inalámbricos dentro del alcance con el uso de credenciales fraudulentas.

9.6.3 Abuso de recursos

Probar y documentar la profundidad de los requisitos para enviar la propiedad fuera del alcance a un fuente conocida y confiable o en todo el alcance a otro personal sin ningún tipo de credenciales establecidas y requeridas.

9.6.4 Confianza ciega

Pruebe y documente las conexiones que se realizan a un receptor falso o comprometido.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

9.7 Verificación de controles

Pruebas para enumerar los tipos de controles de pérdidas utilizados para proteger la información.

9.7.1 No repudio

Enumerar y probar el uso o las deficiencias de demonios y sistemas para identificar y registrar adecuadamente el acceso o las interacciones a la propiedad en busca de evidencia específica para impugnar el repudio, y documentar la profundidad de la interacción registrada y el proceso de identificación.

9.7.2 Confidencialidad

Enumerar y probar el uso de equipos para amortiguar señales de transmisión electromagnética fuera de la empresa y los controles establecidos para asegurar o cifrar las transmisiones inalámbricas.

9.7.3 Privacidad

Determinar el nivel de controles de acceso físico a los puntos de acceso y los dispositivos que los controlan (cerraduras con llave, lectores de tarjetas, cámaras, etc.).

9.7.4 Integridad

Determinar que solo aquellos que estén autorizados puedan acceder a los datos y modificarlos y garantizar que se utilice un cifrado adecuado para garantizar la firma y la confidencialidad de las comunicaciones.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

9.8 Verificación del proceso

Pruebas para examinar el mantenimiento de la conciencia de seguridad funcional del personal en los procesos establecidos y la debida diligencia según se define en la Revisión de Postura.

9.8.1 Línea base

Examine y documente la configuración básica para garantizar que la postura de seguridad esté en línea con la política de seguridad.

9.8.2 Blindaje adecuado

Examine y determine que exista el blindaje adecuado. Por ejemplo, determine que las impresoras estén en gabinetes especialmente blindados para bloquear los EMT, se utilicen paneles o pintura metálica para bloquear las señales inalámbricas, etc.

9.8.3 Debida diligencia

Mapee y verifique cualquier brecha entre la práctica y los requisitos según lo determinado en la Revisión de Postura a través de todos los canales.

9.8.4 Indemnización

Documente y enumere que los objetivos y servicios que están protegidos contra el abuso o la elusión de la política de los empleados, están asegurados contra robo o daños, o utilizan exenciones de responsabilidad y permisos. Verificar la legalidad y adecuación del lenguaje en los avisos legales.

9.9 Verificación de la configuración

Pruebas para examinar la capacidad de eludir o alterar la seguridad funcional de los activos.

9.9.1 Errores de configuración comunes

Realice ataques de fuerza bruta contra puntos de acceso para discernir la seguridad de las contraseñas. Verifique que las contraseñas contengan letras mayúsculas y minúsculas, números y caracteres especiales. Los puntos de acceso que utilizan contraseñas que no distinguen entre mayúsculas y minúsculas facilitan a los atacantes realizar un ataque de adivinación de fuerza bruta debido al espacio más pequeño de contraseñas posibles.

9.9.2 Controles de configuración

Examine los controles, incluida la configuración básica, para validar que las configuraciones estén de acuerdo con la política de seguridad.

9.9.3 Evaluar y probar el cableado y las emisiones

Verifique que todo el cableado que entra y sale de las habitaciones blindadas esté hecho de fibra, siempre que sea posible.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

9.10 Validación de propiedad

Pruebas para examinar información y propiedad física disponible dentro del alcance, o proporcionada por el personal, que pueden ser ilegales o poco éticas.

9.10.1 Compartir

Verificar en qué medida el personal comparte propiedad con licencia individual, privada, falsificada, reproducida, no libre o no abierta, ya sea intencionalmente a través de procesos y programas compartidos, bibliotecas y cachés personales o involuntariamente a través de una mala gestión de licencias, y recursos, o negligencia.

9.10.2 Transceptores inalámbricos no autorizados

Realice un inventario completo de todos los dispositivos inalámbricos. Verificar que la organización cuente con una política de seguridad adecuada que aborde el uso de tecnología inalámbrica.

9.11 Revisión de segregación

Pruebas para la separación adecuada de la propiedad de información privada o personal de la información comercial. Al igual que una revisión de privacidad, es el punto central del almacenamiento, la transmisión y el control legal y ético de la propiedad de información privada del personal, los socios y los clientes.

9.11.1 Mapeo de contención de privacidad

Mapee los guardianes de la información privada dentro del alcance, qué información se almacena, cómo y dónde se almacena la información y a través de qué canales se comunica la información.

9.11.3 Divulgación

Examinar y documentar tipos de divulgaciones de información privada en el espectro inalámbrico.

9.11.4 Limitaciones

Examinar y documentar tipos de puertas de enlace y alternativas de canales accesibles para personas con limitaciones físicas dentro de ese canal.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

9.12 Verificación de exposición

Pruebas para descubrir información que proporciona o conduce a un acceso autenticado o permite el acceso a múltiples ubicaciones con la misma autenticación.

9.12.1 Mapeo de exposición

Enumerar y mapear información del personal relacionada con la organización, como organigramas, títulos de personal clave, descripciones de puestos, números de teléfono personales y laborales, números de teléfonos móviles, tarjetas de presentación, documentos compartidos, currículums, afiliaciones organizacionales, información privada y pública. -direcciones de correo electrónico, inicios de sesión, esquemas de inicio de sesión, contraseñas, métodos de respaldo, aseguradoras o cualquier información organizacional particular declarada implícitamente como confidencial en las regulaciones y políticas.

9.12.2 Creación de

perfiles Examine y verifique con el uso de una antena direccional y de alta ganancia si las señales inalámbricas con información sobre el dispositivo se extienden más allá de las paredes o la propiedad del objetivo.

9.13 Exploración de Inteligencia Competitiva

Pruebas de eliminación de propiedades que pueden analizarse como inteligencia empresarial. Si bien la inteligencia competitiva como campo está relacionado con el marketing, el proceso aquí incluye cualquier forma de recopilación de inteligencia competitiva, incluido, entre otros, el espionaje económico e industrial.

9.13.1 Molienda empresarial

Mapear objetivos dentro del alcance del análisis activo y pasivo de emanaciones: qué información se almacena, cómo y dónde se almacena la información, y cómo se comunica la información.

9.13.2 Entorno empresarial

Explore y documente detalles comerciales como alianzas, socios, clientes principales, proveedores, distribuidores, inversores, relaciones comerciales, producción, desarrollo, información de productos, planificación, acciones y comercialización, y cualquier información o propiedad comercial particular declarada implícitamente como confidencial en las regulaciones y política.

9.13.3 Entorno organizacional

Examinar y documentar los tipos de divulgaciones de propiedad comercial de los guardianes sobre operaciones, procesos, jerarquía, informes financieros, oportunidades de inversión, fusiones, adquisiciones, inversiones de canales, mantenimiento de canales, políticas sociales internas, insatisfacción del personal y tasa de rotación, principales tiempos de vacaciones. contrataciones, despidos y cualquier propiedad organizacional particular declarada implícitamente como confidencial en las regulaciones y políticas.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

9.14 Verificación de cuarentena

La determinación y medición del uso efectivo de la cuarentena para todos los accesos hacia y dentro del objetivo.

9.14.1 Identificación del proceso de contención

Identificar y examinar métodos y procesos de cuarentena en el objetivo en todos los canales para detectar contactos agresivos y hostiles.

9.14.2 Niveles de Contención

Verificar el estado de contención, el tiempo y todos los canales donde las interacciones tienen métodos de cuarentena. Asegúrese de que los métodos estén dentro del contexto y los límites legales.

9.15 Auditoría de privilegios

Pruebas en las que se proporcionan credenciales al usuario y se le otorga permiso para realizar pruebas con esas credenciales.

9.15.1 Identificación

Examinar y documentar el proceso para la obtención de identificación por medios tanto legítimos como fraudulentos en todos los canales.

9.15.2 Autorización

Verificar el uso de autorizaciones fraudulentas en todos los canales para obtener privilegios similares a los del resto del personal.

9.15.3 Escalamiento

Verifique y mapee el acceso a la información mediante el uso de privilegios para obtener mayores privilegios.

9.15.4 Subyugación

Enumere y pruebe las deficiencias de todos los canales para usar o habilitar controles de pérdidas no habilitados de forma predeterminada.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

9.16 Validación de supervivencia

Determinar y medir la resiliencia del objetivo dentro del alcance a cambios excesivos u hostiles diseñados para causar fallas en el servicio.

9.16.1 Continuidad

Enumere y pruebe las deficiencias del objetivo con respecto a los retrasos en el acceso y el tiempo de respuesta del servicio a través de personal de respaldo o medios automatizados para acceso alternativo.

9.16.2 Resiliencia

Mapee y documente el proceso de los guardianes que desconectan canales debido a violaciones o problemas de seguridad como un análisis de brechas con la regulación y la política de seguridad.

9.17 Revisión de alertas y registros

Un análisis de brechas entre las actividades realizadas con la prueba y la verdadera profundidad de esas actividades registradas o desde percepciones de terceros, tanto humanas como mecánicas.

9.17.1 Alarma

Verificar y enumerar el uso de un sistema, registro o mensaje de advertencia localizado o de todo el alcance para cada puerta de enlace de acceso a través de cada canal donde el personal detecta una situación sospechosa ante la sospecha de intentos de elusión, ingeniería social o actividad fraudulenta.

9.17.2 Almacenamiento y recuperación

Documente y verifique el acceso sin privilegios a propiedades y ubicaciones de almacenamiento de alarmas, registros y notificaciones.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

En las telecomunicaciones, las personas forman parte del proceso tanto como las máquinas. Rara vez son mutuamente excluyentes.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

Capítulo 10 - Pruebas de seguridad de las telecomunicaciones

COMSEC es una clasificación para la seguridad material dentro del ámbito ELSEC que se encuentra dentro de los límites de las telecomunicaciones por cable.

Este canal cubre la interacción del Analista con los objetivos. Si bien algunos servicios consideran esto simplemente como "phreaking", el verdadero objetivo de cumplimiento de las pruebas de seguridad en este canal es la prueba de barreras lógicas y la medición de brechas con respecto al estándar de seguridad requerido como se describe en la política de la empresa, las regulaciones de la industria o la legislación regional.

Se requerirá que el analista tenga múltiples herramientas y métodos para completar algunas tareas a fin de garantizar que no se generen sospechas entre el personal por el timbre continuo y secuencial de los teléfonos y que las pruebas no queden invalidadas debido a un descubrimiento temprano o una mayor paranoia. Los analistas también deberán estar preparados para trabajar con equipos de telecomunicaciones digitales y analógicos, analizadores de frecuencia de sonido y dentro de redes de información que proporcionen contenido regional a través de proveedores telefónicos locales.

Los analistas competentes necesitarán experiencia en electrónica, telefonía analógica y digital, y habilidades de pensamiento crítico para garantizar que la recopilación de datos fácticos genere resultados fácticos a través de la correlación y el análisis.

Consideraciones

Tenga en cuenta las siguientes consideraciones para garantizar una prueba segura y de alta calidad:

1. Ignorantia legis neminem excusat: los analistas que no realizan una revisión de postura adecuada para el alcance y las regiones objetivo de los negocios o las interacciones no pueden escapar al castigo por violar las leyes simplemente porque desconocían la ley; es decir, las personas tienen presunto conocimiento de la ley. Los analistas son considerados profesionales en este tema y, por lo tanto, existe la suposición de que incluso lo que puede no ser conocimiento común para una persona normal sobre las leyes de una región extranjera en materia de sistemas informáticos, será conocido por los profesionales, ya que conocen las leyes necesarias para participar en sus emprendimientos.
2. Derechos de propiedad: Las pruebas deben apuntar específicamente solo a sistemas que estén bajo propiedad legal directa del propietario del alcance o sistemas informáticos en propiedad del propietario del alcance. Dichos bienes o efectos personales deben seguir siendo personales y privados a menos que involucren específicamente al propietario del alcance mediante menosprecio, falsa iluminación, competitividad o razones establecidas en los acuerdos contractuales de personal. Los analistas deben hacer esfuerzos para no invadir la vida privada de una persona cuando esa vida privada ha hecho esfuerzos por separarse del alcance. Los analistas con un acuerdo especial para probar sistemas que están bajo contrato directo pero que no son de propiedad, o que son de propiedad pero no están alojados en la propiedad legal del propietario, deben tener mucho cuidado para garantizar que las pruebas tengan un impacto mínimo en otros sistemas fuera del alcance o contrato.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

10.1 Revisión de la postura

Los estudios iniciales de la postura incluyen las leyes, la ética, las políticas, las regulaciones de la industria y la cultura política que influyen en los requisitos de seguridad y privacidad del alcance. En la mayoría de los casos, un objetivo también puede tener contratos con proveedores y otros terceros que pueden necesitar ser revisados y documentados. Esta revisión forma una matriz con respecto a la cual se deben mapear las pruebas, pero no restringirlas, debido a la ubicuidad de los puntos finales del canal. Por lo tanto es importante considerar, como exige alguna legislación, el mercado objetivo o usuarios finales de este canal que también debe agregarse al alcance de este módulo.

10.1.1 Política

- (a) Revisar y documentar la política organizacional apropiada con respecto a los requisitos de seguridad, integridad y privacidad del alcance. Verificar las limitaciones a las telecomunicaciones impuestas por la política de seguridad.
- (b) Revisar y documentar contratos y acuerdos de nivel de servicio (SLA) con proveedores de servicios. y otros terceros involucrados.

10.1.2 Legislación

Revisar y documentar la legislación regional y nacional apropiada con respecto a los requisitos de seguridad y privacidad de la organización en el alcance, así como la que incluye a los clientes, socios, sucursales de la organización o revendedores apropiados fuera del alcance. Cuando corresponda, preste especial atención a la privacidad y la retención de datos de los registros detallados de llamadas, las leyes y normas que rigen la interceptación o el monitoreo de telecomunicaciones y la prestación de servicios críticos como el E-911.

10.1.3 Cultura

Revise y documente la cultura organizacional adecuada en el ámbito de la concientización sobre seguridad y privacidad, la capacitación del personal requerida y disponible, la jerarquía organizacional, el uso de la mesa de ayuda y los requisitos para informar problemas de seguridad.

10.1.4 Edad

Revisar y documentar la antigüedad de los sistemas, el software y las aplicaciones de servicio necesarios para las operaciones.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

10.1.5 Artefactos frágiles

Revise y documente cualquier sistema, software y aplicación de servicio que requiera cuidado especial debido al alto uso, inestabilidades o una alta tasa de cambio.

10.1.6 Vectores de ataque

- (a) Prueba de PBX
- (b) Prueba de buzón de voz (c) Inspección, sondeo y prueba de FAX y módem (d) Prueba de servicios de acceso remoto (RAS) (e) Prueba de líneas RDSI de respaldo (f) Prueba de voz sobre IP (g) Pruebas de red conmutada por paquetes X.25

10.2 Logística

La preparación del entorno de prueba del canal es necesaria para evitar falsos positivos y falsos negativos que conduzcan a resultados de prueba inexactos.

10.2.1 Marco

- (a) Verificar el alcance y los propietarios de los objetivos descritos para la auditoría, junto con los operadores y otros terceros que gestionan las líneas de telecomunicaciones y la infraestructura de los objetivos.
- (b) Determinar la ubicación de la propiedad y el dueño de la propiedad que alberga a los objetivos. (c) Buscar otros objetivos del mismo propietario. (d) Encontrar y verificar las rutas de los servicios de telecomunicaciones que interactúan fuera del objetivo para los caminos que siguen dentro y fuera del alcance. (e) Determinar la ubicación física de los objetivos. (f) Pruebe qué protocolos se utilizan dentro del alcance (ejemplo: PSTN, ISDN, GSM, UMTS, SIP, H.323, RTP, XOT, DECNET, IPX, etc.). (g) Verificar y documentar las limitaciones especiales impuestas por el contrato con el cliente.

10.2.2 Calidad de la red

- (a) Medir las velocidades de conexión máximas y mínimas admitidas por los objetivos. (b) Determinar y verificar la velocidad de conexión, la paridad, el tiempo de RING y otros parámetros de configuración específicos adecuados que se utilizarán para el escaneo y las pruebas. (c) Verificar y documentar limitaciones particulares impuestas por el alcance (ejemplo: red X.25 congestión, rutas estrictas XOT, filtros de acceso basados en CLID).



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

10.2.3 Tiempo y costos adicionales

- (a) Pruebe el período de funcionamiento del equipo (ejemplo: redirección de llamada al contestador automático del horario comercial normal).
- (b) Determinar y documentar la configuración horaria (zona horaria, horario de verano, etc.) para los objetivos.
- (c) Asegurar que el reloj del analista esté sincronizado con el tiempo de los objetivos. Ciertos equipos, como los artefactos frágiles, pueden tener configuraciones de hora que no representan una hora válida; Si el reloj del analista se sincroniza con estos, puede tener un impacto en el resultado de la prueba.
- (d) Determinar los costos financieros adicionales involucrados en la realización de pruebas exhaustivas desde una ubicación remota (ejemplo: escaneo en busca de módems/FAX, prueba de servicios de acceso remoto que no sean en números gratuitos, realización de llamadas X.25 sin cobro revertido).

10.3 Verificación de detección activa

La determinación de los controles activos para detectar intrusiones y filtrar o negar intentos de prueba debe realizarse antes de la prueba para mitigar el riesgo de corromper los datos de los resultados de la prueba, así como cambiar el estado de alarma del personal o agentes de monitoreo. Puede ser necesario coordinar estas pruebas con el personal adecuado dentro del alcance.

10.3.1 Monitoreo

- (a) Probar si las telecomunicaciones son monitoreadas por una parte autorizada para transmitir datos de red inadecuados, inyecciones de códigos, contenido malicioso y conducta inapropiada, y registrar las respuestas y el tiempo de respuesta. (b) Probar si existen controles para monitorear actividades fraudulentas o manipulación de servicios, y registrar las respuestas y el tiempo de respuesta, como en la conciliación periódica de facturación utilizando Registros de detalles de llamadas (CDR).

10.3.2 Filtrado

- (a) Probar si existen controles a nivel de red para bloquear actividades no autorizadas y registrar las respuestas y el tiempo de respuesta, como filtros de acceso basados en la identificación de la línea de llamada (CLID), la dirección de usuario de la red (NUA) o el grupo cerrado de usuarios (CUG).
- (b) Probar si existen controles a nivel de aplicación para bloquear actividades no autorizadas y registrar las respuestas y el tiempo de respuesta.

10.3.3 Detección activa

- (a) Verificar las respuestas activas a las sondas de los sistemas y servicios. (b) Verificar si existe protección contra ataques de fuerza bruta, como el bloqueo de cuentas. (c) Mapear cualquier aplicación, sistema o segmento de red dentro del alcance que produzca registros, alarmas o notificaciones.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

10.4 Auditoría de Visibilidad

Enumeración e indexación de los objetivos en el alcance mediante interacción directa e indirecta con o entre sistemas en vivo.

10.4.1 Levantamiento de red

- (a) Compilar un mapa de los protocolos de comunicación en uso dentro del alcance. (b) Delinear la topología de las redes de telecomunicaciones dentro del alcance.

10.4.2 Enumeración

- (a) Pruebas de PBX: enumerar los sistemas de telefonía dentro del alcance.
- (b) Prueba de buzones de voz: busque buzones de voz dentro del alcance. (c) Pruebas de FAX: enumerar los sistemas de FAX dentro del alcance.
- (d) Encuesta de módem: encuentre todos los sistemas con módems interactivos y de escucha dentro del alcance. (e) Pruebas de servicios de acceso remoto: enumerar los sistemas RAS dentro del alcance. (f) Prueba de líneas RDSI de respaldo: enumere los dispositivos de red con líneas RDSI de respaldo dentro del alcance. (g) Pruebas de voz sobre IP: enumerar los sistemas de VoIP dentro del alcance. (h) Pruebas de red conmutada por paquetes X.25: encuentre sistemas activos y accesibles dentro del alcance, registrando sus códigos de respuesta.

10.4.3 Identificación

- (a) Identificar los tipos y versiones de SO que se utilizan en los sistemas dentro del alcance. (b) Identificar los tipos y versiones de servicios en uso en los sistemas dentro del alcance. (c) Identificar tipos de módem y FAX y programas operativos.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

10.5 Verificación de acceso

Pruebas para la medición de la amplitud y profundidad de los puntos de acceso interactivos dentro del alcance y autenticación requerida.

10.5.1 Proceso de acceso

- (a) Pruebas de PBX: busque sistemas PBX que permitan la administración remota o el acceso mundial a la terminal de mantenimiento, ya sea mediante marcación telefónica o red IP. (b) Prueba de buzones de voz: encuentre buzones de voz que sean accesibles en todo el mundo.
- (c) Pruebas de FAX: encuentre sistemas de FAX que permitan la administración remota o el acceso mundial a la terminales de mantenimiento.
- (d) Encuesta de módem: probar y documentar los protocolos de autenticación en uso (ejemplo: terminal, PAP, CHAP, otros).
- (e) Pruebas de Servicios de Acceso Remoto: probar y documentar los protocolos de autenticación en uso (ejemplo: terminal, PAP, CHAP, otros). (f) Pruebas de líneas RDSI de respaldo: probar y documentar los protocolos de autenticación en uso (ejemplo: terminal, PAP, CHAP, otros). (g) Pruebas de voz sobre IP: verificar la posibilidad de realizar fraude telefónico, escucha o rastreo de llamadas, secuestro de llamadas, suplantación de CLID y denegación de servicio, utilizando ataques dirigidos a redes convergentes, elementos de red VoIP, protocolos de señalización y transporte de medios. (h) Pruebas de red de conmutación de paquetes X.25: encontrar sistemas que permitan la administración remota, el acceso a otros servicios a través de CUD específicos o el cobro revertido, verificar cuántos Canales Virtuales (VC) y Canales Virtuales Permanentes (PVC) están en uso y cómo se gestionan (CUG, mapeo de subdirecciones, filtrado de llamadas entrantes X.25, filtrado basado en NUA, etc.).

10.5.2 Servicios

- (a) Solicitar servicios remotos conocidos y comunes. (b) Identificar los componentes de los servicios y sus versiones. (c) Verificar el tiempo de actividad del servicio hasta las últimas vulnerabilidades y lanzamientos de parches. (d) Para cada servicio identificado, probar remotamente y documentar los errores de configuración. (e) Para cada aplicación identificada, probar remotamente y documentar errores de programación.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

10.5.3 Autenticación

- (a) Enumerar los recursos de telecomunicaciones que requieren autenticación y verificar todos los recursos aceptables. formas de privilegios para interactuar o recibir acceso.
- (b) Documentar los esquemas de autenticación en uso, verificar el proceso para recibir la autenticación, y probar errores lógicos.
- (c) Verificar los métodos de autorización y la identificación requerida. (d) Asegúrese de que las cuentas administrativas no tengan credenciales predeterminadas o fáciles de adivinar. (e) Asegúrese de que las cuentas de usuario no tengan credenciales predeterminadas o fáciles de adivinar. (f) Verificar y probar las protecciones contra ataques de fuerza bruta y de tipo diccionario. (g) Verificar y probar las comprobaciones de complejidad de la contraseña y el tamaño del PIN del buzón de voz, la antigüedad de la contraseña y frecuencia de los controles de cambio.
- (h) Pruebe credenciales "conocidas" en todos los puntos de acceso enumerados para verificar los controles de reutilización de contraseñas. (i) Verificar el formato utilizado para el almacenamiento de las credenciales de autenticación y documentar texto claro o contraseñas ofuscadas y algoritmos de cifrado débiles.
- (j) Verificar el formato utilizado para la transmisión de credenciales de autenticación a través de la red y documentar contraseñas en texto claro u ofuscadas y algoritmos de cifrado débiles. (k) Verificar esa información de autenticación, ya sea que se haya intentado, haya tenido éxito o haya fallado. está debidamente registrado.

10.6 Verificación de confianza

Pruebas de confianza entre sistemas dentro del alcance, donde la confianza se refiere al acceso a información o propiedad física sin necesidad de credenciales de autenticación.

10.6.1 Suplantación de identidad

- (a) Probar y documentar los métodos de acceso en uso que no requieren la presentación de credenciales de autenticación.
- (b) Probar y documentar la profundidad de los requisitos para la interacción y el acceso a la propiedad dentro del alcance mediante la suplantación de una fuente confiable (ejemplo: suplantación de CLID y X.25 NUA).

10.6.2 Abuso de recursos

- (a) Probar y documentar la profundidad de los requisitos para llevar propiedad fuera del alcance a una fuente conocida y confiable o a todo el alcance sin ninguna credencial requerida establecida.
- (b) Probar y documentar la propiedad disponible fuera del alcance debido a fugas de información.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

10.7 Verificación de controles

Pruebas para enumerar y verificar la funcionalidad operativa de las medidas de seguridad de activos y servicios, definidas mediante controles de pérdidas basados en procesos (Clase B). El control de alarma se verifica al final de la metodología.

10.7.1 No repudio

- (a) Enumerar y probar el uso o las deficiencias de las aplicaciones y sistemas para identificar y registrar adecuadamente el acceso o las interacciones a la propiedad en busca de evidencia específica para impugnar el repudio.
- (b) Documentar la profundidad de la interacción registrada y el proceso de identificación. (c) Verificar que todos los métodos de interacción estén debidamente registrados con la identificación adecuada. (d) Identificar métodos de identificación que venzan el repudio.

10.7.2 Confidencialidad

- (a) Enumerar todas las interacciones con servicios dentro del alcance de las comunicaciones o activos transportados a través del canal utilizando líneas seguras, encriptación, interacciones "silenciadas" o "cerradas" para proteger la confidencialidad de la propiedad de la información entre las partes involucradas.
- (b) Verificar los métodos aceptables utilizados para la confidencialidad.
- (c) Probar la solidez y el diseño de los métodos de cifrado u ofuscación. (d) Verificar los límites exteriores de comunicación que pueden protegerse mediante el método aplicado de confidencialidad.

10.7.3 Privacidad

Enumere todas las interacciones con servicios dentro del alcance de las comunicaciones o activos transportados a través del canal utilizando líneas seguras, cifrado, interacciones "silenciadas" o "cerradas" para proteger la privacidad de la interacción y el proceso de proporcionar activos solo a aquellos dentro del marco de seguridad adecuado. autorización para ese proceso, comunicación o activo.

10.7.4 Integridad

Enumerar y probar las deficiencias de integridad cuando se utiliza un proceso documentado, firmas, cifrado, hash o marcas para garantizar que el activo no se pueda cambiar, cambiar, redirigir o revertir sin que las partes involucradas lo sepan.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

10.8 Verificación del proceso

Pruebas para examinar el mantenimiento de la seguridad funcional y la eficacia en los procesos establecidos y la debida diligencia según se define en la Revisión de Postura.

10.8.1 Línea base

Examinar y documentar los servicios básicos para garantizar que los procesos estén en línea con la política de seguridad.

10.8.2 Mantenimiento

Examinar y documentar la oportunidad, idoneidad, acceso y alcance de los procesos para la notificación y conciencia de seguridad del personal con respecto a la seguridad operativa, la seguridad real y los controles de pérdidas.

10.8.3 Desinformación

Determinar hasta qué punto las notificaciones de seguridad del personal y las noticias de seguridad pueden ampliarse o alterarse con información errónea.

10.8.4 Debida Diligencia

Mapear y verificar cualquier brecha entre la práctica y los requisitos según lo determinado en la Revisión de Postura a través de todos los canales.

10.8.5 Indemnización

- (a) Documentar y enumerar objetivos y servicios que están protegidos contra abuso o elusión de la política de los empleados, que están asegurados contra robo o daños, o utilizan exenciones de responsabilidad y permisos. (b) Verificar la legalidad y adecuación del lenguaje en los avisos legales. (c) Verificar el efecto de las exenciones de responsabilidad sobre las medidas de seguridad o protección. (d) Examinar el lenguaje de la póliza de seguro para detectar limitaciones sobre tipos de daños o bienes. (e) Comparar la política de acceso cultural con la política de indemnización en busca de evidencia de debilidades.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

10.9 Verificación de la configuración

Pruebas para recopilar toda la información, técnica y no técnica, sobre cómo se pretende que funcionen los activos y para examinar la capacidad de eludir o alterar la seguridad funcional de los activos, explotando la configuración inadecuada de los controles de acceso, los controles de pérdidas y las aplicaciones.

10.9.1 Controles de configuración

- (a) Examinar los controles, incluida la configuración de referencia, para validar las configuraciones adecuadas de equipos, sistemas y aplicaciones dentro del alcance.
- (b) Examinar los controles para garantizar que las configuraciones de equipos, sistemas y aplicaciones coincidan con la intención de la organización y reflejen una justificación comercial. (c) Examinar las Listas de control de acceso (ACL) configuradas en redes, sistemas, servicios y aplicaciones dentro del alcance, para garantizar que coincidan con la intención de la organización y reflejen una justificación comercial.

10.9.2 Errores de configuración comunes

- (a) Pruebas de PBX: verifique si hay servicios/características innecesarias, inseguras o no utilizadas y credenciales predeterminadas, verifique el nivel de parche de los sistemas PBX para identificar vulnerabilidades conocidas. (b) Prueba de buzón de voz: compruebe si hay servicios/características innecesarias, inseguras o no utilizadas y credenciales predeterminadas, verifique el nivel de parche de los sistemas de buzón de voz para identificar vulnerabilidades conocidas.
- (c) Pruebas de FAX: compruebe si hay servicios/características innecesarias, inseguras o no utilizadas y credenciales predeterminadas, verifique el nivel de parche de los sistemas de FAX para identificar vulnerabilidades conocidas. (d) Encuesta de módem: verifique si hay módems de respuesta innecesarios o no utilizados dentro del alcance. (e) Prueba de servicios de acceso remoto: compruebe si hay servicios/características innecesarias, inseguras o no utilizadas y credenciales predeterminadas, verifique el nivel de parche de los servidores RAS para identificar vulnerabilidades conocidas. (f) Pruebas de líneas RDSI de respaldo: verifique si hay servicios innecesarios, inseguros o no utilizados y credenciales predeterminadas, verifique el nivel de parche del equipo de red para identificar vulnerabilidades conocidas. (g) Pruebas de voz sobre IP: verifique si hay servicios/protocolos innecesarios, inseguros o no utilizados y credenciales predeterminadas en todos los sistemas dentro de la infraestructura de VoIP, y verifique su nivel de parche para identificar vulnerabilidades conocidas. (h) En las pruebas de red conmutada por paquetes X.25, verifique si hay servicios innecesarios, inseguros o no utilizados y credenciales predeterminadas en todos los sistemas X.25, y verifique su nivel de parche para identificar vulnerabilidades conocidas.

10.9.3 Auditoría de código fuente

Examinar el código fuente disponible de las aplicaciones donde estén disponibles para validar las operaciones de equilibrio de controles.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

10.10 Validación de propiedad

Pruebas para examinar información y propiedad física disponible dentro del alcance o proporcionada por personal que pueda ser ilegal o poco ética.

10.10.1 Compartir

Verificar en qué medida el personal comparte propiedad con licencia individual, privada, falsificada, reproducida, no libre o no abierta, ya sea intencionalmente a través de procesos y programas compartidos, bibliotecas y cachés personales o de manera involuntaria a través de una mala gestión de licencias y recursos, o negligencia.

10.10.2 Mercado negro

Verificar en qué medida se promueve, comercializa o vende entre el personal o la organización propiedad con licencia individual, privada, falsificada, reproducida, no libre o no abierta.

10.10.3 Canales de Ventas

Verifique negocios públicos, fuera del alcance, subastas o ventas de propiedades que proporcionen información de contacto a través de canales que se originen dentro del alcance.

10.10.4 Módems no autorizados

Realice un inventario completo de todos los módems dentro del alcance. Verificar que la organización haya adoptado una política de seguridad adecuada que aborde el uso y suministro de módems.

10.11 Revisión de segregación

Pruebas para la separación adecuada de la información privada o personal de la información comercial. Al igual que una revisión de privacidad, es el punto central del almacenamiento, transmisión y control legal y ético de la información privada del personal, los socios y los clientes.

10.11.1 Mapeo de contención de privacidad

Mapee los guardianes de la información privada dentro del alcance, qué información se almacena, cómo y dónde se almacena la información y a través de qué canales se comunica la información.

10.11.2 Divulgación

Examinar y documentar los tipos de divulgaciones de información privada en servicios de comunicación por parte de los guardianes responsables de esta segregación de acuerdo con las políticas y regulaciones según lo determinado en la Revisión de Postura y el derecho humano básico a.

10.11.3 Limitaciones

Examinar y documentar tipos de puertas de enlace y alternativas de canales con puertas de enlace accesibles para personas con limitaciones físicas dentro de ese canal, como en el servicio TTY.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

10.12 Verificación de exposición

Pruebas para descubrir información pública que describe la visibilidad indirecta de los objetivos dentro del alcance o proporciona o conduce a un acceso autenticado.

10.12.1 Mapeo de exposición

- (a) Identificar información personal y comercial, como números de teléfono personales y laborales, números de teléfonos móviles, números de teléfono gratuitos, números de FAX, propietarios de líneas de telecomunicaciones, operadores y afiliaciones organizativas, utilizando todos los medios disponibles, como sitios web de empresas, directorios telefónicos, información de directorios en línea y bases de datos de suscriptores de telecomunicaciones.
- (b) Identifique otras líneas de telecomunicaciones, como X.25, utilizando tanto los sitios web de la empresa como la búsqueda motores.
- (c) Identificar información personal y comercial, como organigramas, títulos de personal clave, descripciones de puestos, direcciones de correo electrónico públicas y privadas, inicios de sesión (ejemplo: filtración de información de correo X.25 PSI), esquemas de inicio de sesión, contraseñas, métodos de respaldo, aseguradoras o cualquier información organizacional particular declarada implícitamente como confidencial en las regulaciones y políticas.

10.12.2 Elaboración de perfiles

Perfilar y verificar la organización, sus redes públicas de telecomunicaciones, empleados, tecnologías y dirección comercial.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

10.13 Exploración de Inteligencia Competitiva

Pruebas de eliminación de propiedades que pueden analizarse como inteligencia empresarial. Si bien la inteligencia competitiva como campo está relacionado con el marketing, el proceso aquí incluye cualquier forma de recopilación de inteligencia competitiva, incluido, entre otros, el espionaje económico e industrial.

10.13.1 Rectificado empresarial

- (a) Mapear los guardianes de la propiedad comercial dentro del alcance, qué información se almacena, cómo y dónde se almacena la información y a través de qué canales se comunica la información. (b) Medir el costo de la infraestructura de telecomunicaciones en función del equipo (ejemplo: teléfonos, PBX, módems, FAX, etc.).
- (c) Medir el costo de la infraestructura de soporte, con base en los costos de transportista y mantenimiento, incluido el personal técnico. (d) Verificar qué tipo de negocio se gestiona a través de la infraestructura de telecomunicaciones (ejemplo: call center, atención al cliente, mesa de ayuda, etc.).
- (e) Verificar la cantidad de tráfico en un rango de tiempo definido.

10.13.2 Entorno empresarial

- (a) Explorar y documentar detalles comerciales como alianzas, socios, clientes principales, proveedores, distribuidores, inversores, relaciones comerciales, producción, desarrollo, información de productos, planificación, acciones y comercio, y cualquier información o propiedad comercial particular declarada implícitamente como confidencial en regulaciones y políticas. (b) Identificar las líneas de telecomunicaciones que forman parte del negocio de los socios.

10.13.3 Entorno organizacional

Examinar y documentar los tipos de divulgaciones de propiedad comercial de los guardianes sobre operaciones, procesos, jerarquía, informes financieros, oportunidades de inversión, fusiones, adquisiciones, inversiones de canales, mantenimiento de canales, políticas sociales internas, insatisfacción del personal y tasa de rotación, principales tiempos de vacaciones, contrataciones, despidos y cualquier propiedad organizacional particular declarada implícitamente como confidencial en las regulaciones y políticas.

10.14 Verificación de cuarentena

Pruebas para verificar el correcto despliegue y contención de contactos agresivos u hostiles en los puntos de entrada.

10.14.1 Identificación del proceso de contención

Identifique y examine los métodos y procesos de cuarentena en el objetivo en todos los canales para detectar contactos molestos, agresivos u hostiles, como vendedores telefónicos, cazadores de cabezas y acosadores.

10.14.2 Niveles de contención

Verificar el estado de contención, el tiempo y todos los canales donde las interacciones tienen métodos de cuarentena. Asegúrese de que los métodos estén dentro del contexto y los límites legales.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

10.15 Auditoría de privilegios

Pruebas en las que se proporcionan credenciales al usuario y se le otorga permiso para realizar pruebas con esas credenciales.

10.15.1 Identificación

Examinar y documentar el proceso para la obtención de identificación por medios tanto legítimos como fraudulentos en todos los canales.

10.15.2 Autorización

- (a) Verificar el uso de autorización fraudulenta en todos los canales para obtener privilegios similares a los de otro personal.
- (b) Probar y documentar posibles rutas para eludir las Listas de control de acceso (ACL) configuradas para redes, sistemas, servicios y aplicaciones dentro del alcance.

10.15.3 Escalada

Verifique y mapee el acceso a la información mediante el uso de privilegios para obtener mayores privilegios.

10.15.4 Subyugación

Enumere y pruebe las deficiencias de todos los canales para usar o habilitar controles de pérdidas no habilitados de forma predeterminada.

10.16 Validación de supervivencia

Determinar y medir la resiliencia del objetivo dentro del alcance a cambios excesivos u hostiles diseñados para causar fallas en el servicio.

10.16.1 Continuidad

- (a) Enumerar y probar las deficiencias del objetivo con respecto a los retrasos en el acceso y el tiempo de respuesta del servicio a través de personal de respaldo o medios automatizados para acceso alternativo. (b) Enumerar y probar las deficiencias del objetivo con respecto a los problemas de Calidad del Servicio y Requisitos de rendimiento de las tecnologías de telecomunicaciones.

10.16.2 Resiliencia

Mapee y documente el proceso de los guardianes que desconectan canales debido a violaciones o problemas de seguridad como un análisis de brechas con la regulación y la política de seguridad.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

10.17 Revisión de alertas y registros

Un análisis de brechas entre las actividades realizadas con la prueba y la verdadera profundidad de esas actividades registradas o según las percepciones de terceros, tanto humanas como mecánicas.

10.17.1 Alarma

- (a) Verificar y enumerar el uso de un sistema, registro o mensaje de advertencia localizado o de todo el alcance para cada puerta de enlace de acceso a través de cada canal donde una situación sospechosa se eleva ante la sospecha de intentos de intrusión o actividad fraudulenta y determinar los niveles de recorte.
- (b) Revisar los registros detallados de llamadas salientes y entrantes en busca de signos de abuso o fraude.
- (c) Sistemas de gestión de registros de prueba y documentación.

10.17.2 Almacenamiento y recuperación

- (a) Documentar y verificar el acceso sin privilegios a las ubicaciones de almacenamiento de alarmas, registros y notificaciones. y propiedad.
- (b) Probar y documentar la política de respaldo de registros y el registro en múltiples ubicaciones, para garantizar que Las pistas de auditoría no se pueden alterar. (c) Sistemas de gestión de registros de prueba y documentación.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

Las 3 reglas de las herramientas de seguridad de datos son: 1. las herramientas no saben cuándo mienten, 2. las herramientas son tan inteligentes como sus diseñadores y 3. las herramientas solo pueden funcionar correctamente dentro de los límites del entorno para el que fueron creadas.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

Capítulo 11 - Pruebas de seguridad de redes de datos

Las pruebas para el canal de Seguridad de Redes de Datos (COMSEC) requieren interacciones con las salvaguardias operativas de la red de comunicación de datos existentes utilizadas para controlar el acceso a la propiedad.

Este canal cubre la participación de los sistemas informáticos, principalmente las redes operativas dentro del alcance o marco objetivo. Si bien algunas organizaciones consideran esto simplemente como “pruebas de penetración”, el verdadero objetivo de cumplimiento de las pruebas de seguridad en este canal es la interacción del sistema y las pruebas de calidad operativa con mediciones de brechas con respecto al estándar de seguridad requerido descrito en la política de la empresa, las regulaciones de la industria o la legislación regional.

Durante las pruebas, los operadores finales y la inteligencia artificial pueden reconocer los ataques en curso tanto por proceso como por firma. Por esta razón, se requerirá que el Analista tenga una variedad suficiente de métodos para evitar la divulgación de las pruebas o trabaje con los operadores para garantizar que se saque a la luz dónde falla la seguridad y dónde tiene éxito. Las pruebas que se centran únicamente en el descubrimiento de nuevos problemas sólo dejan espacio para soluciones y no diseños para futuras mejoras.

Los analistas competentes requerirán conocimientos de redes adecuados, habilidades diligentes en pruebas de seguridad y habilidades de pensamiento crítico para garantizar que la recopilación de datos fácticos genere resultados fácticos a través de la correlación y el análisis.

Consideraciones

Tenga en cuenta las siguientes consideraciones para garantizar una prueba segura y de alta calidad:

1. Ignorantia legis neminem excusat: los analistas que no realizan una revisión de postura adecuada para el alcance y las regiones objetivo de los negocios o las interacciones no pueden escapar al castigo por violar las leyes simplemente porque desconocían la ley; es decir, las personas tienen presunto conocimiento de la ley. Los analistas son considerados profesionales en esta materia y, por lo tanto, existe el supuesto de que lo que puede no ser conocimiento común para una persona normal sobre las leyes de una región extranjera en materia de sistemas informáticos, los profesionales toman conocimiento de las leyes necesarias para desempeñar esa tarea.
2. Derechos de propiedad: Las pruebas deben apuntar específicamente solo a sistemas que estén bajo propiedad legal directa del propietario del alcance y a los sistemas informáticos de propiedad del propietario del alcance. Cualquier efecto personal debe seguir siendo personal y privado a menos que involucre específicamente al propietario del alcance mediante menosprecio, falsa iluminación, competitividad o razones establecidas en los acuerdos contractuales de personal.
Los analistas deben hacer esfuerzos para no invadir la vida privada de una persona cuando esa vida privada ha hecho esfuerzos por separarse del alcance. Los analistas con acuerdos especiales para probar sistemas que están bajo contrato directo pero que no son de propiedad o que son de propiedad pero no están alojados en la propiedad legal del propietario deben tener mucho cuidado para garantizar que las pruebas tengan un impacto mínimo en otros sistemas y partes terciarias fuera del alcance o contrato.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

11.1 Revisión de la postura

Los estudios iniciales de la postura incluyen las leyes, la ética, las políticas, las regulaciones de la industria y la cultura política que influyen en los requisitos de seguridad y privacidad del alcance. Esta revisión forma una matriz con respecto a la cual se deben mapear las pruebas, pero no restringirlas debido a la ubicuidad de los puntos finales del canal. Por lo tanto, es importante considerar, como exige alguna legislación, el mercado objetivo o usuarios finales de este canal que también debe agregarse al alcance de este módulo.

11.1.1 Política

Revisar y documentar la política organizacional adecuada con respecto a los requisitos de seguridad, integridad y privacidad del alcance. Revisar y documentar contratos y acuerdos de nivel de servicio (SLA) con proveedores de servicios y otros terceros involucrados.

11.1.2 Legislación y Reglamentos

Revisar y documentar la legislación regional y nacional apropiada, y las regulaciones de la industria con respecto a los requisitos de seguridad y privacidad de la organización en el alcance, así como aquellas que incluyen a los clientes, socios, sucursales de la organización o revendedores apropiados fuera del alcance.

11.1.3 Cultura

Revise y documente la cultura organizacional adecuada en el ámbito de la concientización sobre seguridad y privacidad, la capacitación del personal requerida y disponible, la jerarquía organizacional, el uso de la mesa de ayuda y los requisitos para informar problemas de seguridad.

11.1.4 Edad

Revisar y documentar la antigüedad de los sistemas, el software y las aplicaciones de servicio necesarios para las operaciones.

11.1.5 Artefactos frágiles

Revise y documente cualquier sistema, software y aplicación de servicio que requiera cuidado especial debido al alto uso, inestabilidades o una alta tasa de cambio.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

11.2 Logística

Esta es la preparación del entorno de prueba del canal necesaria para evitar falsos positivos y falsos negativos que conduzcan a resultados de prueba inexactos.

11.2.1 Marco

- (a) Verificar el alcance y la titularidad de los objetivos previstos para la auditoría. (b) Determinar la ubicación de la propiedad y el dueño de la propiedad que alberga a los objetivos. (c) Verificar el propietario de los objetivos a partir de la información de registro de la red. (d) Verificar el propietario de los dominios de destino a partir de la información de registro de dominio. (e) Verificar los ISP que proporcionan acceso a la red o redundancia. (f) Buscar otros bloques y objetivos de IP relacionados con los mismos propietarios. (g) Buscar nombres de dominio similares o nombres de dominio mal escritos que puedan confundirse con el objetivo.
- (h) Verificar qué nombres de dominio de destino se resuelven en sistemas fuera del control del propietario, como dispositivos de almacenamiento en caché.
- (i) Verificar qué direcciones IP de destino se remontan a ubicaciones diferentes a la ubicación del propietario. (j) Verificar que las búsquedas inversas de nombres de direcciones del sistema de destino correspondan con el alcance y el propietario del alcance.
- (k) Encontrar y verificar las rutas de los servicios de red que interactúan fuera del objetivo para las rutas que siga dentro y fuera del alcance.
- (l) Preparar la resolución de nombres local para asignar nombres de dominio solo a los sistemas específicos que se probarán y no a ningún dispositivo fuera del objetivo o de la propiedad del objetivo.
- (m) Utilizar búsquedas inversas de nombres como fuente de información adicional para determinar la existencia de todas las máquinas en una red.

11.2.2 Calidad de la red

- (a) Mida la tasa de velocidad y pérdida de paquetes hasta el alcance de un servicio solicitado en TCP, UDP e ICMP como una solicitud de servicio completa y como un par de solicitud/respuesta. Repita cada solicitud en sucesión al menos 100 veces y registre el promedio tanto de las solicitudes de servicio completo como de las respuestas de paquetes para cada uno de los tres protocolos.
- (b) Determine las velocidades de envío y recepción de paquetes para un total de 6 promedios (por protocolo) como solicitudes por segundo por segmento de red en el alcance. (c) Registrar los porcentajes de pérdida de paquetes para las tasas de envío y recepción de paquetes determinadas.

11.2.3 Tiempo

- (a) Verificar la zona horaria, los días festivos y los horarios de trabajo para los diversos sistemas dentro del alcance, incluidos socios, revendedores y clientes influyentes que interactúan con el alcance.
- (b) Identifique la distancia del tiempo de vida (TTL) hasta la puerta de enlace y los objetivos. (c) Asegurar que el reloj del analista esté sincronizado con la hora de los objetivos.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

11.3 Verificación de detección activa

La determinación de los controles activos y pasivos para detectar intrusiones para filtrar o negar intentos de prueba debe realizarse antes de la prueba para mitigar el riesgo de corromper los datos de los resultados de la prueba, así como cambiar el estado de alarma del personal o agentes de monitoreo. Puede ser necesario coordinar estas pruebas con las personas apropiadas dentro del alcance.

11.3.1 Filtrado

- (a) Probar si los datos de red ENTRANTE o las comunicaciones a través de la web, mensajería instantánea, chat, foros basados en la web o correo electrónico son monitoreados o filtrados por una parte autorizada para la transmisión de materiales inapropiados, inyecciones de código, contenido malicioso y uso inapropiado. conducir y registrar las respuestas y el tiempo de respuesta.
- (b) Probar si los datos de la red SALIENTE o las comunicaciones a través de la web, mensajería instantánea, chat, foros basados en la web o correo electrónico son monitoreados o filtrados por una parte autorizada para la transmisión de materiales inapropiados, inyecciones de código, contenido malicioso y uso inapropiado. conducir y registrar las respuestas y el tiempo de respuesta.

11.3.2 Detección activa

- (a) Verificar las respuestas activas a las sondas de los sistemas y servicios. Podrían ser notificaciones legibles por humanos o máquinas, respuestas de paquetes, activaciones de alarma silenciosas o similares. (b) Mapear cualquier aplicación, sistema o segmento de red dentro del alcance que produzca registros, alarmas o notificaciones. Esto podría incluir sistemas de prevención o detección de intrusiones basados en red o host, syslog, herramientas de gestión de información de seguridad (SIM), registros de aplicaciones y similares.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

11.4 Auditoría de Visibilidad

Enumeración e indexación de los objetivos en el alcance mediante interacción directa e indirecta con o entre sistemas en vivo.

11.4.1 Levantamiento de red (a)

Identifique el perímetro de los segmentos de red objetivo y el vector desde el cual serán probado.

(b) Utilizar el rastreo de redes para identificar los protocolos que emanan de las respuestas o solicitudes de servicios de red, cuando corresponda. Por ejemplo, Netbios, ARP, SAP, NFS, BGP, OSPF, MPLS, RIPv2, etc. (c) Consultar todos los servidores de nombres y los servidores de nombres del ISP o proveedor de hosting, si están disponibles, para A, AAAA y PTR correspondientes. registros, así como la capacidad de realizar transferencias de zona para determinar la existencia de todos los objetivos en la red y cualquier redundancia relacionada, equilibrio de carga, almacenamiento en caché, proxy y alojamiento virtual. (d) Verificar las solicitudes de transmisión y las respuestas

de todos los objetivos. (e) Verificar y examinar el uso de protocolos de tráfico y enrutamiento para todos los objetivos. (f) Verificar las respuestas ICMP para los tipos ICMP 0-255 y códigos ICMP 0-2 de todos los objetivos. (g) Verificar que los nombres de comunidad SNMP predeterminados y probables en uso se ajusten a las prácticas

Implementaciones de todas las versiones de SNMP.

(h) Verificar las respuestas de los objetivos para seleccionar puertos con caducidad de TTL establecida en menos de 1 y 2 saltos desde los objetivos. Por ejemplo: TCP

8, 22, 23, 25, 80, 443, 445, 1433 UDP 0, 53, 139,

161 ICMP T00:C00,

T13:C00, T15:C00, T17:C00 (i) Rastree la ruta de

Paquetes ICMP a todos los objetivos. (j) Rastree la ruta de los

paquetes TCP a todos los destinos para los puertos SSH, SMTP, HTTP y HTTPS. (k) Rastrear la ruta de los paquetes

UDP a todos los destinos para los puertos DNS y SNMP. (l) Identificar la previsibilidad del número

de secuencia TCP ISN para todos los objetivos. (m) Verificar los incrementos de IPID

de las respuestas para todos los objetivos. (n) Verificar el uso de

enrutamiento de origen suelto hacia la puerta de enlace de destino y los sistemas de perímetro exterior para enrutar paquetes a todos los objetivos.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

11.4.2 Enumeración (a)

Buscar en grupos de noticias, foros, IRC, IM, P2P, VoIP y comunicaciones basadas en web para conectar información del objetivo para determinar los sistemas de puerta de enlace salientes y el direccionamiento interno.

- (b) Examinar encabezados de correo electrónico, correos devueltos, confirmaciones de lectura, errores de correo y rechazos de malware. para determinar los sistemas de puerta de enlace salientes y el direccionamiento interno.
- (c) Examinar el código fuente y los scripts de la aplicación basada en web de destino para determinar la existencia de objetivos adicionales en la red.
- (d) Examinar las emanaciones de servicio y solicitud. Manipule y reproduzca el tráfico capturado para invocar nuevas solicitudes o respuestas, ganar profundidad o exponer información adicional. Por ejemplo, SQL, Citrix, HTTP, SAP, DNS, ARP, etc. (e) Busque registros web y registros de intrusiones para rastrear el sistema desde la red de destino. (f) Verifique todas las respuestas de las solicitudes de paquetes UDP a los puertos 0-65535. (g) Verificar las respuestas a las solicitudes de paquetes UDP DESDE los puertos FUENTE 0, 53, 139 y 161 a 0, 53, 69, 131 y 161.
- (h) Verifique las respuestas a las solicitudes de paquetes UDP con BAD CHECKSUMS en todos los puertos descubiertos y para 0, 53, 69, 131 y 161.
- (i) Verificar las respuestas a las solicitudes de servicio frente al malware de acceso remoto UDP común y actual puertos.
- (j) Verificar las respuestas de las solicitudes de paquetes TCP SYN a los puertos 0-65535. (k) Verificar las respuestas de las solicitudes de servicio TCP a los puertos 0, 21, 22, 23, 25, 53, 80 y 443. (l) Verificar las respuestas de un ACK TCP con un puerto FUENTE de 80 a los puertos 3100-3150, 10001 -10050, 33500-33550 y 50 puertos aleatorios por encima de 35000.
- (m) Verificar las respuestas de los fragmentos TCP SYN a los puertos 0, 21, 22, 23, 25, 53, 80 y 443. (n) Verificar las respuestas de todas las combinaciones de indicadores TCP a los puertos 0, 21, 22, 23, 25, 53, 80 y 443. (o) Verificar el uso de todos los objetivos con VPN, servidores proxy y redirectores de URL basados en HTTP o HTTPS para redirigir las solicitudes de objetivos dentro del alcance.
- (p) Verificar el uso de todos los objetivos con IPID secuenciales para enumerar sistemas dentro de la red. (q) Mapear y verificar la coherencia de los sistemas visibles y los puertos de respuesta mediante TTL.

11.4.3 Identificación

Identifique la respuesta TTL de los objetivos, el tiempo de actividad del sistema, los servicios, las aplicaciones y los fallos de las aplicaciones, y correlacione esto con las respuestas de las herramientas de toma de huellas digitales del sistema y del servicio.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

11.5 Verificación de acceso

Pruebas para la enumeración de puntos de acceso líderes dentro del alcance.

11.5.1 Red

- (a) Solicitar servicios comunes conocidos que utilicen UDP para conexiones desde todas las direcciones. (b) Solicitar servicios VPN comunes y conocidos, incluidos aquellos que utilizan IPSEC e IKE para conexiones desde todas las direcciones.
- (c) Manipular el servicio de red y el enrutamiento para acceder a restricciones pasadas dentro del alcance. (d) Solicitar servicios troyanos comunes y conocidos que utilicen UDP para conexiones desde todas las direcciones. (e) Solicitar servicios troyanos comunes y conocidos que utilicen ICMP para conexiones desde todas las direcciones. (f) Solicitar servicios troyanos comunes y conocidos que utilicen TCP para conexiones desde todas las direcciones y puertos sin filtrar que no han enviado respuesta a un TCP SYN.

11.5.2 Servicios

- (a) Solicite todos los banners (banderas) de servicio para los puertos TCP descubiertos. (b) Verificar los carteles (banderas) del servicio a través de interacciones con el servicio que comprenden anuncios válidos y solicitudes inválidas.
- (c) Relacionar cada puerto abierto con un demonio (servicio), aplicación (código o producto específico que utiliza el servicio) y protocolo (el medio para interactuar con ese servicio o aplicación).
- (d) Verificar el tiempo de actividad del sistema en comparación con las últimas vulnerabilidades y versiones de parches. (e) Verificar la aplicación al sistema y la versión. (f) Identificar los componentes del servicio de escucha. (g) Verificar el tiempo de actividad del servicio en comparación con las últimas vulnerabilidades y lanzamientos de parches. (h) Verificar el servicio y la aplicación con los resultados de huellas digitales TTL y del sistema operativo para todas las direcciones. (i) Verificar HTTP y HTTPS para alojamiento virtual. (j) Verificar los servicios de VoIP. (k) Manipular solicitudes de aplicaciones y servicios fuera de los límites estándar para incluir caracteres especiales o terminología especial de ese servicio o aplicación para obtener acceso.

11.5.3 Autenticación

- (a) Enumerar los accesos que requieren autenticación y documentar todos los privilegios descubiertos que se puede utilizar para proporcionar acceso. (b) Verificar el método para obtener la Autorización adecuada para la autenticación. (c) Verificar el método de identificación adecuada para proporcionarle la autenticación. (d) Verificar el método lógico de autenticación. (e) Verificar la solidez de la autenticación descifrando y volviendo a aplicar la contraseña contraseñas descubiertas para todos los puntos de acceso que requieren autenticación.
- (f) Verificar el proceso para recibir la autenticación. (g) Prueba de errores lógicos en la aplicación de la autenticación.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

11.6 Verificación de confianza

Pruebas de confianza entre sistemas dentro del alcance donde la confianza se refiere al acceso a información o propiedad física sin necesidad de identificación o autenticación.

11.6.1 Suplantación de identidad

- (a) Probar medidas para acceder a propiedades dentro del alcance falsificando su dirección de red como una de los anfitriones de confianza.
- (b) Verificar si los mecanismos de almacenamiento en caché disponibles pueden estar envenenados.

11.6.2 Suplantación de identidad

- (a) Verificar que las URL para envíos y consultas sobre el destino sean concisas y estén dentro del mismo dominio. utilice únicamente el método POST y utilice una marca coherente.
- (b) Verificar que las imágenes/registros/datos del contenido objetivo no existan en sitios fuera del objetivo para crear un duplicado del objetivo.
- (c) Examinar los registros de dominio de nivel superior en busca de dominios similares a los identificados dentro del alcance. (d) Verificar que el objetivo utilice personalización en sitios web y correo cuando interactúa con usuarios autenticados.
- (e) Verificar el control y la respuesta del destinatario a los rebotes de correo en los que el FROM está falsificado en el campo de encabezado sea el del dominio de destino.

11.6.3 Abuso de recursos

- (a) Probar la profundidad del acceso a información comercial o confidencial disponible en servidores web sin ninguna credencial requerida establecida. (b) Pruebe si la información se envía fuera del alcance como relleno de paquetes de red como lo que ha ocurrido anteriormente como "Etherleak".
- (c) Verificar que las medidas de continuidad, específicamente el equilibrio de carga, sean fluidas fuera del alcance para evitar que los usuarios usen, hagan referencias, vinculen, agreguen marcadores o abusen de solo uno de los recursos.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

11.7 Verificación de controles

Pruebas para enumerar y verificar la funcionalidad operativa de las medidas de seguridad de activos y servicios.

11.7.1 No repudio (a)

Enumerar y probar el uso o las deficiencias de demonios y sistemas para identificar y registrar adecuadamente el acceso o las interacciones a la propiedad para obtener evidencia específica para impugnar el repudio. (b) Documentar la profundidad de la interacción registrada y el proceso de identificación. (c) Verificar que todos los métodos de interacción estén debidamente registrados con la identificación adecuada. (d) Identificar métodos de identificación que venzan el repudio.

11.7.2 Confidencialidad

(a) Enumerar todas las interacciones con servicios dentro del alcance de las comunicaciones o activos transportados a través del canal utilizando líneas seguras, encriptación, interacciones "silenciadas" o "cerradas" para proteger la confidencialidad de la propiedad de la información entre las partes involucradas. (b) Verificar los métodos aceptables utilizados para la confidencialidad. (c) Probar la solidez y el diseño del método de cifrado u ofuscación. (d) Verificar los límites exteriores de la comunicación que pueden protegerse mediante los métodos aplicados de confidencialidad.

11.7.3 Privacidad

(a) Enumerar los servicios dentro del alcance de las comunicaciones o activos transportados utilizando firmas individuales específicas, identificación personal, interacciones personales "en silencio" o en "cuartos cerrados" para proteger la privacidad de la interacción y el proceso de proporcionar activos solo a aquellos dentro del alcance. autorización de seguridad adecuada para ese proceso, comunicación o activo. (b) Correlacionar la información con los puertos TCP y UDP que no responden para determinar si la disponibilidad es depende de un tipo privado de contacto o protocolo.

11.7.4 Integridad

Enumere y pruebe las deficiencias de integridad cuando se utilice un proceso documentado, firmas, cifrado, hash o marcas para garantizar que el activo no pueda cambiarse, redirigirse o revertirse sin que las partes involucradas lo sepan.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

11.8 Verificación del proceso

Pruebas para examinar el mantenimiento de la seguridad funcional en los procesos establecidos y la debida diligencia según se define en la Revisión de Postura.

11.8.1 Mantenimiento

- (a) Examinar y documentar la oportunidad, idoneidad, acceso y alcance de los procesos de notificación y respuesta de seguridad con respecto a la red y el monitoreo de seguridad. (b) Verificar la idoneidad y funcionalidad de la respuesta a incidentes y las capacidades forenses para todo tipo de sistemas.
- (c) Verificar el nivel de incidencia o compromiso que los canales de soporte pueden detectar y el duración del tiempo de respuesta.

11.8.2 Información errónea

Determinar hasta qué punto las notificaciones y alarmas de seguridad pueden ampliarse o alterarse con información errónea.

11.8.3 Debida diligencia

Mapee y verifique cualquier brecha entre la práctica y los requisitos según lo determinado en la Revisión de Postura a través de todos los canales.

11.8.4 Indemnización (a)

Documentar y enumerar los objetivos y servicios que están protegidos contra el abuso o elusión de la política de los empleados, que están asegurados contra robo o daños, o utilizan exenciones de responsabilidad y permisos. (b) Verificar la legalidad y adecuación del lenguaje en los avisos legales. (c) Verificar el efecto de las exenciones de responsabilidad sobre las medidas de seguridad o protección. (d) Examinar el lenguaje de la póliza de seguro para detectar limitaciones sobre tipos de daños o bienes.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

11.9 Verificación de la configuración

Pruebas para recopilar toda la información, técnica y no técnica, sobre cómo se pretende que funcionen los activos y para examinar la capacidad de eludir o alterar la seguridad funcional de los activos, explotando la configuración inadecuada de los controles de acceso, los controles de pérdidas y las aplicaciones.

11.9.1 Controles de configuración

- (a) Examinar los controles para verificar que las configuraciones y líneas base de los sistemas, equipos y aplicaciones cumplan con la intención de la organización y reflejen una justificación comercial. (b) Examinar las listas de control de acceso (ACL) y los roles comerciales configurados en redes, sistemas, servicios y aplicaciones dentro del alcance para garantizar que cumplan con la intención de la organización y reflejen una justificación comercial.

11.9.2 Errores de configuración comunes

- (a) Verificar que los servicios disponibles no sean innecesariamente redundantes y que coincidan con los sistemas función empresarial prevista.
- (b) Verifique que se hayan cambiado las configuraciones predeterminadas. Algunos dispositivos o aplicaciones se envían con una cuenta administrativa predeterminada u oculta. Estas cuentas deben cambiarse o, si es posible, deshabilitarse o eliminarse y reemplazarse con una nueva cuenta administrativa. (c) Verificar que la Administración se haga localmente o con controles para limitar quién o qué puede acceder a la Interfaces de administración remota del equipo.

11.9.3 Mapeo de limitaciones

- (a) Verifique si hay servicios/funciones disponibles innecesarios o no utilizados. (b) Verifique las credenciales predeterminadas.
- (c) Identificar si existen vulnerabilidades conocidas en los sistemas.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

11.10 Validación de propiedad

Pruebas para examinar información y datos disponibles dentro del alcance o proporcionados por personal que puedan ser ilegales o poco éticos.

11.10.1 Compartir

Verificar en qué medida se comparte propiedad con licencia individual, privada, falsificada, reproducida, no libre o no abierta, ya sea intencionalmente a través de procesos y programas compartidos, bibliotecas y cachés personales o de manera involuntaria a través de una mala gestión de licencias y recursos, o negligencia.

11.10.2 Mercado negro

Verificar en qué medida se promueve, comercializa o vende entre el personal o la organización propiedad con licencia individual, privada, falsificada, reproducida, no libre o no abierta.

11.10.3 Canales de Venta

Verifique si algún negocio público, fuera del alcance, subastas o ventas de propiedades proporciona información de contacto de objetivos dentro del alcance.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

11.11 Revisión de segregación

Pruebas para la separación adecuada de la propiedad de información privada o personal de la información comercial. Al igual que una revisión de privacidad, es el punto central del almacenamiento, la transmisión y el control legal y ético de la propiedad de información privada del personal, los socios y los clientes.

11.11.1 Mapeo de contención de privacidad

Mapee las ubicaciones clave de la propiedad de información privada dentro del alcance, qué información se almacena, cómo y dónde se almacena la información y a través de qué canales se comunica la información.

11.11.2 Divulgación

- (a) Examinar y documentar los tipos de divulgaciones de propiedad de información privada para su segregación de acuerdo con la política y regulaciones según lo determinado en la Revisión de Postura.
- (b) Verificar que la información privada y la propiedad intelectual confidencial, como documentos, contratos de servicio, claves de SO/software, etc., no estén disponibles para nadie sin los privilegios adecuados.

11.11.3 Limitaciones

- (a) Verificar que existan consideraciones de diseño o alternativas de canal para personas con discapacidad física. limitaciones para interactuar con el objetivo.
- (b) Identificar cualquier parte de la infraestructura diseñada para interactuar con niños legalmente identificados como menores y verificar qué y cómo se proporciona información de identificación de ese niño.

11.11.4 Discriminación

Verificar la información solicitada y los privilegios otorgados a los guardianes en los casos en que la edad (específicamente menores), el sexo, la raza, las costumbres/cultura y la religión sean factores que puedan ser discriminados de acuerdo con la Revisión de Postura.

11.12 Verificación de exposición

Pruebas para descubrir información que proporciona o conduce al acceso o permite el acceso a múltiples ubicaciones con la misma autenticación.

11.12.1 Enumeración de exposición

- (a) Enumerar información sobre la organización, como organigramas, títulos del personal clave, descripciones de puestos, números de teléfono personales y laborales, números de teléfonos móviles, tarjetas de presentación, documentos compartidos, currículums, afiliaciones organizativas, direcciones de correo electrónico públicas y privadas, registros, -ins, esquemas de inicio de sesión, contraseñas, métodos de respaldo, aseguradoras o cualquier información organizacional particular declarada implícitamente como confidencial en las regulaciones y políticas. (b) Enumerar las exposiciones del sistema, servicio y aplicación detallando el diseño, tipo, versión o estado de los objetivos o de recursos fuera del alcance, como publicaciones o filtraciones.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

11.13 Exploración de Inteligencia Competitiva

Pruebas para buscar información que pueda analizarse como inteligencia empresarial. Si bien la inteligencia competitiva como campo está relacionado con el marketing, el proceso aquí incluye cualquier forma de recopilación de inteligencia competitiva, incluido, entre otros, el espionaje económico e industrial. La información comercial incluye, entre otras, relaciones comerciales como empleados, socios o revendedores, contactos, finanzas, estrategias y planes.

11.13.1 Rectificado empresarial

Enumerar y evaluar los puntos de acceso (puertas de enlace) a la propiedad empresarial dentro del alcance: qué información empresarial se almacena, cómo se almacena y dónde se almacena la información.

11.13.2 Elaboración de perfiles

- (a) Perfilar los tipos de requisitos de habilidades de los empleados, escalas salariales, información de canales y puertas de enlace, tecnologías y dirección organizacional de fuentes fuera del alcance.
- (b) Configuraciones y configuraciones de redes de datos de perfiles a partir de bases de datos de empleo y anuncios de contratación de periódicos para puestos de redes de datos dentro de la organización relacionados con ingeniería o administración de hardware y software dentro del idioma comercial predeterminado del objetivo.

11.13.3 Entorno empresarial

- (a) Explorar y documentar a partir del personal de la puerta de enlace individual detalles comerciales tales como alianzas, socios, clientes principales, proveedores, distribuidores, inversores, relaciones comerciales, producción, desarrollo, información de productos, planificación, acciones y comercialización, y cualquier información o propiedad comercial en particular. declarado implícitamente como confidencial en las regulaciones y políticas. (b) Revisar las notas web de terceros, las anotaciones y el contenido del sitio de marcadores sociales creados para la presencia web del alcance.

11.13.4 Entorno organizacional

Examinar y documentar los tipos de divulgaciones de propiedad comercial de los guardianes sobre operaciones, procesos, jerarquía, informes financieros, oportunidades de inversión, fusiones, adquisiciones, inversiones de canales, mantenimiento de canales, políticas sociales internas, insatisfacción del personal y tasa de rotación, principales tiempos de vacaciones. contrataciones, despidos y cualquier propiedad organizacional particular declarada implícitamente como confidencial en las regulaciones y políticas.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

11.14 Verificación de cuarentena

Las medidas de contención dictan el manejo del cruce, los programas maliciosos y la salida. La identificación

Es necesario abordar los problemas de los mecanismos de seguridad y de la política de respuesta. Puede que sea necesario solicitar primero un

Nueva cuenta de correo de prueba o sistema de escritorio que el administrador puede monitorear. Pruebas para verificar la adecuada

Colocación y contención de contactos agresivos u hostiles en los puntos de entrada.

11.14.1 Identificación del proceso de contención

Identificar y examinar métodos de cuarentena para detectar contactos agresivos y hostiles, como malware, puntos de acceso no autorizados, dispositivos de almacenamiento no autorizados, etc.

11.14.2 Niveles de contención

- (a) Medir los recursos mínimos que deben estar disponibles para este subsistema para que pueda realizar su tarea.
- (b) Verificar los recursos disponibles para este subsistema que no necesita para realizar sus tareas y qué recursos están protegidos del uso de este subsistema.
- (c) Verificar las medidas de detección presentes para la detección de intento de acceso al recinto blindado. recursos.
- (d) Verificar las características del sistema de contención.
- (e) Verificar que existan medidas de detección para detectar el acceso "inusual" a los servicios necesarios. recursos
- (f) Medir la respuesta y el proceso frente a datos codificados, empaquetados, condensados, renombrados o entradas enmascaradas.
- (g) Verificar el estado de contención y la duración de los métodos de cuarentena tanto dentro como fuera del alcance. Garantizar la integridad y minuciosidad de los métodos y que sean dentro del contexto y los límites legales.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

11.15 Auditoría de privilegios

Pruebas en las que se proporcionan credenciales al usuario y se le otorga permiso para realizar pruebas con esas credenciales.

11.15.1 Identificación

Examinar y documentar el proceso de autorización para obtener la identificación de los usuarios a través de medios tanto legítimos como fraudulentos en todos los canales.

11.15.2 Autorización

- (a) Examinar y verificar cualquier medio para obtener autorización fraudulenta para obtener privilegios similares a la del resto del personal.
- (b) Enumerar el uso de cuentas predeterminadas en los objetivos.
- (c) Probar el acceso a puntos de acceso autenticados mediante las técnicas de craqueo más apropiadas y disponibles. El descifrado de contraseñas mediante diccionario o fuerza bruta puede estar limitado por el período de la auditoría y, por lo tanto, no es una prueba válida de la protección de ese esquema de autenticación; sin embargo, cualquier descubrimiento exitoso da fe de su debilidad.

11.15.3 Escalamiento

- (a) Recopilar información sobre personas con altos privilegios. Busque roles o puestos confiables, puertas de acceso para personas confiables y cualquier medio de acceso físico requerido, como tokens o tarjetas inteligentes.
- (b) Verificar los límites de los privilegios en el objetivo o entre múltiples objetivos y si los medios existe para aumentar esos privilegios.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

11.16 Validación de supervivencia

Determinar y medir la resiliencia de los objetivos dentro del alcance a cambios excesivos u hostiles diseñados para causar fallas o degradación del servicio.

La denegación de servicio (DoS) es una situación en la que una circunstancia, ya sea intencional o accidentalmente, impide que el sistema funcione según lo previsto. En ciertos casos, el sistema puede estar funcionando exactamente como fue diseñado, sin embargo, nunca fue pensado para manejar la carga, el alcance o los parámetros que se le imponen. Las pruebas de supervivencia deben ser monitoreadas de cerca ya que la intención es causar fallas y esto puede ser inaceptable para el objetivo. dueño.

11.16.1 Resiliencia

- (a) Verificar puntos únicos de falla (puntos de estrangulamiento) en la infraestructura donde el cambio o la falla pueden provocar una interrupción del servicio.
- (b) Verificar el impacto en el acceso objetivo que causará una falla del sistema o servicio.
- (c) Verificar los privilegios disponibles desde el acceso inducido por falla.
- (d) Verificar la funcionalidad operativa de los controles para evitar el acceso o permisos por encima del mínimo posibles privilegios en caso de fracaso.

11.16.2 Continuidad

- (a) Enumerar y probar las deficiencias de todos los objetivos con respecto a las demoras en el acceso y el servicio. tiempos de respuesta a través de sistemas de respaldo o el cambio a canales alternos.
- (b) Verificar que los esquemas de bloqueo contra intrusos no puedan usarse contra usuarios válidos.

11.16.3 Seguridad

Mapear y documentar el proceso de los guardianes que cierran los sistemas objetivo debido a preocupaciones de evacuación o seguridad como un análisis de brechas con la regulación y la política de seguridad.

11.17 Revisión de alertas y registros

Un análisis de brechas entre las actividades realizadas con la prueba y la verdadera profundidad de esas actividades registradas o desde percepciones de terceros, tanto humanas como mecánicas.

11.17.1 Alarma

Verificar y enumerar el uso de un sistema, registro o mensaje de advertencia localizado o de todo el alcance para cada puerta de enlace de acceso a través de cada canal donde el personal detecta una situación sospechosa ante la sospecha de intentos de elusión, ingeniería social o actividad fraudulenta.

11.17.2 Almacenamiento y recuperación

- (a) Documentar y verificar el acceso sin privilegios a las ubicaciones de almacenamiento de alarmas, registros y notificaciones y propiedad.
- (b) Verificar la calidad y la duración del almacenamiento del documento para garantizar que los datos mantengan la integridad de ese medio de almacenamiento durante el tiempo requerido.



Los requisitos de cumplimiento que imponen medidas de protección como sustituto de la responsabilidad también sustituyen a la rendición de cuentas.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

Capítulo 12 - Cumplimiento

El cumplimiento es la alineación con un conjunto de políticas generales, donde el tipo de cumplimiento requerido depende de la región y del gobierno vigente, la industria y los tipos de negocios, y la legislación de respaldo.

El cumplimiento es obligatorio; sin embargo, como ocurre con cualquier otra amenaza, se debe realizar una evaluación de riesgos para invertir o no en algún tipo de cumplimiento. A menudo, el cumplimiento no es tan blanco o negro como parece. La OSSTMM reconoce tres tipos de cumplimiento:

1. **Legislativo.** El cumplimiento de la legislación está de acuerdo con la región donde se puede hacer cumplir la legislación. La fuerza y el compromiso con la legislación provienen de argumentos legales previamente exitosos y de medidas de aplicación justas y apropiadamente establecidas. El incumplimiento de la legislación puede dar lugar a cargos penales. Algunos ejemplos son Sarbanes-Oxley, HIPAA y las diversas leyes de privacidad y protección de datos.

2. **Contractuales.** El cumplimiento de los requisitos contractuales está de acuerdo con la industria o dentro del grupo que requiere el contrato y puede tomar medidas para hacer cumplir el cumplimiento. El incumplimiento de los requisitos contractuales a menudo conduce al despido del grupo, la pérdida de privilegios, la pérdida de reputación, cargos civiles y, en algunos casos, cuando existe legislación para respaldar al organismo regulador, cargos penales.

Un ejemplo es el estándar de seguridad de datos de la industria de tarjetas de pago (PCI DSS) promovido y requerido por VISA y MasterCard.

3. **Basado en estándares.** El cumplimiento de los estándares está de acuerdo con la empresa u organización donde se aplica el cumplimiento de los estándares como política. El incumplimiento de las normas a menudo conduce al despido de la organización, pérdida de privilegios, pérdida de reputación o confianza en la marca, cargos civiles y, en algunos casos, cuando existe legislación para apoyar a los responsables de las políticas, cargos penales. Algunos ejemplos son OSSTMM, ISO 27001/5 e ITIL.

El OSSTMM se desarrolla teniendo en cuenta la legislación principal, los requisitos contractuales y el cumplimiento de las normas. Como no todos los objetivos de cumplimiento se crean de la misma manera, el enfoque principal del OSSTMM es la seguridad. Las medidas de cumplimiento que requieren productos o servicios específicos, comerciales o de otro tipo, a menudo a través de esfuerzos especialmente presionados, pueden tener buenas intenciones; sin embargo, en realidad puede ser un desperdicio de recursos o una versión de seguridad inferior a la deseada. Que un objetivo de cumplimiento pueda requerir un producto específico debería ser en sí mismo ilegal.

Como la legislación y los reglamentos pueden ser auditados según la letra de la ley o el espíritu de la ley, dependiendo del organismo de auditoría, demostrar una protección y controles operativos adecuados y válidos, que puedan ser probados mediante una prueba OSSTMM, puede o no ser satisfactorio. Por lo tanto, además, también se debe presentar a los organismos de auditoría correspondientes una prueba OSSTMM certificada completa con el STAR.

La siguiente lista es solo para el cumplimiento que ha sido verificado con OSSTMM y no limita el alcance real de los cuerpos regulatorios y legislativos a los que se puede aplicar esta norma. Si puede verificar medidas de cumplimiento que no figuran aquí según OSSTMM o necesita verificar una medida de cumplimiento específica, envíela a ISECOM para su inclusión en esta lista. La medida de cumplimiento debe estar en inglés o enviarse a un socio de ISECOM que exista dentro de una región con ese idioma local.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

Reglamentos

Australia

- Enmiendas a la Ley de Privacidad de Australia: Ley N° 119 de 1988 según enmendada, preparada el 2 de agosto de 2001 incorporando enmiendas hasta la Ley N° 55 de 2001. La Ley de Privacidad de 1988 (la Ley de Privacidad) busca equilibrar la privacidad individual con la pública. interés en la aplicación de la ley y los objetivos regulatorios del gobierno.
- El Principio Nacional de Privacidad (NPP) 6 proporciona a un individuo el derecho de acceso a la información que posee sobre ellos por parte de una organización.
- El Principio Nacional de Privacidad (NPP) 4.1 establece que una organización debe tomar medidas razonables para proteger la información personal que posee contra el uso indebido y la pérdida y contra el acceso, modificación o divulgación no autorizados.
- Ley de Privacidad del Commonwealth.
- Autoridad de Comunicaciones de Australia: <http://www.aca.gov.au/>
- Agencia Australiana de Protección Radiológica y Seguridad Nuclear <http://www.arpsa.gov.au/mph2.htm>

Austria

- Ley de Protección de Datos de Austria de 2000 (Bundesgesetz über den Schutz personenbezogener Daten (Datenschutzgesetz 2000 - DSG 2000)), concretamente los requisitos del artículo 14.

Bélgica

- Belgisch Staatsblad N. 189, junio de 2005

Canadá

- Ley de Privacidad, 1983.
- Ley Municipal de Libertad de Información y Protección de la Privacidad (MFIPPA), 1991.
- Ley de Quebec sobre la Protección de Información Personal en el Sector Privado, 1993.
- Ley de Protección de Información Personal y Documentos Electrónicos (PIPEDA), 2000.
- Proyecto de ley 198 de Ontario, 2002.
- Ley de protección de información personal (PIPA), provincias de Alberta y Columbia Británica, 2004.
- Ley de protección de información de salud personal (PHIPA), 2004.
- Sociedad Real de Canadá - <http://www.rsc.ca/>

Estonia

- Ministro de Economía y Comunicaciones Política de Seguridad de la Información

Francia

- Sociedad Francesa de Radioprotección - <http://www.sfrp.asso.fr/>



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

Alemania

- Deutsche Bundesdatenschutzgesetz (BDSG) – Artículo 1 des Gesetzes zur Fortentwicklung der Datenverarbeitung und des Datenschutzes del 20 de diciembre de 1990, BGBl. I S. 2954, 2955, zuletzt geändert durch das Gesetz zur Neuordnung des Postwesens und der Telekommunikation vom 14. September de 1994, BGBl. I S. 2325.
- Manual de protección básica de TI (catálogos IT-Grundschutz) publicado por Bundesamt für Sicherheit in der Informationstechnik (Oficina Federal de Seguridad de la Información (BSI)) disponible en <http://www.bsi.de/gshb/english/menue.htm>.
- Sistemas informáticos alemanes. S6.68 (Prueba de la eficacia del sistema de gestión para la gestión de incidentes de seguridad) y pruebas S6.67 (Uso de medidas de detección de incidentes de seguridad).
- Bundesamt für Strahlenschutz - <http://www.bfs.de/>

India

- La Ley de Tecnología de la Información de 2000.

Italia

- D.Lgs. norte. 196/2003 - Codice in materia di protezione dei dati personali. Donde en un Contrato/Acuerdo el Cliente, titular del tratamiento de los datos, debe asumir cualquier responsabilidad legal por tratarse de datos sensibles como médicos, personales, judiciales de Empleados o Clientes pero incluso de Distribuidores y Socios. Un tester debe estar dispuesto a aceptar toda la responsabilidad consiguiente al aceptar el Acuerdo de Confidencialidad especialmente sobre el riesgo derivado del posible conocimiento de datos sensibles y la cláusula de reserva al plazo de este cuidado especial que podrá ser indefinido.

Malasia

- Ley de Abuso y Fraude Informático.
- La Ley de Delitos Informáticos.

México

- Ley Federal de Transparencia y Acceso a la Información Pública Gubernamental.
- Ley de Propiedad Industrial (LPI).
- Ley Federal de Derechos de Autor (LFDA) y su reglamento (RLFDA).
- Código Penal Federal y Código Federal de Procedimientos Penales.

Países Bajos

- Ley holandesa sobre delitos informáticos II del 1 de septiembre de 2006, que modifica la Ley holandesa sobre delitos informáticos de 1993
 - Convenio sobre la Ciberdelincuencia (CCC) del Consejo de Europa, 23 de noviembre de 2001
- La ratificación del Tratado "Convención sobre la Ciberdelincuencia, Budapest, 23.XI.2001", en vigor a partir del 1 de junio de 2006



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

Singapur

- Ley sobre el uso indebido de ordenadores. • Código de Comercio Electrónico para la Protección de Información Personal y Comunicaciones de los Consumidores de Comercio por Internet.

España

- LOPD Ley Orgánica de Protección de Datos de Carácter Personal. • LSSICE 31/2002 (Ley de Servicios de la Sociedad de la Información y el Correo Electrónico), de 11 de julio de 2002.
- RD 14/1999 (Real Decreto de Regulación de la Firma Electrónica), 17 de septiembre de 1999. • Real Decreto 1720/2007, de 21 de diciembre, por el que se aprueba el Reglamento de desarrollo de la Ley Orgánica 15/1999, de 13 de diciembre, de protección de datos de carácter personal.

Suiza

- Bundesverfassung (BV) de 18 de diciembre de 1998, artículos 7 y 13. • Obligationenrecht (OR) 2002 (Stand am 1 de octubre de 2002), artículos 707, 716, 716b, 717, 727ff y 321a.
- Datenschutzgesetz (DSG) del 19 de junio de 1992 (Stand am 3 de octubre de 2000). • Bundesamt für Kommunikation (BAKOM) • Bundesamt für Umwelt

Tailandia

- Ley de Delitos Informáticos. • Privacidad Ley de Protección de Datos.

Reino Unido

- Ley de Protección de Datos del Reino Unido de 1998 • Ley de Libertad de Información de 2000 • Ley de Derechos Humanos de 2000 • Ley de Regulación de los Poderes de Investigación de 2000 • Ley de Acceso a Registros Médicos de 1990 • Ley de Producto del Crimen de 2002 • Regulaciones sobre Lavado de Dinero de 2003 • Ley de Comunicaciones Electrónicas de 2000 • Electrónica Reglamento de firmas de 2002
- Reglamento de privacidad y comunicaciones electrónicas (Directiva CE) de 2003 • Reglamento de comercio electrónico (Directiva CE) de 2003 • Proyecto de ley de empresas (auditoría, investigaciones y empresas comunitarias)
- Biblioteca de información de TI disponible en <http://www.ogc.gov.uk/index.asp?id=2261> emitida por la Oficina Británica de Comercio Gubernamental (OGC). • BSI ISO 17799-2000 (BS 7799): este manual cumple totalmente con todos los requisitos de prueba y auditoría remota de BS7799 (y su equivalente internacional ISO 17799) para auditoría de seguridad de la información.
- UK CESG CHECK: específicamente el servicio CESG IT Health CHECK.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

Estados Unidos de América

- AICPA SAS 70: las actividades de verificación de control de procesos son aplicables al Informe del Auditor de Servicio en la Declaración sobre Normas de Auditoría (SAS) No. 70 de la guía para auditores internos del Instituto Americano de Contadores Públicos Certificados. • Ley Clinger-Cohen.
- Ley de Desempeño y Resultados Gubernamentales. • Ley de la FTC, 15 USC 45(a), Sección 5(a). • Ley de Protección de la Privacidad Infantil en Línea (COPPA). • Ley de Protección Anticiberocupación (ACPA). • Ley Federal de Gestión de Seguridad de la Información. • Ley Sarbanes-Oxley (SOX) de Estados Unidos. • Proyecto de Ley del Senado sobre Privacidad Individual de California – SB1386. • Ley de reforma de la seguridad de la información del gobierno de EE. UU. de 2000, sección 3534(a)(1)(A). • Vulnerabilidades y exposiciones comunes de MITRE: las limitaciones de seguridad descritas en este manual cumplen con las descripciones de CVE para categorizaciones más eficientes (<http://cve.mitre.org/about/terminology.html>). • DoD FM 31-21, Guerra de Guerrillas y Operaciones de Fuerzas Especiales. • Ley de Responsabilidad y Portabilidad del Seguro Médico de 1996 (HIPAA). • OCR HIPAA Privacidad TA 164.502E.001, Socios comerciales [45 CFR §§ 160.103, 164.502(e), 164.514(e)]. • OCR HIPAA Privacidad TA 164.514E.001, Comunicaciones y marketing relacionados con la salud [45 CFR §§ 164.501, 164.514(e)]. • OCR HIPAA Privacidad TA 164.502B.001, Mínimo Necesario [45 CFR §§ 164.502(b), 164.514(d)]. • OCR HIPAA Privacidad TA 164.501.002, Pago [45 CFR 164.501]. • Estándares HIPAA para la privacidad de la información de salud de identificación individual (45 CFR partes 160 y 164).
- FDA: Sistemas Computarizados utilizados en Registros Clínicos. Registros Electrónicos; Firmas Electrónicas; [21 CFR Parte 11].
- Ley Gramm-Leach-Bliley de Estados Unidos (GLBA). • Ley de Seguridad Informática de 1987 (PL 100-235) • Oficina de Gestión de Personal (OPM): Reglamento que implementa los requisitos de capacitación de Ley de seguridad informática de 1987 - 5 CFR Parte 930, Subparte C
- COSO sección 7 Información y comunicación • COBIT sección 3 Educar y capacitar a los usuarios • Consejo Norteamericano de Confiabilidad Eléctrica (NERC) - Norma 1300 sección 1303.a.1, 1303.a.2, 1303.a.3
- Manual del Servicio Geológico de EE. UU., 600.5 - Seguridad de sistemas de información automatizados - General Requisitos, sección 6 A
- Departamento de Asuntos de Veteranos - DIRECTIVA VA 6210 sección 2(d)(3) Conciencia y capacitación sobre seguridad • Ley Federal de Gestión de Seguridad de la Información (FISMA) § 3544(a)(4), (b)(4) • Directiva Ejecutiva Apéndice III a la Circular OMB No. A-130 • Estado de Virginia ITRM Estándar 95-1 sección VI • Administración de Alimentos y Medicamentos - <http://www.fda.gov>
- Comisión Federal de Comunicaciones: <http://www.fcc.gov/>



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

Publicaciones del

- NIST • Introducción a la seguridad informática: el manual del NIST, 800-12. •
- Directrices sobre cortafuegos y política de cortafuegos, 800-41.
- Requisitos de capacitación en seguridad de la tecnología de la información: un modelo basado en roles y desempeño, 800-16.
- Directriz sobre pruebas de seguridad de redes, 800-42. •
- Guía de Autoevaluación de Seguridad de Sistemas de Tecnologías de la Información.
- Análisis de vulnerabilidad de PBX: encontrar agujeros en su PBX antes de que alguien más lo haga, 800-24. • Guía de Gestión de Riesgos para Sistemas de Tecnología de la Información, 800-30. • Sistemas de detección de intrusiones, 800-31. • Creación de un programa de capacitación y concientización sobre seguridad de la tecnología de la información, 800-50. • Publicación especial del NIST 800-53, Controles de seguridad recomendados para sistemas de información federales. • Guía de métricas de seguridad para sistemas de tecnología de la información, 800-55. • Guía para la Certificación de Seguridad y Acreditación de Sistemas de Información Federales, 800-37. • BORRADOR: Guía introductoria de recursos para implementar la regla de seguridad de la Ley de Responsabilidad y Portabilidad del Seguro Médico (HIPAA), 800-66.
- Consejo Federal de Examen de Instituciones Financieras (FFIEC): Operaciones Electrónicas, 12 CFR Parte 555. •
- Directrices interinstitucionales que establecen estándares para salvaguardar la información del cliente, 12 CFR 570 Apéndice B.
- Directrices interinstitucionales que establecen estándares de seguridad y solidez, 12 CFR 570, Apéndice A. • Privacidad de la información financiera del consumidor, 12 CFR 573. •
- Procedimientos para monitorear el cumplimiento de la Ley de Secreto Bancario, 12 CFR 563.177. • Procedimientos de seguridad según la Ley de Protección Bancaria, 12 CFR 568. • Informes de actividades sospechosas y otros informes y declaraciones, 12 CFR 563.180.

General

- SAC: este manual cumple con el diseño de los sistemas del Instituto de Auditores Internos (IIA). Modelo de Aseguramiento y Control (SAC).
- ITIL: este manual es aplicable a la revisión de los controles operativos de seguridad y las interrelaciones de procesos de acuerdo con la Biblioteca de infraestructura de TI (ITIL). • PCI-DSS 1.2 (Industria de tarjetas de pago - Estándar de seguridad de datos) • ISO/IEC 27001:2005 (Sistemas de gestión de seguridad de la información - Requisitos) • ISO/IEC 27002:2005 (Código de prácticas para la gestión de seguridad de la información) • Código de la OIT y la OMI de Práctica – Seguridad en los Puertos, Sección 10 • Basilea II (Internacional)



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

La conciencia de la seguridad debe ser la práctica continua de una habilidad y no el recordatorio continuo de una amenaza.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

Capítulo 13 – Informes con el STAR

El STAR es el Informe de Auditoría de Pruebas de Seguridad. Su propósito es servir como un resumen ejecutivo de cálculos precisos que indiquen la superficie de ataque de los objetivos probados dentro de un alcance particular. Esta precisión se logra mediante el requisito de anotar específicamente lo que NO fue probado además de lo que ha sido probado de acuerdo con la OSSTMM.

La plantilla proporcionada debe completarse en su totalidad (se puede encontrar una copia de esta plantilla en el sitio web de ISECOM) y firmarse por el analista. Luego se proporciona a ISECOM con el permiso explícito del propietario del alcance o directamente al propietario del alcance junto con el informe completo de la prueba de seguridad. No sustituye a un informe completo.

Cuando se proporciona la STAR a ISECOM para su verificación, ésta se imprime, la firma el auditor de verificación y la sella ISECOM. Se proporciona un certificado para todas las pruebas que indiquen que el alcance ha sido probado y verificado. No hay aprobación ni falla, ya que no existe un valor particular de rav de superficie de ataque para todos los ámbitos como límite entre uno que pasa y uno que falla. Sin embargo, los valores rav para un alcance superior al 90% estarán marcados con un sello de excelencia.





Informe de auditoría de prueba de seguridad

Certificación de verificación de seguridad OSSTMM 3.0
OSSTMM.ORG - ISECOM.ORG

ID de informe		Fecha	
Auditor líder		Fecha de la prueba Duración	
Alcance e índice		Vectores	
Canales		Tipo de prueba	

Soy responsable de la información contenida en este informe y he verificado personalmente que toda la información contenida en este informe es objetiva y verdadera.

FIRMA

SELLO/SELLO DE LA EMPRESA

Certificación ISECOM #		Certificación ISECOM #	
------------------------	----------------------	------------------------	----------------------

VALORES DE SEGURIDAD OPERATIVA

Visibilidad	
Acceso	
Confianza	

VALORES DE CONTROL

Autenticación	
Indemnización	
Resiliencia	
Subyugación	
Continuidad	
No repudio	
Confidencialidad	
Privacidad	
Integridad	
Alarma	
Controles verdaderos	
Seguridad Δ	

VALORES DE LIMITACIONES

Vulnerabilidad	
Debilidad	
Inquietud	
Exposición	
Anomalía	
Seguridad de Operaciones	
Limitaciones	

Verdadera protección		Seguridad real	
----------------------	-------------	----------------	-------------

DESCRIPCIÓN

GENERAL Este Manual de Metodología de Pruebas de Seguridad de Código Abierto proporciona una metodología para una prueba de seguridad exhaustiva. Una prueba de seguridad es una medición precisa de la seguridad a nivel operativo, sin suposiciones ni evidencia anecdótica. Una metodología adecuada permite realizar una medición de seguridad válida, consistente y repetible.

ACERCA DE ISECOM

ISECOM, el creador y mantenedor de OSSTMM, es una organización de investigación de seguridad y autoridad de certificación independiente y sin fines de lucro definida por los principios de colaboración abierta y transparencia.

TÉRMINOS Y DEFINICIONES RELACIONADOS

Este informe puede hacer referencia a palabras y términos que pueden interpretarse con otras intenciones o significados. Esto es especialmente cierto en el caso de las traducciones internacionales. Este informe intenta utilizar términos y definiciones estándar tal como se encuentran en el vocabulario OSSTMM 3, que se ha basado en NCSC-TG-004 (Teal Green Book) del Departamento de Defensa de EE. UU., cuando corresponda.

PROPÓSITO

El propósito principal de este Informe de Auditoría es proporcionar un esquema de informes estándar basado en una metodología científica para la caracterización precisa de la seguridad a través del examen y la correlación de una manera consistente y confiable. El propósito secundario es proporcionar pautas que, una vez seguidas, permitirán al auditor realizar una auditoría OSSTMM certificada.

PROCESO

Este Informe de Auditoría debe acompañar el documento completo del informe de prueba de seguridad que proporciona evidencia de la prueba y los resultados tal como se define en la declaración de trabajo entre la organización de pruebas y el cliente.

VIGENCIA

Para que este Informe de Auditoría OSSTMM sea válido deberá ser diligenciado de forma clara, adecuada y completa. El Informe de Auditoría OSSTMM debe estar firmado por el probador o analista principal o responsable y acompañarse del sello de la empresa titular del contrato o subcontrato de la prueba. Este informe de auditoría debe mostrar en ESTADO DE FINALIZACIÓN qué canal y los módulos y tareas asociados se han probado hasta su finalización, no se han probado hasta su finalización y qué pruebas no fueron aplicables y por qué. Un informe que documente que solo se han completado partes específicas de la prueba del Canal debido a limitaciones de tiempo, problemas del proyecto o rechazo del cliente aún puede reconocerse como una auditoría oficial de OSSTMM si va acompañado de este informe que muestra claramente las deficiencias y las razones de esas deficiencias. .

CERTIFICACIÓN

La certificación OSSTMM es la garantía de la seguridad de una organización de acuerdo con las pruebas exhaustivas dentro del estándar OSSTMM y está disponible por vector y canal para organizaciones o partes de organizaciones que mantienen vigilancia sobre sus niveles de rav y los validan anualmente por un auditor externo independiente. . La validación de pruebas de seguridad o métricas trimestrales está sujeta a los requisitos de validación de ISECOM para asegurar consistencia e integridad.



1. REVISIÓN DE POSTURA

	TAREA	COMENTARIOS	ESTADO DE FINALIZACIÓN
1.1	Objetivos de negocio y mercados identificados.		
1.2	Legislación y regulaciones identificadas aplicable a los objetivos en el alcance.		
1.3	Políticas comerciales identificadas.		
1.4	Ética empresarial e industrial identificada políticas.		
1.5	Culturas y normas de operación identificadas.		
1.6	Tiempos y flujos de operación identificados aplicable a los objetivos en el alcance.		
1.7	Identificó todos los canales necesarios para esto. alcance.		
1.8	Se identificaron todos los vectores para este alcance.		

2. LOGÍSTICA

	TAREA	COMENTARIOS	ESTADO DE FINALIZACIÓN
2.1	Medidas de seguridad de pruebas aplicadas.		
2.2	Prueba determinada y contabilizada. inestabilidades.		
2.3	Tiempo de inactividad determinado y contabilizado en alcance.		
2.4	Determinado y contabilizado el ritmo de prueba. según el entorno de prueba y el Presencia de seguridad.		

3. VERIFICACIÓN DE DETECCIÓN ACTIVA

	TAREA	COMENTARIOS	ESTADO DE FINALIZACIÓN
3.1	Determinado y contabilizado interferencias.		
3.2	Probado con interferencias activas y inactivo.		
3.3	Restricciones determinadas impuestas a las pruebas.		
3.4	Reglas de detección verificadas y previsibilidad.		

4. AUDITORÍA DE VISIBILIDAD

	TAREA	COMENTARIOS	ESTADO DE FINALIZACIÓN
4.1	Objetivos determinados en todas tareas de enumeración.		
4.2	Determinados nuevos objetivos mediante la investigación objetivos conocidos.		

5. VERIFICACIÓN DE ACCESO

	TAREA	COMENTARIOS	ESTADO DE FINALIZACIÓN
5.1	Interacciones verificadas con puntos de acceso a todos los objetivos en el alcance.		
5.2	Tipo de interacción determinado para todos los puntos de acceso.		
5.3	Fuente determinada de interacción definida como un servicio o proceso.		
5.4	Profundidad de acceso verificada.		
5.5	Limitaciones de seguridad conocidas verificadas de los puntos de acceso descubiertos.		
5.6	Búsqueda de elusión novedosa técnicas y limitaciones de seguridad de los puntos de acceso descubiertos.		

6. VERIFICACIÓN DE CONFIANZA

	TAREA	COMENTARIOS	ESTADO DE FINALIZACIÓN
6.1	Interacciones determinadas que dependen de otras interacciones para completar la interacción de prueba de acuerdo con las tareas.		
6.2	Objetivos determinados con relaciones de confianza con otros objetivos en el alcance para completar interacciones.		
6.3	Objetivos determinados con relaciones de confianza con otros objetivos fuera del alcance para completar interacciones.		
6.4	Limitaciones de seguridad conocidas verificadas de los fideicomisos descubiertos entre los fideicomisos.		
6.5	Limitaciones de seguridad conocidas verificadas de confianzas descubiertas entre objetivos en el alcance y las interacciones confiables.		
6.6	Búsqueda de elusión novedosa técnicas y limitaciones de seguridad de los fideicomisos descubiertos.		

7. VERIFICACIÓN DE CONTROLES

	TAREA	COMENTARIOS	ESTADO DE FINALIZACIÓN
7.1	Controles verificados para el funcionamiento del No Repudio según todas las tareas.		
7.2	Controles verificados de Confidencialidad que funcionan de acuerdo con todas las tareas.		
7.3	Controles verificados de Privacidad que funcionan de acuerdo con todas las tareas.		
7.4	Controles verificados para el funcionamiento de Integridad de acuerdo con todas las tareas.		
7.5	Controles verificados para el funcionamiento de la Alarma según todas las tareas.		
7.6	Limitaciones de seguridad conocidas verificadas de todos los controles categorías Clase B.		
7.7	Búsqueda de elusión novedosa técnicas y limitaciones de seguridad de todos los controles categorías Clase B.		

8. VERIFICACIÓN DEL PROCESO

	TAREA	COMENTARIOS	ESTADO DE FINALIZACIÓN
8.1	Determinados todos los procesos controlando la acción de interactividad con cada acceso.		
8.2	Verificado que la interacción opera dentro de los límites del proceso determinado.		
8.3	Verificado que la interacción opera dentro de los límites de la política de seguridad para tales interacciones.		
8.4	Se determinó la brecha entre las operaciones de interacciones y los requisitos de postura de la Revisión de Postura.		
8.5	Limitaciones de seguridad conocidas verificadas de los procesos descubiertos.		
8.6	Búsqueda de elusión novedosa técnicas y limitaciones de seguridad de los procesos descubiertos.		

9. VERIFICACIÓN DE CONFIGURACIÓN Y ENTRENAMIENTO

TAREA		COMENTARIOS	ESTADO DE FINALIZACIÓN
9.1	Requisitos de configuración/entrenamiento verificados según la postura en Posture Review.		
9.2	Verificó la aplicación de los mecanismos de seguridad adecuados según lo definido en la Revisión de Postura.		
9.3	Verificada la funcionalidad y seguridad limitaciones dentro de las configuraciones/entrenamiento para los objetivos en el alcance.		
9.4	Búsqueda de elusión novedosa técnicas y limitaciones de seguridad dentro de las configuraciones/entrenamiento.		

10. VALIDACIÓN DE PROPIEDAD

TAREA		COMENTARIOS	ESTADO DE FINALIZACIÓN
10.1	Se determina la cantidad y el tipo de propiedad intelectual sin licencia distribuida dentro del alcance.		
10.2	Verificada la cantidad y tipo de sin licencia propiedad intelectual disponible para la venta/comercio con el vendedor que se origina dentro del alcance.		

11. REVISIÓN DE LA SEGREGACIÓN

TAREA		COMENTARIOS	ESTADO DE FINALIZACIÓN
11.1	Se determinó la cantidad y ubicación de información privada como se define en la Revisión de Postura disponible a través de los objetivos.		
11.2	Se determinó el tipo de información privada según se define en la Revisión de Postura disponible dentro del alcance.		
11.3	Verificó la relación entre la información de acceso público fuera del objetivo que detalla información privada o confidencial definida en la Revisión de Postura y la alcance.		
11.4	Verificada la accesibilidad de los accesos públicos dentro de la meta para personas con discapacidad.		

12. VERIFICACIÓN DE LA EXPOSICIÓN

TAREA		COMENTARIOS	ESTADO DE FINALIZACIÓN
12.1	Se buscaron objetivos disponibles a través de fuentes disponibles públicamente fuera del alcance.		
12.2	Se buscó organización disponible activos tal como se definen en la Revisión de Postura a través de fuentes disponibles públicamente fuera del alcance.		
12.3	Acceso determinado, visibilidad, confianza y controles de la información disponible públicamente dentro de los objetivos.		
12.4	Se determinó un perfil de la organización infraestructura de canales para todos los canales probados a través de información disponible públicamente dentro de los objetivos.		
12.5	Se determinó un perfil de la organización infraestructura de canales para todos los canales probados a través de información disponible públicamente fuera del alcance.		

13. EXPLORACIÓN DE INTELIGENCIA COMPETITIVA

TAREA		COMENTARIOS	ESTADO DE FINALIZACIÓN
13.1	Determinado el entorno empresarial de socios, proveedores, trabajadores y mercado a través de información disponible públicamente sobre los objetivos dentro del alcance.		
13.2	Determinado el entorno empresarial de socios, vendedores, distribuidores, proveedores, trabajadores y mercado a través de información disponible públicamente fuera del alcance.		
13.3	Determinar el ambiente organizacional a través de información disponible públicamente sobre los objetivos dentro del alcance.		
13.4	Determinado el ambiente organizacional a través de información disponible públicamente fuera del alcance.		

14. VERIFICACIÓN DE CUARENTENA

TAREA		COMENTARIOS	ESTADO DE FINALIZACIÓN
14.1	Métodos de cuarentena verificados para interacciones con los objetivos en el alcance.		
14.2	Métodos de cuarentena verificados para interacciones de los objetivos con otros objetivos fuera del alcance.		
14.3	Duración verificada de la cuarentena.		
14.4	Proceso de cuarentena verificado desde la recepción hasta la liberación.		
14.5	Limitaciones de seguridad conocidas verificadas de las cuarentenas descubiertas.		
14.6	Búsqueda de elusión novedosa técnicas y limitaciones de seguridad de las cuarentenas descubiertas.		

15. AUDITORÍA DE PRIVILEGIOS

	TAREA	COMENTARIOS	ESTADO DE FINALIZACIÓN
15.1	Verificó los medios para obtener privilegios legítimos para todas las interacciones autenticadas.		
15.2	Verificó el uso de identificación fraudulenta para obtener privilegios.		
15.3	Verificó los medios para eludir los requisitos de autenticación.		
15.4	Verificó la forma de obtener privilegios de autenticación no pública.		
15.5	Se verificaron los medios para secuestrar otros privilegios de autenticación.		
15.6	Limitaciones de seguridad conocidas verificadas de los mecanismos de autenticación descubiertos para escalar privilegios.		
15.7	Búsqueda de elusión novedosa técnicas y limitaciones de seguridad de los mecanismos de autenticación descubiertos para escalar privilegios.		
15.8	Profundidad determinada de todos los privilegios de autenticación descubiertos.		
15.9	Se determinó la reutilización de todos los privilegios de autenticación descubiertos en los mecanismos de autenticación en todos los objetivos.		
15.10	Requisitos verificados para la obtención de privilegios de autenticación por prácticas discriminatorias según la Revisión de Postura.		
15.11	Medios verificados para obtener privilegios de autenticación para prácticas discriminatorias para personas con discapacidades.		

16. VALIDACIÓN DE SUPERVIVENCIA Y CONTINUIDAD DEL SERVICIO

TAREA		COMENTARIOS	ESTADO DE FINALIZACIÓN
16.1	Medidas determinadas aplicables a interrumpir o detener la continuidad del servicio hacia y desde los objetivos.		
16.2	Continuidad verificada de los procesos y mecanismos de seguridad activos para los objetivos.		
16.3	Limitaciones de seguridad conocidas verificadas de descubierto procesos y mecanismos de seguridad y continuidad del servicio.		
16.4	Búsqueda de elusión novedosa técnicas y limitaciones de seguridad de los procesos y mecanismos de seguridad y continuidad del servicio descubiertos.		

17. FINALIZAR DE REVISIÓN DE ENCUESTA, ALERTA Y

REGISTRO		COMENTARIOS	ESTADO DE FINALIZACIÓN
17.1	Métodos verificados para registrar y alertar de interacciones a los objetivos en el alcance.		
17.2	Métodos verificados para registrar y alertar de las interacciones de los objetivos a otros objetivos fuera del alcance.		
17.3	Velocidad verificada de grabación y alerta.		
17.4	Persistencia verificada de grabación y alerta.		
17.5	Integridad verificada de grabación y alerta.		
17.6	Proceso de distribución verificado de registros y alertas.		
17.7	Limitaciones de seguridad conocidas verificadas de los métodos de alerta y grabación descubiertos.		
17.8	Búsqueda de elusión novedosa técnicas y limitaciones de seguridad de los métodos de alerta y grabación descubiertos.		

Cuanto más se aleje del concepto de seguridad penitenciario, más se requerirá la cooperación y las buenas intenciones de las personas a las que se protege.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

Capítulo 14 – Lo que obtienes

Lo que obtendremos al utilizar OSSTMM es en realidad tener una comprensión profunda de la interconexión de las cosas. Las personas, los procesos, los sistemas y el software tienen algún tipo de relación. Esta interconexión requiere interacciones. Algunas interacciones son pasivas y otras no. Algunas interacciones son simbióticas mientras que otras son parasitarias. Algunas interacciones están controladas por un lado de la relación, mientras que otras están controladas por ambos. Entonces algunos controles son defectuosos o superfluos, lo que es perjudicial para al menos un lado de la relación, si no para ambos. Otros controles se equilibran perfectamente con las interacciones. Cualquiera que sea el destino de la interconexión, sin importar cómo ocurran las interacciones, sin importar cómo se controlen, son las operaciones las que hacen posible la supervivencia. Cuando probamos las operaciones obtenemos una visión general de nuestras relaciones. Podemos ver la interconexión de las operaciones con gran detalle.

Podemos trazar un mapa de cómo nosotros, nuestros negocios y nuestras operaciones sobreviviremos e incluso prosperaremos.

Desafortunadamente, la forma en que interactuamos se basa únicamente en una colección de prejuicios que acumulamos durante la vida, los cuales están sujetos al estado emocional o bioquímico en el que nos encontramos cuando los tenemos. Estos son nuestros atajos. Debido a la increíble cantidad de decisiones que debemos tomar a lo largo de todas nuestras interacciones, utilizamos una hoja de trucos mental para comparar interacciones similares en lugar de calcular cada situación de forma independiente. Después de todo, somos humanos. Aunque la mayoría de las veces nuestras opiniones son limitadas y restringidas a un pequeño ámbito que conocemos como "nuestro pequeño mundo". Los aplicamos en todas partes porque hacen la vida más fácil.

Pero cuando los llevamos con nosotros y tratamos de adherirlos a series y tipos de interacciones más amplios, diferentes y más complicados, es probable que cometamos errores. Lo que puede tener perfecto sentido para nosotros según nuestras experiencias puede no tener ningún sentido fuera de "nuestro pequeño mundo". Así que lo que necesitamos es una manera mejor y menos sesgada de mirar el mundo más grande, más dinámico y menos personal, más allá de nosotros mismos.

Además, nuestro pequeño mundo es algo que llevamos con nosotros. Cuando estamos afuera, nuestro pequeño mundo está afuera con nosotros. Interactuamos en el espacio sobre las suposiciones y prejuicios que conocemos y llevamos. Cuando entramos, nos llevamos nuestro pequeño mundo interior con nosotros. Esto significa que llevamos nuestras formas de hacer las cosas y nuevas interacciones a un nuevo entorno. Y siempre ha sido así. No hay perímetro. No existen nosotros y ellos. Es cada individuo interactuando e interconectándose con todos y con todo; cada individuo con su propio pequeño mundo de problemas y preconceitos que impactan al resto, y al mismo tiempo son impactados por los demás. Esto significa que necesitamos una forma de ver algo más que el mundo en general; También necesitamos una forma de ver los pequeños mundos de cada individuo.

A menudo se atribuye la dificultad para crear seguridad a la sofisticación y la persistencia de los ataques.

Sin embargo, eso sólo sirve para echarle la culpa, pero no para resolver el problema. El verdadero desafío está en proteger interacciones particulares en un mundo interconectado lleno de elementos incontrolables. Tomado al pie de la letra, la gran cantidad de interacciones puede resultar desalentadora. Las soluciones de protección a menudo abordan este desafío abordando de manera amplia tipos particulares de interacciones o monitoreando todas las interacciones a medida que ocurren para detectar intenciones maliciosas. Desafortunadamente, los programas y procesos de seguridad amplios no pueden abordar suficientes elementos como para brindar una protección significativa. Esto lleva a que la seguridad en la práctica sea más un arte que depende de que el practicante aplique su propio pequeño mundo al desafío de la seguridad. Esto sólo puede añadir más complejidad y nuevos problemas. El medio para encontrar una protección global y persistente en perfecto equilibrio con las operaciones es a través de la Defensa Möbius.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

La defensa de Moebius

Debido a la multitud de medios por los que se producen las interacciones hacia y desde cualquier organización, como los distintos canales y vectores, los perímetros a defender parecen tomar la forma de una franja de Möbius.

Una franja de Möbius es una forma sin interior ni exterior, lo que significa que no hay un "lado" del que defenderse.

Por lo tanto, lo que se necesita es una defensa diseñada para proteger un entorno donde en cada individuo pueda interactuar e interconectarse con todos y con todo. La Defensa Möbius lo hace en tres pasos:

1. Mejorar la verificación y el análisis: verificar y analizar operaciones para interacciones y controles. y no sólo defectos.
2. Establecer una defensa amplia: aplicar tácticas defensivas para equilibrar los controles de todas las interacciones. con operaciones.
3. Implementar una estrategia de confianza: compartimentar cómo se autorizan o controlan las interacciones.

1. Mejorar la verificación y el análisis

La práctica de verificar la seguridad operativa debe incluir algo más que simplemente encontrar fallas. Es necesario tener una mejor contabilidad y comprensión de los errores que harán que las pruebas sean inexactas. Es necesario mejorar la precisión de las pruebas mediante una mejor comprensión de qué probar y cuándo probarlo.

Aumentar la precisión de los resultados de las pruebas servirá para proporcionar resultados que puedan repetirse y resultados que puedan usarse para realizar mediciones consistentes. La prueba de seguridad debe catalogar y clasificar todos los puntos de interacción, determinar qué controles existen para esas interacciones y verificar la funcionalidad de esos controles. Las fallas dentro del alcance o los controles deben clasificarse por cómo afectan las operaciones y no por el riesgo posible o potencial que representan para las operaciones. La prueba de seguridad también debe rastrear lo que no se probó y qué pruebas no se realizaron para garantizar la repetibilidad y comparaciones justas con pruebas pasadas y futuras. Finalmente, el analista de pruebas debe ser capaz de comprender adecuadamente los resultados de la prueba y lo que significan para las operaciones. Los medios para hacer todo esto se proporcionan en este manual.

2. Establecer una defensa a lo ancho

El concepto principal detrás de una Defensa Möbius es proporcionar Defensa en Ancho y una variedad equilibrada de controles para cada punto interactivo. Se logra un equilibrio perfecto con la aplicación impecable de los diez tipos de controles operativos para cada punto interactivo. Esto difiere de la Defensa en Profundidad al garantizar que se apliquen diferentes tipos de controles a todos los puntos interactivos en lugar de solo cualquier control en varios puntos dentro de un proceso. Con nueva información de la prueba de seguridad, se puede crear una postura defensiva verificando que exista un equilibrio de controles en todos los puntos de interacción. Esto cambia el entorno en el que se produce la interconectividad y reduce los posibles cambios operativos causados por elementos caóticos ya sea dentro o fuera.

El equilibrio de los controles es importante porque cada control puede aumentar la superficie de ataque de una operación. Asegurar un equilibrio también asegura que se utilicen diferentes tipos de controles que brinden protección de diferentes maneras. Esto aumenta la variedad de tipos de ataques y problemas contra los que se puede defender el punto interactivo. Los ravs deben usarse para medir la cantidad de equilibrio alcanzado y para asegurar que se mantenga el equilibrio a medida que se introducen nuevas operaciones en el alcance. Este manual cubre toda la información necesaria para construir una Defensa en Ancho.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

3. Implementar una estrategia de confianza

Saber qué interacciones requieren menos equilibrio que otras de Defensa en Ancho es cuestión de saber en qué interacciones debemos confiar. Para las operaciones en las que tenemos menos motivos para confiar, deberíamos aplicar más de los diez controles para lograr un equilibrio perfecto. A las personas en las que tenemos menos motivos para confiar las colocamos en entornos donde todas las interacciones están protegidas por más de los diez controles. Por el contrario, se puede autorizar a las personas confiables a tener un mayor control individual sobre las interacciones en su entorno.

Finalmente debemos separar elementos del entorno cuando no se pueda encontrar en esos elementos ninguna razón significativa para confiar o beneficiar la operación. Hacerlo también mantendrá la Defensa en Ancho dentro de una escala de operaciones razonable para que la eficiencia y los gastos no superen los beneficios de la protección.

Las métricas de confianza proporcionadas en este manual garantizan que las razones para confiar se basen en hechos. A medida que los motivos para confiar se acercan al 100%, no sólo estamos seguros de que el individuo o la operación son incapaces de sufrir daños maliciosos o accidentales, sino que ha sido demostrado. No se trata de una evaluación de riesgos ni de una suposición basada en lo que sabemos de nuestro "pequeño mundo". Sin embargo, la dificultad en este proceso puede estar en asignar métricas de confianza a las personas. A diferencia de la forma informal y casi caprichosa en que se suele asignar la confianza, esta nueva manera puede parecer fría y desalmada. Pero no es así porque mientras investigas qué razones tienes para confiar en alguien, también puedes informarle completamente sobre lo que puede hacer para darte más razones para confiar en él. La forma típica de confiar o no confiar no es tan específica ni tan amable. Es más bien un juego social de agradar o no a la persona que otorga la autorización. Las métricas de confianza son más transparentes y más neutrales, aparte de cómo se siente alguien en función de su "propio pequeño mundo". Las métricas de confianza pueden incluso ser verificadas por otros, como una junta o un departamento, que pueden mantener los cálculos de confianza de forma neutral y reevaluarlos periódicamente o cuando sea necesario.

Obtener lo que necesitamos

La aplicación de la Defensa de Möbius tiene muchas ramificaciones. Primero, asegura que los resultados de las pruebas de seguridad son los hechos. Asegura que las pruebas han sido exhaustivas y basadas en los procesos de operaciones y no en las habilidades del Analista. Esto proporciona a una organización una cantidad increíble de inteligencia sobre sus propias operaciones para realizar comparaciones con otras organizaciones, o incluso simplemente autoevaluaciones de tendencias. Es el tipo de información que requieren las decisiones y la que fomenta mejoras operativas significativas.

En segundo lugar, cambia la frecuencia de las pruebas de seguridad requeridas porque, en lugar de que las defensas se basen en reaccionar ante ataques y vulnerabilidades, son parte del control de cambios. Por lo tanto, cuando se inicien nuevas operaciones, se volverá a evaluar el entorno para detectar puntos de interacción nuevos o diferentes. Ya no es necesaria la necesidad de probar nuevas fallas ni tampoco la necesidad de probar la compatibilidad de las actualizaciones de seguridad después de corregir esas fallas. Las actualizaciones de seguridad, si lo desea, pasarán a formar parte del proceso de control de cambios y podrán probarse según lo programado. Esto reducirá drásticamente el tiempo dedicado a apagar incendios para que se pueda centrar la atención en mejorar las operaciones y construir una mejor infraestructura.

En tercer lugar, cambia la forma, a menudo reservada y socialmente exigente, en que utilizamos la confianza dentro de las organizaciones. Permite que el desempeño y la historia de cada individuo hablen por sí mismos. Esto agrega responsabilidad a cada rol y elimina prejuicios que pueden estrangular a una organización, ya sea operativa o legalmente. Sin mencionar que es el medio más justo de asegurar que cada persona tenga la responsabilidad de sus propios éxitos y fracasos.

Los cambios que requiere una organización típica para lograr estos beneficios son en realidad pequeños. Los cambios requeridos por la industria de la seguridad para satisfacer las nuevas necesidades de quienes implementan la Defensa Möbius serán enormes. Y el cambio traerá nuevas oportunidades.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

Esta metodología es gratuita precisamente porque preferimos serlo también.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

Capítulo 15 – Licencia de Metodología Abierta

El OML 3

Esta licencia se proporciona bajo Creative Commons 3.0 Attribution, 2010 de ISECOM.

PREÁMBULO

Esta licencia tiene como objetivo proteger una metodología como un conjunto complejo de métodos, procesos o procedimientos que se aplicarán dentro de una disciplina. Los requisitos clave de esta licencia son que: 1) la metodología tiene valor como propiedad intelectual que mediante su aplicación puede producir un valor cuantificable, y 2) que la metodología esté disponible públicamente y se haga un esfuerzo apropiado para que la metodología sea transparente. a cualquiera.

Con respecto a la Licencia Pública General GNU (GPL), esta licencia es similar con la excepción de que otorga a los desarrolladores el derecho de incluir esta Licencia de Metodología Abierta (OML) a cualquier cosa que no sea modificable ni distribuida comercialmente.

La principal preocupación cubierta por esta licencia es que los desarrolladores de metodologías abiertas reciban el crédito adecuado por su contribución y desarrollo.

Consideraciones especiales a la Free Software Foundation y la Licencia Pública General GNU para conceptos y redacción legales.

TÉRMINOS Y CONDICIONES

1. La licencia se aplica a cualquier metodología u otra herramienta intelectual (es decir, matriz, lista de verificación, etc.) que contenga un aviso colocado por el creador indicando que está protegida bajo los términos de esta Licencia de Metodología Abierta 3.0 u OML 3.0.

2. La Metodología se refiere a cualquier metodología, herramienta intelectual o cualquier trabajo basado en la Metodología. Un “trabajo basado en la Metodología” significa la Metodología o cualquier trabajo derivado según la ley de Secretos Comerciales que se aplica a un trabajo que contiene la Metodología o una parte de ella, ya sea palabra por palabra o con modificaciones o traducida a otro idioma.

3. Todas las personas pueden usar, distribuir, enseñar y promover la Metodología exactamente como ha sido recibida, en cualquier medio, siempre que publiquen de manera visible y apropiada en cada copia el aviso de Licencia de Metodología Abierta correspondiente y la atribución para el creador o creadores. de la Metodología; conservar intactos todos los avisos que se refieran a esta Licencia y a la ausencia de cualquier garantía; Proporcionar a cualquier otro destinatario de la Metodología una copia de esta Licencia junto con la Metodología y la ubicación donde pueden recibir una copia original de la Metodología del creador de la Metodología.

4. Cualquier persona que venda capacitación o servicios de la Metodología debe mostrar claramente el nombre de los creadores de esta Metodología además de los términos de esta licencia.

5. Todas las personas pueden incluir esta Metodología en parte o en su totalidad en ofertas de servicios comerciales, uso privado, interno o no comercial, incluido software, listas de verificación o herramientas, o dentro de una clase o capacitación con fines educativos sin el consentimiento explícito del creador. siempre que se cumplan los puntos 3 y 4.



OSSTMM 3 – Manual de metodología de pruebas de seguridad de código abierto

6. Ninguna persona podrá distribuir una adaptación, modificación o cambio de esta Metodología ni comercializar vender un producto, herramienta, lista de verificación o software que aplique esta Metodología sin el consentimiento explícito de el creador.

7. Todas las personas pueden utilizar la Metodología o cualquier parte de ella para crear o mejorar software libre y copiar y distribuir dicho software bajo cualquier término, siempre que también cumplan con todas estas condiciones:

- a) Se cumplen estrictamente los puntos 3, 4, 5 y 6 de esta Licencia.
- b) Cualquier reducción o uso incompleto de la Metodología en el software debe ser estricta y explícita indicar qué partes de la Metodología fueron utilizadas en el software y cuáles no.
- c) Cuando se ejecuta el software, todo el software que utiliza la Metodología debe causar que el software, cuando comenzó a ejecutarse, para imprimir o mostrar un anuncio de uso de la Metodología, incluido un aviso de garantía cómo ver una copia de esta Licencia o hacer disposiciones claras en otra forma, como en documentación o código fuente abierto entregado.

8. Si, como consecuencia de una sentencia judicial o alegación de infracción de Patente, la ley de Secretos Comerciales infracción, o por cualquier otra razón legal, donde se imponen condiciones a cualquier persona (ya sea por orden judicial, acuerdo o de otro modo) que contradicen las condiciones de esta Licencia, no excusan dicha persona de las condiciones de esta Licencia. Si dicha persona no puede satisfacer simultáneamente las obligaciones bajo esta Licencia y cualquier otra obligación pertinente, entonces como consecuencia dicha persona no podrá usar, copiar, aplicar, utilizar, distribuir o promover la Metodología en absoluto. Si alguna parte de esta sección se considera inválida o inaplicable bajo cualquier circunstancia particular, se pretende que se aplique el resto de la sección y la sección en su conjunto está destinada a aplicarse en otras circunstancias.

9. Si la distribución o el uso de la Metodología está restringido en ciertos países ya sea por patentes o por Interfaces de secreto comercial, el creador original que coloca la Metodología bajo esta Licencia puede agregar una limitación explícita de distribución geográfica excluyendo esos países, de modo que la aplicación, uso o la distribución está permitida sólo en o entre países no excluidos. En tal caso, esta Licencia incorpora la limitación como si estuviera escrita en el cuerpo de esta Licencia.

10. ISECOM podrá publicar versiones nuevas o revisadas de la Licencia de Metodología Abierta. Estas nuevas versiones ser similar en espíritu a la versión actual, pero puede diferir en detalles para abordar nuevos problemas o inquietudes.

SIN GARANTÍA

11. Debido a que la metodología tiene licencia gratuita, no hay garantía para la metodología, hasta el medida permitida por la ley aplicable, excepto cuando se indique lo contrario por escrito, el creador u otras partes proporcionar la metodología "tal cual" sin garantía de ningún tipo, ya sea expresa o implícita, incluyendo, pero no limitado a, las garantías implícitas de comerciabilidad e idoneidad para un propósito particular. La totalidad El riesgo en cuanto a la calidad y desempeño en el uso de la metodología es de las personas que aceptan esta licencia. En caso de que la metodología resulte incompleta o incompatible dicha persona asume el costo de todos servicio, reparación o corrección necesarios.

12. En ningún caso, a menos que lo exija la ley aplicable o se acuerde por escrito, el creador, o cualquier otro parte que pueda usar, aplicar o enseñar la metodología sin modificaciones según lo permitido en este documento, será responsable de cualquier personas por daños, incluyendo cualquier daño general, especial, incidental o consecuente que surja de el uso o la imposibilidad de utilizar la metodología (incluidos, entre otros, pérdida, inexactitudes o fallo de la metodología para operar con cualquier otra metodología), incluso si dicho titular u otra parte ha sido advertido de la posibilidad de tales daños.



OSSTMM 3



¿Por qué probar operaciones? Desafortunadamente, no todo funciona según lo configurado. No todo el mundo se comporta según lo entrenado. Por tanto la verdad de la configuración y el entrenamiento está en las operaciones resultantes. Por eso necesitamos probar las operaciones.

El Manual de metodología de pruebas de seguridad de código abierto se esfuerza por ser la guía de seguridad definitiva. Mejor conocido tanto por los expertos en seguridad como por los piratas informáticos como OSSTMM, dicho como "impresionante" pero con una "t", es una metodología formal para romper cualquier seguridad y atacar cualquier cosa de la manera más completa posible.

Publicado de forma gratuita por primera vez en 2001 como el desvalido de los consejos de seguridad centrados en productos de la industria de la seguridad, el manual logró un seguimiento instantáneo. Estar abierto a cualquier persona para la revisión por pares y más investigaciones lo llevó a crecer desde su lanzamiento inicial de 12 páginas hasta su tamaño actual de más de 200 páginas. Para probar operaciones de seguridad e idear tácticas no tiene igual.

El OSSTMM está en su tercera versión y es una reescritura completa de la metodología original. Ahora incluye las siempre esquivas métricas de seguridad y confianza en su base. Se necesitaron 7 años de investigación y desarrollo para producir la métrica de seguridad operativa perfecta, un algoritmo que calcula la superficie de ataque de cualquier cosa. En esencia, es una escala numérica para mostrar cuán desprotegido y expuesto está algo actualmente. Los profesionales de la seguridad, los tácticos militares y los investigadores de seguridad saben que sin saber qué tan expuesto está un objetivo, simplemente no es posible decir qué probabilidades hay de que una amenaza cause daños y en qué medida. Pero para saber esto se requiere una prueba de seguridad exhaustiva que resulta ser exactamente lo que proporciona OSSTMM.

Decir que OSSTMM 3 es una metodología muy exhaustiva es quedarse corto. Cubre procedimientos de ataque adecuados, manejo de errores, reglas de participación, análisis adecuado, pensamiento crítico de seguridad y métricas de confianza. Proporciona 17 módulos como Auditoría de Visibilidad, Verificación de Confianza, Validación de Propiedad y Exploración de Inteligencia Competitiva, cada uno de los cuales describe múltiples ataques (llamados Tareas), para 5 tipos diferentes de interacción con un objetivo (llamados Canales) organizados por conocimiento técnico y requisitos de equipo como Humano, Físicas, Telecomunicaciones, Redes de Datos e Inalámbricas. De hecho, el OSSTMM se ha convertido en un organismo complejo, pero con un nuevo enfoque en la legibilidad y la usabilidad, su uso está lejos de ser complicado.

La seguridad no tiene por qué durar para siempre; solo más que todo lo demás que pueda notar que se ha ido.